

NIST SP 800-171 Revision 3 Compliance Report

August 20, 2025 at 2:13:46 PM UTC

Prepared for SA demo prod - 5456550640829084205

Table of Contents

00

Executive Summary

[Overview](#)

01

Access Control

[Section Overview](#)

[Section Details](#)

02

Audit and Accountability

[Section Overview](#)

[Section Details](#)

03

Configuration Management

[Section Overview](#)

[Section Details](#)

04

Identification and Authentication

[Section Overview](#)

[Section Details](#)

05

Incident response

[Section Overview](#)

[Section Details](#)

Table of Contents (Continued)

06

System and Communications Protection

[Section Overview](#)

[Section Details](#)

07

System and Information Integrity

[Section Overview](#)

[Section Details](#)

Executive Summary

CLOUD ACCOUNT(S)

AWS Cloud Account 1739983856, Finance AWS Account, JackAccounts

REGION(S)

All cloud regions

DATES

Generated on: August 20, 2025, 2:13:46 PM UTC

From: February 23, 2023, 4:25:04 PM UTC

To: August 20, 2025, 2:13:02 PM UTC

Executive Summary

Resources Passed	Resources Failed	Resources Monitored	Accounts Monitored
831	279	1,110	3

Compliance Coverage Breakdown

Access Control 108 Policies Enabled	Passed 74	Failed 34	Audit and Accountability 20 Policies Enabled	Passed 6	Failed 14
Configuration Management 49 Policies Enabled	Passed 42	Failed 7	Identification and Authentication 15 Policies Enabled	Passed 4	Failed 11
Incident response 16 Policies Enabled	Passed 2	Failed 14	System and Communications Protec... 73 Policies Enabled	Passed 58	Failed 15

System and Information Integrity

21 Policies Enabled

Passed

Failed

7

14



NIST SP 800-171 Revision 3

Requirements	Pass	Fail	Overall
Access Control	781	167	Fail
Configuration Management	77	138	Fail
Svstem and Communications Protection	378	122	Fail
System and Information Integrity	239	39	Fail
Identification and Authentication	73	6	Fail
Audit and Accountability	26	5	Fail
Incident response	0	3	Fail
Supply Chain Risk Management	0	0	Pass
Risk Assessment	0	0	Pass
Personnel Security	0	0	Pass
System and Services Acquisition	0	0	Pass
Maintenance	0	0	Pass
Planning	0	0	Pass
Awareness and Training	0	0	Pass
Media Protection	0	0	Pass
Security Assessment	0	0	Pass
Physical Protection	0	0	Pass

1

Access Control

Access Control Overview

Section			Pass Rate	Failed	Passed
Account Management	AWS CodeBuild project environment privileged mode is enabled	●●●● Medium	91%	1	11
Account Management	AWS Elasticsearch domain has Index slow logs set to disabled	●●●● Informational	100%	0	0
Account Management	AWS Elasticsearch domain has Search slow logs set to disabled	●●●● Informational	100%	0	0
Account Management	AWS IAM Groups with administrator access permissions	●●●● Medium	100%	0	3
Account Management	AWS IAM Roles with Administrator Access Permissions	●●●● Medium	93%	11	148
Account Management	AWS IAM policy allows decryption actions on all KMS keys	●●●● Low	96%	6	183
Account Management	AWS Inactive users for more than 30 days	●●●● Low	3%	50	2
Account Management	AWS Log metric filter and alarm does not exist for AWS Config con...	●●●● Informational	0%	2	0
Account Management	AWS Log metric filter and alarm does not exist for AWS Organization...	●●●● Informational	0%	2	0
Account Management	AWS Log metric filter and alarm does not exist for AWS management...	●●●● Informational	0%	2	0

Section				Pass Rate	Failed	Passed
Account Management	AWS Log metric filter and alarm does not exist for CloudTrail config...	Informational		0%	2	0
Account Management	AWS Log metric filter and alarm does not exist for IAM policy changes	Informational		0%	2	0
Account Management	AWS Log metric filter and alarm does not exist for Network Access...	Informational		0%	2	0
Account Management	AWS Log metric filter and alarm does not exist for Network gateways...	Informational		0%	2	0
Account Management	AWS Log metric filter and alarm does not exist for Route table...	Informational		0%	2	0
Account Management	AWS Log metric filter and alarm does not exist for S3 bucket policy...	Informational		0%	2	0
Account Management	AWS Log metric filter and alarm does not exist for VPC changes	Informational		0%	2	0
Account Management	AWS Log metric filter and alarm does not exist for disabling or sched...	Informational		0%	2	0
Account Management	AWS Log metric filter and alarm does not exist for unauthorized API...	Informational		0%	2	0
Account Management	AWS Log metric filter and alarm does not exist for usage of root...	Informational		0%	2	0
Account Management	AWS Neptune Cluster not configured with IAM authentication	Low		100%	0	0

Section			Pass Rate	Failed	Passed
Account Management	AWS OpenSearch Fine-grained access control is disabled	Low	100%	0	0
Account Management	AWS RDS cluster not configured with IAM authentication	Low	100%	0	0
Account Management	AWS RDS instance not configured with IAM authentication	Medium	0%	1	0
Account Management	AWS SageMaker notebook instance with root access enabled	Informational	100%	0	0
Account Management	AWS Secret Manager Automatic Key Rotation is not enabled	Low	100%	0	5
Access Enforcement	AWS EC2 Instance IAM Role not enabled	Informational	100%	0	17
Access Enforcement	AWS IAM policyv allows assume role permission across all services	Medium	99%	1	188
Access Enforcement	AWS IAM policyv overly permissive to STS services	Medium	100%	0	189
Access Enforcement	AWS KMS Key policyv overly permissive	Medium	100%	0	31
Access Enforcement	AWS Lambda Function resource-based policyv is overly permissive	Low	100%	0	3
Access Enforcement	AWS Lambda IAM policyv overly permissive to all traffic	Low	100%	0	189

Section			Pass Rate	Failed	Passed
Access Enforcement	AWS Lambda execution role having overly permissive inline policy Informational	100%	0	159	
Access Enforcement	AWS Lambda function URL having overly permissive cross-origin resource... Medium	100%	0	3	
Access Enforcement	AWS OpenSearch attached security group overly permissive to all traffic Low	100%	0	50	
Access Enforcement	AWS Private ECR repository policy is overly permissive Medium	100%	0	6	
Access Enforcement	AWS RDS Cluster snapshot is accessible to public Medium	100%	0	0	
Access Enforcement	AWS RDS Event subscription All event categories and All instances dis... Informational	100%	0	0	
Access Enforcement	AWS RDS PostgreSQL exposed to local file read vulnerability Medium	100%	0	1	
Access Enforcement	AWS RDS Postgres Cluster does not have query logging enabled Informational	100%	0	0	
Access Enforcement	AWS RDS cluster encryption in transit is not configured Medium	100%	0	0	
Access Enforcement	AWS RDS database instance encrypted with Customer Managed Key... Informational	100%	0	0	
Access Enforcement	AWS RDS database instance not configured with encryption in transit Medium	0%	1	0	

Section			Pass Rate	Failed	Passed
Access Enforcement	AWS RDS event subscription disabled for DB security groups	Informational	100%	0	0
Access Enforcement	AWS RDS instance delete protection is disabled	Informational	0%	1	0
Access Enforcement	AWS RDS instance not in private subnet	Low	100%	0	1
Access Enforcement	AWS RDS retention policy less than 7 days	Low	100%	0	1
Access Enforcement	AWS S3 Buckets Block public access setting disabled	Low	72%	7	18
Access Enforcement	AWS S3 bucket encrypted using Customer Managed Key (CMK) with overly permissive policy	Medium	100%	0	25
Access Enforcement	AWS S3 bucket having policy overly permissive to VPC endpoints	Low	100%	0	25
Access Enforcement	AWS S3 bucket policy overly permissive to any principal	Medium	100%	0	25
Access Enforcement	AWS S3 bucket publicly readable	Medium	88%	3	22
Access Enforcement	AWS S3 bucket publicly writable	High	100%	0	25
Access Enforcement	AWS SNS topic policy overly permissive for publishing	Low	100%	0	6

Section			Pass Rate	Failed	Passed
Access Enforcement	AWS SNS topic policy overly permissive for subscription	Low	100%	0	6
Access Enforcement	AWS SOS queue access policy is overly permissive	Informational	100%	0	0
Access Enforcement	AWS SageMaker notebook instance IAM policy overly permissive to all traffic	Medium	100%	0	189
Access Enforcement	AWS VPC gateway endpoint policy is overly permissive	Low	100%	0	0
Access Enforcement	AWS route table with VPC peering overly permissive to all traffic	Low	100%	0	36
Least Privilege	AWS ACM Certificate with wildcard domain name	Low	100%	0	0
Least Privilege	AWS Access key enabled on root account	High	100%	0	2
Least Privilege	AWS EC2 Instance IAM Role not enabled	Informational	100%	0	17
Least Privilege	AWS ECS Fargate task definition root user found	Medium	100%	0	0
Least Privilege	AWS ECS task definition elevated privileges enabled	Medium	100%	0	0
Least Privilege	AWS IAM Groups with administrator access permissions	Medium	100%	0	3

Section				Pass Rate	Failed	Passed
Least Privilege	AWS IAM Roles with Administrator Access Permissions	Medium		93%	11	148
Least Privilege	AWS IAM deprecated managed policies in use by User	Low		100%	0	50
Least Privilege	AWS IAM policy allows assume role permission across all services	Medium		99%	1	188
Least Privilege	AWS IAM policy allows full administrative privileges	Medium		98%	3	186
Least Privilege	AWS IAM policy attached to users	Low		4%	48	2
Least Privilege	AWS IAM role/user with unused CloudTrail delete or full permission	Low		100%	0	263
Least Privilege	AWS IAM support access policy is not associated to any role	Informational		100%	0	189
Least Privilege	AWS IAM user has both Console access and Access Keys	Informational		100%	0	52
Least Privilege	AWS IAM user has two active Access Keys	Informational		100%	0	52
Least Privilege	AWS KMS Key policy overly permissive	Medium		100%	0	31
Least Privilege	AWS S3 bucket has global view ACL permissions enabled	Low		100%	0	25

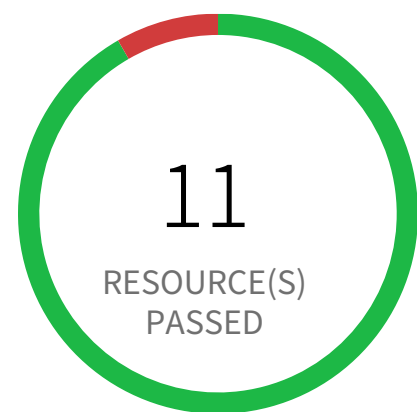
Section				Pass Rate	Failed	Passed
Least Privilege	AWS S3 bucket having policy overly permissive to VPC endpoints	●●●● Low		100%	0	25
Least Privilege	AWS SOS queue access policy is overly permissive	● Informational		100%	0	0
Least Privilege	AWS SageMaker notebook instance with root access enabled	● Informational		100%	0	0
Least Privilege	AWS root account configured with Virtual MFA	●●●● Medium		100%	0	0
System Use Notification	AWS Amazon Machine Image (AMI) is publicly accessible	●●●● Low		100%	0	7
System Use Notification	AWS CloudTrail bucket is publicly accessible	●●●● Low		100%	0	25
System Use Notification	AWS EBS Snapshot with access for unmonitored cloud accounts	●●●● Low		16%	5	1
System Use Notification	AWS EBS snapshots are accessible to public	●●●● Medium		100%	0	6
System Use Notification	AWS RDS Snapshot with access for unmonitored cloud accounts	●●●● Low		100%	0	5
System Use Notification	AWS RDS database instance is publicly accessible	●●●● Medium		100%	0	1
System Use Notification	AWS RDS snapshots are accessible to public	●●●● Medium		100%	0	5

Section				Pass Rate	Failed	Passed
System Use Notification	AWS S3 bucket accessible to unmonitored cloud accounts	●●●● Low		68%	8	17
System Use Notification	AWS S3 buckets are accessible to any authenticated user	●●●● Medium		100%	0	25
System Use Notification	AWS S3 buckets are accessible to public via ACL	●●●● High		88%	3	22
System Use Notification	Instances exposed to network traffic from the internet	●●●● Medium		0%	3	0
Remote Access	AWS CloudFront origin protocol policy does not enforce HTTPS-only	●●●● Medium		100%	0	0
Remote Access	AWS DvnamoDB encrvpted using AWS owned CMK instead of AWS managed CMK	Informational		100%	0	0
Remote Access	AWS EBS volume region with encryption is disabled	●●●● Low		0%	17	0
Remote Access	AWS EKS cluster security group overly permissive to all traffic	●●●● Low		96%	2	48
Remote Access	AWS EMR cluster is not configured with CSE CMK for data at rest encryption...	Informational		100%	0	0
Remote Access	AWS EMR cluster is not configured with SSE KMS for data at rest encryption (Amazon S3...	●●●● Low		100%	0	0
Remote Access	AWS EMR cluster is not enabled with data encryption at rest	●●●● Low		100%	0	0

Section			Pass Rate	Failed	Passed
Remote Access	AWS EMR cluster is not enabled with data encrvption in transit	●●●● Low	100%	0	0
Remote Access	AWS EMR cluster is not enabled with local disk encryption	●●●● Low	100%	0	0
Remote Access	AWS EMR cluster is not enabled with local disk encryption using Custom key provider	●●●● Low	100%	0	0
Remote Access	AWS ElastiCache Redis cluster with encryption for data at rest disabled	●●●● Low	100%	0	0
Remote Access	AWS ElastiCache Redis cluster with in-transit encryption disabled (Replication group)	●●●● Low	100%	0	0
Remote Access	AWS Elastic File Svstem (EFS) not encrvpted using Customer Managed Key	Informational	100%	0	0
Remote Access	AWS Elastic File Svstem (EFS) with encryption for data at rest is disabled	●●●● Low	100%	0	0
Remote Access	AWS Elastic Load Balancer (ELB) has security group with no inbound rules	Informational	100%	0	0
Remote Access	AWS RDS DB cluster encrvption is disabled	●●●● Low	100%	0	0
Remote Access	AWS RDS DB cluster is encrypted using default KMS key instead of CMK	Informational	100%	0	0
Remote Access	AWS RDS DB snapshot is not encrypted	●●●● Low	40%	3	2

Section			Pass Rate	Failed	Passed
Remote Access	AWS RDS database not encrvpted using Customer Managed Key	Informational	100%	0	1
Remote Access	AWS RDS instance is not encrvpted	Low	0%	1	0
Remote Access	AWS Redshift Cluster not encrvpted using Customer Managed Key	Informational	100%	0	1
Remote Access	AWS Redshift instances are not encrvpted	Low	0%	1	0
Remote Access	AWS SOS Queue not configured with server side encrvption	Low	100%	0	0
Remote Access	AWS SOS queue encrvption using default KMS key instead of CMK	Informational	100%	0	0
Remote Access	AWS SSM Parameter is not encrvpted	Low	100%	0	0
Remote Access	AWS route table with VPC peering overly permissive to all traffic	Low	100%	0	36

Access Control / Section Account Management



1 Resource(s) Failed

cloud-security-lab-one-run

Compliance Section: Account Management ●●● Medium

- a. Define the types of system accounts allowed and prohibited.
- b. Create, enable, modify, disable, and remove system accounts in accordance with policy, procedures, prerequisites, and criteria.
- c. Specify:
 1. Authorized users of the system,
 2. Group and role membership, and
 3. Access authorizations (i.e., privileges) for each account.
- d. Authorize access to the system based on:
 1. A valid access authorization and
 2. Intended system usage.
- e. Monitor the use of system accounts.
- f. Disable system accounts when:
 1. The accounts have expired,
 2. The accounts have been inactive for [Assignment: organization-defined time period],
 3. The accounts are no longer associated with a user or individual,
 4. The accounts are in violation of organizational policy, or
 5. Significant risks associated with individuals are discovered.
- g. Notify account managers and designated personnel or roles within:
 1. [Assignment: organization-defined time period] when accounts are no longer required.
 2. [Assignment: organization-defined time period] when users are terminated or transferred.
 3. [Assignment: organization-defined time period] when system usage or the need-to-know changes for an individual.
- h. Require that users log out of the system after [Assignment: organization-defined time period] of expected inactivity or when [Assignment: organization-defined circumstances].

AWS CodeBuild project environment privileged mode is enabled

This policy identifies the CodeBuild projects where the privileged mode is enabled. Privileged mode grants unrestricted access to all devices and runs the Docker daemon inside the container. It is recommended to enable this mode only for building Docker images. It is recommended disabling the privileged mode to prevent unintended access to Docker APIs and container hardware, reducing the risk of potential tampering or critical resource deletion.

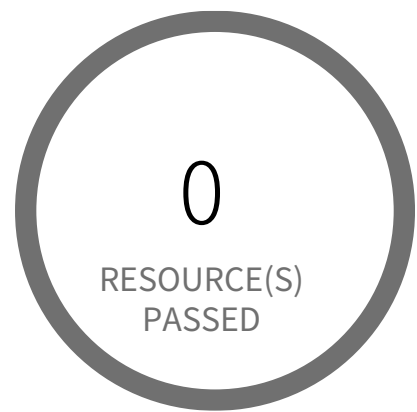
First Seen June 11, 2024 at 6:11:26 PM UTC | **Resource Type** Other

Recommendations

To disable the Privileged mode for the CodeBuild project:

1. Log in to the AWS Management Console.
2. In the console, select the specific region from the region drop-down in the top right corner, for which the alert is generated.
3. Navigate to 'Developer Tools' from the 'Services' dropdown and select the 'CodeBuild'.
4. In the navigation pane, choose 'Build projects'.
5. Select the reported Build project and choose Edit, then click 'Environment'.
6. On the Edit Environment page, expand the configuration by clicking the 'Override image' button.
7. Uncheck the checkbox 'Enable this flag if you want to build Docker images or want your builds to get elevated privileges.' under the 'Privileged' section.
8. When you have finished changing your CodeBuild environment configuration, click 'Update environment'.

Access Control / Section Account Management



0 Resource(s) Failed

Compliance Section: Account Management — Informational

- a. Define the types of system accounts allowed and prohibited.
- b. Create, enable, modify, disable, and remove system accounts in accordance with policy, procedures, prerequisites, and criteria.
- c. Specify:
 - 1. Authorized users of the system,
 - 2. Group and role membership, and
 - 3. Access authorizations (i.e., privileges) for each account.
- d. Authorize access to the system based on:
 - 1. A valid access authorization and
 - 2. Intended system usage.
- e. Monitor the use of system accounts.
- f. Disable system accounts when:
 - 1. The accounts have expired,
 - 2. The accounts have been inactive for [Assignment: organization-defined time period],
 - 3. The accounts are no longer associated with a user or individual,
 - 4. The accounts are in violation of organizational policy, or
 - 5. Significant risks associated with individuals are discovered.
- g. Notify account managers and designated personnel or roles within:
 - 1. [Assignment: organization-defined time period] when accounts are no longer required.
 - 2. [Assignment: organization-defined time period] when users are terminated or transferred.
 - 3. [Assignment: organization-defined time period] when system usage or the need-to-know changes for an individual.
- h. Require that users log out of the system after [Assignment: organization-defined time period] of expected inactivity or when [Assignment: organization-defined circumstances].

[AWS Elasticsearch domain has Index slow logs set to disabled](#)

This policy identifies Elasticsearch domains for which Index slow logs is disabled in your AWS account. Enabling support for publishing indexing slow logs to AWS CloudWatch Logs enables you have full insight into the performance of indexing operations performed on your Elasticsearch clusters. This will help you in identifying performance issues caused by specific queries or due to changes in cluster usage, so that you can optimize your index configuration to address the problem.

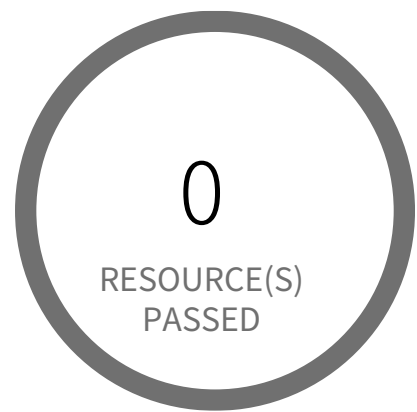
First Seen N/A | **Resource Type** Other

Recommendations

1. Sign into the AWS console
2. In the console, select the specific region from region drop down on the top right corner, for which the alert is generated
3. Navigate to Elasticsearch Service Dashboard
4. Choose reported Elasticsearch domain
5. Select the 'Logs' tab
6. In 'Set up Index slow logs' section,
 - a. click on 'Setup'
 - b. In 'Select CloudWatch Logs log group' setting, Create/Use existing CloudWatch Logs log group as per your requirement
 - c. In 'Specify CloudWatch access policy', Create new/Select an existing policy as per your requirement
 - d. Click on 'Enable'

The Index slow logs setting 'Status' should change now to 'Enabled'.

Access Control / Section Account Management



0 Resource(s) Failed

Compliance Section: Account Management — Informational

- a. Define the types of system accounts allowed and prohibited.
- b. Create, enable, modify, disable, and remove system accounts in accordance with policy, procedures, prerequisites, and criteria.
- c. Specify:
 - 1. Authorized users of the system,
 - 2. Group and role membership, and
 - 3. Access authorizations (i.e., privileges) for each account.
- d. Authorize access to the system based on:
 - 1. A valid access authorization and
 - 2. Intended system usage.
- e. Monitor the use of system accounts.
- f. Disable system accounts when:
 - 1. The accounts have expired,
 - 2. The accounts have been inactive for [Assignment: organization-defined time period],
 - 3. The accounts are no longer associated with a user or individual,
 - 4. The accounts are in violation of organizational policy, or
 - 5. Significant risks associated with individuals are discovered.
- g. Notify account managers and designated personnel or roles within:
 - 1. [Assignment: organization-defined time period] when accounts are no longer required.
 - 2. [Assignment: organization-defined time period] when users are terminated or transferred.
 - 3. [Assignment: organization-defined time period] when system usage or the need-to-know changes for an individual.
- h. Require that users log out of the system after [Assignment: organization-defined time period] of expected inactivity or when [Assignment: organization-defined circumstances].

[AWS Elasticsearch domain has Search slow logs set to disabled](#)

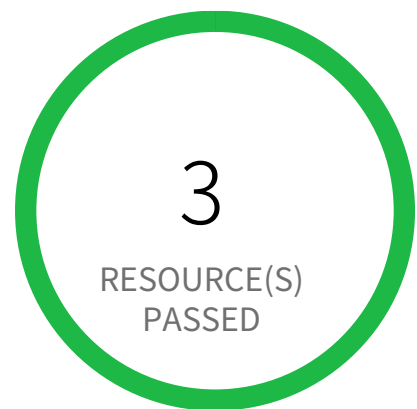
This policy identifies Elasticsearch domains for which Search slow logs is disabled in your AWS account. Enabling support for publishing Search slow logs to AWS CloudWatch Logs enables you to have full insight into the performance of search operations performed on your Elasticsearch clusters. This will help you in identifying performance issues caused by specific search queries so that you can optimize your queries to address the problem.

First Seen N/A | **Resource Type** Other

Recommendations

1. Sign into the AWS console
2. In the console, select the specific region from region drop down on the top right corner, for which the alert is generated
3. Navigate to Amazon OpenSearch Service Dashboard
4. From the navigation panel, Click on 'Domains' Under the 'Managed clusters'
5. Select the reported domain
6. Select the 'Logs' tab
7. In 'CloudWatch Logs' section, Choose 'Search slow logs' and click on 'Enable'
8. In 'Set up Search slow logs' section,
 - a. In 'Select log group from CloudWatch logs' setting, Create/Use existing CloudWatch Logs log group as per your requirement
 - b. In 'Specify CloudWatch access policy' section, Create/Select the 'Resource access policy' as per your requirement
9. Click 'Enable'

Access Control / Section Account Management



0 Resource(s) Failed

Compliance Section: Account Management ●●● Medium

- a. Define the types of system accounts allowed and prohibited.
- b. Create, enable, modify, disable, and remove system accounts in accordance with policy, procedures, prerequisites, and criteria.
- c. Specify:
 1. Authorized users of the system,
 2. Group and role membership, and
 3. Access authorizations (i.e., privileges) for each account.
- d. Authorize access to the system based on:
 1. A valid access authorization and
 2. Intended system usage.
- e. Monitor the use of system accounts.
- f. Disable system accounts when:
 1. The accounts have expired,
 2. The accounts have been inactive for [Assignment: organization-defined time period],
 3. The accounts are no longer associated with a user or individual,
 4. The accounts are in violation of organizational policy, or
 5. Significant risks associated with individuals are discovered.
- g. Notify account managers and designated personnel or roles within:
 1. [Assignment: organization-defined time period] when accounts are no longer required.
 2. [Assignment: organization-defined time period] when users are terminated or transferred.
 3. [Assignment: organization-defined time period] when system usage or the need-to-know changes for an individual.
- h. Require that users log out of the system after [Assignment: organization-defined time period] of expected inactivity or when [Assignment: organization-defined circumstances].

[AWS IAM Groups with administrator access permissions](#)

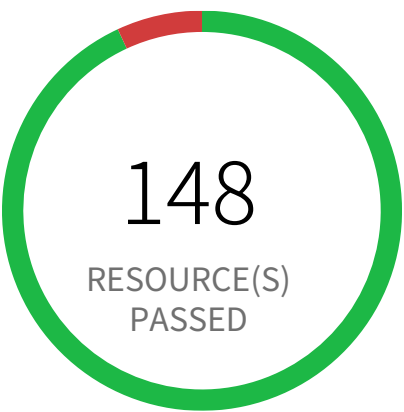
This policy identifies AWS IAM groups which has administrator access permission set. This would allow all users under this group to have administrative privileges. As a security best practice, it is recommended to grant least privilege access like granting only the permissions required to perform a task, instead of providing excessive permissions.

First Seen N/A | **Resource Type** Other

Recommendations

1. Log in to AWS console
2. Navigate to IAM service
3. Click on Groups
4. Click on reported IAM group
5. Under 'Managed Policies' click on 'Detach Policy' which is having excessive permissions and assign a limited permission policy as required for a particular group
OR
6. Under 'Inline Policies' click on 'Edit Policy' or 'Remove Policy' and assign a limited permission as required for a particular group

Access Control / Section Account Management



11 Resource(s) Failed

OrganizationAccountAccessRole,
privesc-AssumeRole-ending-role,
sales-trading-admin-role-qa-hz6vX,
stack-
sets-exec-04a521ff20cd15073e5aefd21b5dba97,
privesc-high-priv-service-role,
AWSCloudFormationStackSetExecutionRole,
AWSReservedSSO_AdministratorAc-
cess_426d8e7cca35042a,
AWSReservedSSO_AdministratorAc-
cess_5bc2bc21a64c12ba,
fp2-allow-and-deny-multiple-policies-role & 1
more

Compliance Section: Account Management ●●● Medium

- a. Define the types of system accounts allowed and prohibited.
- b. Create, enable, modify, disable, and remove system accounts in accordance with policy, procedures, prerequisites, and criteria.
- c. Specify:
 - 1. Authorized users of the system,
 - 2. Group and role membership, and
 - 3. Access authorizations (i.e., privileges) for each account.
- d. Authorize access to the system based on:
 - 1. A valid access authorization and
 - 2. Intended system usage.
- e. Monitor the use of system accounts.
- f. Disable system accounts when:
 - 1. The accounts have expired,
 - 2. The accounts have been inactive for [Assignment: organization-defined time period],
 - 3. The accounts are no longer associated with a user or individual,
 - 4. The accounts are in violation of organizational policy, or
 - 5. Significant risks associated with individuals are discovered.
- g. Notify account managers and designated personnel or roles within:
 - 1. [Assignment: organization-defined time period] when accounts are no longer required.
 - 2. [Assignment: organization-defined time period] when users are terminated or transferred.
 - 3. [Assignment: organization-defined time period] when system usage or the need-to-know changes for an individual.
- h. Require that users log out of the system after [Assignment: organization-defined time period] of expected inactivity or when [Assignment: organization-defined circumstances].

AWS IAM Roles with Administrator Access Permissions

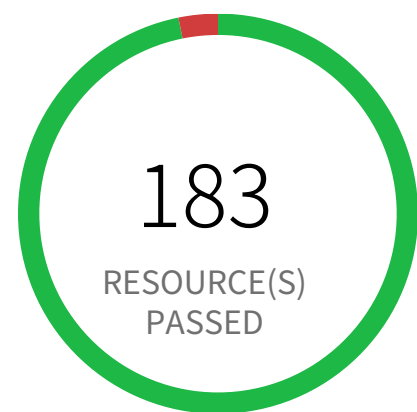
This policy identifies AWS IAM roles which has administrator access permission set. This would allow all users who assume this role to have administrative privileges. As a security best practice, it is recommended to grant least privilege access like granting only the permissions required to perform a task, instead of providing excessive permissions.

First Seen June 11, 2024 at 6:11:26 PM UTC | **Resource Type** Other

Recommendations

1. Log in to AWS console
2. Navigate to IAM service
3. Click on Roles
4. Click on reported IAM role
5. Under 'Permissions policies' click on 'X' to detach or remove the policy having excessive permissions and assign a limited permission policy as required for a particular role.

Access Control / Section Account Management



6 Resource(s) Failed

prisma_cloud_1-806079733791502336-PrismaCloudRole-806079733791502336-member,
prisma_cloud_2-1078351365594031104-PrismaCloudRole-1078351365594031104,
CodeBuildBasePolicy-darwin-project-run-us-east-1,
prisma_cloud_2-1273671299063257088-PrismaCloudRole-1273671299063257088

Compliance Section: Account Management ●●● Low

- a. Define the types of system accounts allowed and prohibited.
- b. Create, enable, modify, disable, and remove system accounts in accordance with policy, procedures, prerequisites, and criteria.
- c. Specify:
 1. Authorized users of the system,
 2. Group and role membership, and
 3. Access authorizations (i.e., privileges) for each account.
- d. Authorize access to the system based on:
 1. A valid access authorization and
 2. Intended system usage.
- e. Monitor the use of system accounts.
- f. Disable system accounts when:
 1. The accounts have expired,
 2. The accounts have been inactive for [Assignment: organization-defined time period],
 3. The accounts are no longer associated with a user or individual,
 4. The accounts are in violation of organizational policy, or
 5. Significant risks associated with individuals are discovered.
- g. Notify account managers and designated personnel or roles within:
 1. [Assignment: organization-defined time period] when accounts are no longer required.
 2. [Assignment: organization-defined time period] when users are terminated or transferred.
 3. [Assignment: organization-defined time period] when system usage or the need-to-know changes for an individual.
- h. Require that users log out of the system after [Assignment: organization-defined time period] of expected inactivity or when [Assignment: organization-defined circumstances].

AWS IAM policy allows decryption actions on all KMS keys

This policy identifies IAM policies that allow decryption actions on all KMS keys. Instead of granting permissions for all keys, determine the minimum set of keys that users need to access encrypted data. You should grant to identities only the kms:Decrypt or kms:ReEncryptFrom permissions and only for the keys that are required to perform a task. By adopting the principle of least privilege, you can reduce the risk of unintended disclosure of your data.

First Seen June 11, 2024 at 6:11:26 PM UTC | **Resource Type** Other

Recommendations

To allow a user to encrypt and decrypt with any CMK in a specific AWS account; refer following example:

<https://docs.aws.amazon.com/kms/latest/developerguide/customer-managed-policies.html#iam-policy-example-encrypt-decrypt-one-account>

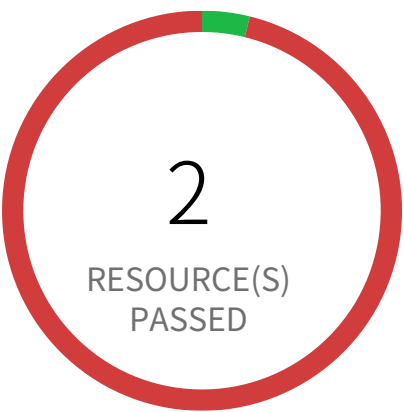
To allow a user to encrypt and decrypt with any CMK in a specific AWS account and Region; refer following example:

<https://docs.aws.amazon.com/kms/latest/developerguide/customer-managed-policies.html#iam-policy-example-encrypt-decrypt-one-account-one-region>

To allow a user to encrypt and decrypt with specific CMKs; refer following example:

<https://docs.aws.amazon.com/kms/latest/developerguide/customer-managed-policies.html#iam-policy-example-encrypt-decrypt-specific-cmks>

Access Control / Section Account Management



50 Resource(s) Failed

privesc8-AttachGroupPolicy-user,
privesc-sageMakerCreateProcessingJobPass-
Role-user, fn1-privesc3-partial-user,
read-only-access-engg,
fp4-nonExploitableResourceConstraint-user,
privesc9-AttachRolePolicy-user,
privesc4-CreateAccessKey-user,
privesc5-CreateLoginProfile-user,
privesc-sageMakerCreateTrainingJobPass-
Role-user, privesc6-UpdateLoginProfile-user &
40 more

Compliance Section: Account Management ●●●● Low

- a. Define the types of system accounts allowed and prohibited.
- b. Create, enable, modify, disable, and remove system accounts in accordance with policy, procedures, prerequisites, and criteria.
- c. Specify:
 - 1. Authorized users of the system,
 - 2. Group and role membership, and
 - 3. Access authorizations (i.e., privileges) for each account.
- d. Authorize access to the system based on:
 - 1. A valid access authorization and
 - 2. Intended system usage.
- e. Monitor the use of system accounts.
- f. Disable system accounts when:
 - 1. The accounts have expired,
 - 2. The accounts have been inactive for [Assignment: organization-defined time period],
 - 3. The accounts are no longer associated with a user or individual,
 - 4. The accounts are in violation of organizational policy, or
 - 5. Significant risks associated with individuals are discovered.
- g. Notify account managers and designated personnel or roles within:
 - 1. [Assignment: organization-defined time period] when accounts are no longer required.
 - 2. [Assignment: organization-defined time period] when users are terminated or transferred.
 - 3. [Assignment: organization-defined time period] when system usage or the need-to-know changes for an individual.
- h. Require that users log out of the system after [Assignment: organization-defined time period] of expected inactivity or when [Assignment: organization-defined circumstances].

AWS Inactive users for more than 30 days

This policy identifies users who are inactive for more than 30 days. Inactive user accounts are an easy target for attacker because any activity on the account will largely get unnoticed.

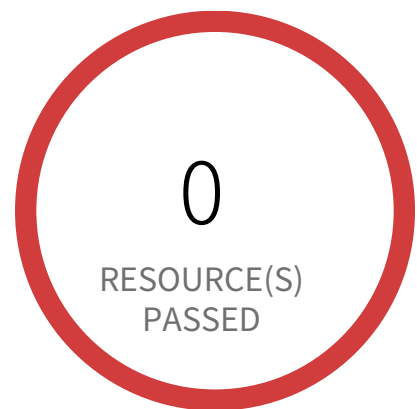
NOTE: Exception to this policy is, it is not valid for SSO login users and Root users

First Seen June 11, 2024 at 6:11:26 PM UTC | **Resource Type** IAM Credentials Report

Recommendations

1. Sign in to AWS console and navigate to IAM.
2. Identify the user reported and Make sure that the user has legitimate reason to be inactive for such an extended period.
3. Delete the user account, if the user no longer needs access to the console or no longer exists.

Access Control / Section Account Management



2 Resource(s) Failed

058264157785, 818698786219

Compliance Section: Account Management — Informational

- a. Define the types of system accounts allowed and prohibited.
- b. Create, enable, modify, disable, and remove system accounts in accordance with policy, procedures, prerequisites, and criteria.
- c. Specify:
 - 1. Authorized users of the system,
 - 2. Group and role membership, and
 - 3. Access authorizations (i.e., privileges) for each account.
- d. Authorize access to the system based on:
 - 1. A valid access authorization and
 - 2. Intended system usage.
- e. Monitor the use of system accounts.
- f. Disable system accounts when:
 - 1. The accounts have expired,
 - 2. The accounts have been inactive for [Assignment: organization-defined time period],
 - 3. The accounts are no longer associated with a user or individual,
 - 4. The accounts are in violation of organizational policy, or
 - 5. Significant risks associated with individuals are discovered.
- g. Notify account managers and designated personnel or roles within:
 - 1. [Assignment: organization-defined time period] when accounts are no longer required.
 - 2. [Assignment: organization-defined time period] when users are terminated or transferred.
 - 3. [Assignment: organization-defined time period] when system usage or the need-to-know changes for an individual.
- h. Require that users log out of the system after [Assignment: organization-defined time period] of expected inactivity or when [Assignment: organization-defined circumstances].

AWS Log metric filter and alarm does not exist for AWS Config configuration changes

This policy identifies the AWS regions which do not have a log metric filter and alarm for AWS Config configuration changes. Monitoring changes to AWS Config configuration will help ensure sustained visibility of configuration items within the AWS account. It is recommended that a metric filter and alarm be established for detecting changes to AWS Config's configurations.

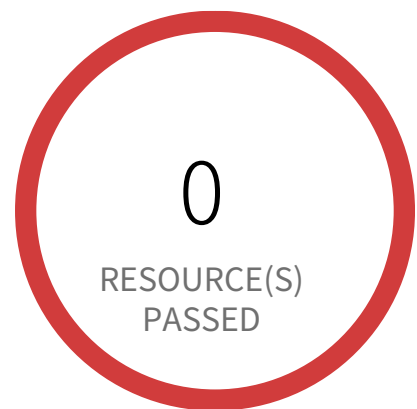
NOTE: This policy will trigger alert if you have at least one Cloudtrail with the multi trail is enabled, Logs all management events in your account and is not set with specific log metric filter and alarm.

First Seen January 28, 2025 at 12:06:58 PM UTC | **Resource Type** Other

Recommendations

1. Sign in to AWS Console
2. Navigate to CloudWatch dashboard
3. Click on 'Log groups' in the 'Logs' section (Left panel)
4. Select the log group created for your CloudTrail trail event logs (CloudTrail should be multi trail enabled with all management events captured) and click 'Create Metric Filter' button.
5. In 'Define Logs Metric Filter' page, add 'Filter pattern' value as
`{ ($.eventSource = config.amazonaws.com) && (($.eventName=StopConfigurationRecorder)||($.eventName=DeleteDeliveryChannel)||($.eventName=PutDeliveryChannel)||($.eventName=PutConfigurationRecorder)) }`
and Click on 'Assign Metric'
6. In 'Create Metric Filter and Assign a Metric' page, Choose Filter Name, Metric Details parameter according to your requirement and click on 'Create Filter'
7. Click on 'Create Alarm',
 - In Step 1 specify metric details and conditions details as required and click on 'Next'
 - In Step 2 Select an SNS topic either by creating a new topic or use existing SNS topic/ARN and click on 'Next'
 - In Step 3 Select name and description to alarm and click on 'Next'
 - In Step 4 Preview your data entered and click on 'Create Alarm'

Access Control / Section Account Management



2 Resource(s) Failed

818698786219, 058264157785

Compliance Section: Account Management — Informational

- a. Define the types of system accounts allowed and prohibited.
- b. Create, enable, modify, disable, and remove system accounts in accordance with policy, procedures, prerequisites, and criteria.
- c. Specify:
 - 1. Authorized users of the system,
 - 2. Group and role membership, and
 - 3. Access authorizations (i.e., privileges) for each account.
- d. Authorize access to the system based on:
 - 1. A valid access authorization and
 - 2. Intended system usage.
- e. Monitor the use of system accounts.
- f. Disable system accounts when:
 - 1. The accounts have expired,
 - 2. The accounts have been inactive for [Assignment: organization-defined time period],
 - 3. The accounts are no longer associated with a user or individual,
 - 4. The accounts are in violation of organizational policy, or
 - 5. Significant risks associated with individuals are discovered.
- g. Notify account managers and designated personnel or roles within:
 - 1. [Assignment: organization-defined time period] when accounts are no longer required.
 - 2. [Assignment: organization-defined time period] when users are terminated or transferred.
 - 3. [Assignment: organization-defined time period] when system usage or the need-to-know changes for an individual.
- h. Require that users log out of the system after [Assignment: organization-defined time period] of expected inactivity or when [Assignment: organization-defined circumstances].

AWS Log metric filter and alarm does not exist for AWS Organization changes

This policy identifies the AWS regions that do not have a log metric filter and alarm for AWS Organizations changes. Monitoring changes to AWS Organizations will help to ensure any unwanted, accidental, or intentional modifications that may lead to unauthorized access or other security breaches within the AWS account. It is recommended that a metric filter and alarm be established for detecting changes to AWS Organization's configurations.

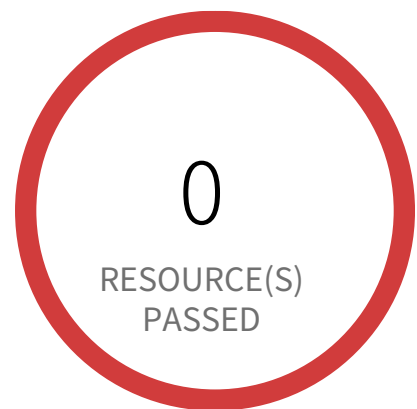
NOTE: This policy will trigger an alert if you have at least one Cloudtrail with the multi trail enabled, Logs all management events in your account, and is not set with a specific log metric filter and alarm.

First Seen January 28, 2025 at 12:06:58 PM UTC | **Resource Type** Other

Recommendations

1. Sign in to the AWS Console.
2. Navigate to the CloudWatch dashboard.
3. Click on 'Log groups' in the 'Logs' section (Left panel)
4. Select the log group created for your CloudTrail trail event logs (Cloudtrail should be multi-trail enabled with all Management Events captured) and click the Actions Dropdown Button -> Click 'Create Metric Filter' button.
5. In the 'Define Pattern' page, add the 'Filter pattern' value as
{ (\$.eventSource = organizations.amazonaws.com) && ((\$.eventName = "AcceptHandshake") || (\$.eventName = "AttachPolicy") || (\$.eventName = "CreateAccount") || (\$.eventName = "CreateOrganizationalUnit") || (\$.eventName = "CreatePolicy") || (\$.eventName = "DeclineHandshake") || (\$.eventName = "DeleteOrganization") || (\$.eventName = "DeleteOrganizationalUnit") || (\$.eventName = "DeletePolicy") || (\$.eventName = "DetachPolicy") || (\$.eventName = "DisablePolicyType") || (\$.eventName = "EnablePolicyType") || (\$.eventName = "InviteAccountToOrganization") || (\$.eventName = "LeaveOrganization") || (\$.eventName = "MoveAccount") || (\$.eventName = "RemoveAccountFromOrganization") || (\$.eventName = "UpdatePolicy") || (\$.eventName = "UpdateOrganizationalUnit")) }
and Click on 'NEXT'.
6. In the 'Assign Metric' page, Choose Filter Name, and Metric Details parameter according to your requirement and click on 'Next'.
7. Under the 'Review and Create' page, Review details and click 'Create Metric Filter'.
8. To create an alarm based on a log group-metric filter, Refer to the below link
https://docs.aws.amazon.com/AmazonCloudWatch/latest/monitoring/Create_alarm_log_group_metric_filter.html

Access Control / Section Account Management



2 Resource(s) Failed

818698786219, 058264157785

Compliance Section: Account Management — Informational

- a. Define the types of system accounts allowed and prohibited.
- b. Create, enable, modify, disable, and remove system accounts in accordance with policy, procedures, prerequisites, and criteria.
- c. Specify:
 1. Authorized users of the system,
 2. Group and role membership, and
 3. Access authorizations (i.e., privileges) for each account.
- d. Authorize access to the system based on:
 1. A valid access authorization and
 2. Intended system usage.
- e. Monitor the use of system accounts.
- f. Disable system accounts when:
 1. The accounts have expired,
 2. The accounts have been inactive for [Assignment: organization-defined time period],
 3. The accounts are no longer associated with a user or individual,
 4. The accounts are in violation of organizational policy, or
 5. Significant risks associated with individuals are discovered.
- g. Notify account managers and designated personnel or roles within:
 1. [Assignment: organization-defined time period] when accounts are no longer required.
 2. [Assignment: organization-defined time period] when users are terminated or transferred.
 3. [Assignment: organization-defined time period] when system usage or the need-to-know changes for an individual.
- h. Require that users log out of the system after [Assignment: organization-defined time period] of expected inactivity or when [Assignment: organization-defined circumstances].

AWS Log metric filter and alarm does not exist for AWS management console authentication failures

This policy identifies the AWS accounts which do not have a log metric filter and alarm for AWS management console authentication failures. Monitoring failed console logins may decrease lead time to detect an attempt to brute force a credential, which may provide an indicator, such as source IP, that can be used in other event correlation. It is recommended that a metric filter and alarm be established for failed console authentication attempts.

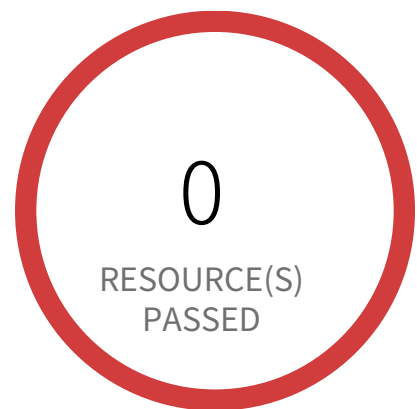
NOTE: This policy will trigger alert if you have at least one Cloudtrail with the multi trail is enabled, Logs all management events and is not set with specific log metric filter and alarm in your account.

First Seen January 28, 2025 at 12:06:58 PM UTC | **Resource Type** Other

Recommendations

1. Sign in to AWS Console
2. Navigate to CloudWatch dashboard
3. Click on 'Log groups' in the 'Logs' section (Left panel)
4. Select the log group created for your CloudTrail trail event logs (Cloudtrail should be multi trail enabled with all Management Events captured) and click 'Create Metric Filter' button.
5. In 'Define Logs Metric Filter' page, add 'Filter pattern' value as
{ (\$.eventName = ConsoleLogin) && (\$.errorMessage = "Failed authentication") }
and Click on 'Assign Metric'
6. In 'Create Metric Filter and Assign a Metric' page, Choose Filter Name, Metric Details parameter according to your requirement and click on 'Create Filter'
7. Click on 'Create Alarm',
 - In Step 1, specify metric details and conditions details as required and click on 'Next'
 - In Step 2, Select an SNS topic either by creating a new topic or use existing SNS topic/ARN and click on 'Next'
 - In Step 3, Select name and description to alarm and click on 'Next'
 - In Step 4, Preview your data entered and click on 'Create Alarm'

Access Control / Section Account Management



2 Resource(s) Failed

058264157785, 818698786219

Compliance Section: Account Management — Informational

- a. Define the types of system accounts allowed and prohibited.
- b. Create, enable, modify, disable, and remove system accounts in accordance with policy, procedures, prerequisites, and criteria.
- c. Specify:
 - 1. Authorized users of the system,
 - 2. Group and role membership, and
 - 3. Access authorizations (i.e., privileges) for each account.
- d. Authorize access to the system based on:
 - 1. A valid access authorization and
 - 2. Intended system usage.
- e. Monitor the use of system accounts.
- f. Disable system accounts when:
 - 1. The accounts have expired,
 - 2. The accounts have been inactive for [Assignment: organization-defined time period],
 - 3. The accounts are no longer associated with a user or individual,
 - 4. The accounts are in violation of organizational policy, or
 - 5. Significant risks associated with individuals are discovered.
- g. Notify account managers and designated personnel or roles within:
 - 1. [Assignment: organization-defined time period] when accounts are no longer required.
 - 2. [Assignment: organization-defined time period] when users are terminated or transferred.
 - 3. [Assignment: organization-defined time period] when system usage or the need-to-know changes for an individual.
- h. Require that users log out of the system after [Assignment: organization-defined time period] of expected inactivity or when [Assignment: organization-defined circumstances].

AWS Log metric filter and alarm does not exist for CloudTrail configuration changes

This policy identifies the AWS regions which do not have a log metric filter and alarm for CloudTrail configuration changes. Monitoring changes to CloudTrail's configuration will help ensure sustained visibility to activities performed in the AWS account. It is recommended that a metric filter and alarm be established for detecting changes to CloudTrail's configurations.

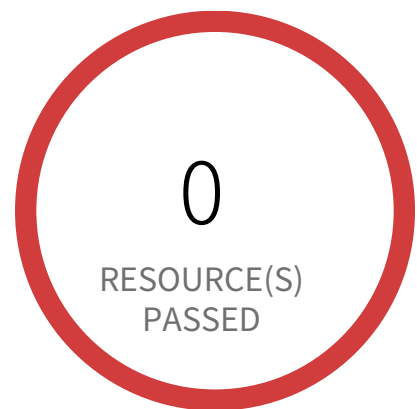
NOTE: This policy will trigger alert if you have at least one Cloudtrail with the multi trail is enabled, Logs all management events in your account and is not set with specific log metric filter and alarm.

First Seen January 28, 2025 at 12:06:58 PM UTC | **Resource Type** Other

Recommendations

1. Sign in to AWS Console
2. Navigate to CloudWatch dashboard
3. Click on 'Log groups' in the 'Logs' section (Left panel)
4. Select the log group created for your CloudTrail trail event logs (CloudTrail should be multi trail enabled with all management events captured) and click 'Create Metric Filter' button.
5. In 'Define Logs Metric Filter' page, add 'Filter pattern' value as
`{ ($.eventName = CreateTrail) || ($.eventName = UpdateTrail) || ($.eventName = DeleteTrail) || ($.eventName = StartLogging) || ($.eventName = StopLogging) }`
and Click on 'Assign Metric'
6. In 'Create Metric Filter and Assign a Metric' page, Choose Filter Name, Metric Details parameter according to your requirement and click on 'Create Filter'
7. Click on 'Create Alarm',
 - In Step 1 specify metric details and conditions details as required and click on 'Next'
 - In Step 2 Select an SNS topic either by creating a new topic or use existing SNS topic/ARN and click on 'Next'
 - In Step 3 Select name and description to alarm and click on 'Next'
 - In Step 4 Preview your data entered and click on 'Create Alarm'

Access Control / Section Account Management



2 Resource(s) Failed

058264157785, 818698786219

Compliance Section: Account Management — Informational

- a. Define the types of system accounts allowed and prohibited.
- b. Create, enable, modify, disable, and remove system accounts in accordance with policy, procedures, prerequisites, and criteria.
- c. Specify:
 1. Authorized users of the system,
 2. Group and role membership, and
 3. Access authorizations (i.e., privileges) for each account.
- d. Authorize access to the system based on:
 1. A valid access authorization and
 2. Intended system usage.
- e. Monitor the use of system accounts.
- f. Disable system accounts when:
 1. The accounts have expired,
 2. The accounts have been inactive for [Assignment: organization-defined time period],
 3. The accounts are no longer associated with a user or individual,
 4. The accounts are in violation of organizational policy, or
 5. Significant risks associated with individuals are discovered.
- g. Notify account managers and designated personnel or roles within:
 1. [Assignment: organization-defined time period] when accounts are no longer required.
 2. [Assignment: organization-defined time period] when users are terminated or transferred.
 3. [Assignment: organization-defined time period] when system usage or the need-to-know changes for an individual.
- h. Require that users log out of the system after [Assignment: organization-defined time period] of expected inactivity or when [Assignment: organization-defined circumstances].

AWS Log metric filter and alarm does not exist for IAM policy changes

This policy identifies the AWS regions which do not have a log metric filter and alarm for IAM policy changes. Monitoring changes to IAM policies will help ensure authentication and authorization controls remain intact. It is recommended that a metric filter and alarm be established changes made to Identity and Access Management (IAM) policies.

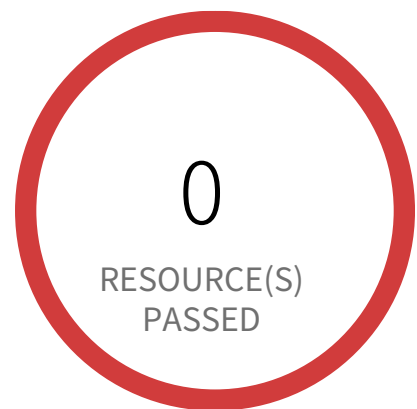
NOTE: This policy will trigger alert if you have at least one Cloudtrail with the multi trail is enabled, Logs all management events in your account and is not set with specific log metric filter and alarm.

First Seen January 28, 2025 at 12:06:58 PM UTC | **Resource Type** Other

Recommendations

1. Sign in to AWS Console
2. Navigate to CloudWatch dashboard
3. Click on 'Log groups' in the 'Logs' section (Left panel)
4. Select the log group created for your CloudTrail trail event logs (CloudTrail should be multi trail enabled with all management events captured) and click 'Create Metric Filter' button.
5. In 'Define Logs Metric Filter' page, add 'Filter pattern' value as
{
(\$eventName=DeleteGroupPolicy)||(\$eventName=DeleteRolePolicy)||(\$eventName=DeleteUserPolicy)||(\$eventName=PutGroupPolicy)||(\$eventName=PutRolePolicy)||(\$eventName=PutUserPolicy)||(\$eventName=CreatePolicy)||(\$eventName=DeletePolicy)||(\$eventName=CreatePolicyVersion)||(\$eventName=DeletePolicyVersion)||(\$eventName=AttachRolePolicy)||(\$eventName=DetachRolePolicy)||(\$eventName=AttachUserPolicy)||(\$eventName=DetachUserPolicy)||(\$eventName=AttachGroupPolicy)||(\$eventName=DetachGroupPolicy) }
and Click on 'Assign Metric'
6. In 'Create Metric Filter and Assign a Metric' page, Choose Filter Name, Metric Details parameter according to your requirement and click on 'Create Filter'
7. Click on 'Create Alarm',
 - ▣- In Step 1 specify metric details and conditions details as required and click on 'Next'
 - ▣- In Step 2 Select an SNS topic either by creating a new topic or use existing SNS topic/ARN and click on 'Next'
 - ▣- In Step 3 Select name and description to alarm and click on 'Next'
 - ▣- In Step 4 Preview your data entered and click on 'Create Alarm'

Access Control / Section Account Management



2 Resource(s) Failed

058264157785, 818698786219

Compliance Section: Account Management — Informational

- a. Define the types of system accounts allowed and prohibited.
- b. Create, enable, modify, disable, and remove system accounts in accordance with policy, procedures, prerequisites, and criteria.
- c. Specify:
 - 1. Authorized users of the system,
 - 2. Group and role membership, and
 - 3. Access authorizations (i.e., privileges) for each account.
- d. Authorize access to the system based on:
 - 1. A valid access authorization and
 - 2. Intended system usage.
- e. Monitor the use of system accounts.
- f. Disable system accounts when:
 - 1. The accounts have expired,
 - 2. The accounts have been inactive for [Assignment: organization-defined time period],
 - 3. The accounts are no longer associated with a user or individual,
 - 4. The accounts are in violation of organizational policy, or
 - 5. Significant risks associated with individuals are discovered.
- g. Notify account managers and designated personnel or roles within:
 - 1. [Assignment: organization-defined time period] when accounts are no longer required.
 - 2. [Assignment: organization-defined time period] when users are terminated or transferred.
 - 3. [Assignment: organization-defined time period] when system usage or the need-to-know changes for an individual.
- h. Require that users log out of the system after [Assignment: organization-defined time period] of expected inactivity or when [Assignment: organization-defined circumstances].

AWS Log metric filter and alarm does not exist for Network Access Control Lists (NACL) changes

This policy identifies the AWS regions which do not have a log metric filter and alarm for Network Access Control Lists (NACL) changes. Monitoring changes to NACLs will help ensure that AWS resources and services are not unintentionally exposed. It is recommended that a metric filter and alarm be established for changes made to NACLs.

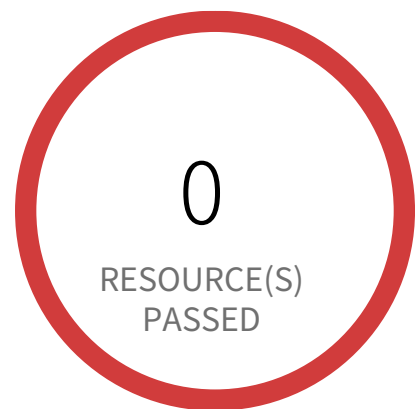
NOTE: This policy will trigger alert if you have at least one Cloudtrail with the multi trail is enabled, Logs all management events in your account and is not set with specific log metric filter and alarm.

First Seen January 28, 2025 at 12:06:58 PM UTC | **Resource Type** Other

Recommendations

1. Sign in to AWS Console
2. Navigate to CloudWatch dashboard
3. Click on 'Log groups' in the 'Logs' section (Left panel)
4. Select the log group created for your CloudTrail trail event logs (CloudTrail should be multi trail enabled with all management events captured) and click 'Create Metric Filter' button.
5. In 'Define Logs Metric Filter' page, add 'Filter pattern' value as
`{ ($.eventName = CreateNetworkAcl) || ($.eventName = CreateNetworkAclEntry) || ($.eventName = DeleteNetworkAcl) || ($.eventName = DeleteNetworkAclEntry) || ($.eventName = ReplaceNetworkAclEntry) || ($.eventName = ReplaceNetworkAclAssociation) }`
and Click on 'Assign Metric'
6. In 'Create Metric Filter and Assign a Metric' page, Choose Filter Name, Metric Details parameter according to your requirement and click on 'Create Filter'
7. Click on 'Create Alarm',
 - In Step 1 specify metric details and conditions details as required and click on 'Next'
 - In Step 2 Select an SNS topic either by creating a new topic or use existing SNS topic/ARN and click on 'Next'
 - In Step 3 Select name and description to alarm and click on 'Next'
 - In Step 4 Preview your data entered and click on 'Create Alarm'

Access Control / Section Account Management



2 Resource(s) Failed

058264157785, 818698786219

Compliance Section: Account Management — Informational

- a. Define the types of system accounts allowed and prohibited.
- b. Create, enable, modify, disable, and remove system accounts in accordance with policy, procedures, prerequisites, and criteria.
- c. Specify:
 1. Authorized users of the system,
 2. Group and role membership, and
 3. Access authorizations (i.e., privileges) for each account.
- d. Authorize access to the system based on:
 1. A valid access authorization and
 2. Intended system usage.
- e. Monitor the use of system accounts.
- f. Disable system accounts when:
 1. The accounts have expired,
 2. The accounts have been inactive for [Assignment: organization-defined time period],
 3. The accounts are no longer associated with a user or individual,
 4. The accounts are in violation of organizational policy, or
 5. Significant risks associated with individuals are discovered.
- g. Notify account managers and designated personnel or roles within:
 1. [Assignment: organization-defined time period] when accounts are no longer required.
 2. [Assignment: organization-defined time period] when users are terminated or transferred.
 3. [Assignment: organization-defined time period] when system usage or the need-to-know changes for an individual.
- h. Require that users log out of the system after [Assignment: organization-defined time period] of expected inactivity or when [Assignment: organization-defined circumstances].

AWS Log metric filter and alarm does not exist for Network gateways changes

This policy identifies the AWS regions which do not have a log metric filter and alarm for Network gateways changes. Monitoring changes to network gateways will help ensure that all ingress/egress traffic traverses the VPC border via a controlled path. It is recommended that a metric filter and alarm be established for changes to network gateways.

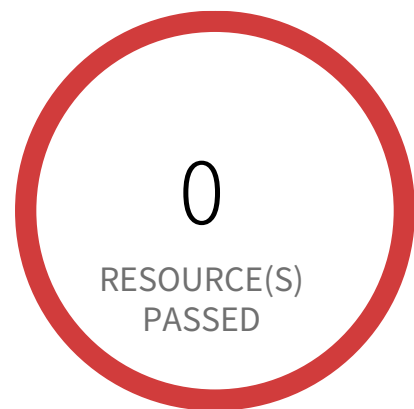
NOTE: This policy will trigger alert if you have at least one Cloudtrail with the multi trail is enabled, Logs all management events in your account and is not set with specific log metric filter and alarm.

First Seen January 28, 2025 at 12:06:58 PM UTC | **Resource Type** Other

Recommendations

1. Sign in to AWS Console
2. Navigate to CloudWatch dashboard
3. Click on 'Log groups' in the 'Logs' section (Left panel)
4. Select the log group created for your CloudTrail trail event logs (CloudTrail should be multi trail enabled with all management events captured) and click 'Create Metric Filter' button.
5. In 'Define Logs Metric Filter' page, add 'Filter pattern' value as
{ (\$.eventName = CreateCustomerGateway) || (\$.eventName = DeleteCustomerGateway) || (\$.eventName = AttachInternetGateway) || (\$.eventName = CreateInternetGateway) || (\$.eventName = DeleteInternetGateway) || (\$.eventName = DetachInternetGateway) }
and Click on 'Assign Metric'
6. In 'Create Metric Filter and Assign a Metric' page, Choose Filter Name, Metric Details parameter according to your requirement and click on 'Create Filter'
7. Click on 'Create Alarm',
 - In Step 1 specify metric details and conditions details as required and click on 'Next'
 - In Step 2 Select an SNS topic either by creating a new topic or use existing SNS topic/ARN and click on 'Next'
 - In Step 3 Select name and description to alarm and click on 'Next'
 - In Step 4 Preview your data entered and click on 'Create Alarm'

Access Control / Section Account Management



2 Resource(s) Failed

058264157785, 818698786219

Compliance Section: Account Management — Informational

- a. Define the types of system accounts allowed and prohibited.
- b. Create, enable, modify, disable, and remove system accounts in accordance with policy, procedures, prerequisites, and criteria.
- c. Specify:
 1. Authorized users of the system,
 2. Group and role membership, and
 3. Access authorizations (i.e., privileges) for each account.
- d. Authorize access to the system based on:
 1. A valid access authorization and
 2. Intended system usage.
- e. Monitor the use of system accounts.
- f. Disable system accounts when:
 1. The accounts have expired,
 2. The accounts have been inactive for [Assignment: organization-defined time period],
 3. The accounts are no longer associated with a user or individual,
 4. The accounts are in violation of organizational policy, or
 5. Significant risks associated with individuals are discovered.
- g. Notify account managers and designated personnel or roles within:
 1. [Assignment: organization-defined time period] when accounts are no longer required.
 2. [Assignment: organization-defined time period] when users are terminated or transferred.
 3. [Assignment: organization-defined time period] when system usage or the need-to-know changes for an individual.
- h. Require that users log out of the system after [Assignment: organization-defined time period] of expected inactivity or when [Assignment: organization-defined circumstances].

AWS Log metric filter and alarm does not exist for Route table changes

This policy identifies the AWS regions which do not have a log metric filter and alarm for Route table changes. Monitoring changes to route tables will help ensure that all VPC traffic flows through an expected path. It is recommended that a metric filter and alarm be established for changes to route tables.

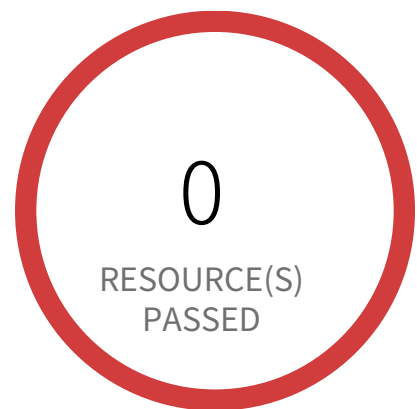
NOTE: This policy will trigger alert if you have at least one Cloudtrail with the multi trail is enabled, Logs all management events in your account and is not set with specific log metric filter and alarm.

First Seen January 28, 2025 at 12:06:58 PM UTC | **Resource Type** Other

Recommendations

1. Sign in to AWS Console
2. Navigate to CloudWatch dashboard
3. Click on 'Log groups' in the 'Logs' section (Left panel)
4. Select the log group created for your CloudTrail trail event logs (CloudTrail should be multi trail enabled with all management events captured) and click 'Create Metric Filter' button.
5. In 'Define Logs Metric Filter' page, add 'Filter pattern' value as
{ (\$.eventName = CreateRoute) || (\$.eventName = CreateRouteTable) || (\$.eventName = ReplaceRoute) || (\$.eventName = ReplaceRouteTable-Association) || (\$.eventName = DeleteRouteTable) || (\$.eventName = DeleteRoute) || (\$.eventName = DisassociateRouteTable) }
and Click on 'Assign Metric'
6. In 'Create Metric Filter and Assign a Metric' page, Choose Filter Name, Metric Details parameter according to your requirement and click on 'Create Filter'
7. Click on 'Create Alarm',
 - In Step 1 specify metric details and conditions details as required and click on 'Next'
 - In Step 2 Select an SNS topic either by creating a new topic or use existing SNS topic/ARN and click on 'Next'
 - In Step 3 Select name and description to alarm and click on 'Next'
 - In Step 4 Preview your data entered and click on 'Create Alarm'

Access Control / Section Account Management



2 Resource(s) Failed

058264157785, 818698786219

Compliance Section: Account Management — Informational

- a. Define the types of system accounts allowed and prohibited.
- b. Create, enable, modify, disable, and remove system accounts in accordance with policy, procedures, prerequisites, and criteria.
- c. Specify:
 - 1. Authorized users of the system,
 - 2. Group and role membership, and
 - 3. Access authorizations (i.e., privileges) for each account.
- d. Authorize access to the system based on:
 - 1. A valid access authorization and
 - 2. Intended system usage.
- e. Monitor the use of system accounts.
- f. Disable system accounts when:
 - 1. The accounts have expired,
 - 2. The accounts have been inactive for [Assignment: organization-defined time period],
 - 3. The accounts are no longer associated with a user or individual,
 - 4. The accounts are in violation of organizational policy, or
 - 5. Significant risks associated with individuals are discovered.
- g. Notify account managers and designated personnel or roles within:
 - 1. [Assignment: organization-defined time period] when accounts are no longer required.
 - 2. [Assignment: organization-defined time period] when users are terminated or transferred.
 - 3. [Assignment: organization-defined time period] when system usage or the need-to-know changes for an individual.
- h. Require that users log out of the system after [Assignment: organization-defined time period] of expected inactivity or when [Assignment: organization-defined circumstances].

AWS Log metric filter and alarm does not exist for S3 bucket policy changes

This policy identifies the AWS regions which do not have a log metric filter and alarm for S3 bucket policy changes. Monitoring changes to S3 bucket policies may reduce time to detect and correct permissive policies on sensitive S3 buckets. It is recommended that a metric filter and alarm be established for changes to S3 bucket policies.

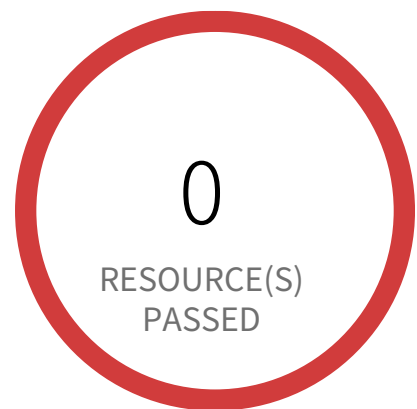
NOTE: This policy will trigger alert if you have at least one Cloudtrail with the multi trail is enabled, Logs all management events in your account and is not set with specific log metric filter and alarm.

First Seen January 28, 2025 at 12:06:58 PM UTC | **Resource Type** Other

Recommendations

1. Sign in to AWS Console
2. Navigate to CloudWatch dashboard
3. Click on 'Log groups' in the 'Logs' section (Left panel)
4. Select the log group created for your CloudTrail trail event logs (CloudTrail should be multi trail enabled with all management events captured) and click 'Create Metric Filter' button.
5. In 'Define Logs Metric Filter' page, add 'Filter pattern' value as
`{ ($.eventSource = s3.amazonaws.com) && (($.eventName = PutBucketAcl) || ($.eventName = PutBucketPolicy) || ($.eventName = PutBucketCors) || ($.eventName = PutBucketLifecycle) || ($.eventName = PutBucketReplication) || ($.eventName = DeleteBucketPolicy) || ($.eventName = DeleteBucketCors) || ($.eventName = DeleteBucketLifecycle) || ($.eventName = DeleteBucketReplication)) }`
and Click on 'Assign Metric'
6. In 'Create Metric Filter and Assign a Metric' page, Choose Filter Name, Metric Details parameter according to your requirement and click on 'Create Filter'
7. Click on 'Create Alarm',
 - ▣- In Step 1 specify metric details and conditions details as required and click on 'Next'
 - ▣- In Step 2 Select an SNS topic either by creating a new topic or use existing SNS topic/ARN and click on 'Next'
 - ▣- In Step 3 Select name and description to alarm and click on 'Next'
 - ▣- In Step 4 Preview your data entered and click on 'Create Alarm'

Access Control / Section Account Management



2 Resource(s) Failed

058264157785, 818698786219

Compliance Section: Account Management — Informational

- a. Define the types of system accounts allowed and prohibited.
- b. Create, enable, modify, disable, and remove system accounts in accordance with policy, procedures, prerequisites, and criteria.
- c. Specify:
 - 1. Authorized users of the system,
 - 2. Group and role membership, and
 - 3. Access authorizations (i.e., privileges) for each account.
- d. Authorize access to the system based on:
 - 1. A valid access authorization and
 - 2. Intended system usage.
- e. Monitor the use of system accounts.
- f. Disable system accounts when:
 - 1. The accounts have expired,
 - 2. The accounts have been inactive for [Assignment: organization-defined time period],
 - 3. The accounts are no longer associated with a user or individual,
 - 4. The accounts are in violation of organizational policy, or
 - 5. Significant risks associated with individuals are discovered.
- g. Notify account managers and designated personnel or roles within:
 - 1. [Assignment: organization-defined time period] when accounts are no longer required.
 - 2. [Assignment: organization-defined time period] when users are terminated or transferred.
 - 3. [Assignment: organization-defined time period] when system usage or the need-to-know changes for an individual.
- h. Require that users log out of the system after [Assignment: organization-defined time period] of expected inactivity or when [Assignment: organization-defined circumstances].

AWS Log metric filter and alarm does not exist for VPC changes

This policy identifies the AWS regions which do not have a log metric filter and alarm for VPC changes. Monitoring changes to VPC will help ensure that resources and services are not unintentionally exposed. It is recommended that a metric filter and alarm be established for changes made to VPCs.

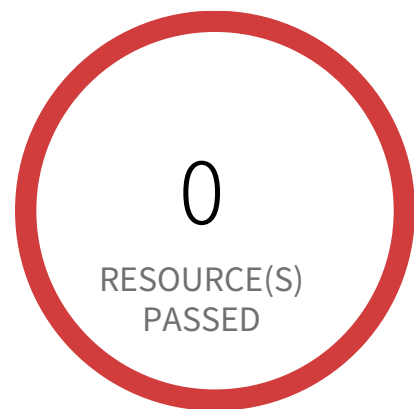
NOTE: This policy will trigger alert if you have at least one Cloudtrail with the multi trail is enabled, Logs all management events in your account and is not set with specific log metric filter and alarm.

First Seen January 28, 2025 at 12:06:58 PM UTC | **Resource Type** Other

Recommendations

1. Sign in to AWS Console
2. Navigate to CloudWatch dashboard
3. Click on 'Log groups' in the 'Logs' section (Left panel)
4. Select the log group created for your CloudTrail trail event logs (CloudTrail should be multi trail enabled with all management events captured) and click 'Create Metric Filter' button.
5. In 'Define Logs Metric Filter' page, add 'Filter pattern' value as
`{ ($.eventName = CreateVpc) || ($.eventName = DeleteVpc) || ($.eventName = ModifyVpcAttribute) || ($.eventName = AcceptVpcPeeringConnection) || ($.eventName = CreateVpcPeeringConnection) || ($.eventName = DeleteVpcPeeringConnection) || ($.eventName = RejectVpcPeeringConnection) || ($.eventName = AttachClassicLinkVpc) || ($.eventName = DetachClassicLinkVpc) || ($.eventName = DisableVpcClassicLink) || ($.eventName = EnableVpcClassicLink) }`
and Click on 'Assign Metric'
6. In 'Create Metric Filter and Assign a Metric' page, Choose Filter Name, Metric Details parameter according to your requirement and click on 'Create Filter'
7. Click on 'Create Alarm',
 - ▣- In Step 1 specify metric details and conditions details as required and click on 'Next'
 - ▣- In Step 2 Select an SNS topic either by creating a new topic or use existing SNS topic/ARN and click on 'Next'
 - ▣- In Step 3 Select name and description to alarm and click on 'Next'
 - ▣- In Step 4 Preview your data entered and click on 'Create Alarm'

Access Control / Section Account Management



2 Resource(s) Failed

058264157785, 818698786219

Compliance Section: Account Management — Informational

- a. Define the types of system accounts allowed and prohibited.
- b. Create, enable, modify, disable, and remove system accounts in accordance with policy, procedures, prerequisites, and criteria.
- c. Specify:
 1. Authorized users of the system,
 2. Group and role membership, and
 3. Access authorizations (i.e., privileges) for each account.
- d. Authorize access to the system based on:
 1. A valid access authorization and
 2. Intended system usage.
- e. Monitor the use of system accounts.
- f. Disable system accounts when:
 1. The accounts have expired,
 2. The accounts have been inactive for [Assignment: organization-defined time period],
 3. The accounts are no longer associated with a user or individual,
 4. The accounts are in violation of organizational policy, or
 5. Significant risks associated with individuals are discovered.
- g. Notify account managers and designated personnel or roles within:
 1. [Assignment: organization-defined time period] when accounts are no longer required.
 2. [Assignment: organization-defined time period] when users are terminated or transferred.
 3. [Assignment: organization-defined time period] when system usage or the need-to-know changes for an individual.
- h. Require that users log out of the system after [Assignment: organization-defined time period] of expected inactivity or when [Assignment: organization-defined circumstances].

AWS Log metric filter and alarm does not exist for disabling or scheduled deletion of customer created CMKs

This policy identifies the AWS regions which do not have a log metric filter and alarm for disabling or scheduled deletion of customer created CMKs. Data encrypted with disabled or deleted keys will no longer be accessible. It is recommended that a metric filter and alarm be established for customer created CMKs which have changed state to disabled or scheduled deletion.

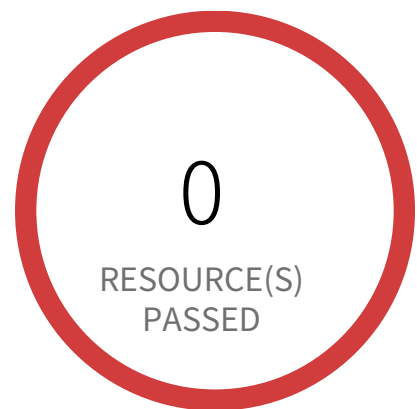
NOTE: This policy will trigger alert if you have at least one Cloudtrail with the multi trail is enabled, Logs all management events in your account and is not set with specific log metric filter and alarm.

First Seen January 28, 2025 at 12:06:58 PM UTC | **Resource Type** Other

Recommendations

1. Sign in to AWS Console
2. Navigate to CloudWatch dashboard
3. Click on 'Log groups' in the 'Logs' section (Left panel)
4. Select the log group created for your CloudTrail trail event logs (CloudTrail should be multi trail enabled with all management events captured) and click 'Create Metric Filter' button.
5. In 'Define Logs Metric Filter' page, add 'Filter pattern' value as
`{ ($.eventSource = kms.amazonaws.com) && (($.eventName=DisableKey)||($.eventName=ScheduleKeyDeletion)) }`
and Click on 'Assign Metric'
6. In 'Create Metric Filter and Assign a Metric' page, Choose Filter Name, Metric Details parameter according to your requirement and click on 'Create Filter'
7. Click on 'Create Alarm',
 - In Step 1 specify metric details and conditions details as required and click on 'Next'
 - In Step 2 Select an SNS topic either by creating a new topic or use existing SNS topic/ARN and click on 'Next'
 - In Step 3 Select name and description to alarm and click on 'Next'
 - In Step 4 Preview your data entered and click on 'Create Alarm'

Access Control / Section Account Management



2 Resource(s) Failed

058264157785, 818698786219

Compliance Section: Account Management — Informational

- a. Define the types of system accounts allowed and prohibited.
- b. Create, enable, modify, disable, and remove system accounts in accordance with policy, procedures, prerequisites, and criteria.
- c. Specify:
 1. Authorized users of the system,
 2. Group and role membership, and
 3. Access authorizations (i.e., privileges) for each account.
- d. Authorize access to the system based on:
 1. A valid access authorization and
 2. Intended system usage.
- e. Monitor the use of system accounts.
- f. Disable system accounts when:
 1. The accounts have expired,
 2. The accounts have been inactive for [Assignment: organization-defined time period],
 3. The accounts are no longer associated with a user or individual,
 4. The accounts are in violation of organizational policy, or
 5. Significant risks associated with individuals are discovered.
- g. Notify account managers and designated personnel or roles within:
 1. [Assignment: organization-defined time period] when accounts are no longer required.
 2. [Assignment: organization-defined time period] when users are terminated or transferred.
 3. [Assignment: organization-defined time period] when system usage or the need-to-know changes for an individual.
- h. Require that users log out of the system after [Assignment: organization-defined time period] of expected inactivity or when [Assignment: organization-defined circumstances].

AWS Log metric filter and alarm does not exist for unauthorized API calls

This policy identifies the AWS regions which do not have a log metric filter and alarm for unauthorized API calls. Monitoring unauthorized API calls will help reveal application errors and may reduce the time to detect malicious activity. It is recommended that a metric filter and alarm be established for unauthorized API calls.

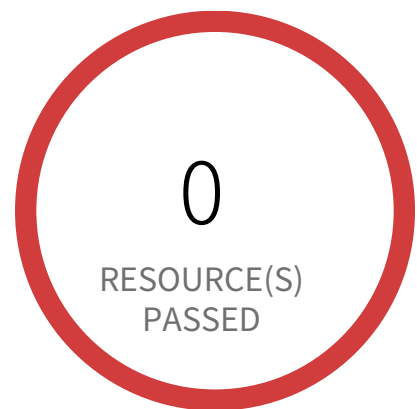
NOTE: This policy will trigger alert if you have at least one Cloudtrail with the multi trail is enabled, Logs all management events in your account and is not set with specific log metric filter and alarm.

First Seen January 28, 2025 at 12:07:04 PM UTC | **Resource Type** Other

Recommendations

1. Sign in to AWS Console
2. Navigate to CloudWatch dashboard
3. Click on 'Log groups' in the 'Logs' section (Left panel)
4. Select the log group created for your CloudTrail trail event logs (CloudTrail should be multi trail enabled with all management events captured) and click 'Create Metric Filter' button.
5. In 'Define Logs Metric Filter' page, add 'Filter pattern' value as
`{ ($.errorCode = "*UnauthorizedOperation") || ($.errorCode = "AccessDenied*") }`
and Click on 'Assign Metric'
6. In 'Create Metric Filter and Assign a Metric' page, Choose Filter Name, Metric Details parameter according to your requirement and click on 'Create Filter'
7. Click on 'Create Alarm',
 - In Step 1 specify metric details and conditions details as required and click on 'Next'
 - In Step 2 Select an SNS topic either by creating a new topic or use existing SNS topic/ARN and click on 'Next'
 - In Step 3 Select name and description to alarm and click on 'Next'
 - In Step 4 Preview your data entered and click on 'Create Alarm'

Access Control / Section Account Management



2 Resource(s) Failed

058264157785, 818698786219

Compliance Section: Account Management — Informational

- a. Define the types of system accounts allowed and prohibited.
- b. Create, enable, modify, disable, and remove system accounts in accordance with policy, procedures, prerequisites, and criteria.
- c. Specify:
 1. Authorized users of the system,
 2. Group and role membership, and
 3. Access authorizations (i.e., privileges) for each account.
- d. Authorize access to the system based on:
 1. A valid access authorization and
 2. Intended system usage.
- e. Monitor the use of system accounts.
- f. Disable system accounts when:
 1. The accounts have expired,
 2. The accounts have been inactive for [Assignment: organization-defined time period],
 3. The accounts are no longer associated with a user or individual,
 4. The accounts are in violation of organizational policy, or
 5. Significant risks associated with individuals are discovered.
- g. Notify account managers and designated personnel or roles within:
 1. [Assignment: organization-defined time period] when accounts are no longer required.
 2. [Assignment: organization-defined time period] when users are terminated or transferred.
 3. [Assignment: organization-defined time period] when system usage or the need-to-know changes for an individual.
- h. Require that users log out of the system after [Assignment: organization-defined time period] of expected inactivity or when [Assignment: organization-defined circumstances].

AWS Log metric filter and alarm does not exist for usage of root account

This policy identifies the AWS regions that do not have a log metric filter and alarm for usage of a root account. Monitoring for root account logins will provide visibility into the use of a fully privileged account and an opportunity to reduce its use it. Failure to monitor root account logins may result in a lack of visibility into unauthorized use or attempts to access the root account, posing potential security risks to your AWS environment. It is recommended that a metric filter and alarm be established for detecting changes to CloudTrail's configurations.

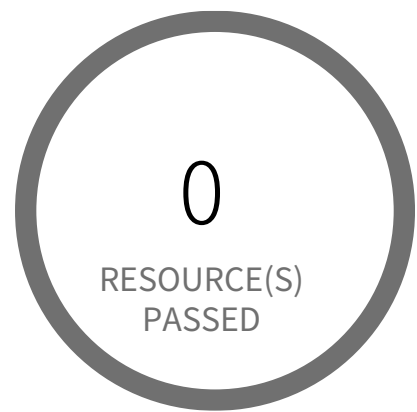
NOTE: This policy will trigger alert if you have at least one Cloudtrail with the multi trail is enabled, Logs all management events in your account and is not set with specific log metric filter and alarm.

First Seen January 28, 2025 at 12:06:58 PM UTC | **Resource Type** Other

Recommendations

1. Sign in to the AWS Console.
2. Navigate to the CloudWatch dashboard.
3. Click on 'Log groups' in the 'Logs' section (Left panel)
4. Select the log group created for your CloudTrail trail event logs (Cloudtrail should be multi-trail enabled with all Management Events captured) and click the Actions Dropdown Button -> Click 'Create Metric Filter' button.
5. In the 'Define Pattern' page, add the 'Filter pattern' value as
`{ $.userIdentity.type = "Root" && $.userIdentity.invokedBy NOT EXISTS && $.eventType != "AwsServiceEvent" }`
and Click on 'NEXT'.
6. In the 'Assign Metric' page, Choose Filter Name, and Metric Details parameter according to your requirement and click on 'Next'.
7. Under the 'Review and Create' page, Review details and click 'Create Metric Filter'.
8. To create an alarm based on a log group-metric filter, Refer to the below link
https://docs.aws.amazon.com/AmazonCloudWatch/latest/monitoring/Create_alarm_log_group_metric_filter.html

Access Control / Section Account Management



0 Resource(s) Failed

Compliance Section: Account Management ●●●● Low

- a. Define the types of system accounts allowed and prohibited.
- b. Create, enable, modify, disable, and remove system accounts in accordance with policy, procedures, prerequisites, and criteria.
- c. Specify:
 - 1. Authorized users of the system,
 - 2. Group and role membership, and
 - 3. Access authorizations (i.e., privileges) for each account.
- d. Authorize access to the system based on:
 - 1. A valid access authorization and
 - 2. Intended system usage.
- e. Monitor the use of system accounts.
- f. Disable system accounts when:
 - 1. The accounts have expired,
 - 2. The accounts have been inactive for [Assignment: organization-defined time period],
 - 3. The accounts are no longer associated with a user or individual,
 - 4. The accounts are in violation of organizational policy, or
 - 5. Significant risks associated with individuals are discovered.
- g. Notify account managers and designated personnel or roles within:
 - 1. [Assignment: organization-defined time period] when accounts are no longer required.
 - 2. [Assignment: organization-defined time period] when users are terminated or transferred.
 - 3. [Assignment: organization-defined time period] when system usage or the need-to-know changes for an individual.
- h. Require that users log out of the system after [Assignment: organization-defined time period] of expected inactivity or when [Assignment: organization-defined circumstances].

AWS Neptune Cluster not configured with IAM authentication

This policy identifies AWS Neptune clusters that are not configured with IAM authentication. If you enable IAM authentication you don't need to store user credentials in the database, because authentication is managed externally using IAM. IAM database authentication ensures the network traffic to and from database clusters is encrypted using Secure Sockets Layer (SSL), provides central access management to your database resources and enforces use of profile credentials instead of a password, for greater security.

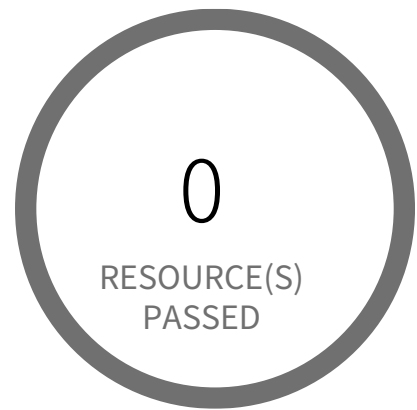
First Seen N/A | **Resource Type** Other

Recommendations

To enable IAM authentication for AWS Neptune cluster follow the steps mentioned in below URL:

<https://docs.aws.amazon.com/neptune/latest/userguide/iam-auth-enable.html>

Access Control / Section Account Management



0 Resource(s) Failed

Compliance Section: Account Management ●●●● Low

- a. Define the types of system accounts allowed and prohibited.
- b. Create, enable, modify, disable, and remove system accounts in accordance with policy, procedures, prerequisites, and criteria.
- c. Specify:
 1. Authorized users of the system,
 2. Group and role membership, and
 3. Access authorizations (i.e., privileges) for each account.
- d. Authorize access to the system based on:
 1. A valid access authorization and
 2. Intended system usage.
- e. Monitor the use of system accounts.
- f. Disable system accounts when:
 1. The accounts have expired,
 2. The accounts have been inactive for [Assignment: organization-defined time period],
 3. The accounts are no longer associated with a user or individual,
 4. The accounts are in violation of organizational policy, or
 5. Significant risks associated with individuals are discovered.
- g. Notify account managers and designated personnel or roles within:
 1. [Assignment: organization-defined time period] when accounts are no longer required.
 2. [Assignment: organization-defined time period] when users are terminated or transferred.
 3. [Assignment: organization-defined time period] when system usage or the need-to-know changes for an individual.
- h. Require that users log out of the system after [Assignment: organization-defined time period] of expected inactivity or when [Assignment: organization-defined circumstances].

[AWS OpenSearch Fine-grained access control is disabled](#)

This policy identifies AWS OpenSearch which has Fine-grained access control disabled. Fine-grained access control offers additional ways of controlling access to your data on AWS OpenSearch Service. It is highly recommended enabling fine-grained access control to protect the data on your domain.

For more information, please follow the URL given below,
<https://docs.aws.amazon.com/opensearch-service/latest/developerguide/fgac.html>

First Seen N/A | **Resource Type** Other

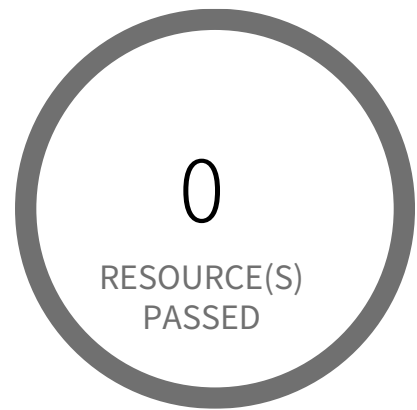
Recommendations

To enable fine-grained access control on an existing domain (console)

Enabling the encryption feature on existing domains requires Elasticsearch 6.7 or later. If your Elasticsearch 6.7 or later, follow below steps to enable encryption on existing Elasticsearch domain:

1. Sign into the AWS console
2. In the console, select the specific region from region drop down on the top right corner, for which the alert is generated
3. Navigate to Amazon OpenSearch Service Dashboard
4. From the navigation panel, Click on 'Domains' Under the 'Managed clusters'
5. Select the reported domain and choose 'Actions' and 'Edit security configuration'.
6. Select Enable fine-grained access control under the 'Fine-grained access control' section.
 - 6a. Choose how to create the master user:
 - i. If you want to use IAM for user management, choose Set IAM ARN as master user and specify the ARN for an IAM role.
 - ii. If you want to use the internal user database, choose Create master user and specify a username and password.
 - 6b. (Optional) Select Enable migration period for open/IP-based access policy.
7. Choose Save changes.

Access Control / Section Account Management



0 Resource(s) Failed

Compliance Section: Account Management ●●●● Low

- a. Define the types of system accounts allowed and prohibited.
- b. Create, enable, modify, disable, and remove system accounts in accordance with policy, procedures, prerequisites, and criteria.
- c. Specify:
 - 1. Authorized users of the system,
 - 2. Group and role membership, and
 - 3. Access authorizations (i.e., privileges) for each account.
- d. Authorize access to the system based on:
 - 1. A valid access authorization and
 - 2. Intended system usage.
- e. Monitor the use of system accounts.
- f. Disable system accounts when:
 - 1. The accounts have expired,
 - 2. The accounts have been inactive for [Assignment: organization-defined time period],
 - 3. The accounts are no longer associated with a user or individual,
 - 4. The accounts are in violation of organizational policy, or
 - 5. Significant risks associated with individuals are discovered.
- g. Notify account managers and designated personnel or roles within:
 - 1. [Assignment: organization-defined time period] when accounts are no longer required.
 - 2. [Assignment: organization-defined time period] when users are terminated or transferred.
 - 3. [Assignment: organization-defined time period] when system usage or the need-to-know changes for an individual.
- h. Require that users log out of the system after [Assignment: organization-defined time period] of expected inactivity or when [Assignment: organization-defined circumstances].

AWS RDS cluster not configured with IAM authentication

This policy identifies RDS clusters that are not configured with IAM authentication. If you enable IAM authentication you don't need to store user credentials in the database, because authentication is managed externally using IAM. IAM database authentication provides the network traffic to and from database clusters is encrypted using Secure Sockets Layer (SSL), Centrally manage access to your database resources and Profile credentials instead of a password, for greater security.

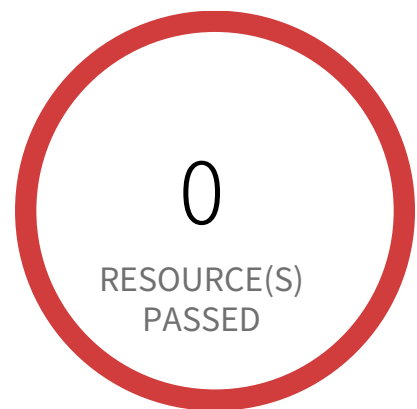
For details:
<https://docs.aws.amazon.com/AmazonRDS/latest/AuroraUserGuide/UsingWithRDS.IAMDBAuth.html>

First Seen N/A | **Resource Type** Other

Recommendations

To enable IAM authentication on your RDS cluster follow the below mentioned URL:
<https://docs.aws.amazon.com/AmazonRDS/latest/AuroraUserGuide/UsingWithRDS.IAMDBAuth.Enabling.html>

Access Control / Section Account Management



1 Resource(s) Failed

database-1

Compliance Section: Account Management ●●● Medium

- a. Define the types of system accounts allowed and prohibited.
- b. Create, enable, modify, disable, and remove system accounts in accordance with policy, procedures, prerequisites, and criteria.
- c. Specify:
 - 1. Authorized users of the system,
 - 2. Group and role membership, and
 - 3. Access authorizations (i.e., privileges) for each account.
- d. Authorize access to the system based on:
 - 1. A valid access authorization and
 - 2. Intended system usage.
- e. Monitor the use of system accounts.
- f. Disable system accounts when:
 - 1. The accounts have expired,
 - 2. The accounts have been inactive for [Assignment: organization-defined time period],
 - 3. The accounts are no longer associated with a user or individual,
 - 4. The accounts are in violation of organizational policy, or
 - 5. Significant risks associated with individuals are discovered.
- g. Notify account managers and designated personnel or roles within:
 - 1. [Assignment: organization-defined time period] when accounts are no longer required.
 - 2. [Assignment: organization-defined time period] when users are terminated or transferred.
 - 3. [Assignment: organization-defined time period] when system usage or the need-to-know changes for an individual.
- h. Require that users log out of the system after [Assignment: organization-defined time period] of expected inactivity or when [Assignment: organization-defined circumstances].

AWS RDS instance not configured with IAM authentication

This policy identifies RDS instances that are not configured with IAM authentication. If you enable IAM authentication you don't need to store user credentials in the database, because authentication is managed externally using IAM. IAM database authentication provides the network traffic to and from database instances is encrypted using Secure Sockets Layer (SSL), Centrally manage access to your database resources and Profile credentials instead of a password, for greater security.

For details:

<https://docs.aws.amazon.com/AmazonRDS/latest/UserGuide/UsingWithRDS.IAMDBAuth.html>

NOTE: IAM database authentication works only with MySQL and PostgreSQL. IAM database authentication is not available on all database engines; please refer <https://docs.aws.amazon.com/AmazonRDS/latest/UserGuide/UsingWithRDS.IAMDBAuth.html#UsingWithRDS.IAMDBAuth.Availability> for available versions.

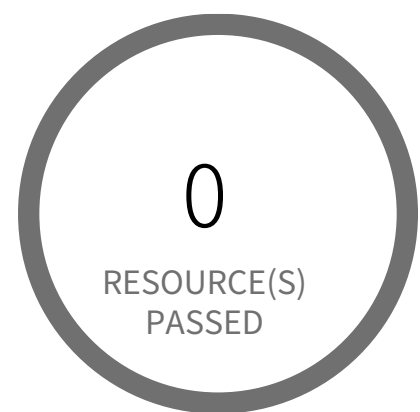
First Seen June 16, 2025 at 12:19:29 PM UTC | **Resource Type** Other

Recommendations

To enable IAM authentication follow the below mentioned URL:

<https://docs.aws.amazon.com/AmazonRDS/latest/UserGuide/UsingWithRDS.IAMDBAuth.Enabling.html>

Access Control / Section Account Management



0 Resource(s) Failed

Compliance Section: Account Management — Informational

- a. Define the types of system accounts allowed and prohibited.
- b. Create, enable, modify, disable, and remove system accounts in accordance with policy, procedures, prerequisites, and criteria.
- c. Specify:
 - 1. Authorized users of the system,
 - 2. Group and role membership, and
 - 3. Access authorizations (i.e., privileges) for each account.
- d. Authorize access to the system based on:
 - 1. A valid access authorization and
 - 2. Intended system usage.
- e. Monitor the use of system accounts.
- f. Disable system accounts when:
 - 1. The accounts have expired,
 - 2. The accounts have been inactive for [Assignment: organization-defined time period],
 - 3. The accounts are no longer associated with a user or individual,
 - 4. The accounts are in violation of organizational policy, or
 - 5. Significant risks associated with individuals are discovered.
- g. Notify account managers and designated personnel or roles within:
 - 1. [Assignment: organization-defined time period] when accounts are no longer required.
 - 2. [Assignment: organization-defined time period] when users are terminated or transferred.
 - 3. [Assignment: organization-defined time period] when system usage or the need-to-know changes for an individual.
- h. Require that users log out of the system after [Assignment: organization-defined time period] of expected inactivity or when [Assignment: organization-defined circumstances].

[AWS SageMaker notebook instance with root access enabled](#)

This policy identifies the SageMaker notebook instances which are enabled with root access. Root access means having administrator privileges, users with root access can access and edit all files on the compute instance, including system-critical files. Removing root access prevents notebook users from deleting system-level software, installing new software, and modifying essential environment components. NOTE: Lifecycle configurations need root access to be able to set up a notebook instance. Because of this, lifecycle configurations associated with a notebook instance always run with root access even if you disable root access for users.

For more details:
<https://docs.aws.amazon.com/sagemaker/latest/dg/nbi-root-access.html>

First Seen N/A | **Resource Type** Other

Recommendations

1. Log in to AWS console
 2. Navigate to the AWS SageMaker dashboard
 3. Choose Notebook instances (Left panel)
 4. Click on the reported SageMaker notebook instance
- Note: To update root access for SageMaker notebook instances; Instances need to be stopped. So stop running instance before editing.
5. In the 'Notebook instance settings' section, click on 'Edit'
 6. On the Edit notebook instance page, within the 'Permissions and encryption' section,
From the 'Root access - optional' options, select 'Disable - Don't give users root access to the notebook'
 7. Click on the 'Update notebook instance'

Access Control / Section Account Management



0 Resource(s) Failed

Compliance Section: Account Management ●●● Low

- a. Define the types of system accounts allowed and prohibited.
- b. Create, enable, modify, disable, and remove system accounts in accordance with policy, procedures, prerequisites, and criteria.
- c. Specify:
 - 1. Authorized users of the system,
 - 2. Group and role membership, and
 - 3. Access authorizations (i.e., privileges) for each account.
- d. Authorize access to the system based on:
 - 1. A valid access authorization and
 - 2. Intended system usage.
- e. Monitor the use of system accounts.
- f. Disable system accounts when:
 - 1. The accounts have expired,
 - 2. The accounts have been inactive for [Assignment: organization-defined time period],
 - 3. The accounts are no longer associated with a user or individual,
 - 4. The accounts are in violation of organizational policy, or
 - 5. Significant risks associated with individuals are discovered.
- g. Notify account managers and designated personnel or roles within:
 - 1. [Assignment: organization-defined time period] when accounts are no longer required.
 - 2. [Assignment: organization-defined time period] when users are terminated or transferred.
 - 3. [Assignment: organization-defined time period] when system usage or the need-to-know changes for an individual.
- h. Require that users log out of the system after [Assignment: organization-defined time period] of expected inactivity or when [Assignment: organization-defined circumstances].

AWS Secret Manager Automatic Key Rotation is not enabled

This policy identifies AWS Secret Manager that are not enabled with key rotation. As a security best practice, it is important to rotate the keys periodically so that if the keys are compromised, the data in the underlying service is still secure with the new keys.

NOTE: This policy does not include secret manager which are managed by some of the AWS services that store AWS Secrets Manager secrets on your behalf. Refer: <https://docs.aws.amazon.com/secretsmanager/latest/userguide/service-linked-secrets.html>

First Seen N/A | **Resource Type** Other

Recommendations

To enable Automatic Key Rotation for AWS Secret Manager follow the steps mentioned in below URL:

<https://aws.amazon.com/blogs/security/how-to-configure-rotation-windows-for-secrets-stored-in-aws-secrets-manager/#:~:text=Use%20Case%20>

Access Control / Section Access Enforcement



0 Resource(s) Failed

Compliance Section: Access Enforcement Informational

Enforce approved authorizations for logical access to CUI and system resources in accordance with applicable access control policies.

AWS EC2 Instance IAM Role not enabled

AWS provides Identity Access Management (IAM) roles to securely access AWS services and resources. The role is an identity with permission policies that define what the identity can and cannot do in AWS. As a best practice, create IAM roles and attach the role to manage EC2 instance permissions securely instead of distributing or sharing keys or passwords.

First Seen N/A | Resource Type Other

Recommendations

The most common setup is the AWS default that allows for EC2 access to AWS Services. For most, this is a great way to realize flexible, yet secure, EC2 access enabled for your instances. Select this when you launch EC2 instances to automatically inherit these permissions.

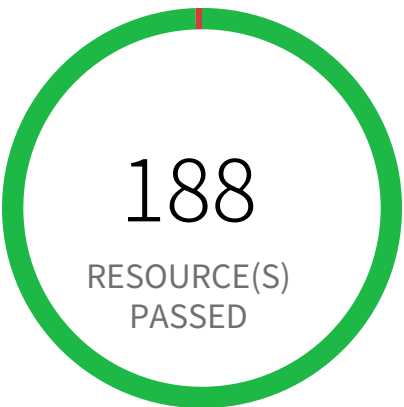
IAM

1. Go to the AWS console IAM dashboard.
2. In the navigation pane, choose Roles, Create new role.
3. Under 'Choose the service that will use this role' select EC2, then 'Next:Permissions.'
4. On the Attach permissions policies page, select an AWS managed policy that grants your instance access to the resources that they need, then 'Next:Tags.'
5. Add tags (optional), then select 'Next:Review.'
6. On the Create role and Review page, type a name for the role and choose Create role.

EC2

1. Go to the AWS console EC2 dashboard.
2. Select Running Instances.
3. Check the instance you want to modify.
4. From the Actions pull down menu, select Instance Settings and Attach/Replace IAM Role.
5. On the Attach/Replace IAM Role page, under the IAM role pull down menu, choose the role created in the IAM steps above.

Access Control / Section Access Enforcement



1 Resource(s) Failed
privesc14-UpdatingAssumeRolePolicy

Compliance Section: Access Enforcement ●●● Medium

Enforce approved authorizations for logical access to CUI and system resources in accordance with applicable access control policies.

AWS IAM policy allows assume role permission across all services

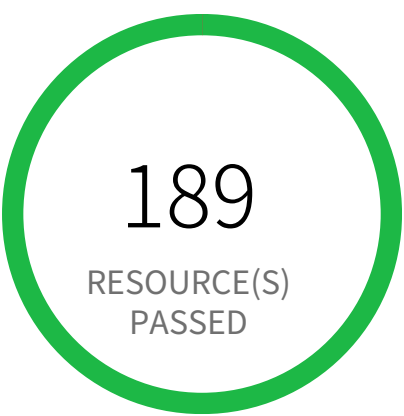
This policy identifies AWS IAM policy which allows assume role permission across all services. Typically, AssumeRole is used if you have multiple accounts and need to access resources from each account then you can create long term credentials in one account and then use temporary security credentials to access all the other accounts by assuming roles in those accounts.

First Seen June 11, 2024 at 11:14:30 PM UTC | **Resource Type** IAM Policy

Recommendations

- 1. Log in to the AWS Console
- 2. Navigate to the 'IAM' service.
- 3. Identify the reported policy
- 4. Change the Service element of the policy document to be more restrictive so that it only allows AssumeRole permission on select services.

Access Control / Section Access Enforcement



0 Resource(s) Failed

Compliance Section: Access Enforcement ●●●● Medium

Enforce approved authorizations for logical access to CUI and system resources in accordance with applicable access control policies.

AWS IAM policy overly permissive to STS services

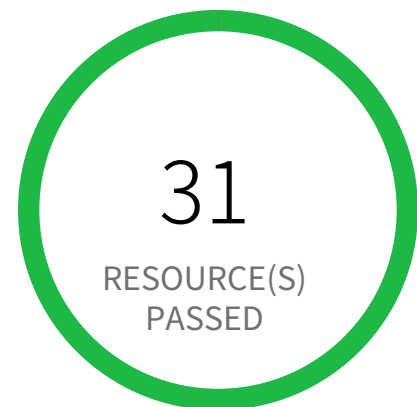
This policy identifies the IAM policies that are overly permissive to STS services. AWS Security Token Service (AWS STS) is a web service that enables you to request temporary credentials for AWS Identity and Access Management (IAM) users or for users that you authenticate (federated users). It is recommended to follow the principle of least privileges ensuring that only restricted STS services for restricted resources.

First Seen N/A | **Resource Type** Other

Recommendations

- 1. Log in to the AWS Console
- 2. Navigate to the 'IAM' service
- 3. Click on the 'Policies' in left hand panel and Click on the reported IAM policy
- 4. Under Permissions tab, Change the element of the policy document to be more restrictive so that it only allows restricted STS permissions on selected resources instead of wildcards (sts:* and Resource:*) OR Put condition statement with least privilege access.

Access Control / Section Access Enforcement



0 Resource(s) Failed

Compliance Section: Access Enforcement ●●●● Medium

Enforce approved authorizations for logical access to CUI and system resources in accordance with applicable access control policies.

AWS KMS Key policy overly permissive

This policy identifies KMS Keys that have a key policy overly permissive. Key policies are the primary way to control access to customer master keys (CMKs) in AWS KMS. It is recommended to follow the principle of least privilege ensuring that KMS key policy does not have all the permissions to be able to complete a malicious action.

For more details:

<https://docs.aws.amazon.com/kms/latest/developerguide/control-access-overview.html#overview-policy-elements>

First Seen N/A | **Resource Type** Other

Recommendations

1. Log in to the AWS console
2. In the console, select the specific region from region drop-down on the top right corner, for which the alert is generated
3. Navigate to Key Management Service (KMS)
4. Click on 'Customer managed keys' (Left Panel)
5. Select reported KMS Customer managed key
6. Click on the 'Key policy' tab
7. Click on 'Edit',
Replace the 'Everyone' grantee (i.e. '*') from the Principal element value with an AWS account ID or an AWS account ARN.
OR
Add a Condition clause to the existing policy statement so that the KMS key is restricted.
8. Click on 'Save Changes'

Access Control / Section Access Enforcement



0 Resource(s) Failed

Compliance Section: Access Enforcement ●●●● Low

Enforce approved authorizations for logical access to CUI and system resources in accordance with applicable access control policies.

AWS Lambda Function resource-based policy is overly permissive

This policy identifies Lambda Functions that have overly permissive resource-based policy. Lambda functions having overly permissive policy could lead to lateral movement in account or privilege being escalated when compromised. It is highly recommended to have the least privileged access policy to protect the Lambda Functions from unauthorized access.

For more details:

<https://docs.aws.amazon.com/lambda/latest/dg/access-control-resource-based.html>

First Seen N/A | **Resource Type** Other

Recommendations

To modify permission from AWS Lambda Function resource-based policy

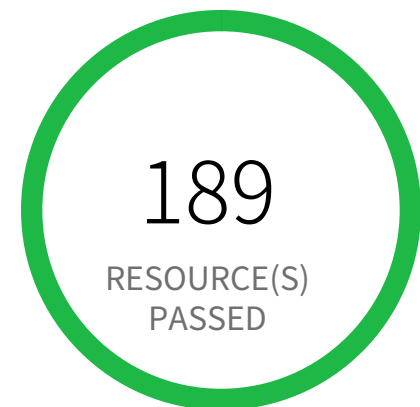
1. Sign in to the AWS console
2. Select the region, from the region drop-down, for which the alert is generated
3. Navigate to AWS Lambda Dashboard
4. Click on the 'Functions' (Left panel)
5. Select the lambda function on which the alert is generated
6. Go to Configuration tab
7. Select Permissions
8. Scroll to the \"Resource-based policy\" area
9. For each policy statement, use fine-grained and restrictive permissions instead of using wildcards (Lambda:* and Resource:*) OR add in appropriate conditions with least privilege access.
10. Click on \"Edit\" button to modify the statement
11. When you finish configuring the statement, choose 'Save'.

To remove permission from AWS Lambda Function resource-based policy

1. Sign in to the AWS console
2. Select the region, from the region drop-down, for which the alert is generated
3. Navigate to AWS Lambda Dashboard
4. Click on the 'Functions' (Left panel)
5. Select the lambda function on which the alert is generated
6. Go to Configuration tab
7. Select Permissions
8. Scroll to the \"Resource-based policy\" area
9. For each policy statement, use fine-grained and restrictive permissions instead of using wildcards (Lambda:* and Resource:*) OR add in

appropriate conditions with least privilege access.
10. Click on \"Delete\" button to modify the statement
11. In Delete statement dialog box, click on \"Delete\" button.

Access Control / Section Access Enforcement



0 Resource(s) Failed

Compliance Section: Access Enforcement ●●●● Low

Enforce approved authorizations for logical access to CUI and system resources in accordance with applicable access control policies.

AWS Lambda IAM policy overly permissive to all traffic

This policy identifies AWS Lambda IAM policies that are overly permissive to all traffic. It is recommended that the Lambda should be granted access restrictions so that only authorized users and applications have access to the service.

For more details:

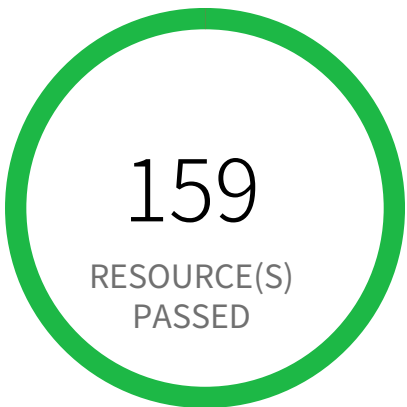
<https://docs.aws.amazon.com/lambda/latest/dg/security-iam.html>

First Seen N/A | **Resource Type** Other

Recommendations

1. Login to AWS console
2. Goto IAM Services
3. Click on 'Policies' in left hand panel
4. Search for the Policy for which the Alert is generated and click on it
5. Under Permissions tab, click on Edit policy
6. Under the Visual editor, for each of the 'lambda' Service, click to expand and perform following.
 - 6.a. Click to expand 'Request conditions'
 - 6.b. Under the 'Source IP', remove the row with the entry '0.0.0.0/0' or ':::/0'. Add condition with restrictive IP ranges.
7. Click on Review policy and Save changes

Access Control / Section Access Enforcement



0 Resource(s) Failed

Compliance Section: Access Enforcement Informational

Enforce approved authorizations for logical access to CUI and system resources in accordance with applicable access control policies.

AWS Lambda execution role having overly permissive inline policy

This policy identifies AWS Lambda Function execution role having overly permissive inline policy embedded. Lambda functions having overly permissive policy could lead to lateral movement in account or privilege being escalated when compromised. It is highly recommended to have the least privileged access policy to protect the Lambda Functions from unauthorized access.

First Seen N/A | **Resource Type** Other

Recommendations

Refer to the following URL to give fine-grained and restrictive permissions to IAM Role Inline Policy:
https://docs.aws.amazon.com/IAM/latest/UserGuide/access_policies_manage-edit.html#edit-inline-policy-console

Access Control / Section Access Enforcement



0 Resource(s) Failed

Compliance Section: Access Enforcement ●●●● Medium

Enforce approved authorizations for logical access to CUI and system resources in accordance with applicable access control policies.

[AWS Lambda function URL having overly permissive cross-origin resource sharing permissions](#)

AWS Lambda functions with overly permissive CORS configurations expose sensitive data and functionality to unauthorized access. Improperly configured CORS settings, specifically using wildcard characters in 'allowOrigins', enable any origin to invoke the function.

Lambda functions act as crucial components in serverless architectures. Misconfiguration of CORS settings allows malicious actors to send unauthorized requests, potentially leading to data breaches, denial-of-service attacks, or exploitation of the function's logic via cross-site scripting. This undermines the security of your application and its associated data.

The impact of this misconfiguration is significant, potentially resulting in unauthorized data access, application logic manipulation, and service disruption. Restricting CORS configuration to specific origins and HTTP methods ensures that only legitimate clients can interact with the Lambda function, mitigating these risks.

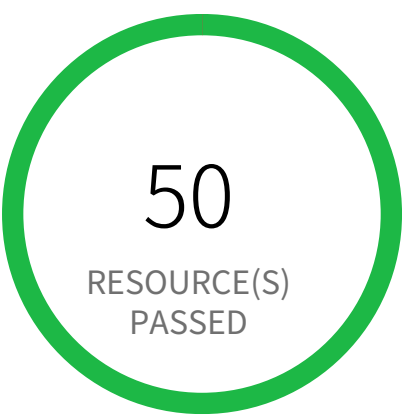
To remediate, configure Lambda function CORS settings to explicitly list allowed origins ('allowOrigins') and HTTP methods ('allowMethods'). Avoid using wildcard characters. Regularly review and update these settings as your application's access needs change. Employ least privilege principles in configuring your Lambda function's access control.

First Seen N/A | **Resource Type** Other

Recommendations

To properly configure CORS permissions, refer the following URL:
https://docs.aws.amazon.com/lambda/latest/dg/API_Cors.html

Access Control / Section Access Enforcement



0 Resource(s) Failed

Compliance Section: Access Enforcement ●●●● Low

Enforce approved authorizations for logical access to CUI and system resources in accordance with applicable access control policies.

AWS OpenSearch attached security group overly permissive to all traffic

This policy identifies AWS OpenSearch attached Security group that are overly permissive to all traffic. Security group enforces IP-based access policies to OpenSearch. As a best practice, restrict traffic solely from known static IP addresses or CIDR range.

First Seen N/A | **Resource Type** Other

Recommendations

Before making any changes, please check the impact on your applications/services. If the Security Group reported indeed need to restrict all traffic, follow the instructions below:

- 1. Log in to the AWS console
- 2. Navigate to the 'VPC' service
- 3. Select the 'Security Group' reported in the alert
- 4. Click on 'Inbound Rules'
- 5. Remove the rule which has the 'Source' value as 0.0.0.0/0 or ::/0

Access Control / Section Access Enforcement



0 Resource(s) Failed

Compliance Section: Access Enforcement ●●●● Medium

Enforce approved authorizations for logical access to CUI and system resources in accordance with applicable access control policies.

AWS Private ECR repository policy is overly permissive

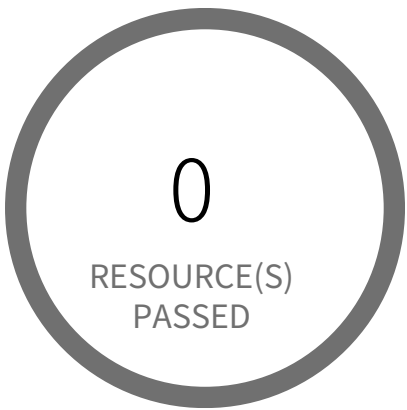
This policy identifies AWS Private ECR repositories that have overly permissive registry policies. An ECR(Elastic Container Registry) repository is a collection of Docker images available on the AWS cloud. These images might contain sensitive information which should be restricted to unauthorized users.

First Seen N/A | **Resource Type** Other

Recommendations

- 1. Log in to the AWS Console
- 2. In the console, select the specific region from region drop down on the top right corner, for which the alert is generated.
- 3. Navigate to 'ECR' dashboard from 'Services' dropdown
- 4. Go to 'Repository', from the left panel
- 5. Select the repository for which alert is being generated
- 6. Select the 'Permissions' option from left menu below 'repositories'
- 7. Click on 'Edit policy JSON' to modify the JSON so that Principal is restrictive
- 8. After modifications, click on 'Save'.

Access Control / Section Access Enforcement



0 Resource(s) Failed

Compliance Section: Access Enforcement ●●●● Medium

Enforce approved authorizations for logical access to CUI and system resources in accordance with applicable access control policies.

AWS RDS Cluster snapshot is accessible to public

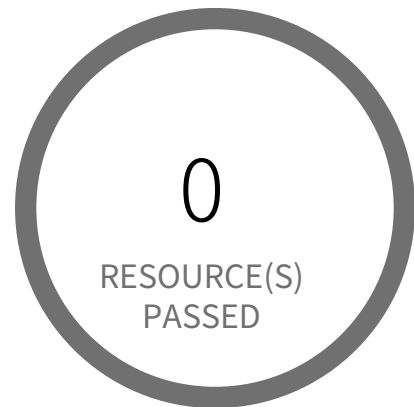
This policy identifies AWS RDS Cluster snapshots which is accessible to public. Amazon Relational Database Service (Amazon RDS) is a web service that makes it easier to setup and manage databases. If RDS Cluster snapshots are inadvertently shared to public, any unauthorized user with AWS console access can gain access to the snapshots and gain access to sensitive data.

First Seen N/A | **Resource Type** Other

Recommendations

- 1. Sign in to the AWS console
- 2. In the console, select the specific region from region drop down on the top right corner, for which the alert is generated
- 3. Navigate to the 'RDS' service
- 4. Click on 'Snapshots'
- 5. Under 'Manual' tab select the reported RDS Cluster
- 6. Click on 'Actions' and select 'Share snapshot'
- 7. Under 'DB snapshot visibility' select 'Private'
- 8. Click on 'Save'

Access Control / Section Access Enforcement



0 Resource(s) Failed

Compliance Section: Access Enforcement — Informational

Enforce approved authorizations for logical access to CUI and system resources in accordance with applicable access control policies.

AWS RDS Event subscription All event categories and All instances disabled for DB instance

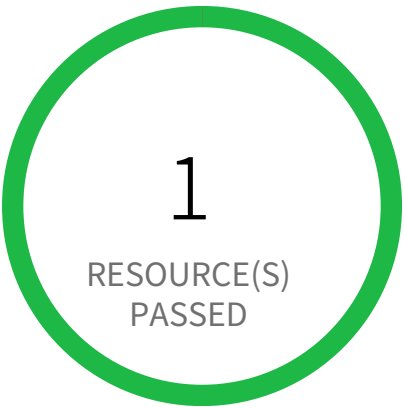
This policy identifies AWS RDS event subscriptions for DB instance which has 'All event categories' and 'All instances' is disabled. As a best practice enabling 'All event categories' for 'All instances' helps to get notified when an event occurs for a DB instance.

First Seen N/A | **Resource Type** Other

Recommendations

1. Sign into the AWS console
2. In the console, select the specific region from region drop down on the top right corner, for which the alert is generated
3. Navigate to Amazon RDS Dashboard
4. Click on 'Event subscriptions' (Left Panel)
5. Choose the reported Event subscription
6. Click on 'Edit'
7. On 'Edit event subscription' page, Under 'Details' section; Select 'Yes' for 'Enabled' and Make sure you have subscribed your DB to 'All instances' and 'All event categories'
8. Click on 'Edit'

Access Control / Section Access Enforcement



0 Resource(s) Failed

Compliance Section: Access Enforcement ●●●● Medium

Enforce approved authorizations for logical access to CUI and system resources in accordance with applicable access control policies.

AWS RDS PostgreSQL exposed to local file read vulnerability

This policy identifies AWS RDS PostgreSQL which are exposed to local file read vulnerability. AWS RDS PostgreSQL installed with vulnerable 'log_fdw' extension is exposed to local file read vulnerability, due to which attacker could gain access to local system files of the database instance within their account, including a file which contained credentials specific to PostgreSQL. It is highly recommended to upgrade AWS RDS PostgreSQL to the latest version.

For more information,
<https://aws.amazon.com/security/security-bulletins/AWS-2022-004/>

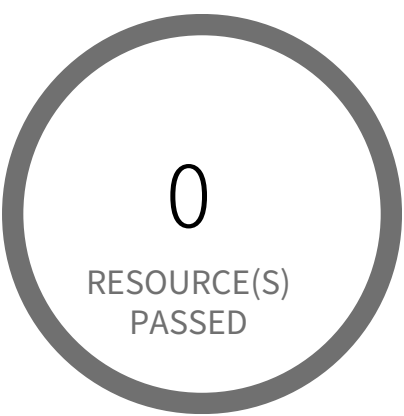
First Seen N/A | **Resource Type** Other

Recommendations

Amazon has deprecated affected versions of RDS for PostgreSQL and customers can no longer create new instances with the affected versions.

To upgrade the latest version of Amazon RDS for PostgreSQL, please follow below URL:
https://docs.aws.amazon.com/AmazonRDS/latest/UserGuide/USER_UpgradeDBInstance.PostgreSQL.html

Access Control / Section Access Enforcement



0 Resource(s) Failed

Compliance Section: Access Enforcement — Informational

Enforce approved authorizations for logical access to CUI and system resources in accordance with applicable access control policies.

AWS RDS Postgres Cluster does not have query logging enabled

This policy identifies RDS Postgres clusters with query logging disabled.

In AWS RDS PostgreSQL, by default, the logging level captures login failures, fatal server errors, deadlocks, and query failures. To log data changes, we recommend enabling cluster logging for monitoring and troubleshooting. To obtain adequate logs, an RDS cluster should have log_statement and log_min_duration_statement parameters configured.

It is a best practice to enable additional RDS cluster logging, which will help in data change monitoring and troubleshooting.

First Seen N/A | **Resource Type** Other

Recommendations

To modify the custom DB cluster parameter group to enable query logging, follow the below steps:

1. Sign in to the AWS Management Console and open the Amazon RDS console.
2. In the navigation pane, choose 'Parameter groups'.
3. In the list, choose the above-created parameter group that you want to modify.
4. For Parameter group actions, choose 'Edit'.
5. Change the value of the 'log_min_duration_statement' parameter to any value other than -1 you want to modify.
6. Change the value of 'log_statement' according to the requirements.
7. Choose 'Save Changes'.
8. Reboot the primary (writer) DB instance in the cluster to apply the changes to it.
9. Then reboot the reader DB instances to apply the changes to them.

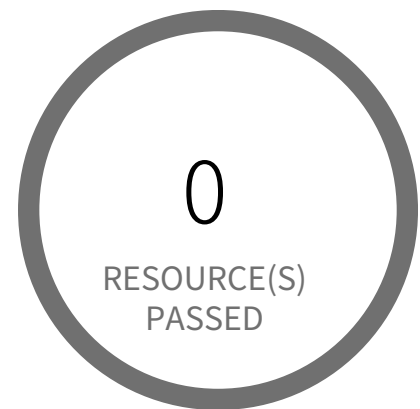
Please create a custom parameter group if the cluster has only the default parameter group using the following steps:

1. Sign in to the AWS Management Console and open the Amazon RDS console.
2. In the navigation pane, choose 'Parameter groups'.
3. Choose 'Create parameter group'. The Create parameter group window appears.
4. In the Parameter group family list, select a 'DB parameter group family'.
5. In the Type list, select 'DB cluster parameter group'.
6. In the Group name box, enter the name of the new DB cluster parameter group.
7. In the Description box, enter a description for the new DB cluster parameter group.
8. Choose 'Create'.

To modify an RDS cluster to use the custom parameter group, follow the below steps:

1. Sign in to the AWS Management Console and open the Amazon RDS console.
2. In the navigation pane, choose 'Databases', and then choose the 'DB instance' that you want to modify.
3. Choose 'Modify'. The Modify DB instance page appears.
4. Under 'Additional Configuration', select the above-created cluster parameter group from the DB parameter group dropdown.
5. Choose 'Continue' and check the summary of modifications.
6. (Optional) Choose 'Apply immediately' to apply the changes immediately. Choosing this option can cause downtime in some cases.
7. On the confirmation page, review your changes. If they are correct, choose 'Modify DB instance' to save your changes.

Access Control / Section Access Enforcement



0 Resource(s) Failed

Compliance Section: Access Enforcement ●●● Medium

Enforce approved authorizations for logical access to CUI and system resources in accordance with applicable access control policies.

AWS RDS cluster encryption in transit is not configured

This policy identifies AWS RDS database clusters that are not configured with encryption in transit. This covers MySQL, PostgreSQL, and Aurora clusters.

Enabling encryption is crucial to protect data as it moves through the network and enhances the security between clients and storage servers. Without encryption, sensitive data transmitted between your application and the database is vulnerable to interception by malicious actors. This could lead to unauthorized access, data breaches, and potential compromises of confidential information.

It is recommended that data be encrypted while in transit to ensure its security and reduce the risk of unauthorized access or data breaches.

First Seen N/A | **Resource Type** Other

Recommendations

To enable the in-transit encryption feature for your Amazon RDS cluster, perform the following actions:

Default cluster parameter groups for RDS DB clusters cannot be modified. Therefore, you must create a custom parameter group, modify it, and then attach it to your RDS for Cluster. Changes to parameters in a customer-created DB cluster parameter group are applied to all DB clusters that are associated with the DB cluster parameter group.

Follow the below links to create and associate a DB parameter group with a DB cluster,

To Create a DB cluster parameter group, refer to the below link

https://docs.aws.amazon.com/AmazonRDS/latest/UserGuide/USER_WorkingWithDBClusterParamGroups.html#USER_WorkingWith-ParamGroups.CreatingCluster

To Modifying parameters in a DB cluster parameter group,

1. Sign in to the AWS Management Console and open the Amazon RDS console at <https://console.aws.amazon.com/rds/>.

2. In the navigation pane, choose 'Parameter Groups'.

3. In the list, choose the parameter group that is associated with the reported RDS DB Cluster.

4. For Parameter group actions, choose 'Edit'.

5. Change the values of the parameters that you want to modify. You can scroll through the parameters using the arrow keys at the top right of the dialog box.

6. In the 'Modifiable parameters' section, enter 'rds.force_ssl' in the Filter Parameters search box for PostgreSQL and Aurora PostgreSQL databases, and type 'require_secure_transport' in the search box for MySQL and Aurora MySQL databases.

a. For the 'rds.force_ssl' database parameter, enter '1' in the Value configuration box to enable the Transport Encryption feature.

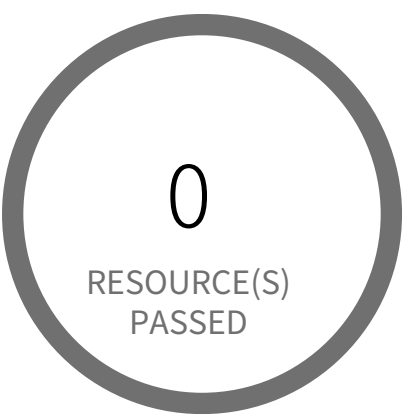
or

b. For the 'require_secure_transport' parameter, enter '1' for MySQL Databases or 'ON' for Aurora MySQL databases based on allowed values in the Value configuration box to enable the Transport Encryption feature.

7. Choose Save changes.

8. Reboot the primary (writer) DB instance in the cluster to apply the changes to it.
9. Then reboot the reader DB instances to apply the changes to them.

Access Control / Section Access Enforcement



0 Resource(s) Failed

Compliance Section: Access Enforcement — Informational

Enforce approved authorizations for logical access to CUI and system resources in accordance with applicable access control policies.

AWS RDS database instance encrypted with Customer Managed Key (CMK) is not enabled for regular rotation

This policy identifies Amazon RDS instances that use Customer Managed Keys (CMKs) for encryption but are not enabled with key rotation. Amazon RDS instance encryption key rotation failure can result in prolonged exposure of sensitive data and potential compliance violations. As a security best practice, it is important to periodically rotate these keys. This ensures that if the keys are compromised, the data in the underlying service remains secure with the new keys.

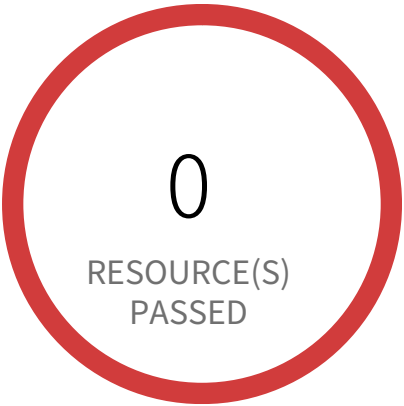
First Seen N/A | **Resource Type** Other

Recommendations

The following steps are recommended to enable the automatic rotation of the KMS key used by the RDS instance

- 1. Log in to the AWS console.
- 2. In the console, select the specific region from the region drop-down in the top right corner, for which the alert is generated.
- 4. Navigate to the 'RDS' service.
- 5. Select the RDS instance reported in the alert, and click on the 'Configuration' tab.
- 6. Under the 'Storage' section, click on the KMS key link in 'AWS KMS key'.
- 7. Under the 'Key rotation' tab on the navigated KMS key window, enable the 'Automatically rotate this CMK every year' check box.
- 8. Click on Save.

Access Control / Section Access Enforcement



1 Resource(s) Failed
database-1

Compliance Section: Access Enforcement ●●● Medium

Enforce approved authorizations for logical access to CUI and system resources in accordance with applicable access control policies.

AWS RDS database instance not configured with encryption in transit

This policy identifies AWS RDS database instances that are not configured with encryption in transit. This covers MySQL, SQL Server, PostgreSQL, MariaDB, and DB2 RDS instances.

Enabling encryption is crucial to protect data as it moves through the network and enhances the security between clients and storage servers. Without encryption, sensitive data transmitted between your application and the database is vulnerable to interception by malicious actors. This could lead to unauthorized access, data breaches, and potential compromises of confidential information.

It is recommended that data be encrypted while in transit to ensure its security and reduce the risk of unauthorized access or data breaches.

First Seen June 11, 2024 at 6:11:26 PM UTC | **Resource Type** Other

Recommendations

To enable the in-transit encryption feature for your Amazon RDS databases, perform the following actions:

Default parameter groups for RDS DB instances cannot be modified. Therefore, you must create a custom parameter group, modify it, and then attach it to your RDS for DB instances. Changes to parameters in a customer-created DB parameter group are applied to all DB instances that are associated with the DB parameter group.

Follow the below links to create and associate a DB parameter group with a DB instance,

To Create a DB parameter group, refer to the below link
https://docs.aws.amazon.com/AmazonRDS/latest/UserGuide/USER_WorkingWithDBInstanceParamGroups.html#USER_WorkingWith-ParamGroups.Creating

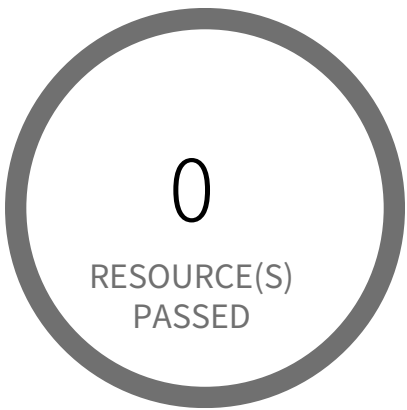
To Associating a DB parameter group with a DB instance, refer the below link
https://docs.aws.amazon.com/AmazonRDS/latest/UserGuide/USER_WorkingWithDBInstanceParamGroups.html#USER_WorkingWith-ParamGroups.Associating

To Modifying parameters in a DB parameter group,

1. Sign in to the AWS Management Console and open the Amazon RDS console at <https://console.aws.amazon.com/rds/>.
2. In the navigation pane, choose 'Parameter Groups'.
3. In the list, choose the parameter group that is associated with the RDS instance.
4. For Parameter group actions, choose 'Edit'.

5. Change the values of the parameters that you want to modify. You can scroll through the parameters using the arrow keys at the top right of the dialog box.
6. In the 'Modifiable parameters' section, enter 'rds.force_ssl' in the Filter Parameters search box for SQL Server and PostgreSQL databases, and type 'require_secure_transport' in the search box for MySQL and MariaDB databases and type DB2COMM for DB2 databases.
 - a. For the 'rds.force_ssl' database parameter, enter '1' in the Value configuration box to enable the Transport Encryption feature.
or
 - b. For the 'require_secure_transport' parameter, enter '1' in the Value configuration box to enable the Transport Encryption feature.
or
 - c. For the 'DB2COMM' parameter, enter 'SSL' in the Value box based on the allowed values to enable Transport Encryption.
7. Choose Save changes.

Access Control / Section Access Enforcement



0 Resource(s) Failed

Compliance Section: Access Enforcement — Informational

Enforce approved authorizations for logical access to CUI and system resources in accordance with applicable access control policies.

AWS RDS event subscription disabled for DB security groups

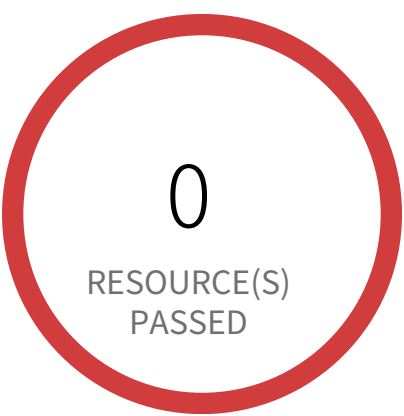
This policy identifies RDS event subscriptions for which DB security groups event subscription is disabled. You can create an Amazon RDS event notification subscription so that you can be notified when an event occurs for given DB security groups.

First Seen N/A | **Resource Type** Other

Recommendations

- 1. Sign into the AWS console
- 2. In the console, select the specific region from region drop down on the top right corner, for which the alert is generated
- 3. Navigate to Amazon RDS Dashboard
- 4. Click on 'Event subscriptions' (Left Panel)
- 5. Choose the reported Event subscription
- 6. Click on 'Edit'
- 7. On 'Edit event subscription' page, Under 'Details' section; Select 'Yes' for 'Enabled' and Make sure you have subscribed your DB to 'All instances' and 'All event categories'
- 8. Click on 'Edit'

Access Control / Section Access Enforcement



1 Resource(s) Failed
database-1

Compliance Section: Access Enforcement — Informational

Enforce approved authorizations for logical access to CUI and system resources in accordance with applicable access control policies.

AWS RDS instance delete protection is disabled

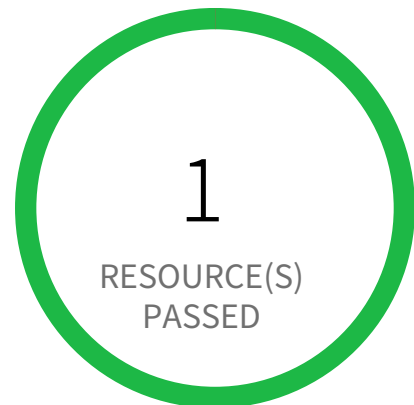
This policy identifies RDS instances for which delete protection is disabled. Enabling delete protection for these RDS instances prevents irreversible data loss resulting from accidental or malicious operations.

First Seen June 16, 2025 at 12:19:29 PM UTC | **Resource Type** Other

Recommendations

1. Sign into the AWS console
2. In the console, select the specific region from region drop down on the top right corner, for which the alert is generated
3. Navigate to 'Aurora abd RDS' console.
4. In the navigation pane, choose 'Databases', and then choose the DB instance is reported.
5. Choose 'Modify'.
6. Expand to 'Additional configuration', Check the box 'Enable deletion protection' for Deletion protection.
7. Click on 'Continue'
8. Under 'Schedule modifications', select 'When to apply modifications' and click on 'Modify DB Instance' to save your changes.

Access Control / Section Access Enforcement



0 Resource(s) Failed

Compliance Section: Access Enforcement ●●●● Low

Enforce approved authorizations for logical access to CUI and system resources in accordance with applicable access control policies.

AWS RDS instance not in private subnet

This policy identifies AWS RDS instance which are not in a private subnet. RDS should not be deployed in a public subnet, production databases should be located behind a DMZ in a private subnet with limited access in most scenarios.

First Seen N/A | **Resource Type** Other

Recommendations

To resolve this alert, you should redeploy RDS into a private RDS Subnet group.

Note: You can not move an existing RDS instance from one subnet to another.

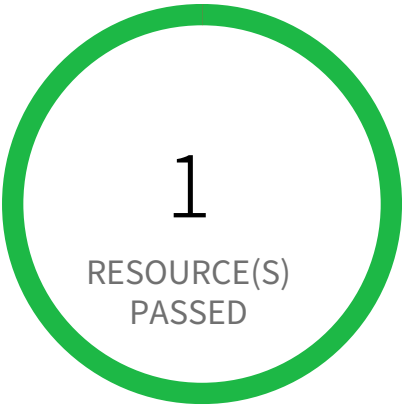
Create a RDS Subnet group:

A DB subnet group is a collection of subnets (typically private) that you create for a VPC and that you then designate for your DB instances.

1. Open the Amazon RDS console
2. In the navigation pane, choose 'Subnet groups'
3. Choose 'Create DB Subnet Group'
4. Type the 'Name' of your DB subnet group
5. Add a 'Description' for your DB subnet group
6. Choose your 'VPC'
7. Choose 'Availability Zones'
8. In the Add subnets section, add your Private subnets related to this VPC
9. Choose Create

When creating your RDS DB, under Configure advanced settings, choose the Subnet group created above.

Access Control / Section Access Enforcement



0 Resource(s) Failed

Compliance Section: Access Enforcement ●●●● Low

Enforce approved authorizations for logical access to CUI and system resources in accordance with applicable access control policies.

AWS RDS retention policy less than 7 days

RDS Retention Policies for Backups are an important part of your DR/BCP strategy. Recovering data from catastrophic failures, malicious attacks, or corruption often requires a several day window of potentially good backup material to leverage. As such, the best practice is to ensure your RDS clusters are retaining at least 7 days of backups, if not more (up to a maximum of 35).

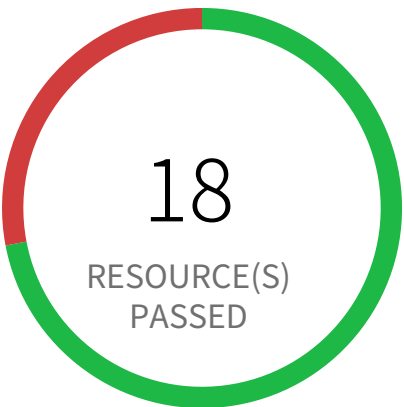
First Seen N/A | **Resource Type** Other

Recommendations

Configure your RDS backup retention policy to at least 7 days.

- 1. Go to the AWS console RDS dashboard.
- 2. In the navigation pane, choose Instances.
- 3. Select the database instance you wish to configure.
- 4. Click on 'Modify'.
- 5. Scroll down to Additional Configuration and set the retention period to at least 7 days under 'Backup retention period'.
- 6. Click Continue.
- 7. Under 'Scheduling of modifications' choose 'When to apply modifications'
- 8. On the confirmation page, Review the changes and Click on 'Modify DB Instance' to save your changes.

Access Control / Section Access Enforcement



7 Resource(s) Failed

cloudfoundation-lab-3248823847893,
sa-bedrock-kb-09f239,
pays-app-dev-jd3jnx92j3,
finance-secret-asdfsd3r53rtr-one,
finance-secret-der4t4tg5ght-three,
main-app-stage-2ncien92,
finance-secret-der4t4tg5ght-two

Compliance Section: Access Enforcement ●●●● Low

Enforce approved authorizations for logical access to CUI and system resources in accordance with applicable access control policies.

AWS S3 Buckets Block public access setting disabled

This policy identifies AWS S3 buckets which have 'Block public access' setting disabled. Amazon S3 provides 'Block public access' setting to manage public access of AWS S3 buckets. Enabling 'Block public access' setting prevents S3 resource data being accidentally or maliciously becoming publicly accessible. It is highly recommended to enable 'Block public access' setting for all AWS s3 buckets appropriately.

First Seen February 7, 2024 at 8:51:07 PM UTC | **Resource Type** Other

Recommendations

- 1. Login to the AWS Console
- 2. Navigate to the 'S3' service
- 3. Click on the 'S3' resource reported in the alert
- 4. Click on the 'Permissions'
- 5. Under 'Block public access' click on 'Edit'
- 6. Select 'Block all public access' checkbox
- 7. Click on Save
- 8. 'Confirm' the changes

Note: Make sure updating 'Block public access' setting does not affect S3 bucket data access.

Access Control / Section Access Enforcement



0 Resource(s) Failed

Compliance Section: Access Enforcement ●●●● Medium

Enforce approved authorizations for logical access to CUI and system resources in accordance with applicable access control policies.

AWS S3 bucket encrypted using Customer Managed Key (CMK) with overly permissive policy

Overly permissive key policies on AWS S3 buckets encrypted with Customer Managed Keys (CMKs) allow unauthorized access to sensitive data, leading to data breaches and compliance violations.

AWS S3 utilizes Customer Managed Keys (CMKs) for encryption, stored and managed within AWS Key Management Service (KMS). A mis-configured KMS key policy granting excessive permissions to untrusted principals, exposes the encryption key. Attackers exploiting this misconfiguration can decrypt and access sensitive data stored in the S3 bucket.

The impact of this misconfiguration includes data breaches, financial losses, reputational damage, and regulatory penalties for non-compliance. Restricting permissions to only necessary principals minimizes the potential impact of a compromised key. Following the principle of least privilege ensures only authorized entities can access the encryption key.

Mitigate this risk by implementing least privilege access controls on the KMS key policy. Grant required permissions only to trusted entities and services requiring access. Regularly review and audit the KMS key policy to identify and remove unnecessary permissions. Use a strong, unique CMK for each S3 bucket, and avoid using wildcard characters in the KMS key policy.

First Seen N/A | **Resource Type** Other

Recommendations

The following steps are recommended to add changes to existing key policy of the KMS key used by the S3 bucket

1. Log in to the AWS Console and navigate to the 'S3' service.
2. Click on the S3 bucket reported in the alert.
3. Click on the 'Properties' tab.
4. Under the 'Default encryption' section, click on the KMS key link in 'Encryption key ARN'.
5. Click on the 'Key policy' tab on the navigated KMS key window.
6. Click on 'Edit'.
7. For each policy statement, use fine-grained and restrictive permissions instead of using wildcards (* and kms:*) OR add in appropriate conditions with least privilege access.
8. Click on 'Save Changes'.

Access Control / Section Access Enforcement



0 Resource(s) Failed

Compliance Section: Access Enforcement ●●●● Low

Enforce approved authorizations for logical access to CUI and system resources in accordance with applicable access control policies.

AWS S3 bucket having policy overly permissive to VPC endpoints

This policy identifies S3 buckets that have the bucket policy overly permissive to VPC endpoints. It is recommended to follow the principle of least privileges ensuring that the VPC endpoints have only necessary permissions instead of full permission on S3 operations.

NOTE: When applying the Amazon S3 bucket policies for VPC endpoints described in this section, you might block your access to the bucket without intending to do so. Bucket permissions that are intended to specifically limit bucket access to connections originating from your VPC endpoint can block all connections to the bucket. The policy might disable console access to the specified bucket because console requests don't originate from the specified VPC endpoint. So remediation should be done very carefully.

For details refer <https://docs.aws.amazon.com/AmazonS3/latest/dev/example-bucket-policies-vpc-endpoint.html>

First Seen N/A | **Resource Type** Other

Recommendations

- 1. Log in to the AWS console
 - 2. Navigate to the S3 dashboard
 - 3. Choose the reported S3 bucket
 - 4. In the 'Permissions' tab, click on the 'Bucket Policy'
 - 5. Update the S3 bucket policy for the VPC endpoint so that it has only required permissions instead of full S3 permission.
- Refer for example: <https://docs.aws.amazon.com/AmazonS3/latest/dev/example-bucket-policies-vpc-endpoint.html>

Access Control / Section Access Enforcement



0 Resource(s) Failed

Compliance Section: Access Enforcement ●●● Medium

Enforce approved authorizations for logical access to CUI and system resources in accordance with applicable access control policies.

AWS S3 bucket policy overly permissive to any principal

Overly permissive AWS S3 bucket policies allow unauthorized access to sensitive data. This misconfiguration exposes data to any principal, bypassing intended access controls.

AWS S3 buckets store data; a policy granting AWS 'full access' or '*' allows any user or service to read, write, and delete objects. Untrusted actors could exploit this to exfiltrate sensitive data, modify or delete files, or even perform ransomware attacks.

The impact of this misconfiguration includes data breaches, regulatory non-compliance, and reputational damage. Restricting access to only authorized users and services using the principle of least privilege minimizes the impact of a compromised account. Strong access control is crucial for data protection.

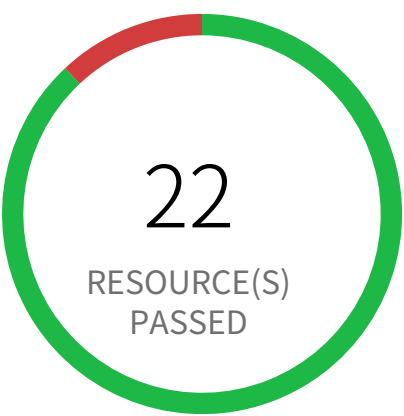
Implement least privilege by granting only necessary permissions to specific users and services. Regularly review and update bucket policies, ensuring that only authorized entities have access. Enable Block Public Access settings to prevent unintended public exposure. Use fine-grained access control mechanisms like IAM roles and policies to further enhance security.

First Seen N/A | **Resource Type** Other

Recommendations

- 1. Log in to the AWS console
- 2. Navigate to the S3 dashboard
- 3. Choose the reported S3 bucket
- 4. In the 'Permissions' tab, click on the 'Bucket Policy'
- 5. Update the S3 bucket policy, by removing Principal containing wildcard (*) to specific accounts, Services or IAM entities. Also restrict S3 action operations to specific instead of using wildcard (*).
- 6. In the 'Permissions' tab, click on the 'Block public access' and enable 'Block public and cross-account access to buckets and objects through any public bucket or access point policies'

Access Control / Section Access Enforcement



3 Resource(s) Failed
finance-secret-der4t4tg5ght-three, fi-
nance-secret-asdfs3r53rtr-one, finance-se-
cret-der4t4tg5ght-two

Compliance Section: Access Enforcement ●●● Medium

Enforce approved authorizations for logical access to CUI and system resources in accordance with applicable access control policies.

AWS S3 bucket publicly readable

Publicly readable AWS S3 buckets allow unauthorized access to sensitive data. This misconfiguration exposes data to anyone with knowledge of the bucket name, potentially leading to data breaches and reputational damage.

The S3 service lacks inherent namespace protection; improperly configured Access Control Lists (ACLs) and bucket policies enable unintended read access. Attackers can exploit this to download or list bucket contents, compromising sensitive information. Failure to implement appropriate security measures increases the risk of data exfiltration.

A data breach resulting from this misconfiguration could expose confidential customer data, intellectual property, or other sensitive information. Implementing strong access controls is critical to protecting data confidentiality and integrity. Maintaining a secure configuration reduces the likelihood of a successful attack.

To mitigate this risk, enforce least privilege by restricting access to only authorized users and services. Regularly review and update bucket policies and ACLs to ensure they align with security best practices. Implement robust monitoring and alerting to detect unauthorized access attempts. Consider using server-side encryption to further protect data at rest.

First Seen February 7, 2024 at 8:51:07 PM UTC | **Resource Type** Other

Recommendations

- 1. Log in to the AWS Console
- 2. Navigate to the 'S3' service
- 3. Click on the S3 resource reported in the alert
- 4. Click on the 'Permissions' tab
- 5. If Access Control List is set to 'Public' follow the below steps
 - a. Under 'Access Control List', Click on 'Everyone' and uncheck all items
 - b. Under 'Access Control List', Click on "Authenticated users group" and uncheck all items
 - c. Click on Save changes
- 6. If 'Bucket Policy' is set to public follow the below steps
 - a. Under 'Bucket Policy', Select 'Edit Bucket Policy' and consider defining what explicit 'Principal' should have the ability to GET/LIST objects in your S3 bucket. You may also want to specifically limit the 'Principal' ability to perform specific GET/LIST functions, without the wild card. If 'Bucket Policy' is not required delete the existing 'Bucket Policy'.
 - b. Click on Save changes

Note: Make sure updating 'Access Control List' or 'Bucket Policy' does not affect S3 bucket data access.

Access Control / Section Access Enforcement



0 Resource(s) Failed

Compliance Section: Access Enforcement High

Enforce approved authorizations for logical access to CUI and system resources in accordance with applicable access control policies.

AWS S3 bucket publicly writable

Publicly writable AWS S3 buckets allow unauthorized access to sensitive data stored within. This misconfiguration exposes data to malicious actors and data breaches.

The S3 service relies on Access Control Lists (ACLs) and bucket policies to manage access. Incorrectly configured ACLs or bucket policies that grant 'Put', 'Create', 'Update', 'Replicate', 'Write', or 'Delete' permissions to the world, allow anyone to modify or delete bucket contents. This exposes data to unauthorized access, modification, or deletion.

A successful attack could lead to data exfiltration, modification, or deletion, resulting in significant financial, legal, and reputational damage. Best practices dictate strict control over S3 bucket permissions to prevent unauthorized access. Data loss and compliance violations are possible consequences.

Implement least privilege access controls. Restrict access to only trusted users and services via appropriately configured ACLs and bucket policies. Regularly review and audit S3 bucket permissions to identify and rectify any misconfigurations. Use strong encryption to protect data at rest and in transit. Employ multi-factor authentication (MFA) for enhanced security.

First Seen N/A | **Resource Type** Other

Recommendations

- 1. Log in to the AWS Console
- 2. Navigate to the 'S3' service
- 3. Click on the S3 resource reported in the alert
- 4. Click on the 'Permissions' tab
- 5. If Access Control List is set to 'Public' follow the below steps
 - a. Under 'Access Control List', Click on 'Everyone' and uncheck all items
 - b. Under 'Access Control List', Click on 'Authenticated users group' and uncheck all items
 - c. Click on Save changes
- 6. If 'Bucket Policy' is set to public follow the below steps
 - a. Under 'Bucket Policy', Select 'Edit Bucket Policy' and consider defining what explicit 'Principal' should have the ability to PUT/CREATE/REPLICATE/DELETE objects in your S3 bucket. You may also want to specifically limit the 'Principal' ability to perform specific PUT/CREATE/REPLICATE/DELETE functions, without the wild card.
 - If 'Bucket Policy' is not required delete the existing 'Bucket Policy'.
 - b. Click on Save changes

Note: Make sure updating 'Access Control List' or 'Bucket Policy' does not affect S3 bucket data access.

Access Control / Section Access Enforcement



0 Resource(s) Failed

Compliance Section: Access Enforcement ●●●● Low

Enforce approved authorizations for logical access to CUI and system resources in accordance with applicable access control policies.

AWS SNS topic policy overly permissive for publishing

This policy identifies AWS SNS topics that have SNS policy overly permissive for publishing. When a message is published, Amazon SNS attempts to deliver the message to the subscribed endpoints. To protect these messages from attackers and unauthorized accesses, permissions should be given to only authorized users.

For more details:

<https://docs.aws.amazon.com/sns/latest/dg/sns-security-best-practices.html#implement-least-privilege-access>

First Seen N/A | **Resource Type** Other

Recommendations

1. Log in to the AWS Console
2. In the console, select the specific region from the region drop-down on the top right corner, for which the alert is generated.
3. Navigate to the 'Simple Notification Service' dashboard
4. Go to 'Topics', from the left panel
5. Select the reported SNS topic
6. Click on the 'Edit' button from the top options bar
7. On the edit page go to the 'Access Policy - optional' section
8. Add the restrictive 'Condition' statement to the JSON editor to specify who can publish messages to the topic.
9. Click on 'Save changes'

Access Control / Section Access Enforcement



0 Resource(s) Failed

Compliance Section: Access Enforcement ●●●● Low

Enforce approved authorizations for logical access to CUI and system resources in accordance with applicable access control policies.

AWS SNS topic policy overly permissive for subscription

This policy identifies AWS SNS topics that have SNS policy overly permissive for the subscription. When you subscribe an endpoint to a topic, the endpoint begins to receive messages published to the associated topic. To protect these messages from attackers and unauthorized accesses, permissions should be given to only authorized users.

For more details:

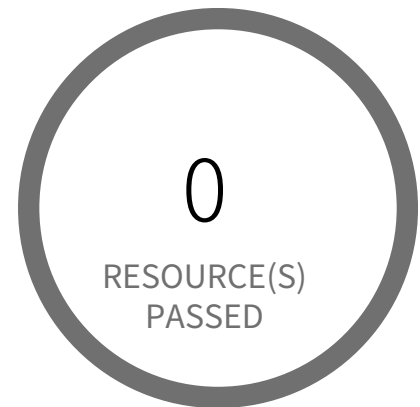
<https://docs.aws.amazon.com/sns/latest/dg/sns-security-best-practices.html#implement-least-privilege-access>

First Seen N/A | **Resource Type** Other

Recommendations

1. Log in to the AWS Console
2. In the console, select the specific region from the region drop-down on the top right corner, for which the alert is generated.
3. Navigate to the 'Simple Notification Service' dashboard
4. Go to 'Topics', from the left panel
5. Select the reported SNS topic
6. Click on the 'Edit' button from the top options bar
7. On the edit page go to the 'Access Policy - optional' section
8. Add the restrictive 'Condition' statement to the JSON editor to specify who can subscribe to this topic.
9. Click on 'Save changes'

Access Control / Section Access Enforcement



0 Resource(s) Failed

Compliance Section: Access Enforcement — Informational

Enforce approved authorizations for logical access to CUI and system resources in accordance with applicable access control policies.

AWS SQS queue access policy is overly permissive

This policy identifies Simple Queue Service (SQS) queues that have an overly permissive access policy. It is highly recommended to have the least privileged access policy to protect the SQS queue from data leakage and unauthorized access.

For more details:

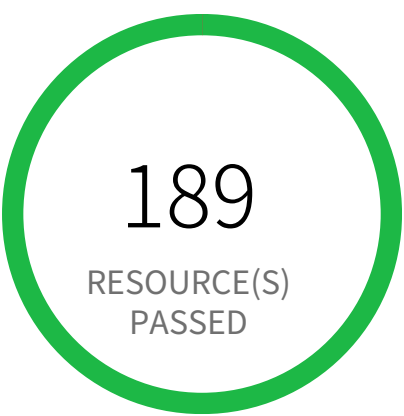
<https://docs.aws.amazon.com/AWSSimpleQueueService/latest/SQSDeveloperGuide/sqs-basic-examples-of-sqs-policies.html>

First Seen N/A | **Resource Type** Other

Recommendations

1. Log in to the AWS console
2. Select the region, from the region drop-down, in which the alert is generated
3. Navigate to Simple Queue Service (SQS) dashboard
4. Choose the reported Simple Queue Service (SQS) and choose 'Edit'
5. Scroll to the 'Access policy' section
6. Edit the access policy statements in the input box, Make sure the 'Principal' is not set to '*', which makes your SQS queues accessible to any anonymous users.
7. When you finish configuring the access policy, choose 'Save'.

Access Control / Section Access Enforcement



0 Resource(s) Failed

Compliance Section: Access Enforcement ●●●● Medium

Enforce approved authorizations for logical access to CUI and system resources in accordance with applicable access control policies.

AWS SageMaker notebook instance IAM policy overly permissive to all traffic

This policy identifies SageMaker notebook instances IAM policies that are overly permissive to all traffic. It is recommended that the SageMaker notebook instances should be granted access restrictions so that only authorized users and applications have access to the service.

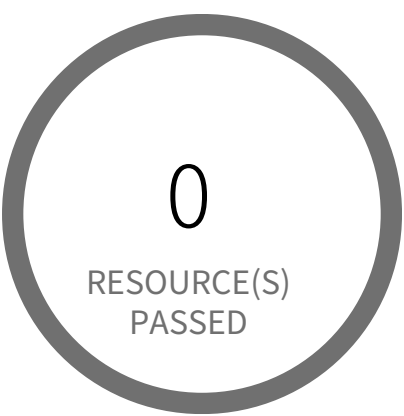
For more details:
https://docs.aws.amazon.com/sagemaker/latest/dg/security_iam_id-based-policy-examples.html

First Seen N/A | **Resource Type** Other

Recommendations

- 1. Login to AWS console
- 2. Goto IAM Services
- 3. Click on 'Policies' in left hand panel
- 4. Search for the Policy for which the Alert is generated and click on it
- 5. Under Permissions tab, click on Edit policy
- 6. Under the Visual editor, for each of the 'SageMaker' Service, click to expand and perform following.
 - 6.a. Click to expand 'Request conditions'
 - 6.b. Under the 'Source IP', remove the row with the entry '0.0.0.0/0' or ':::/0'. Add condition with restrictive IP ranges.
- 7. Click on Review policy and Save changes.

Access Control / Section Access Enforcement



0 Resource(s) Failed

Compliance Section: Access Enforcement ●●●● Low

Enforce approved authorizations for logical access to CUI and system resources in accordance with applicable access control policies.

AWS VPC gateway endpoint policy is overly permissive

This policy identifies AWS VPC gateway endpoints that have a VPC endpoint (VPCE) policy that is overly permissive. When the Principal element value is set to '*' within the access policy, the VPC gateway endpoint allows full access to any IAM user or service within the VPC using credentials from any AWS accounts. It is highly recommended to have the least privileged VPCE policy to protect the data leakage and unauthorized access.

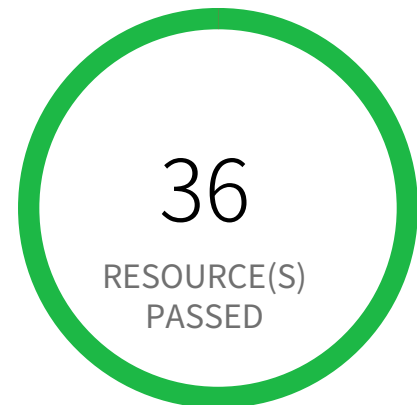
For more details:
<https://docs.aws.amazon.com/vpc/latest/userguide/vpc-endpoints-access.html>

First Seen N/A | **Resource Type** Other

Recommendations

1. Log in to the AWS Console
2. In the console, select the specific region from the region drop-down on the top right corner, for which the alert is generated.
3. Navigate to the VPC dashboard
4. Go to 'Endpoints', from the left panel VIRTUAL PRIVATE CLOUD section
5. Select the reported VPC endpoint
6. On the 'Actions' drop-down button, click on the 'Manage policy'
8. On the 'Edit Policy' page, Choose 'Custom' policy
 - a. Then add policy, without the 'Everyone' grantee (i.e. '*' or 'AWS': '*') from the Principal element value with an AWS account ID (e.g. '123456789'), an AWS account ARN (e.g. 'arn:aws:iam::123456789:root') or an IAM user ARN (e.g. 'arn:aws:iam::123456789:user/vpce-admin').
 - b. Add a Condition clause to the policy statement to filter the endpoint access to specific entities.
9. Click on 'Save'

Access Control / Section Access Enforcement



0 Resource(s) Failed

Compliance Section: Access Enforcement ●●●● Low

Enforce approved authorizations for logical access to CUI and system resources in accordance with applicable access control policies.

AWS route table with VPC peering overly permissive to all traffic

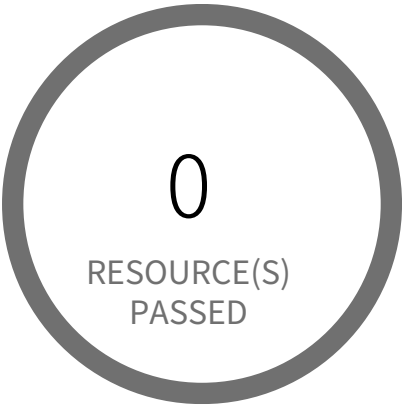
This policy identifies VPC route tables with VPC peering connection which are overly permissive to all traffic. Being highly selective in peering routing tables is a very effective way of minimizing the impact of breach as resources outside of these routes are inaccessible to the peered VPC.

First Seen N/A | **Resource Type** Other

Recommendations

1. Log in to the AWS Console
2. In the console, select the specific region from region drop down on the top right corner, for which the alert is generated.
3. Navigate to 'VPC' dashboard from 'Services' dropdown
4. From left menu, select 'Route Tables'
5. Click on the alerted route table
6. From top click on 'Action' button
7. From the Action menu dropdown, select 'Edit routes'
8. From the list of destination remove the extra permissive destination by clicking the cross symbol available for that destination
9. Add a destination with 'least access'
10. Click on 'Save Routes'.

Access Control / Section Least Privilege



0 Resource(s) Failed

Compliance Section: Least Privilege ●●●● Low

- a. Allow only authorized system access for users (or processes acting on behalf of users) that is necessary to accomplish assigned organizational tasks.
- b. Authorize access to [Assignment: organization-defined security functions] and [Assignment: organization-defined security-relevant information].
- c. Review the privileges assigned to roles or classes of users [Assignment: organization-defined frequency] to validate the need for such privileges.
- d. Reassign or remove privileges, as necessary.

AWS ACM Certificate with wildcard domain name

This policy identifies ACM Certificates which are using wildcard certificates for wildcard domain name instead of single domain name certificates. ACM allows you to use an asterisk (*) in the domain name to create an ACM Certificate containing a wildcard name that can protect several sites in the same domain. For example, a wildcard certificate issued for *.prismacloud.io can match both www.prismacloud.io and images.prismacloud.io. When you use wildcard certificates, if the private key of a certificate is compromised, then all domain and subdomains that use the compromised certificate are potentially impacted. So it is recommended to use single domain name certificates instead of wildcard certificates to reduce the associated risks with a compromised domain or subdomain.

First Seen N/A | **Resource Type** Other

Recommendations

To resolve this alert, you have to replace the reported wildcard certificate with a single domain name certificate for all the first-level subdomains resulting from the domain name of the website secured with the wildcard certificate and delete the reported wildcard domain certificate.

To create a new certificate with a single domain:

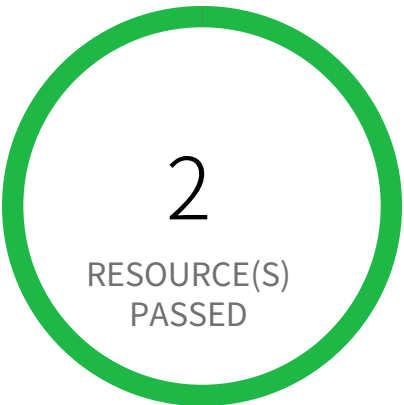
- 1. Sign in to the AWS console
- 2. In the console, select the specific region from the region drop-down on the top right corner, for which the alert is generated
- 3. Navigate to AWS Certificate Manager (ACM) and click on 'Request certificate' from the left panel.
- 4. On the 'Request certificate' page, select 'Request a public certificate' as the 'Certificate type' and click 'Next'.
- 5. In the 'Request public certificate' page,
 - a. Specify Domain Name: In the 'Domain names' section, type the fully qualified domain name (e.g., `subdomain.yourdomain.com`) in the 'Fully qualified domain name' box.
 - b. Select Validation Method: In the 'Validation method' section, choose the validation method that suits your requirements (e.g., DNS validation or Email validation).
 - c. Choose Key Algorithm:** In the 'Key algorithm' section, select an appropriate encryption algorithm. Be aware that some algorithms may not be supported by all AWS services.
 - d. Review and Request:** Review the domain name and validation method details, then click 'Request'.

6. Wait for the certificate status to change from 'Pending validation' to 'Issued'. Once issued, access your application's web server configuration and replace the wildcard certificate with the newly issued single-domain name certificate.

To delete a wildcard certificate:

1. Sign in to the AWS console
2. In the console, select the specific region from the region drop-down on the top right corner, for which the alert is generated
3. Go to Certificate Manager(ACM) service and select 'List certificates' from the left panel.
4. Choose the reported certificate
5. Ensure you disassociate the certificate from all its associated resources (e.g., Load Balancers, CloudFront distributions). After dissociation, click on 'Delete'.
6. On the 'Delete certificate' pop-up windows, click on the 'Delete' button

Access Control / Section Least Privilege



0 Resource(s) Failed

Compliance Section: Least Privilege ●●● High

- a. Allow only authorized system access for users (or processes acting on behalf of users) that is necessary to accomplish assigned organizational tasks.
- b. Authorize access to [Assignment: organization-defined security functions] and [Assignment: organization-defined security-relevant information].
- c. Review the privileges assigned to roles or classes of users [Assignment: organization-defined frequency] to validate the need for such privileges.
- d. Reassign or remove privileges, as necessary.

AWS Access key enabled on root account

Root accounts with enabled access keys pose a significant security risk. Compromising a root account access key grants complete control over all AWS services and resources.

AWS Identity and Access Management (IAM) manages user access to AWS services. Enabling access keys on a root account is a misconfiguration because root accounts inherently possess extensive privileges. A compromised access key allows attackers complete control, leading to data breaches, service disruptions, and financial losses.

The impact of this misconfiguration is catastrophic; attackers gain unrestricted access to all AWS resources, potentially leading to complete account takeover. Best practices dictate that root accounts should only be used for administrative tasks and should never have active access keys.

Mitigate this risk by immediately disabling access keys on the root account. Implement multi-factor authentication (MFA) for all users, including the root account. Create and use IAM users with least privilege access for all day-to-day operations. Regularly rotate IAM access keys for all users.

First Seen N/A | **Resource Type** IAM Account Summary

Recommendations

- 1. Sign in to AWS Console as the root user.
- 2. Click root account name and on the top right select 'Security Credentials' from the dropdown.
- 3. For each key in 'Access Keys', click on "X" to delete the keys.

Access Control / Section Least Privilege



0 Resource(s) Failed

Compliance Section: Least Privilege — Informational

- a. Allow only authorized system access for users (or processes acting on behalf of users) that is necessary to accomplish assigned organizational tasks.
- b. Authorize access to [Assignment: organization-defined security functions] and [Assignment: organization-defined security-relevant information].
- c. Review the privileges assigned to roles or classes of users [Assignment: organization-defined frequency] to validate the need for such privileges.
- d. Reassign or remove privileges, as necessary.

AWS EC2 Instance IAM Role not enabled

AWS provides Identity Access Management (IAM) roles to securely access AWS services and resources. The role is an identity with permission policies that define what the identity can and cannot do in AWS. As a best practice, create IAM roles and attach the role to manage EC2 instance permissions securely instead of distributing or sharing keys or passwords.

First Seen N/A | **Resource Type** Other

Recommendations

The most common setup is the AWS default that allows for EC2 access to AWS Services. For most, this is a great way to realize flexible, yet secure, EC2 access enabled for your instances. Select this when you launch EC2 instances to automatically inherit these permissions.

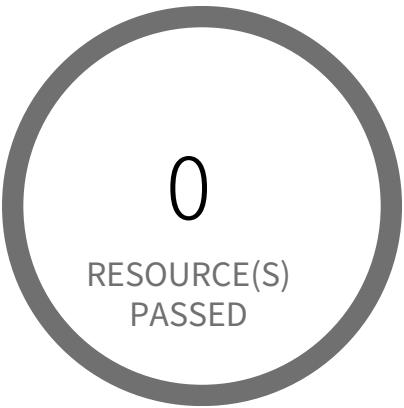
IAM

- 1. Go to the AWS console IAM dashboard.
- 2. In the navigation pane, choose Roles, Create new role.
- 3. Under 'Choose the service that will use this role' select EC2, then 'Next:Permissions.'
- 4. On the Attach permissions policies page, select an AWS managed policy that grants your instance access to the resources that they need, then 'Next:Tags.'
- 5. Add tags (optional), the select 'Next:Review.'
- 6. On the Create role and Review page, type a name for the role and choose Create role.

EC2

- 1. Go to the AWS console EC2 dashboard.
- 2. Select Running Instances.
- 3. Check the instance you want to modify.
- 4. From the Actions pull down menu, select Instance Settings and Attach/Replace IAM Role.
- 5. On the Attach/Replace IAM Role page, under the IAM role pull down menu, choose the role created in the IAM steps above.

Access Control / Section Least Privilege



0 Resource(s) Failed

Compliance Section: Least Privilege ●●● Medium

- a. Allow only authorized system access for users (or processes acting on behalf of users) that is necessary to accomplish assigned organizational tasks.
- b. Authorize access to [Assignment: organization-defined security functions] and [Assignment: organization-defined security-relevant information].
- c. Review the privileges assigned to roles or classes of users [Assignment: organization-defined frequency] to validate the need for such privileges.
- d. Reassign or remove privileges, as necessary.

AWS ECS Fargate task definition root user found

This policy identifies AWS ECS Fargate task definition which has user name as root. As a best practice, the user name to use inside the container should not be root.

Note: This parameter is not supported for Windows containers.

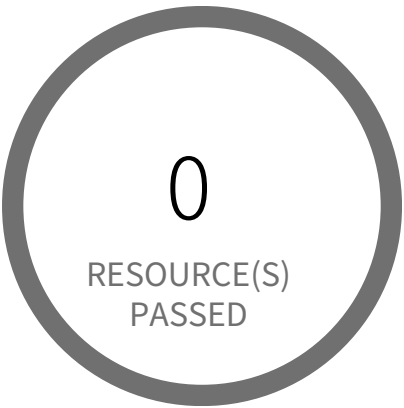
First Seen N/A | **Resource Type** Other

Recommendations

Create a task definition revision.

1. Open the Amazon ECS console.
2. From the navigation bar, choose the region that contains your task definition.
3. In the navigation pane, choose Task Definitions.
4. On the Task Definitions page, select the box to the left of the task definition to revise and choose Create new revision.
5. On the Create new revision of Task Definition page, change the existing Container Definitions.
6. Under Security, remove root from the User field.
7. Verify the information and choose Update, then Create.
8. If your task definition is used in a service, update your service with the updated task definition.
9. Deactivate previous task definition

Access Control / Section Least Privilege



0 Resource(s) Failed

Compliance Section: Least Privilege ●●● Medium

- a. Allow only authorized system access for users (or processes acting on behalf of users) that is necessary to accomplish assigned organizational tasks.
- b. Authorize access to [Assignment: organization-defined security functions] and [Assignment: organization-defined security-relevant information].
- c. Review the privileges assigned to roles or classes of users [Assignment: organization-defined frequency] to validate the need for such privileges.
- d. Reassign or remove privileges, as necessary.

AWS ECS task definition elevated privileges enabled

This policy identifies the ECS containers that are having elevated privileges on the host container instance. When the Privileged parameter is true, the container is given elevated privileges on the host container instance (similar to the root user).

Note: This parameter is not supported for Windows containers or tasks using the Fargate launch type.

First Seen N/A | Resource Type Other

Recommendations

Create a task definition revision.

1. Open the Amazon ECS console.
2. From the navigation bar, choose the region that contains your task definition.
3. In the navigation pane, choose Task Definitions.
4. On the Task Definitions page, select the box to the left of the task definition to revise and choose Create new revision.
5. On the Create new revision of Task Definition page, change the existing Container Definitions.
6. Under Security, uncheck the Privileged box.
7. Verify the information and choose Update, then Create.
8. If your task definition is used in a service, update your service with the updated task definition.
9. Deactivate previous task definition

Access Control / Section Least Privilege



0 Resource(s) Failed

Compliance Section: Least Privilege ●●● Medium

- a. Allow only authorized system access for users (or processes acting on behalf of users) that is necessary to accomplish assigned organizational tasks.
- b. Authorize access to [Assignment: organization-defined security functions] and [Assignment: organization-defined security-relevant information].
- c. Review the privileges assigned to roles or classes of users [Assignment: organization-defined frequency] to validate the need for such privileges.
- d. Reassign or remove privileges, as necessary.

AWS IAM Groups with administrator access permissions

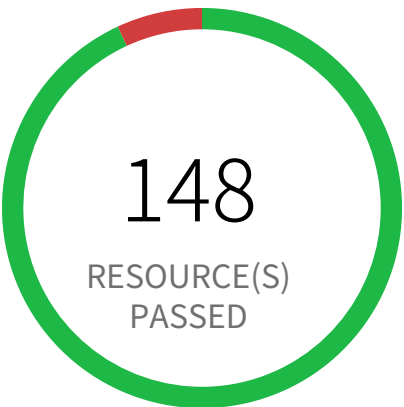
This policy identifies AWS IAM groups which has administrator access permission set. This would allow all users under this group to have administrative privileges. As a security best practice, it is recommended to grant least privilege access like granting only the permissions required to perform a task, instead of providing excessive permissions.

First Seen N/A | **Resource Type** Other

Recommendations

- 1. Log in to AWS console
- 2. Navigate to IAM service
- 3. Click on Groups
- 4. Click on reported IAM group
- 5. Under 'Managed Policies' click on 'Detach Policy' which is having excessive permissions and assign a limited permission policy as required for a particular group
- OR
- 6. Under 'Inline Policies' click on 'Edit Policy' or 'Remove Policy' and assign a limited permission as required for a particular group

Access Control / Section Least Privilege



11 Resource(s) Failed

OrganizationAccountAccessRole,
privesc-AssumeRole-ending-role,
sales-trading-admin-role-qa-hz6vX,
stack-
sets-exec-04a521ff20cd15073e5aefd21b5dba97,
privesc-high-priv-service-role,
AWSCloudFormationStackSetExecutionRole,
AWSReservedSSO_AdministratorAc-
cess_426d8e7cca35042a,
AWSReservedSSO_AdministratorAc-
cess_5bc2bc21a64c12ba,
fp2-allow-and-deny-multiple-policies-role & 1
more

Compliance Section: Least Privilege ●●● Medium

- a. Allow only authorized system access for users (or processes acting on behalf of users) that is necessary to accomplish assigned organizational tasks.
- b. Authorize access to [Assignment: organization-defined security functions] and [Assignment: organization-defined security-relevant information].
- c. Review the privileges assigned to roles or classes of users [Assignment: organization-defined frequency] to validate the need for such privileges.
- d. Reassign or remove privileges, as necessary.

AWS IAM Roles with Administrator Access Permissions

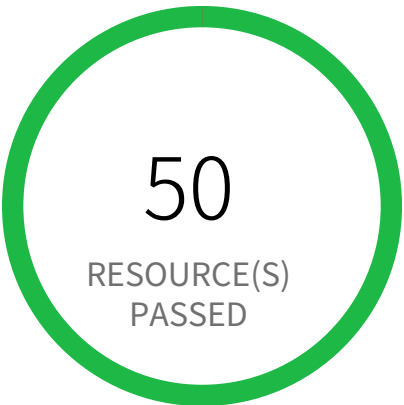
This policy identifies AWS IAM roles which has administrator access permission set. This would allow all users who assume this role to have administrative privileges. As a security best practice, it is recommended to grant least privilege access like granting only the permissions required to perform a task, instead of providing excessive permissions.

First Seen June 11, 2024 at 6:11:26 PM UTC | **Resource Type** Other

Recommendations

1. Log in to AWS console
2. Navigate to IAM service
3. Click on Roles
4. Click on reported IAM role
5. Under 'Permissions policies' click on 'X' to detach or remove the policy having excessive permissions and assign a limited permission policy as required for a particular role.

Access Control / Section Least Privilege



0 Resource(s) Failed

Compliance Section: Least Privilege ●●●● Low

- a. Allow only authorized system access for users (or processes acting on behalf of users) that is necessary to accomplish assigned organizational tasks.
- b. Authorize access to [Assignment: organization-defined security functions] and [Assignment: organization-defined security-relevant information].
- c. Review the privileges assigned to roles or classes of users [Assignment: organization-defined frequency] to validate the need for such privileges.
- d. Reassign or remove privileges, as necessary.

AWS IAM deprecated managed policies in use by User

This policy checks for any usage of deprecated AWS IAM managed policies and returns an alert if it finds one in your cloud resources.

When AWS deprecate an IAM managed policy, a new alternative is released with improved access restrictions. Existing IAM users and roles can continue to use the previous policy without interruption, however new IAM users and roles will use the new replacement policy.

Before you migrate any user or role to the new replacement policy, we recommend you review their differences in the Policy section of AWS IAM console. If you require one or more of the removed permissions, please add them separately to any user or role.

List of deprecated AWS IAM managed policies:

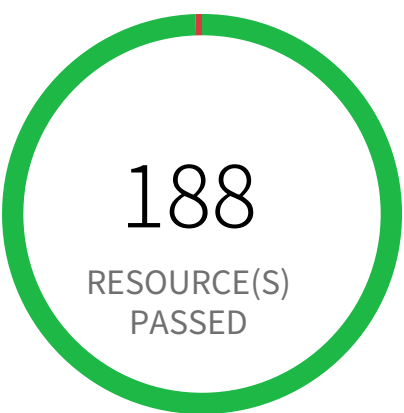
AmazonElasticTranscoderFullAccess (replaced by AmazonElasticTranscoder_FullAccess)

First Seen N/A | Resource Type Other

Recommendations

1. Go to the AWS console IAM dashboard.
2. Click Policies on the left navigation menu.
3. Enter the deprecated IAM policy name into the filter.
4. Click on the policy name.
5. Select the Policy usage tab.
6. Check all attached users, make note of them, then select Detach.
7. Click Policies on the left navigation menu.
8. Enter the new IAM policy name into the filter.
9. Click on the policy name.
10. Select the Policy usage tab.
11. Select Attach and check all the users you made a note of.
12. Click Attach policy.

Access Control / Section Least Privilege



1 Resource(s) Failed
privesc14-UpdatingAssumeRolePolicy

Compliance Section: Least Privilege ●●● Medium

- a. Allow only authorized system access for users (or processes acting on behalf of users) that is necessary to accomplish assigned organizational tasks.
- b. Authorize access to [Assignment: organization-defined security functions] and [Assignment: organization-defined security-relevant information].
- c. Review the privileges assigned to roles or classes of users [Assignment: organization-defined frequency] to validate the need for such privileges.
- d. Reassign or remove privileges, as necessary.

AWS IAM policy allows assume role permission across all services

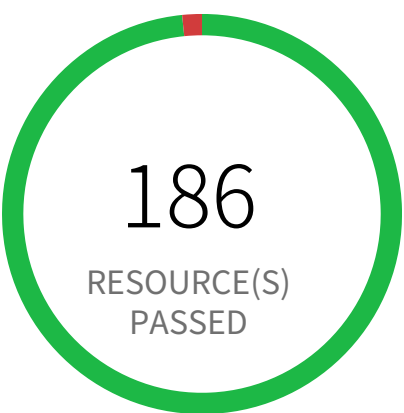
This policy identifies AWS IAM policy which allows assume role permission across all services. Typically, AssumeRole is used if you have multiple accounts and need to access resources from each account then you can create long term credentials in one account and then use temporary security credentials to access all the other accounts by assuming roles in those accounts.

First Seen June 11, 2024 at 11:14:30 PM UTC | **Resource Type** IAM Policy

Recommendations

- 1. Log in to the AWS Console
- 2. Navigate to the 'IAM' service.
- 3. Identify the reported policy
- 4. Change the Service element of the policy document to be more restrictive so that it only allows AssumeRole permission on select services.

Access Control / Section Least Privilege



3 Resource(s) Failed
fp2-allow-all, privesc-high-priv-service-policy,
privesc-AssumeRole-high-priv-policy

Compliance Section: Least Privilege ●●● Medium

- a. Allow only authorized system access for users (or processes acting on behalf of users) that is necessary to accomplish assigned organizational tasks.
- b. Authorize access to [Assignment: organization-defined security functions] and [Assignment: organization-defined security-relevant information].
- c. Review the privileges assigned to roles or classes of users [Assignment: organization-defined frequency] to validate the need for such privileges.
- d. Reassign or remove privileges, as necessary.

AWS IAM policy allows full administrative privileges

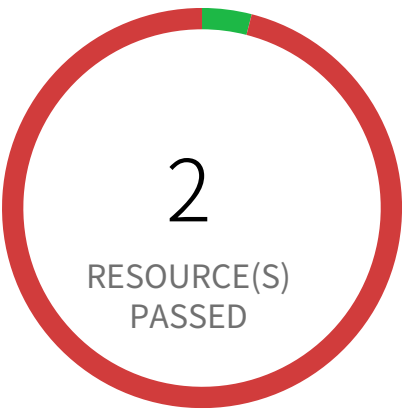
This policy identifies IAM policies with full administrative privileges. IAM policies are the means by which privileges are granted to users, groups, or roles. It is recommended and considered a standard security advice to grant least privilege like granting only the permissions required to perform a task. Determine what users need to do and then craft policies for them that let the users perform only those tasks, instead of allowing full administrative privileges.

First Seen June 11, 2024 at 11:14:30 PM UTC | **Resource Type** Other

Recommendations

- 1. Log in to the AWS Console
- 2. Navigate to the IAM dashboard
- 3. In the navigation pane, click on Policies and then search for the policy name reported
- 4. Select the policy, click on the 'Policy actions', select 'Detach'
- 5. Select all Users, Groups, Roles that have this policy attached, Click on 'Detach policy'

Access Control / Section Least Privilege



48 Resource(s) Failed

privesc-ssmSendCommand-user, fn2-exploitableResourceConstraint-user, k8s, mike-sa, privesc6-UpdateLoginProfile-user, privesc17-EditExistingLambdaFunctionWithRole-user, fp5-nonExploitableConditionConstraint-user, ecr, privesc12-PutRolePolicy-user, privesc4-CreateAccessKey-user & 38 more

Compliance Section: Least Privilege ●●●● Low

- a. Allow only authorized system access for users (or processes acting on behalf of users) that is necessary to accomplish assigned organizational tasks.
- b. Authorize access to [Assignment: organization-defined security functions] and [Assignment: organization-defined security-relevant information].
- c. Review the privileges assigned to roles or classes of users [Assignment: organization-defined frequency] to validate the need for such privileges.
- d. Reassign or remove privileges, as necessary.

AWS IAM policy attached to users

This policy identifies IAM policies attached to user. By default, IAM users, groups, and roles have no access to AWS resources. IAM policies are the means by which privileges are granted to users, groups, or roles. It is recommended that IAM policies be applied directly to groups but not users.

First Seen June 11, 2024 at 6:11:25 PM UTC | **Resource Type** IAM User Managed Policies

Recommendations

1. Sign in to the AWS Console
2. Navigate to the 'IAM' service.
3. Identify the users that were specifically assigned to the reported IAM policy.
4. If a group with a similar policy already exists, put the user into that group. If such a group does not exist, create a new group with relevant policy and assign the user to the group.

Access Control / Section Least Privilege



0 Resource(s) Failed

Compliance Section: Least Privilege ●●●● Low

- a. Allow only authorized system access for users (or processes acting on behalf of users) that is necessary to accomplish assigned organizational tasks.
- b. Authorize access to [Assignment: organization-defined security functions] and [Assignment: organization-defined security-relevant information].
- c. Review the privileges assigned to roles or classes of users [Assignment: organization-defined frequency] to validate the need for such privileges.
- d. Reassign or remove privileges, as necessary.

AWS IAM role/user with unused CloudTrail delete or full permission

This policy identifies IAM roles/users that have unused CloudTrail delete permission or CloudTrail full permissions. As a security best practice, it is recommended to grant the least privilege access like granting only the permissions required to perform a task, instead of providing excessive permissions to a particular role/user. It helps to reduce the potential improper or unintended access to your critical CloudTrail infrastructure.

First Seen N/A | **Resource Type** Other

Recommendations

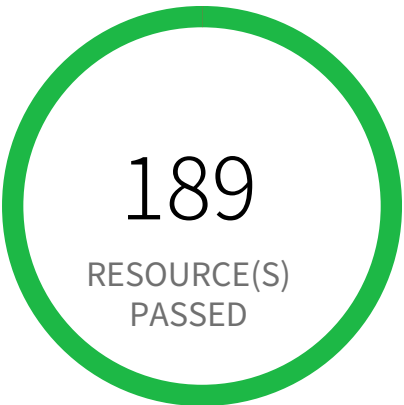
If Roles with unused CloudTrail delete permission,

- 1. Log in to AWS console
- 2. Navigate IAM service
- 3. Click on Roles
- 4. Click on reported IAM role
- 5. In the Permissions tab, Under the 'Permissions policies' section, Remove the policies which have CloudTrail permissions or Delete role if is not required.

If Users with unused CloudTrail delete permission,

- 1. Log in to AWS console
- 2. Navigate IAM service
- 3. Click on Users
- 4. Click on reported IAM user
- 5. In the Permissions tab, Under the 'Permissions policies' section, Remove the policies which have CloudTrail permissions or Delete user if is not required.

Access Control / Section Least Privilege



0 Resource(s) Failed

Compliance Section: Least Privilege — Informational

- a. Allow only authorized system access for users (or processes acting on behalf of users) that is necessary to accomplish assigned organizational tasks.
- b. Authorize access to [Assignment: organization-defined security functions] and [Assignment: organization-defined security-relevant information].
- c. Review the privileges assigned to roles or classes of users [Assignment: organization-defined frequency] to validate the need for such privileges.
- d. Reassign or remove privileges, as necessary.

AWS IAM support access policy is not associated to any role

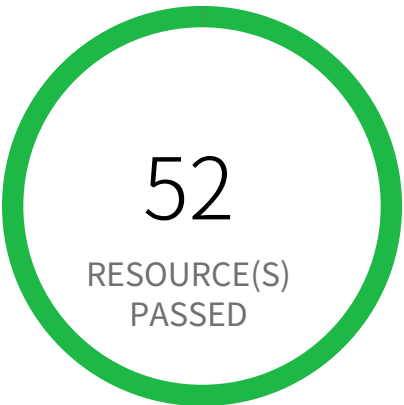
This policy identifies IAM policies with support role access which are not attached to any role for an account. AWS provides a support centre that can be used for incident notification and response, as well as technical support and customer services.

First Seen N/A | **Resource Type** Other

Recommendations

- 1. Log in to AWS console
- 2.Go to service IAM under Services panel.
- 3.From left panel click on 'Policies'
- 4.Search for the existence of a support policy 'AWSSupportAccess'
- 5.Create a IAM role
- 6.Attach 'AWSSupportAccess' managed policy to the created IAM role

Access Control / Section Least Privilege



0 Resource(s) Failed

Compliance Section: Least Privilege — Informational

- a. Allow only authorized system access for users (or processes acting on behalf of users) that is necessary to accomplish assigned organizational tasks.
- b. Authorize access to [Assignment: organization-defined security functions] and [Assignment: organization-defined security-relevant information].
- c. Review the privileges assigned to roles or classes of users [Assignment: organization-defined frequency] to validate the need for such privileges.
- d. Reassign or remove privileges, as necessary.

AWS IAM user has both Console access and Access Keys

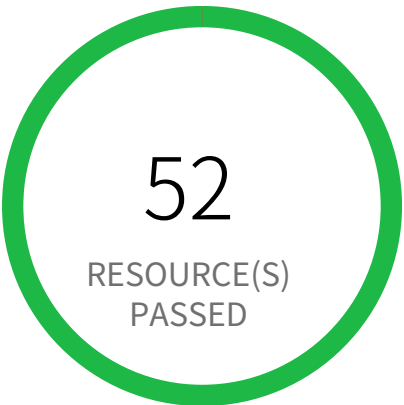
This policy identifies IAM users who have both Console access and Access Keys. When an IAM user is created, the Administrator can assign either Console access or Access Keys or both. Ideally the Console access should be assigned to Users and Access Keys for system / API applications, but not both to the same IAM user.

First Seen N/A | **Resource Type** IAM Credentials Report

Recommendations

- 1. Sign in to the AWS console and navigate to the 'IAM' service.
- 2. Identify the reported IAM user.
- 3. In 'Security credentials' tab check for presence of Access Keys.
- 4. Based on the requirement and company policy, either delete the Access Keys or remove the Console access for this IAM user.

Access Control / Section Least Privilege



0 Resource(s) Failed

Compliance Section: Least Privilege — Informational

- a. Allow only authorized system access for users (or processes acting on behalf of users) that is necessary to accomplish assigned organizational tasks.
- b. Authorize access to [Assignment: organization-defined security functions] and [Assignment: organization-defined security-relevant information].
- c. Review the privileges assigned to roles or classes of users [Assignment: organization-defined frequency] to validate the need for such privileges.
- d. Reassign or remove privileges, as necessary.

AWS IAM user has two active Access Keys

This policy identifies IAM users who have two active Access Keys. Each IAM user can have up to two Access Keys, having two Keys instead of one can lead to increased chances of accidental exposure. So it needs to be ensured that unused Access Keys are deleted.

First Seen N/A | **Resource Type** IAM Credentials Report

Recommendations

- 1. Sign in to the AWS Console and navigate to the 'IAM' service.
- 2. Click on Users in the navigation pane.
- 3. For the identified IAM user which has two active Access Keys, based on policies of your company, take appropriate action.
- 4. Create another IAM user with the specific objective performed by the 2nd Access Key.
- 5. Delete one of the unused Access Keys.

Access Control / Section Least Privilege



0 Resource(s) Failed

Compliance Section: Least Privilege ●●● Medium

- a. Allow only authorized system access for users (or processes acting on behalf of users) that is necessary to accomplish assigned organizational tasks.
- b. Authorize access to [Assignment: organization-defined security functions] and [Assignment: organization-defined security-relevant information].
- c. Review the privileges assigned to roles or classes of users [Assignment: organization-defined frequency] to validate the need for such privileges.
- d. Reassign or remove privileges, as necessary.

AWS KMS Key policy overly permissive

This policy identifies KMS Keys that have a key policy overly permissive. Key policies are the primary way to control access to customer master keys (CMKs) in AWS KMS. It is recommended to follow the principle of least privilege ensuring that KMS key policy does not have all the permissions to be able to complete a malicious action.

For more details:
<https://docs.aws.amazon.com/kms/latest/developerguide/control-access-overview.html#overview-policy-elements>

First Seen N/A | **Resource Type** Other

Recommendations

1. Log in to the AWS console
2. In the console, select the specific region from region drop-down on the top right corner, for which the alert is generated
3. Navigate to Key Management Service (KMS)
4. Click on 'Customer managed keys' (Left Panel)
5. Select reported KMS Customer managed key
6. Click on the 'Key policy' tab
7. Click on 'Edit',
Replace the 'Everyone' grantee (i.e. '*') from the Principal element value with an AWS account ID or an AWS account ARN.
OR
Add a Condition clause to the existing policy statement so that the KMS key is restricted.
8. Click on 'Save Changes'

Access Control / Section Least Privilege



0 Resource(s) Failed

Compliance Section: Least Privilege ●●●● Low

- a. Allow only authorized system access for users (or processes acting on behalf of users) that is necessary to accomplish assigned organizational tasks.
- b. Authorize access to [Assignment: organization-defined security functions] and [Assignment: organization-defined security-relevant information].
- c. Review the privileges assigned to roles or classes of users [Assignment: organization-defined frequency] to validate the need for such privileges.
- d. Reassign or remove privileges, as necessary.

AWS S3 bucket has global view ACL permissions enabled

This policy determines if any S3 bucket(s) has Global View ACL permissions enabled for the All Users group. These permissions allow external resources to see the permission settings associated to the object.

First Seen N/A | Resource Type Other

Recommendations

1. Go to the AWS console S3 dashboard.
2. Select your bucket by clicking on the bucket name.
3. Select the Permissions tab and 'Access Control List.'
4. Under Public Access, select Everyone.
5. In the popup window, under Access to this bucket's ACL, uncheck 'Read bucket permissions' and Save.

Access Control / Section Least Privilege



0 Resource(s) Failed

Compliance Section: Least Privilege ●●●● Low

- a. Allow only authorized system access for users (or processes acting on behalf of users) that is necessary to accomplish assigned organizational tasks.
- b. Authorize access to [Assignment: organization-defined security functions] and [Assignment: organization-defined security-relevant information].
- c. Review the privileges assigned to roles or classes of users [Assignment: organization-defined frequency] to validate the need for such privileges.
- d. Reassign or remove privileges, as necessary.

AWS S3 bucket having policy overly permissive to VPC endpoints

This policy identifies S3 buckets that have the bucket policy overly permissive to VPC endpoints. It is recommended to follow the principle of least privileges ensuring that the VPC endpoints have only necessary permissions instead of full permission on S3 operations.

NOTE: When applying the Amazon S3 bucket policies for VPC endpoints described in this section, you might block your access to the bucket without intending to do so. Bucket permissions that are intended to specifically limit bucket access to connections originating from your VPC endpoint can block all connections to the bucket. The policy might disable console access to the specified bucket because console requests don't originate from the specified VPC endpoint. So remediation should be done very carefully.

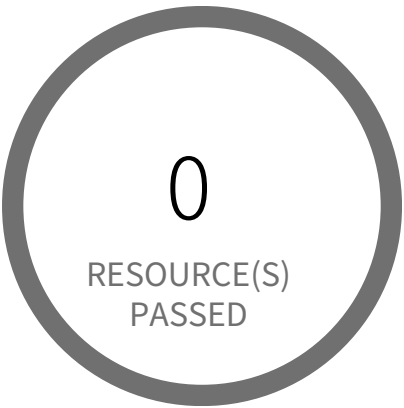
For details refer <https://docs.aws.amazon.com/AmazonS3/latest/dev/example-bucket-policies-vpc-endpoint.html>

First Seen N/A | **Resource Type** Other

Recommendations

- 1. Log in to the AWS console
 - 2. Navigate to the S3 dashboard
 - 3. Choose the reported S3 bucket
 - 4. In the 'Permissions' tab, click on the 'Bucket Policy'
 - 5. Update the S3 bucket policy for the VPC endpoint so that it has only required permissions instead of full S3 permission.
- Refer for example: <https://docs.aws.amazon.com/AmazonS3/latest/dev/example-bucket-policies-vpc-endpoint.html>

Access Control / Section Least Privilege



0 Resource(s) Failed

Compliance Section: Least Privilege — Informational

- a. Allow only authorized system access for users (or processes acting on behalf of users) that is necessary to accomplish assigned organizational tasks.
- b. Authorize access to [Assignment: organization-defined security functions] and [Assignment: organization-defined security-relevant information].
- c. Review the privileges assigned to roles or classes of users [Assignment: organization-defined frequency] to validate the need for such privileges.
- d. Reassign or remove privileges, as necessary.

AWS SQS queue access policy is overly permissive

This policy identifies Simple Queue Service (SQS) queues that have an overly permissive access policy. It is highly recommended to have the least privileged access policy to protect the SQS queue from data leakage and unauthorized access.

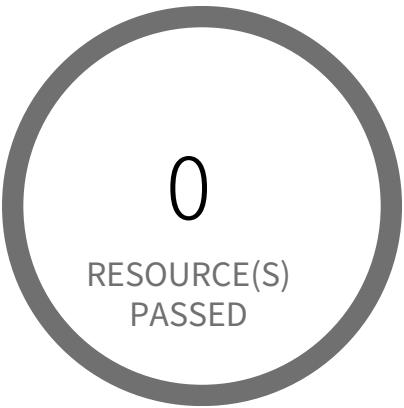
For more details:
<https://docs.aws.amazon.com/AWSSimpleQueueService/latest/SQSDeveloperGuide/sqs-basic-examples-of-sqs-policies.html>

First Seen N/A | **Resource Type** Other

Recommendations

1. Log in to the AWS console
2. Select the region, from the region drop-down, in which the alert is generated
3. Navigate to Simple Queue Service (SQS) dashboard
4. Choose the reported Simple Queue Service (SQS) and choose 'Edit'
5. Scroll to the 'Access policy' section
6. Edit the access policy statements in the input box, Make sure the 'Principal' is not set to '*', which makes your SQS queues accessible to any anonymous users.
7. When you finish configuring the access policy, choose 'Save'.

Access Control / Section Least Privilege



0 Resource(s) Failed

Compliance Section: Least Privilege — Informational

- a. Allow only authorized system access for users (or processes acting on behalf of users) that is necessary to accomplish assigned organizational tasks.
- b. Authorize access to [Assignment: organization-defined security functions] and [Assignment: organization-defined security-relevant information].
- c. Review the privileges assigned to roles or classes of users [Assignment: organization-defined frequency] to validate the need for such privileges.
- d. Reassign or remove privileges, as necessary.

AWS SageMaker notebook instance with root access enabled

This policy identifies the SageMaker notebook instances which are enabled with root access. Root access means having administrator privileges, users with root access can access and edit all files on the compute instance, including system-critical files. Removing root access prevents notebook users from deleting system-level software, installing new software, and modifying essential environment components. NOTE: Lifecycle configurations need root access to be able to set up a notebook instance. Because of this, lifecycle configurations associated with a notebook instance always run with root access even if you disable root access for users.

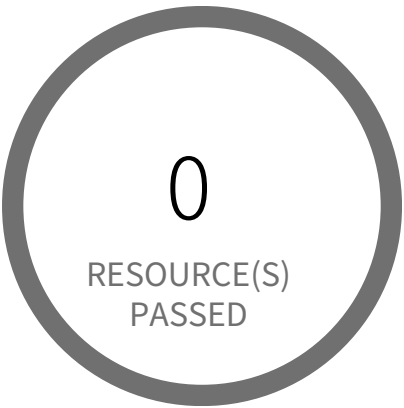
For more details:
<https://docs.aws.amazon.com/sagemaker/latest/dg/nbi-root-access.html>

First Seen N/A | **Resource Type** Other

Recommendations

- 1. Log in to AWS console
- 2. Navigate to the AWS SageMaker dashboard
- 3. Choose Notebook instances (Left panel)
- 4. Click on the reported SageMaker notebook instance
- Note: To update root access for SageMaker notebook instances; Instances need to be stopped. So stop running instance before editing.
- 5. In the 'Notebook instance settings' section, click on 'Edit'
- 6. On the Edit notebook instance page, within the 'Permissions and encryption' section, From the 'Root access - optional' options, select 'Disable - Don't give users root access to the notebook'
- 7. Click on the 'Update notebook instance'

Access Control / Section Least Privilege



0 Resource(s) Failed

Compliance Section: Least Privilege ●●● Medium

- a. Allow only authorized system access for users (or processes acting on behalf of users) that is necessary to accomplish assigned organizational tasks.
- b. Authorize access to [Assignment: organization-defined security functions] and [Assignment: organization-defined security-relevant information].
- c. Review the privileges assigned to roles or classes of users [Assignment: organization-defined frequency] to validate the need for such privileges.
- d. Reassign or remove privileges, as necessary.

AWS root account configured with Virtual MFA

This policy identifies AWS root accounts which are configured with Virtual MFA. Root is an important role in your account and root accounts must be configured with hardware MFA. Hardware MFA adds extra security because it requires users to type a unique authentication code from an approved authentication device when they access AWS websites or services.

First Seen N/A | **Resource Type** Other

Recommendations

To manage MFA devices for your AWS account, you must use your root user credentials to sign in to AWS. You cannot manage MFA devices for the root user while signed in with other credentials.

1. Sign in to the AWS Management Console with your root user credentials
2. Go to IAM
3. Do one of the following:
Option 1: Choose Dashboard, and under Security Status, expand Activate MFA on your root account.
Option 2: On the right side of the navigation bar, select your account name, and then choose My Security Credentials. If necessary, choose Continue to Security Credentials. Then expand the Multi-Factor Authentication (MFA) section on the page.
4. Choose Manage MFA or Activate MFA, depending on which option you chose in the preceding step.
5. In the wizard, choose A hardware MFA device and then choose Next Step.
6. If you have U2F security key as hardware MFA device, choose U2F security key and click on Continue. Next plug the USB U2F security key, when setup is complete click on Close.
If you have any other hardware MFA device, choose Other hardware MFA device option
 - a. In the Serial Number box, type the serial number that is found on the back of the MFA device.
 - b. In the Authentication Code 1 box, type the six-digit number displayed by the MFA device. You might need to press the button on the front of the device to display the number.
 - c. Wait 30 seconds while the device refreshes the code, and then type the next six-digit number into the Authentication Code 2 box. You might need to press the button on the front of the device again to display the second number.
 - d. Choose Next Step. The MFA device is now associated with the AWS account.

Important:

Submit your request immediately after generating the authentication codes. If you generate the codes and then wait too long to submit the request, the MFA device successfully associates with the user but the MFA device becomes out of sync. This happens because time-based one-time passwords (TOTP) expire after a short period of time. If this happens, you can resync the device.

Access Control / Section System Use Notification



0 Resource(s) Failed

Compliance Section: System Use Notification ●●●● Low

Display a system use notification message with privacy and security notices consistent with applicable CUI rules before granting access to the system.

AWS Amazon Machine Image (AMI) is publicly accessible

This policy identifies AWS AMIs which are owned by the AWS account and are accessible to the public. Amazon Machine Image (AMI) provides information to launch an instance in the cloud. The AMIs may contain proprietary customer information and should be accessible only to authorized internal users.

First Seen N/A | **Resource Type** VM Image

Recommendations

- 1. Login to the AWS Console and navigate to 'EC2' service.
- 2. In the navigation pane, choose AMIs.
- 3. Select your AMI from the list, and then choose Actions, Modify Image Permissions.
- 4. Choose Private and choose Save.

Access Control / Section System Use Notifica- tion



0 Resource(s) Failed

Compliance Section: System Use Notification ●●●● Low

Display a system use notification message with privacy and security notices consistent with applicable CUI rules before granting access to the system.

[AWS CloudTrail bucket is publicly accessible](#)

This policy identifies publicly accessible S3 buckets that store CloudTrail data. These buckets contains sensitive audit data and only authorized users and applications should have access.

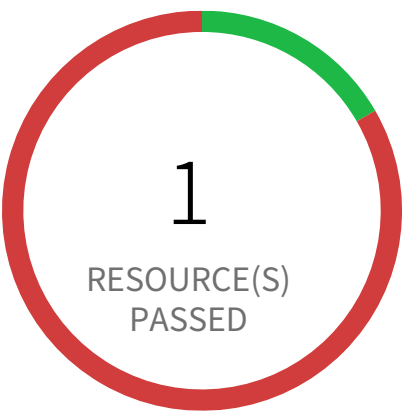
First Seen N/A | **Resource Type** Other

Recommendations

1. Login to the AWS Console
2. Navigate to the 'S3' service
3. Click on the 'S3' resource reported in the alert
4. Click on the 'Permissions'
5. If 'Access Control List' is set to 'Public' follow below steps
 - a. Under 'Access Control List', Click on 'Everyone' and uncheck all items
 - b. Click on Save
6. If 'Bucket Policy' is set to public follow below steps
 - a. Under 'Bucket Policy', modify the policy to remove public access
 - b. Click on Save
 - c. If 'Bucket Policy' is not required delete the existing 'Bucket Policy'.

Note: Make sure updating 'Access Control List' or 'Bucket Policy' does not affect S3 bucket data access.

Access Control / Section System Use Notification



5 Resource(s) Failed

snap-0d47c6cb9d3f1f396,
snap-0bf35b272167e62d2,
snap-036d0921bbb8d3125,
snap-04de50de9719b6b47,
snap-0f097a5ddc78b9b04

Compliance Section: System Use Notification ●●●● Low

Display a system use notification message with privacy and security notices consistent with applicable CUI rules before granting access to the system.

AWS EBS Snapshot with access for unmonitored cloud accounts

This policy identifies EBS Snapshot with access for unmonitored cloud accounts. The EBS Snapshots which have either the read / write permission opened up for Cloud Accounts which are NOT part of Cloud Accounts monitored by Prisma Cloud. These accounts with read / write privileges should be reviewed and confirmed that these are valid accounts of your organisation (or authorised by your organisation) and are not active under Prisma Cloud monitoring.

First Seen March 14, 2025 at 1:51:58 AM UTC | **Resource Type** Other

Recommendations

- 1. Sign in to the AWS console.
- 2. In the console, select the specific region from region drop down on the top right corner, for which the alert is generated.
- 3. Access the EC2 service, navigate to 'Snapshots' under 'Elastic Block Store' in left hand menu.
- 4. Select the identified 'EBS Snapshot' and select the tab 'Permissions'.
- 5. Review and delete the AWS Accounts which should not have read access.

Access Control / Section System Use Notification



0 Resource(s) Failed

Compliance Section: System Use Notification ●●● Medium

Display a system use notification message with privacy and security notices consistent with applicable CUI rules before granting access to the system.

AWS EBS snapshots are accessible to public

This policy identifies EC2 EBS snapshots which are accessible to public. Amazon Elastic Block Store (Amazon EBS) provides persistent block storage volumes for use with Amazon EC2 instances in the AWS Cloud. If EBS snapshots are inadvertently shared to public, any unauthorized user with AWS console access can gain access to the snapshots and gain access to sensitive data.

First Seen N/A | **Resource Type** Snapshot Settings

Recommendations

- 1. Log in to the AWS console
- 2. In the console, select the specific region from region drop down on the top right corner, for which the alert is generated
- 3. Navigate to 'EC2' service.
- 4. Under the 'Elastic Block Storage', click on the 'Snapshots'.
- 5. For the specific Snapshots, change the value of field 'Property' to 'Private'.
- 6. Under the section 'Encryption Details', set the value of 'Encryption Enabled' to 'Yes'.

Access Control / Section System Use Notification



0 Resource(s) Failed

Compliance Section: System Use Notification ●●●● Low

Display a system use notification message with privacy and security notices consistent with applicable CUI rules before granting access to the system.

AWS RDS Snapshot with access for unmonitored cloud accounts

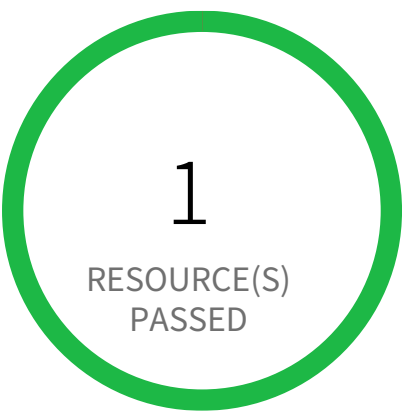
This policy identifies RDS snapshots with access for unmonitored cloud accounts. The RDS Snapshot which have either the read / write permission opened up for Cloud Accounts which are NOT part of Cloud Accounts monitored by Prisma Cloud. These accounts with read / write privileges should be reviewed and confirmed that these are valid accounts of your organisation (or authorised by your organisation) and are not active under Prisma Cloud monitoring.

First Seen N/A | **Resource Type** Other

Recommendations

- 1. Sign into the AWS console.
- 2. In the console, select the specific region from region drop down on the top right corner, for which the alert is generated
- 3. Navigate to the RDS service.
- 4. Select the identified 'RDS Snapshot' under the 'Snapshots' in the left hand menu.
- 5. Under the tab 'Snapshot Actions', selection the option 'Share Snapshot'.
- 6. Review and delete the AWS Accounts which should not have read access.

Access Control / Section System Use Notification



0 Resource(s) Failed

Compliance Section: System Use Notification ●●● Medium

Display a system use notification message with privacy and security notices consistent with applicable CUI rules before granting access to the system.

AWS RDS database instance is publicly accessible

This policy identifies RDS database instances which are publicly accessible. DB instances should not be publicly accessible to protect the integrity of data. Public accessibility of DB instances can be modified by turning on or off the Public accessibility parameter.

First Seen N/A | **Resource Type** Other

Recommendations

To modify the RDS database publicly accessible setting:

1. Sign into the AWS console.
2. In the console, select the specific region from region drop down on the top right corner, for which the alert is generated
3. In the AWS console, locate and select the 'Aurora and RDS' service.
4. In the left navigation pane, click on 'Databases'. From the list of databases, locate and click on the DB identifier (name) of the specific RDS instance mentioned in the alert.
4. Click on the 'Modify' button to access the instance configuration settings.
5. Under the 'Connectivity' section expand to 'Additional configuration', locate the 'Public access' setting. Change the value to 'Not publicly accessible' to disable public access to the instance.
6. Click on 'Continue' to proceed to the next step. Select the desired 'Scheduling of modifications' option and click on 'Modify DB Instance' to apply the changes.

Note: Carefully review and test these steps before implementing them in your production environment. Modifying RDS instance settings can impact your application's functionality. Ensure you have a backup plan in place before making any changes.

Access Control / Section System Use Notifica- tion



0 Resource(s) Failed

Compliance Section: System Use Notification ●●● Medium

Display a system use notification message with privacy and security notices consistent with applicable CUI rules before granting access to the system.

AWS RDS snapshots are accessible to public

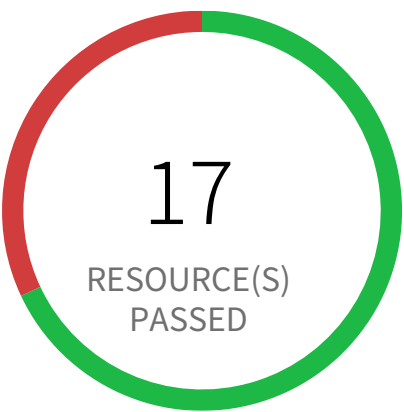
This policy identifies AWS RDS snapshots which are accessible to public. Amazon Relational Database Service (Amazon RDS) is a web service that makes it easier to setup and manage databases. If RDS snapshots are inadvertently shared to public, any unauthorized user with AWS console access can gain access to the snapshots and gain access to sensitive data.

First Seen N/A | **Resource Type** Managed Database Snapshot

Recommendations

- 1. Sign in to the AWS console
- 2. In the console, select the specific region from region drop down on the top right corner, for which the alert is generated
- 3. Navigate to the 'RDS' service.
- 4. For the RDS instance reported in the alert, change 'Publicly Accessible' setting to 'No'.

Access Control / Section System Use Notification



8 Resource(s) Failed

pays-app-dev-jd3jnx92j3,
all-files-mxi29dnc2h92eh823h8934,
main-app-stage-2ncien92,
swiftapp-jdi92j98d3jnxdi32,
subs-dxh8f3n4x8f93, payments-dcnenh93,
maincon-ceio23hnx834,
micro-djm2983hdno3hnxdi23bh8d3yb289yd

Compliance Section: System Use Notification ●●●● Low

Display a system use notification message with privacy and security notices consistent with applicable CUI rules before granting access to the system.

AWS S3 bucket accessible to unmonitored cloud accounts

Unmonitored cloud accounts with read/write access to AWS S3 buckets pose a significant security risk. These accounts could potentially exfiltrate sensitive data or make unauthorized modifications.

AWS S3 buckets are cloud storage services. Granting read/write access to unmonitored cloud accounts bypasses security monitoring and control mechanisms. Attackers gaining access to such accounts could exploit this misconfiguration for data breaches or malicious activity.

The impact of this misconfiguration could be severe, including data loss, regulatory fines, and reputational damage. Restricting access to only authorized and monitored accounts ensures better control over data access and minimizes the risk of unauthorized actions.

To mitigate this risk, regularly review and update access control lists (ACLs) for all S3 buckets. Ensure that only trusted and monitored cloud accounts have necessary permissions. Implement strong authentication and authorization mechanisms and regularly audit access logs for suspicious activities.

First Seen June 19, 2025 at 7:34:42 AM UTC | Resource Type Other

Recommendations

- 1. Log in to the AWS Console
- 2. Navigate to the 'S3' service
- 3. Click on the reported S3 bucket
- 4. Click on the 'Permissions' tab
- 5. Navigate to the 'Access control list (ACL)' section and Click on the 'Edit'
- 6. Under 'Access for other AWS accounts', Add the Cloud Accounts that are monitored by Prisma Cloud
- 7. Click on 'Save changes'

Access Control / Section System Use Notification



0 Resource(s) Failed

Compliance Section: System Use Notification ●●● Medium

Display a system use notification message with privacy and security notices consistent with applicable CUI rules before granting access to the system.

AWS S3 buckets are accessible to any authenticated user

AWS S3 buckets configured with overly permissive access controls allow any authenticated user to access sensitive data. This misconfiguration exposes data to unauthorized internal users or compromised credentials.

AWS S3 buckets offer various access control mechanisms, including bucket policies and access control lists (ACLs). Incorrectly configuring these settings, allowing access to 'authenticated users', bypasses intended restrictions. Attackers with legitimate AWS credentials, even those with limited privileges, could access sensitive data stored in the bucket, leading to data breaches and potential regulatory violations.

Data breaches resulting from this misconfiguration can cause significant financial losses, reputational damage, and legal repercussions. Implementing least privilege access control ensures only authorized users and services can access specific S3 buckets and their contents, thereby minimizing the impact of compromised credentials.

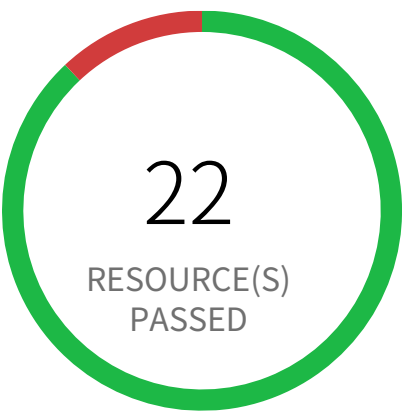
To mitigate this risk, restrict bucket access to specific IAM users, roles, or groups using granular policies. Implement strong access control lists, limiting access only to trusted IPs and services. Regularly review and audit bucket policies and ACLs to ensure appropriate access controls are maintained and updated as needed.

First Seen N/A | **Resource Type** Other

Recommendations

1. Sign in to the AWS Management Console and open the Amazon S3 console at <https://console.aws.amazon.com/s3/>.
2. In the left navigation pane, choose 'General purpose buckets'.
3. In the Buckets list, choose the name of the bucket that is reported.
4. Choose 'Permissions'.
5. Under 'Access control list (ACL)', choose 'Edit'.
6. To undo permissions for anyone with an AWS account, beside 'Authenticated Users group (anyone with an AWS account)', Uncheck the selection from the following ACL permissions: Objects – List, Bucket ACL – Read.
7. To save your changes, choose 'Save changes'.

Access Control / Section System Use Notification



3 Resource(s) Failed

finance-secret-asdfsd3r53rtr-one, fi-
nance-secret-der4t4tg5ght-three, finance-se-
cret-der4t4tg5ght-two

Compliance Section: System Use Notification High

Display a system use notification message with privacy and security notices consistent with applicable CUI rules before granting access to the system.

AWS S3 buckets are accessible to public via ACL

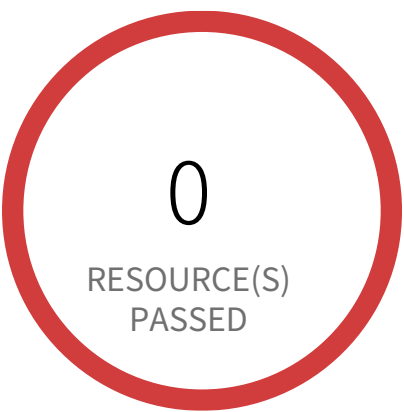
This policy identifies S3 buckets which are publicly accessible via ACL. Amazon S3 often used to store highly sensitive enterprise data and allowing public access to such S3 bucket through ACL would result in sensitive data being compromised. It is highly recommended to disable ACL configuration for all S3 buckets and use resource based policies to allow access to S3 buckets.

First Seen December 3, 2023 at 11:08:42 AM UTC | **Resource Type** Other

Recommendations

- 1. Login to the AWS Console
- 2. Navigate to the 'S3' service
- 3. Click on the 'S3' resource reported in the alert
- 4. Click on the 'Permissions'
- 5. If Access Control List' is set to 'Public' follow below steps
 - a. Under 'Access Control List', Click on 'Everyone' and uncheck all items
 - b. Click on Save

Access Control / Section System Use Notification



3 Resource(s) Failed
Cobra-Attacker, finance-web-app, employ-
ee-portal

Compliance Section: System Use Notification ●●● Medium

Display a system use notification message with privacy and security notices consistent with applicable CUI rules before granting access to the system.

Instances exposed to network traffic from the internet

This policy identifies network traffic coming from the internet to sensitive cloud workloads. Cloud workloads should have appropriate Security Groups and ACLs in place so that only external facing workloads such as load balancers, web servers, bastion hosts are exposed to the internet. Cloud workloads with internet exposure are vulnerable to external threats.

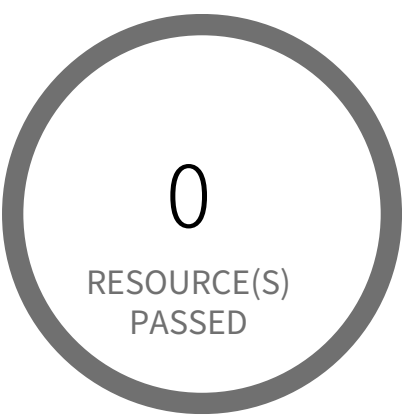
Note: This policy alerts AWS and GCP workloads correctly and for Azure, it may trigger alerts for NAT Gateway configured resources also.

First Seen February 9, 2025 at 10:40:09 PM UTC | **Resource Type** Other

Recommendations

- 1. Log in to the Cloud Console
- 2. Search for the resource reported in the alert
- 3. Check if the Security Group/Firewall Rule of the resource indeed allows connections from the internet
- 4. Assign another Security Group/Firewall Rule to the resource that has a more restrictive ACL, which does not permit connection from the internet

Access Control / Section Remote Access



0 Resource(s) Failed

Compliance Section: Remote Access ●●●● Medium

- a. Establish usage restrictions, configuration requirements, and connection requirements for each type of allowable remote system access.
- b. Authorize each type of remote system access prior to establishing such connections.
- c. Route remote access to the system through authorized and managed access control points.
- d. Authorize the remote execution of privileged commands and remote access to security-relevant information.

AWS CloudFront origin protocol policy does not enforce HTTPS-only

This policy identifies AWS CloudFront which has an origin protocol policy that does not enforce HTTPS-only. Enforcing HTTPS protocol policy between origin and CloudFront will encrypt all communication and will be more secure. As a security best practice, enforce HTTPS-only traffic between a CloudFront distribution and the origin.

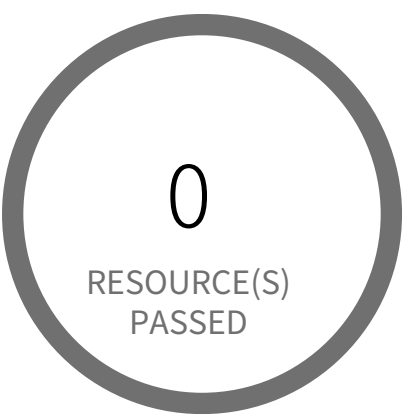
First Seen N/A | **Resource Type** Other

Recommendations

Communication between CloudFront and your Custom Origin should enforce HTTPS-only traffic. Modify the CloudFront Origin's Origin Protocol Policy to HTTPS only.

1. Go to the AWS console CloudFront dashboard.
2. Select your distribution Id.
3. Select the 'Origins' tab.
4. Check the origin you want to modify then select Edit.
5. Change the Origin Protocol Policy to 'https-only.'
6. Select 'Yes, Edit.'

Access Control / Section Remote Access



0 Resource(s) Failed

Compliance Section: Remote Access — Informational

- a. Establish usage restrictions, configuration requirements, and connection requirements for each type of allowable remote system access.
- b. Authorize each type of remote system access prior to establishing such connections.
- c. Route remote access to the system through authorized and managed access control points.
- d. Authorize the remote execution of privileged commands and remote access to security-relevant information.

AWS DynamoDB encrypted using AWS owned CMK instead of AWS managed CMK

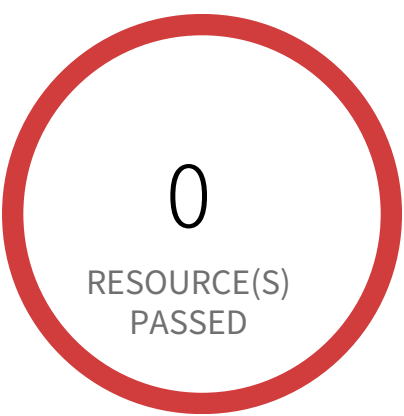
This policy identifies the DynamoDB tables that use AWS owned CMK (default) instead of AWS managed CMK (KMS) to encrypt data. AWS managed CMK provide additional features such as the ability to view the CMK and key policy, and audit the encryption and decryption of DynamoDB tables.

First Seen N/A | **Resource Type** Other

Recommendations

1. Sign in to AWS console
2. In the console, select the specific region from region drop down on the top right corner, for which the alert is generated.
3. Navigate to 'DynamoDB' dashboard
4. Select the reported table from the list of DynamoDB tables
5. In 'Overview' tab, go to 'Table Details' section
6. Click on the 'Manage Encryption' link available for 'Encryption Type'
7. On 'Manage Encryption' pop up window, Select 'KMS' as the encryption type.

Access Control / Section Remote Access



17 Resource(s) Failed

818698786219:EBS:eu-west-3,
818698786219:EBS:us-west-2,
818698786219:EBS:ap-southeast-2,
818698786219:EBS:ap-northeast-1,
818698786219:EBS:ca-central-1,
818698786219:EBS:ap-northeast-3,
818698786219:EBS:eu-west-2,
818698786219:EBS:eu-central-1,
818698786219:EBS:eu-north-1,
818698786219:EBS:us-east-2 & 7 more

Compliance Section: Remote Access ●●●● Low

- a. Establish usage restrictions, configuration requirements, and connection requirements for each type of allowable remote system access.
- b. Authorize each type of remote system access prior to establishing such connections.
- c. Route remote access to the system through authorized and managed access control points.
- d. Authorize the remote execution of privileged commands and remote access to security-relevant information.

AWS EBS volume region with encryption is disabled

This policy identifies AWS regions in which new EBS volumes are getting created without any encryption. Encrypting data at rest reduces unintentional exposure of data stored in EBS volumes. It is recommended to configure EBS volume at the regional level so that every new EBS volume created in that region will be enabled with encryption by using a provided encryption key.

First Seen July 28, 2025 at 9:09:28 PM UTC | **Resource Type** Other

Recommendations

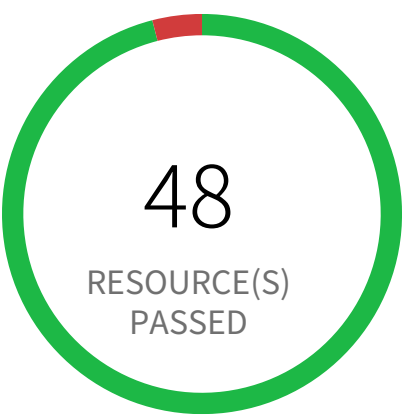
To enable encryption at region level by default, follow below URL:
<https://docs.aws.amazon.com/ebs/latest/userguide/work-with-ebs-encr.html#encryption-by-default>

Additional Information:

To detect existing EBS volumes that are not encrypted ; refer Saved Search:
AWS EBS volumes are not encrypted_RL

To detect existing EBS volumes that are not encrypted with CMK, refer Saved Search:
AWS EBS volume not encrypted using Customer Managed Key_RL

Access Control / Section Remote Access



2 Resource(s) Failed
eks-cluster-sg-pc-national-bank-425600227,
custom-security-group

Compliance Section: Remote Access ●●●● Low

- a. Establish usage restrictions, configuration requirements, and connection requirements for each type of allowable remote system access.
- b. Authorize each type of remote system access prior to establishing such connections.
- c. Route remote access to the system through authorized and managed access control points.
- d. Authorize the remote execution of privileged commands and remote access to security-relevant information.

AWS EKS cluster security group overly permissive to all traffic

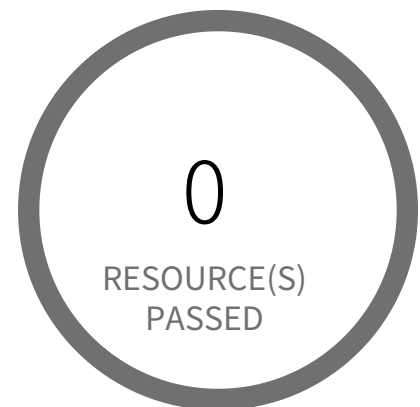
This policy identifies EKS cluster Security groups that are overly permissive to all traffic. Doing so, may allow a bad actor to brute force their way into the system and potentially get access to the entire network. Review your list of security group rules to ensure that your resources are not exposed. As a best practice, restrict traffic solely from known static IP addresses. Limit the access list to include known hosts, services, or specific employees only.

First Seen January 28, 2025 at 12:06:58 PM UTC | **Resource Type** Other

Recommendations

- Before making any changes, please check the impact on your applications/services. If the Security Group reported indeed need to restrict all traffic, follow the instructions below:
- 1. Log in to the AWS console
 - 2. Navigate to the 'VPC' service
 - 3. Select the 'Security Group' reported in the alert
 - 4. Click on 'Inbound Rules'
 - 5. Remove the rule which has the 'Source' value as 0.0.0.0/0 or ::/0

Access Control / Section Remote Access



0 Resource(s) Failed

Compliance Section: Remote Access — Informational

- a. Establish usage restrictions, configuration requirements, and connection requirements for each type of allowable remote system access.
- b. Authorize each type of remote system access prior to establishing such connections.
- c. Route remote access to the system through authorized and managed access control points.
- d. Authorize the remote execution of privileged commands and remote access to security-relevant information.

AWS EMR cluster is not configured with CSE CMK for data at rest encryption (Amazon S3 with EMRFS)

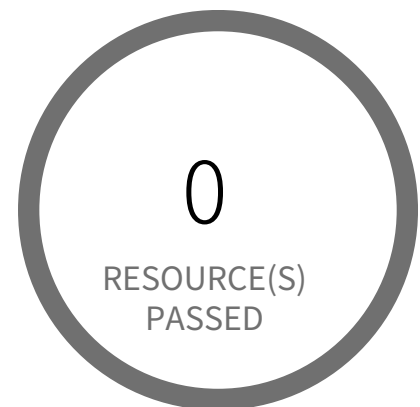
This policy identifies EMR clusters which are not configured with Client Side Encryption with Customer Master Keys(CSE CMK) for data at rest encryption of Amazon S3 with EMRFS. As a best practice, use Customer Master Keys (CMK) to encrypt the data in your EMR cluster and ensure full control over your data.

First Seen N/A | Resource Type Other

Recommendations

1. Log in to the AWS Console
2. In the console, select the specific region from region drop down on the top right corner, for which the alert is generated
3. Navigate to 'EMR' dashboard from 'Services' dropdown
4. Go to 'Security configurations', click 'Create'
5. On the Create security configuration window,
6. In 'Name' box, provide a name for the new EMR security configuration.
7. For encryption At Rest click the checkbox for 'Enable at-rest encryption for EMRFS data in Amazon S3'.
8. From the dropdown 'Default encryption mode' select 'CSE-Custom'. Follow below link for configuration steps.
<https://docs.aws.amazon.com/emr/latest/ManagementGuide/emr-encryption-enable.html>
9. Click on 'Create' button
10. On the left menu of EMR dashboard Click 'Clusters'
11. Select the EMR cluster for which the alert has been generated and click on the 'Clone' button from the top menu
12. In the Cloning popup, choose 'Yes' and Click 'Clone'.
13. On the Create Cluster page, in the Security Options section, click on 'security configuration'
14. From the 'Security configuration' drop down select the name of the security configuration created at step 4 to step 8, click 'Create Cluster'
15. Once you the new cluster is set up verify its working and terminate the source cluster in order to stop incurring charges for it.
16. On the left menu of EMR dashboard Click 'Clusters', from the list of clusters select the source cluster which is alerted
17. Click on the 'Terminate' button from the top menu.
18. On the 'Terminate clusters' pop-up, click 'Terminate'.

Access Control / Section Remote Access



0 Resource(s) Failed

Compliance Section: Remote Access ●●●● Low

- a. Establish usage restrictions, configuration requirements, and connection requirements for each type of allowable remote system access.
- b. Authorize each type of remote system access prior to establishing such connections.
- c. Route remote access to the system through authorized and managed access control points.
- d. Authorize the remote execution of privileged commands and remote access to security-relevant information.

AWS EMR cluster is not configured with SSE KMS for data at rest encryption (Amazon S3 with EMRFS)

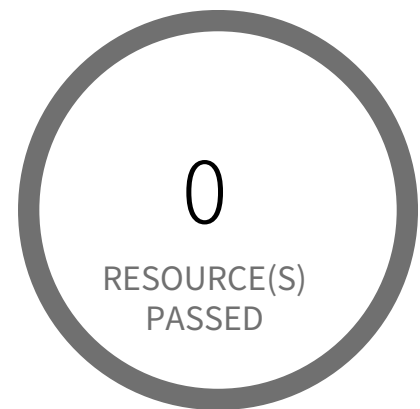
This policy identifies EMR clusters which are not configured with Server Side Encryption(SSE KMS) for data at rest encryption of Amazon S3 with EMRFS. As a best practice, use SSE-KMS for server side encryption to encrypt the data in your EMR cluster and ensure full control over your data.

First Seen N/A | Resource Type Other

Recommendations

1. Log in to the AWS Console
2. In the console, select the specific region from region drop down on the top right corner, for which the alert is generated
3. Navigate to 'EMR' dashboard from 'Services' dropdown
4. Go to 'Security configurations', click 'Create'
5. On the Create security configuration window,
6. In 'Name' box, provide a name for the new EMR security configuration
7. For encryption At Rest click the checkbox for 'Enable at-rest encryption for EMRFS data in Amazon S3'
8. From the dropdown 'Default encryption mode' select 'SSE-KMS'. Follow below link for configuration steps.
<https://docs.aws.amazon.com/emr/latest/ManagementGuide/emr-encryption-enable.html>
9. Click on 'Create' button.
10. On the left menu of EMR dashboard Click 'Clusters'.
11. Select the EMR cluster for which the alert has been generated and click on the 'Clone' button from the top menu.
12. In the Cloning popup, choose 'Yes' and Click 'Clone'.
13. On the Create Cluster page, in the Security Options section, click on 'security configuration'.
14. From the 'Security configuration' drop down select the name of the security configuration created at step 4 to step 8, click 'Create Cluster'
15. Once you the new cluster is set up verify its working and terminate the source cluster in order to stop incurring charges for it.
16. On the left menu of EMR dashboard Click 'Clusters', from the list of clusters select the source cluster which is alerted
17. Click on the 'Terminate' button from the top menu
18. On the 'Terminate clusters' pop-up, click 'Terminate'.

Access Control / Section Remote Access



0 Resource(s) Failed

Compliance Section: Remote Access ●●●● Low

- a. Establish usage restrictions, configuration requirements, and connection requirements for each type of allowable remote system access.
- b. Authorize each type of remote system access prior to establishing such connections.
- c. Route remote access to the system through authorized and managed access control points.
- d. Authorize the remote execution of privileged commands and remote access to security-relevant information.

AWS EMR cluster is not enabled with data encryption at rest

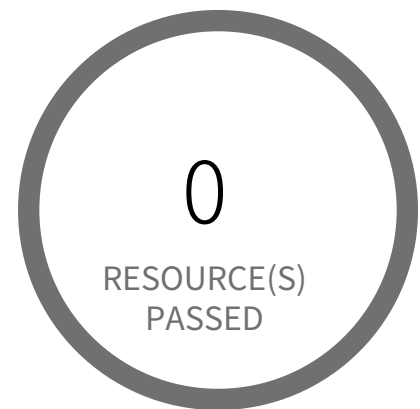
This policy identifies AWS EMR clusters for which data encryption at rest is not enabled. Encryption of data at rest is required to prevent unauthorized users from accessing the sensitive information available on your EMR clusters and associated storage systems.

First Seen N/A | **Resource Type** Other

Recommendations

1. Login to the AWS Console.
2. In the console, select the specific region from region drop down on the top right corner, for which the alert is generated.
3. Navigate to 'EMR' dashboard from 'Services' dropdown.
4. Go to 'Security configurations', click 'Create'.
5. On the Create security configuration window,
6. In 'Name' box, provide a name for the new EMR security configuration.
7. For encryption At Rest select the required encryption type ('S3 encryption'/'Local disk encryption'/both) and follow below link for enabling the same.
8. <https://docs.aws.amazon.com/emr/latest/ManagementGuide/emr-encryption-enable.html>
9. Click on 'Create' button.
10. On the left menu of EMR dashboard Click 'Clusters'.
11. Select the EMR cluster for which the alert has been generated and click on the 'Clone' button from the top menu.
12. In the Cloning popup, choose 'Yes' and Click 'Clone'.
13. On the Create Cluster page, in the Security Options section, click on 'security configuration'.
14. From the 'Security configuration' drop down select the name of the security configuration created at step 4 to step 8, click 'Create Cluster'.
15. Once you the new cluster is set up verify its working and terminate the source cluster in order to stop incurring charges for it.
16. On the left menu of EMR dashboard Click 'Clusters', from the list of clusters select the source cluster which is alerted.
17. Click on the 'Terminate' button from the top menu.
18. On the 'Terminate clusters' pop-up, click 'Terminate'.

Access Control / Section Remote Access



0 Resource(s) Failed

Compliance Section: Remote Access ●●●● Low

- a. Establish usage restrictions, configuration requirements, and connection requirements for each type of allowable remote system access.
- b. Authorize each type of remote system access prior to establishing such connections.
- c. Route remote access to the system through authorized and managed access control points.
- d. Authorize the remote execution of privileged commands and remote access to security-relevant information.

AWS EMR cluster is not enabled with data encryption in transit

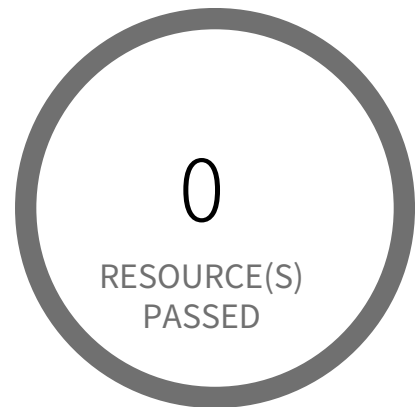
This policy identifies AWS EMR clusters which are not enabled with data encryption in transit. It is highly recommended to implement in-transit encryption in order to protect data from unauthorized access as it travels through the network, between clients and storage server. Enabling data encryption in-transit helps prevent unauthorized users from reading sensitive data between your EMR clusters and their associated storage systems.

First Seen N/A | **Resource Type** Other

Recommendations

1. Login to the AWS Console.
2. In the console, select the specific region from region drop down on the top right corner, for which the alert is generated.
3. Navigate to 'EMR' dashboard from 'Services' dropdown
4. Go to 'Security configurations', click 'Create'.
5. On the Create security configuration window,
6. In 'Name' box, provide a name for the new EMR security configuration.
7. Under 'Data in transit encryption', check the box 'Enable in-transit encryption'.
8. From the dropdown of 'TLS certificate provider' select the appropriate certificate provider type and follow below link to create them.
Reference: <https://docs.aws.amazon.com/emr/latest/ManagementGuide/emr-encryption-enable.html>
9. Click on 'Create' button.
10. On the left menu of EMR dashboard Click 'Clusters'.
11. Select the EMR cluster for which the alert has been generated and click on the 'Clone' button from the top menu.
12. In the Cloning popup, choose 'Yes' and Click 'Clone'.
13. On the Create Cluster page, in the Security Options section, click on 'security configuration'.
14. From the 'Security configuration' drop down select the name of the security configuration created at step 4 to step 8, click 'Create Cluster'.
15. Once you the new cluster is set up verify its working and terminate the source cluster in order to stop incurring charges for it.
16. On the left menu of EMR dashboard Click 'Clusters', from the list of clusters select the source cluster which is alerted.
17. Click on the 'Terminate' button from the top menu.
18. On the 'Terminate clusters' pop-up, click 'Terminate'.

Access Control / Section Remote Access



0 Resource(s) Failed

Compliance Section: Remote Access ●●●● Low

- a. Establish usage restrictions, configuration requirements, and connection requirements for each type of allowable remote system access.
- b. Authorize each type of remote system access prior to establishing such connections.
- c. Route remote access to the system through authorized and managed access control points.
- d. Authorize the remote execution of privileged commands and remote access to security-relevant information.

AWS EMR cluster is not enabled with local disk encryption

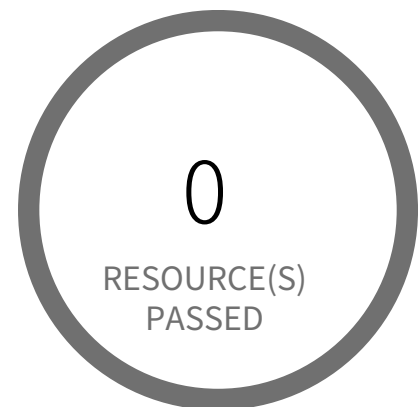
This policy identifies AWS EMR clusters that are not enabled with local disk encryption. Applications using the local file system on each cluster instance for intermediate data throughout workloads, where data could be spilled to disk when it overflows memory. With Local disk encryption at place, data at rest can be protected.

First Seen N/A | **Resource Type** Other

Recommendations

1. Login to the AWS Console.
2. In the console, select the specific region from region drop down on the top right corner, for which the alert is generated.
3. Navigate to 'EMR' dashboard from 'Services' dropdown.
4. Go to 'Security configurations', click 'Create'.
5. On the Create security configuration window,
6. In 'Name' box, provide a name for the new EMR security configuration.
7. Under 'Local disk encryption', check the box 'Enable at-rest encryption for local disks'.
8. Select the appropriate Key provider type from the 'Key provider type' dropdown list.
9. Click on 'Create' button.
10. On the left menu of EMR dashboard Click 'Clusters'.
11. Select the EMR cluster for which the alert has been generated and click on the 'Clone' button from the top menu.
12. In the Cloning popup, choose 'Yes' and Click 'Clone'.
13. On the Create Cluster page, in the Security Options section, click on 'security configuration'.
14. From the 'Security configuration' drop down select the name of the security configuration created at step 4 to step 8, click 'Create Cluster'.
15. Once the new cluster is set up verify its working and terminate the source cluster.
16. On the left menu of EMR dashboard Click 'Clusters', from the list of clusters select the source cluster which is alerted.
17. Click on the 'Terminate' button from the top menu.
18. On the 'Terminate clusters' pop-up, click 'Terminate'.

Access Control / Section Remote Access



0 Resource(s) Failed

Compliance Section: Remote Access ●●●● Low

- Establish usage restrictions, configuration requirements, and connection requirements for each type of allowable remote system access.
- Authorize each type of remote system access prior to establishing such connections.
- Route remote access to the system through authorized and managed access control points.
- Authorize the remote execution of privileged commands and remote access to security-relevant information.

AWS EMR cluster is not enabled with local disk encryption using Custom key provider

This policy identifies AWS EMR clusters that are not enabled with local disk encryption using Custom key provider. Applications using the local file system on each cluster instance for intermediate data throughout workloads, where data could be spilled to disk when it overflows memory. With Local disk encryption at place, data at rest can be protected.

First Seen N/A | Resource Type Other

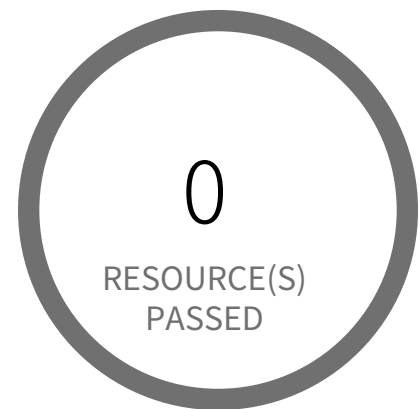
Recommendations

- Login to the AWS Console.
- In the console, select the specific region from region drop down on the top right corner, for which the alert is generated.
- Navigate to 'EMR' dashboard from 'Services' dropdown.
- Go to 'Security configurations', click 'Create'.
- On the Create security configuration window,
- In 'Name' box, provide a name for the new EMR security configuration.
- Under 'Local disk encryption', check the box 'Enable at-rest encryption for local disks'.
- Select 'Custom' Key provider type from the 'Key provider type' dropdown list.
- Follow the below link for creating the custom key,

<https://docs.aws.amazon.com/emr/latest/ManagementGuide/emr-data-encryption-options.html>

- Click on 'Create' button.
- On the left menu of EMR dashboard Click 'Clusters'.
- Select the EMR cluster for which the alert has been generated and click on the 'Clone' button from the top menu.
- In the Cloning popup, choose 'Yes' and Click 'Clone'.
- On the Create Cluster page, in the Security Options section, click on 'security configuration'.
- From the 'Security configuration' drop down select the name of the security configuration created at step 4 to step 8, click 'Create Cluster'.
- Once the new cluster is set up verify its working and terminate the source cluster.
- On the left menu of EMR dashboard Click 'Clusters', from the list of clusters select the source cluster which is alerted.
- Click on the 'Terminate' button from the top menu.
- On the 'Terminate clusters' pop-up, click 'Terminate'.

Access Control / Section Remote Access



0 Resource(s) Failed

Compliance Section: Remote Access ●●●● Low

- a. Establish usage restrictions, configuration requirements, and connection requirements for each type of allowable remote system access.
- b. Authorize each type of remote system access prior to establishing such connections.
- c. Route remote access to the system through authorized and managed access control points.
- d. Authorize the remote execution of privileged commands and remote access to security-relevant information.

AWS ElastiCache Redis cluster with encryption for data at rest disabled

This policy identifies ElastiCache Redis clusters which have encryption for data at rest(at-rest) is disabled. It is highly recommended to implement at-rest encryption in order to prevent unauthorized users from reading sensitive data saved to persistent media available on your Redis clusters and their associated cache storage systems.

First Seen N/A | **Resource Type** Other

Recommendations

AWS ElastiCache Redis cluster at-rest encryption can be set only at the time of the creation of the cluster. So to fix this alert, create a new cluster with at-rest encryption, then migrate all required ElastiCache Redis cluster data from the reported ElastiCache Redis cluster to this newly created cluster and delete reported ElastiCache Redis cluster.

To create new ElastiCache Redis cluster with at-rest encryption set, perform the following:

1. Sign into the AWS console
2. In the console, select the specific region from region drop down on the top right corner, for which the alert is generated
3. Navigate to ElastiCache Dashboard
4. Click on Redis
5. Click on 'Create' button
6. On the 'Create your Amazon ElastiCache cluster' page,
 - a. Select 'Redis' cache engine type.
 - b. Enter a name for the new cache cluster
 - c. Select Redis engine version from 'Engine version compatibility' dropdown list.

Note: As of July 2018, In-transit encryption can be enabled only for AWS ElastiCache clusters with Redis engine version 3.2.6 and 4.0.10.

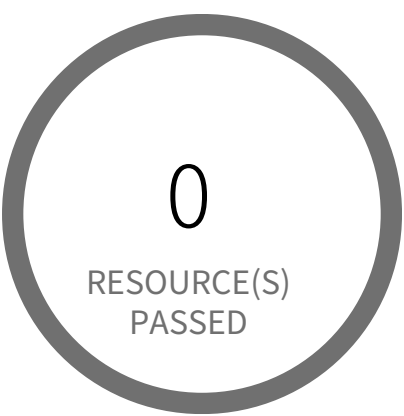
- d. Click on 'Advanced Redis settings' to expand the cluster advanced settings panel
- e. Select 'Encryption at-rest' checkbox to enable encryption along with other necessary parameters
7. Click on 'Create' button to launch your new ElastiCache Redis cluster

To delete reported ElastiCache Redis cluster, perform the following:

1. Sign into the AWS console
2. In the console, select the specific region from region drop down on the top right corner, for which the alert is generated
3. Navigate to ElastiCache Dashboard

4. Click on Redis
5. Select reported Redis cluster
6. Click on 'Delete' button
7. In the 'Delete Cluster' dialog box, if you want a backup for your cluster select 'Yes' from the 'Create final backup' dropdown menu, provide a name for the cluster backup, then click on 'Delete'.

Access Control / Section Remote Access



0 Resource(s) Failed

Compliance Section: Remote Access ●●●● Low

- a. Establish usage restrictions, configuration requirements, and connection requirements for each type of allowable remote system access.
- b. Authorize each type of remote system access prior to establishing such connections.
- c. Route remote access to the system through authorized and managed access control points.
- d. Authorize the remote execution of privileged commands and remote access to security-relevant information.

AWS ElastiCache Redis cluster with in-transit encryption disabled (Replication group)

This policy identifies ElastiCache Redis clusters that are replication groups and have in-transit encryption disabled. It is highly recommended to implement in-transit encryption in order to protect data from unauthorized access as it travels through the network, between clients and cache servers. Enabling data encryption in-transit helps prevent unauthorized users from reading sensitive data between your Redis clusters and their associated cache storage systems.

First Seen N/A | **Resource Type** Other

Recommendations

To modify the in-transit encryption setting for an existing cluster is supported on replication groups running Valkey 7.2 and later, and Redis OSS version 7 and later.

Enabling encryption in transit is a two-step process; you must first set the transit encryption mode to preferred. This mode allows your Valkey or Redis OSS clients to connect using both encrypted and unencrypted connections. After you migrate all your Valkey or Redis OSS clients to use encrypted connections, you can then modify your cluster configuration to set the transit encryption mode to required. Setting the transit encryption mode to required will drop all unencrypted connections and will allow encrypted connections only.

To set your Transit encryption mode to Preferred:

- 1. Sign in to the AWS Management Console and open the Amazon ElastiCache console at <https://console.aws.amazon.com/elasticache/>.
- 2. Choose Valkey caches or Redis OSS caches from the ElastiCache Resources listed on the navigation pane, present on the left-hand side.
- 3. Choose the cache you want to update.
- 4. Choose the Actions dropdown, then choose Modify.
- 5. Choose Enable under Encryption in transit in the Security section.
- 6. Choose Preferred as the Transit encryption mode.
- 7. Choose Preview changes and save your changes.

After you migrate all your Valkey or Redis OSS clients to use encrypted connections:

To set your Transit encryption mode to Required:

- 1. Sign in to the AWS Management Console and open the Amazon ElastiCache console at <https://console.aws.amazon.com/elasticache/>.
- 2. Choose Valkey caches or Redis OSS caches from the ElastiCache Resources listed on the navigation pane, present on the left-hand side.

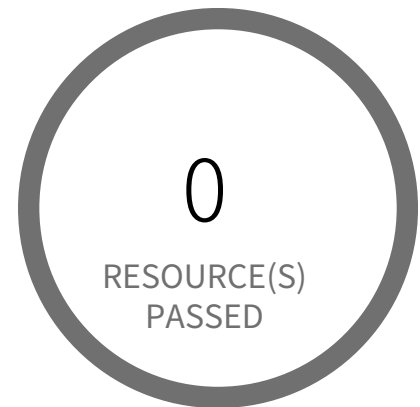
3. Choose the cache you want to update.
4. Choose the Actions dropdown, then choose Modify.
5. Choose Required as the Transit encryption mode in the Security section.
6. Choose Preview changes and save your changes.

To enable in-transit encryption on existing ElastiCache for Redis clusters (versions 3.2.6 and 6.X), you must recreate the cluster, once the new encrypted resource is created, and then migrate all required ElastiCache for Redis cluster data from the reported ElastiCache Redis cluster to this newly created cluster and delete the reported ElastiCache Redis cluster.

To create a new ElastiCache Redis cluster with In-transit encryption set, refer to the URL <https://docs.aws.amazon.com/AmazonElastiCache/latest/dg/Clusters.Create.html#Clusters.Create.CON.RedisCluster>

To delete the reported ElastiCache Redis cluster, refer to the URL <https://docs.aws.amazon.com/AmazonElastiCache/latest/dg/Clusters.Delete.html>

Access Control / Section Remote Access



0 Resource(s) Failed

Compliance Section: Remote Access — Informational

- a. Establish usage restrictions, configuration requirements, and connection requirements for each type of allowable remote system access.
- b. Authorize each type of remote system access prior to establishing such connections.
- c. Route remote access to the system through authorized and managed access control points.
- d. Authorize the remote execution of privileged commands and remote access to security-relevant information.

AWS Elastic File System (EFS) not encrypted using Customer Managed Key

This policy identifies Elastic File Systems (EFSs) which are encrypted with default KMS keys and not with Keys managed by Customer. It is a best practice to use customer managed KMS Keys to encrypt your EFS data. It gives you full control over the encrypted data.

First Seen N/A | **Resource Type** Other

Recommendations

AWS EFS Encryption of data at rest can only be enabled during file system creation. So to resolve this alert, create a new EFS with encryption enabled with the customer-managed key, then migrate all required data from the reported EFS to this newly created EFS and delete reported EFS.

To create new EFS with encryption enabled, perform the following:

1. Sign into the AWS console
2. In the console, select the specific region from region drop down on the top right corner, for which the alert is generated
3. Navigate to EFS dashboard
4. Click on 'File systems' (Left Panel)
5. Click on 'Create file system' button
6. On the 'Configure file system access' step, specify EFS details as per your requirements and Click on 'Next Step'
7. On the 'Configure optional settings' step, Under 'Enable encryption' Choose 'Enable encryption of data at rest' and Select customer managed key [i.e. Other than (default)aws/elasticfilesystem] from 'Select KMS master key' dropdown list along with other parameters and Click on 'Next Step'
8. On the 'Review and create' step, Review all your setting and Click on 'Create File System' button

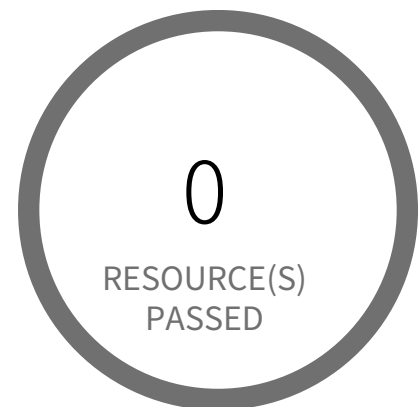
To delete reported EFS which does not has encryption, perform the following:

1. Sign into the AWS console
2. In the console, select the specific region from region drop down on the top right corner, for which the alert is generated
3. Navigate to EFS dashboard
4. Click on 'File systems' (Left Panel)
5. Select the reported file system
6. Click on 'Actions' drop-down

7. Click on 'Delete file system'

8. In the 'Permanently delete file system' popup box, To confirm the deletion enter the file system's ID and Click on 'Delete File System'

Access Control / Section Remote Access



0 Resource(s) Failed

Compliance Section: Remote Access ●●●● Low

- a. Establish usage restrictions, configuration requirements, and connection requirements for each type of allowable remote system access.
- b. Authorize each type of remote system access prior to establishing such connections.
- c. Route remote access to the system through authorized and managed access control points.
- d. Authorize the remote execution of privileged commands and remote access to security-relevant information.

[AWS Elastic File System \(EFS\) with encryption for data at rest is disabled](#)

This policy identifies Elastic File Systems (EFSs) for which encryption for data at rest is disabled. It is highly recommended to implement at-rest encryption in order to prevent unauthorized users from reading sensitive data saved to EFSs.

First Seen N/A | **Resource Type** Other

Recommendations

AWS EFS Encryption of data at rest can only be enabled during file system creation. So to resolve this alert, create a new EFS with encryption enabled, then migrate all required file data from the reported EFS to this newly created EFS and delete reported EFS.

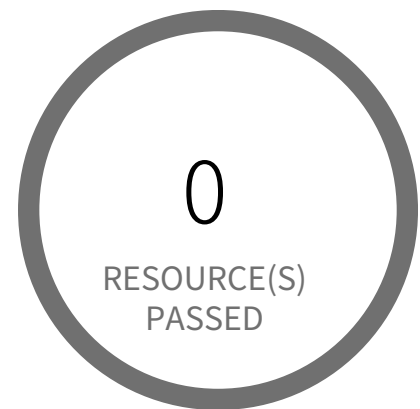
To create a new EFS with encryption enabled, perform the following:

1. Sign in to the AWS console
2. In the console, select the specific region from the region drop-down on the top right corner, for which the alert is generated
3. Navigate to the EFS dashboard
4. Click on 'File systems' (Left Panel)
5. Click on the 'Create file system' button
6. On the 'Create file system' pop-up window,
7. Click on 'Customize' button to replicate the configurations of alerted file system as required
8. Ensure 'Enable encryption of data at rest' is selected
9. On the 'Review and create' step, Review all your setting and click on the 'Create' button

To delete reported EFS which does not has encryption, perform the following:

1. Sign in to the AWS console
2. In the console, select the specific region from the region drop-down on the top right corner, for which the alert is generated
3. Navigate to the EFS dashboard
4. Click on 'File systems' (Left Panel)
5. Select the reported file system
6. Click on 'Delete' button
7. In the 'Delete file system' popup box, To confirm the deletion enter the file system's ID and Click on 'Confirm'

Access Control / Section Remote Access



0 Resource(s) Failed

Compliance Section: Remote Access — Informational

- a. Establish usage restrictions, configuration requirements, and connection requirements for each type of allowable remote system access.
- b. Authorize each type of remote system access prior to establishing such connections.
- c. Route remote access to the system through authorized and managed access control points.
- d. Authorize the remote execution of privileged commands and remote access to security-relevant information.

AWS Elastic Load Balancer (ELB) has security group with no inbound rules

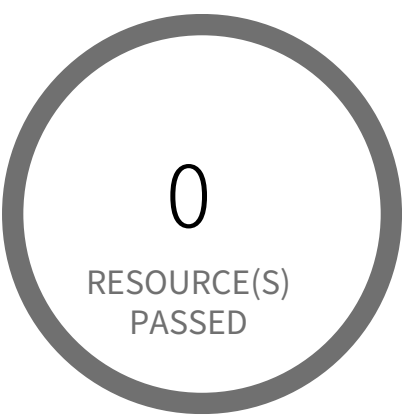
This policy identifies Elastic Load Balancers (ELB) which have security group with no inbound rules. A security group with no inbound rule will deny all incoming requests. ELB security groups should have at least one inbound rule, ELB with no inbound permissions will deny all traffic incoming to ELB; in other words, the ELB is useless without inbound permissions.

First Seen N/A | **Resource Type** Other

Recommendations

1. Sign into the AWS console
2. In the console, select the specific region from region drop down on the top right corner, for which the alert is generated
3. Navigate to EC2 Dashboard
4. Click on 'Load Balancers', choose the reported load balancer
5. Click on the 'Description' tab, click on the security group, it will open Security Group properties in a new tab in your browser
6. Click on the 'Inbound Rules'
7. If there are no rules, click on 'Edit rules', add an inbound rule according to your ELB functional requirement
8. Click on 'Save'

Access Control / Section Remote Access



0 Resource(s) Failed

Compliance Section: Remote Access ●●●● Low

- a. Establish usage restrictions, configuration requirements, and connection requirements for each type of allowable remote system access.
- b. Authorize each type of remote system access prior to establishing such connections.
- c. Route remote access to the system through authorized and managed access control points.
- d. Authorize the remote execution of privileged commands and remote access to security-relevant information.

AWS RDS DB cluster encryption is disabled

This policy identifies RDS DB clusters for which encryption is disabled. Amazon Aurora encrypted DB clusters provide an additional layer of data protection by securing your data from unauthorized access to the underlying storage. You can use Amazon Aurora encryption to increase data protection of your applications deployed in the cloud, and to fulfill compliance requirements for data-at-rest encryption.
NOTE: This policy is applicable only for Aurora DB clusters.
<https://docs.aws.amazon.com/cli/latest/reference/rds/describe-db-clusters.html>

First Seen N/A | **Resource Type** Other

Recommendations

AWS DB clusters can be encrypted only while creating the database cluster. You can't convert an unencrypted DB cluster to an encrypted one. However, you can restore an unencrypted Aurora DB cluster snapshot to an encrypted Aurora DB cluster. To do this, specify a KMS encryption key when you restore from the unencrypted DB cluster snapshot.

For AWS RDS,
1. To create a 'Snapshot' of the unencrypted DB cluster, follow the instruction mentioned in below link:
RDS Link: https://docs.aws.amazon.com/AmazonRDS/latest/AuroraUserGuide/USER_CreateSnapshotCluster.html

NOTE: As you can't restore from a DB cluster snapshot to an existing DB cluster; a new DB cluster is created when you restore. Once the Snapshot status is 'Available', delete the unencrypted DB cluster before restoring from the DB cluster Snapshot by following below steps for AWS RDS,
a. Sign to the AWS Management Console and open the Amazon RDS console at <https://console.aws.amazon.com/rds/>
b. In the navigation pane, choose 'Databases'.
c. In the list of DB instances, choose a writer instance for the DB cluster.
d. Choose 'Actions', and then choose 'Delete'.

2. To restoring the Cluster from a DB Cluster Snapshot, follow the instruction mentioned in below link:
RDS Link: https://docs.aws.amazon.com/AmazonRDS/latest/AuroraUserGuide/USER_RestoreFromSnapshot.html

For AWS Document DB,
1. To create a 'Snapshot' of the unencrypted DB cluster, follow the instruction mentioned in below link:

Document DB Link: https://docs.aws.amazon.com/documentdb/latest/developerguide/backup_restore-create_manual_cluster_snapshot.html

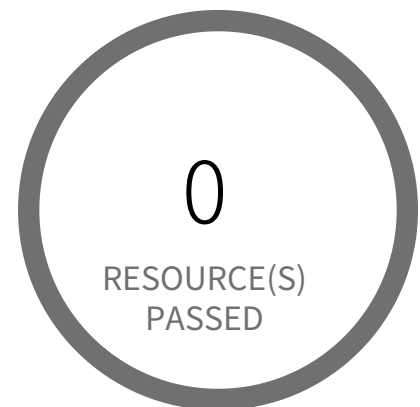
NOTE: As you can't restore from a DB cluster snapshot to an existing DB cluster; a new DB cluster is created when you restore. Once the Snapshot status is 'Available', delete the unencrypted DB cluster before restoring from the DB cluster Snapshot by following below steps for AWS Document DB,

- a. Sign to the AWS Management Console and open the Amazon DocumentDB console at <https://console.aws.amazon.com/docdb/>
- b. In the navigation pane, choose 'Clusters'.
- c. Select the cluster from the list which needs to be deleted
- d. Choose 'Actions', and then choose 'Delete'.

2. To restoring the Cluster from a DB Cluster Snapshot, follow the instruction mentioned in below link:

Document DB Link: https://docs.aws.amazon.com/documentdb/latest/developerguide/backup_restore-restore_from_snapshot.html

Access Control / Section Remote Access



0 Resource(s) Failed

Compliance Section: Remote Access — Informational

- a. Establish usage restrictions, configuration requirements, and connection requirements for each type of allowable remote system access.
- b. Authorize each type of remote system access prior to establishing such connections.
- c. Route remote access to the system through authorized and managed access control points.
- d. Authorize the remote execution of privileged commands and remote access to security-relevant information.

AWS RDS DB cluster is encrypted using default KMS key instead of CMK

This policy identifies RDS DB(Relational Database Service Database) clusters which are encrypted using default KMS key instead of CMK (Customer Master Key). As a security best practice CMK should be used instead of default KMS key for encryption to gain the ability to rotate the key according to your own policies, delete the key, and control access to the key via KMS policies and IAM policies.

First Seen N/A | **Resource Type** Other

Recommendations

RDS DB clusters can be encrypted only while creating the database cluster. You can't convert an unencrypted DB cluster to an encrypted one. However, you can restore an unencrypted Aurora DB cluster snapshot to an encrypted Aurora DB cluster. To do this, specify a KMS encryption key when you restore from the unencrypted DB cluster snapshot.

Step 1: To create a 'Snapshot' of the unencrypted DB cluster,
https://docs.aws.amazon.com/AmazonRDS/latest/AuroraUserGuide/USER_CreateSnapshotCluster.html

NOTE: As you can't restore from a DB cluster snapshot to an existing DB cluster; a new DB cluster is created when you restore. Once the Snapshot status is 'Available'.

Step 2: Follow the below link to restoring the Cluster from a DB Cluster Snapshot,
https://docs.aws.amazon.com/AmazonRDS/latest/AuroraUserGuide/USER_RestoreFromSnapshot.html

Once the DB cluster is restored and verified, follow below steps to delete the reported DB cluster,

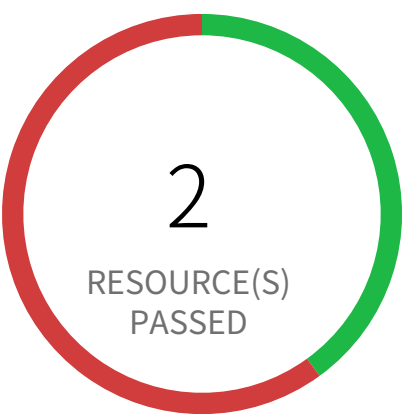
1. Log in to the AWS Management Console
2. In the console, select the specific region from region drop down on the top right corner, for which the alert is generated.
3. Navigate to 'RDS' dashboard from 'Services' dropdown
4. In the navigation pane, choose 'Databases'
5. In the list of DB instances, choose a writer instance for the DB cluster
6. Choose 'Actions', and then choose 'Delete'

FMI:

1. While deleting a RDS DB cluster, customer has to disable 'Enable deletion protection' otherwise instance cannot be deleted
2. While deleting RDS DB instance , AWS application will ask the end user to take Final snapshot

3. If a RDS DB cluster has a writer role instance, then User has to delete the write instance to delete the main cluster (Delete option won't be enabled for main RDS DB cluster)

Access Control / Section Remote Access



3 Resource(s) Failed

pc-national-bank-institutional-db-rds-snap-shot-rdsinstance-xbbmj88b9tz2, pc-national-bank-institutional-db-rds-1-snap-shot, snapshot-02-28-23-4-54-pm

Compliance Section: Remote Access ●●●● Low

- a. Establish usage restrictions, configuration requirements, and connection requirements for each type of allowable remote system access.
- b. Authorize each type of remote system access prior to establishing such connections.
- c. Route remote access to the system through authorized and managed access control points.
- d. Authorize the remote execution of privileged commands and remote access to security-relevant information.

AWS RDS DB snapshot is not encrypted

This policy identifies AWS RDS DB (Relational Database Service Database) cluster snapshots which are not encrypted. It is highly recommended to implement encryption at rest when you are working with production data that have sensitive information, to protect from unauthorized access.

First Seen June 11, 2024 at 6:11:28 PM UTC | **Resource Type** Other

Recommendations

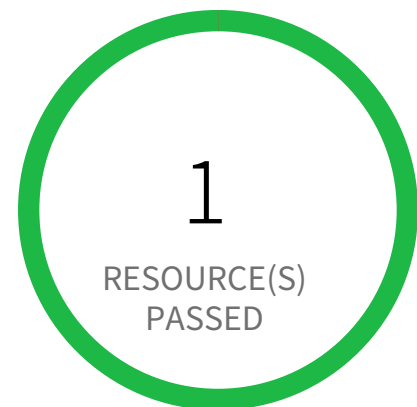
You can encrypt a copy of an unencrypted snapshot. This way, you can quickly add encryption to a previously unencrypted DB instance. Follow below steps to encrypt a copy of an unencrypted snapshot:

1. Log in to the AWS Console.
2. In the console, select the specific region from region drop down on the top right corner, for which the alert is generated.
3. Navigate to 'RDS' dashboard from 'Services' dropdown.
4. Click on 'Snapshot' from left menu.
5. Select the alerted snapshot
6. From 'Action' dropdown, select 'Copy Snapshot'
7. In 'Settings' section, from 'Destination Region' select a region,
8. Provide an identifier for the new snapshot in field 'New DB Snapshot Identifier'
9. In 'Encryption' section, select 'Enable Encryption'
10. Select a master key for encryption from the dropdown 'Master key'.
11. Click on 'Copy Snapshot'.

The source snapshot needs to be removed once the copy is available.

Note: If you delete a source snapshot before the target snapshot becomes available, the snapshot copy may fail. Verify that the target snapshot has a status of AVAILABLE before you delete a source snapshot.

Access Control / Section Remote Access



0 Resource(s) Failed

Compliance Section: Remote Access — Informational

- a. Establish usage restrictions, configuration requirements, and connection requirements for each type of allowable remote system access.
- b. Authorize each type of remote system access prior to establishing such connections.
- c. Route remote access to the system through authorized and managed access control points.
- d. Authorize the remote execution of privileged commands and remote access to security-relevant information.

AWS RDS database not encrypted using Customer Managed Key

This policy identifies RDS databases that are encrypted with default KMS keys and not with customer managed keys. As a best practice, use customer managed keys to encrypt the data on your RDS databases and maintain control of your keys and data on sensitive workloads.

First Seen N/A | Resource Type Other

Recommendations

Because you can set AWS RDS database encryption only during database creation, the process for resolving this alert requires you to create a new RDS database with a customer managed key for encryption, migrate the data from the reported database to this newly created database, and delete the RDS database identified in the alert.

To create a new RDS database with encryption using a customer managed key:

1. Log in to the AWS console.
2. Select the region for which the alert was generated.
3. Navigate to the Amazon RDS Dashboard.
4. Select 'Create database'.
5. On the 'Select engine' page, select 'Engine options' and 'Next'.
6. On the 'Choose use case' page, select 'Use case' of database and 'Next'.
7. On the 'Specify DB details' page, specify the database details you need and click 'Next'.

Note: Amazon RDS encryption has some limitation on region and type instances. For Availability of Amazon RDS Encryption refer to: <https://docs.aws.amazon.com/AmazonRDS/latest/UserGuide/Overview.Encryption.html#Overview.Encryption.Availability>

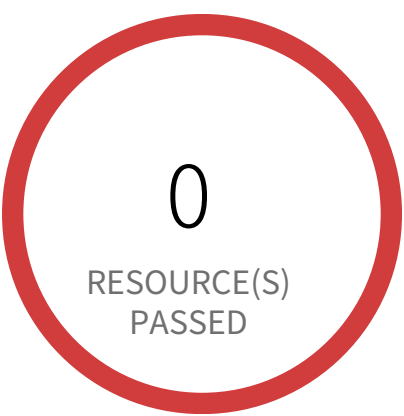
8. On the 'Configure advanced settings' page, Under 'Encryption', select 'Enable encryption' and select the customer managed key [i.e. Other than (default)aws/rds] from 'Master key' dropdown list].
9. Select 'Create database'.

To delete the RDS database that uses the default KMS keys, which triggered the alert:

1. Log in to the AWS console
2. Select the region for which the alert was generated.
3. Navigate to the Amazon RDS Dashboard.
4. Click on Instances, and select the reported RDS database.
5. Select the 'Instance actions' drop-down and click 'Delete'.

7. In the 'Delete' dialog, select the 'Create final snapshot?' checkbox, if you want a backup. Provide a name for the final snapshot, confirm deletion and select 'Delete'.

Access Control / Section Remote Access



1 Resource(s) Failed
database-1

Compliance Section: Remote Access ●●●● Low

- a. Establish usage restrictions, configuration requirements, and connection requirements for each type of allowable remote system access.
- b. Authorize each type of remote system access prior to establishing such connections.
- c. Route remote access to the system through authorized and managed access control points.
- d. Authorize the remote execution of privileged commands and remote access to security-relevant information.

AWS RDS instance is not encrypted

This policy identifies AWS RDS instances which are not encrypted. Amazon Relational Database Service (Amazon RDS) is a web service that makes it easier to set up and manage databases. Amazon allows customers to turn on encryption for RDS which is recommended for compliance and security reasons.

First Seen June 16, 2025 at 12:21:08 PM UTC | **Resource Type** Managed Database

Recommendations

Amazon RDS instance can only be encrypted at the time of DB instance creation. So to resolve this alert, create a new DB instance with encryption and then migrate all required DB instance data from the reported DB instance to this newly created DB instance. To create RDS DB instance with encryption, follow the instructions mentioned in below reference link based on your Database vendor: <http://docs.aws.amazon.com/AmazonRDS/latest/UserGuide/Overview.Encryption.html>

Access Control / Section Remote Access



0 Resource(s) Failed

Compliance Section: Remote Access — Informational

- a. Establish usage restrictions, configuration requirements, and connection requirements for each type of allowable remote system access.
- b. Authorize each type of remote system access prior to establishing such connections.
- c. Route remote access to the system through authorized and managed access control points.
- d. Authorize the remote execution of privileged commands and remote access to security-relevant information.

AWS Redshift Cluster not encrypted using Customer Managed Key

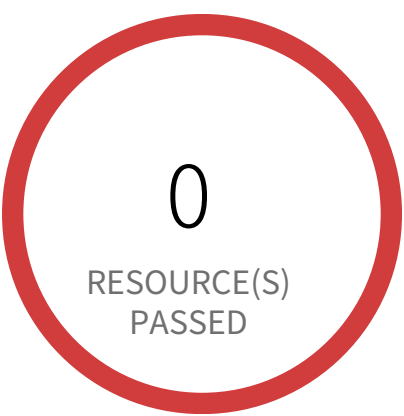
This policy identifies Redshift Clusters which are encrypted with default KMS keys and not with Keys managed by Customer. It is a best practice to use customer managed KMS Keys to encrypt your Redshift databases data. Customer-managed CMKs give you more flexibility, including the ability to create, rotate, disable, define access control for, and audit the encryption keys used to help protect your data.

First Seen N/A | **Resource Type** Other

Recommendations

To enable encryption with Customer Managed Key on your Redshift cluster follow the steps mentioned in below URL:
<https://docs.aws.amazon.com/redshift/latest/mgmt/changing-cluster-encryption.html>

Access Control / Section Remote Access



1 Resource(s) Failed
synthwave-stage-h8hn89cnu394

Compliance Section: Remote Access ●●●● Low

- a. Establish usage restrictions, configuration requirements, and connection requirements for each type of allowable remote system access.
- b. Authorize each type of remote system access prior to establishing such connections.
- c. Route remote access to the system through authorized and managed access control points.
- d. Authorize the remote execution of privileged commands and remote access to security-relevant information.

AWS Redshift instances are not encrypted

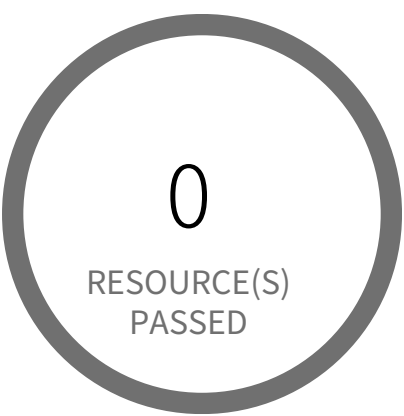
This policy identifies AWS Redshift instances which are not encrypted. These instances should be encrypted for clusters to help protect data at rest which otherwise can result in a data breach.

First Seen February 19, 2025 at 5:10:48 PM UTC | **Resource Type** Managed Database

Recommendations

To enable encryption on your Redshift cluster follow the steps mentioned in below URL:
<https://docs.aws.amazon.com/redshift/latest/mgmt/changing-cluster-encryption.html>

Access Control / Section Remote Access



0 Resource(s) Failed

Compliance Section: Remote Access ●●●● Low

- a. Establish usage restrictions, configuration requirements, and connection requirements for each type of allowable remote system access.
- b. Authorize each type of remote system access prior to establishing such connections.
- c. Route remote access to the system through authorized and managed access control points.
- d. Authorize the remote execution of privileged commands and remote access to security-relevant information.

AWS SQS Queue not configured with server side encryption

This policy identifies AWS SQS queues which are not configured with server side encryption. Enabling server side encryption would encrypt all messages that are sent to the queue and the messages are stored in encrypted form. Amazon SQS decrypts a message only when it is sent to an authorised consumer. It is recommended to enable server side encryption for AWS SQS queues in order to protect sensitive data in the event of a data breach or malicious users gaining access to the data.

First Seen N/A | **Resource Type** Other

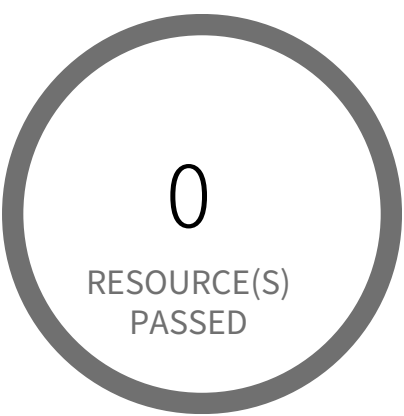
Recommendations

To configure server side encryption for AWS SQS queue follow below URL as required:

To configure Amazon SQS key (SSE-SQS) for a queue:
<https://docs.aws.amazon.com/AWSSimpleQueueService/latest/SQSDeveloperGuide/sqs-configure-sqs-sse-queue.html>

To configure AWS Key Management Service key (SSE-KMS) for a queue:
<https://docs.aws.amazon.com/AWSSimpleQueueService/latest/SQSDeveloperGuide/sqs-configure-sse-existing-queue.html>

Access Control / Section Remote Access



0 Resource(s) Failed

Compliance Section: Remote Access — Informational

- a. Establish usage restrictions, configuration requirements, and connection requirements for each type of allowable remote system access.
- b. Authorize each type of remote system access prior to establishing such connections.
- c. Route remote access to the system through authorized and managed access control points.
- d. Authorize the remote execution of privileged commands and remote access to security-relevant information.

AWS SQS queue encryption using default KMS key instead of CMK

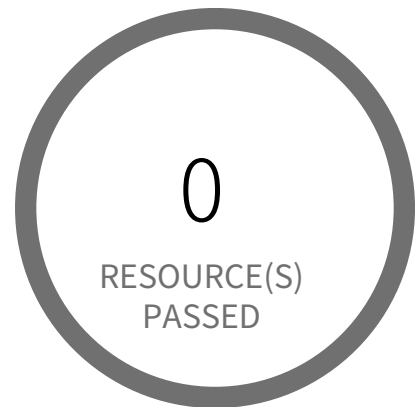
This policy identifies SQS queues which are encrypted with default KMS keys and not with Customer Master Keys(CMKs). It is a best practice to use customer managed Master Keys to encrypt your SQS queue messages. It gives you full control over the encrypted messages data.

First Seen N/A | **Resource Type** Other

Recommendations

- 1. Sign in to the AWS console
- 2. Select the region, from the region drop-down, in which the alert is generated
- 3. Navigate to Simple Queue Service (SQS) dashboard
- 4. Choose the reported Simple Queue Service (SQS)
- 5. Click on 'Queue Actions' and Choose 'Configure Queue' from the dropdown
- 6. On 'Configure' popup, Under 'Server-Side Encryption (SSE) Settings' section; Choose an 'AWS KMS Customer Master Key (CMK)' from the drop-down list or copy existing key ARN instead of (Default) alias/aws/sqs key.
- 7. Click on 'Save Changes'

Access Control / Section Remote Access



0 Resource(s) Failed

Compliance Section: Remote Access ●●●● Low

- a. Establish usage restrictions, configuration requirements, and connection requirements for each type of allowable remote system access.
- b. Authorize each type of remote system access prior to establishing such connections.
- c. Route remote access to the system through authorized and managed access control points.
- d. Authorize the remote execution of privileged commands and remote access to security-relevant information.

AWS SSM Parameter is not encrypted

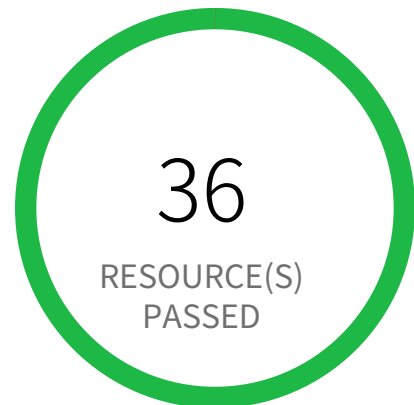
This policy identifies the AWS SSM Parameters which are not encrypted. AWS Systems Manager (SSM) parameters that store sensitive data, for example, passwords, database strings, and permit codes are encrypted so as to meet security and compliance prerequisites. An encrypted SSM parameter is any sensitive information that should be kept and referenced in a protected way.

First Seen N/A | **Resource Type** Other

Recommendations

1. Sign in to the AWS Console
2. Go to System Manager
3. In the navigation panel, Click on 'Parameter Store'
4. Choose the reported parameter and port it to a new parameter with Type 'SecureString'
5. Delete the reported parameter by clicking on 'Delete'
6. Click on 'Delete parameters'

Access Control / Section Remote Access



0 Resource(s) Failed

Compliance Section: Remote Access ●●●● Low

- a. Establish usage restrictions, configuration requirements, and connection requirements for each type of allowable remote system access.
- b. Authorize each type of remote system access prior to establishing such connections.
- c. Route remote access to the system through authorized and managed access control points.
- d. Authorize the remote execution of privileged commands and remote access to security-relevant information.

AWS route table with VPC peering overly permissive to all traffic

This policy identifies VPC route tables with VPC peering connection which are overly permissive to all traffic. Being highly selective in peering routing tables is a very effective way of minimizing the impact of breach as resources outside of these routes are inaccessible to the peered VPC.

First Seen N/A | Resource Type Other

Recommendations

1. Log in to the AWS Console
2. In the console, select the specific region from region drop down on the top right corner, for which the alert is generated.
3. Navigate to 'VPC' dashboard from 'Services' dropdown
4. From left menu, select 'Route Tables'
5. Click on the alerted route table
6. From top click on 'Action' button
7. From the Action menu dropdown, select 'Edit routes'
8. From the list of destination remove the extra permissive destination by clicking the cross symbol available for that destination
9. Add a destination with 'least access'
10. Click on 'Save Routes'.

2

Audit and Accountability

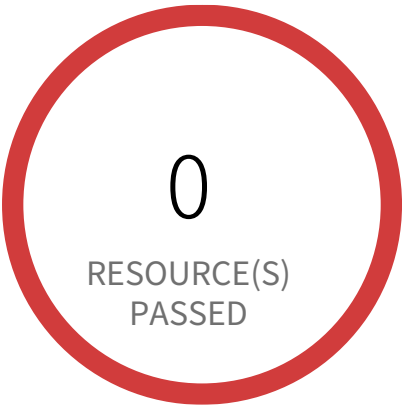


Audit and Accountability Overview

Section				Pass Rate	Failed	Passed
Audit Record Content	AWS Log metric filter and alarm does not exist for AWS Config config...	Informational		0%	2	0
Audit Record Content	AWS Log metric filter and alarm does not exist for AWS management...	Informational		0%	2	0
Audit Record Content	AWS Log metric filter and alarm does not exist for CloudTrail config...	Informational		0%	2	0
Audit Record Content	AWS Log metric filter and alarm does not exist for IAM policy changes	Informational		0%	2	0
Audit Record Content	AWS Log metric filter and alarm does not exist for Network Access...	Informational		0%	2	0
Audit Record Content	AWS Log metric filter and alarm does not exist for Network gateways...	Informational		0%	2	0
Audit Record Content	AWS Log metric filter and alarm does not exist for Route table...	Informational		0%	2	0
Audit Record Content	AWS Log metric filter and alarm does not exist for S3 bucket policy...	Informational		0%	2	0
Audit Record Content	AWS Log metric filter and alarm does not exist for VPC changes	Informational		0%	2	0
Audit Record Content	AWS Log metric filter and alarm does not exist for disabling or sched...	Informational		0%	2	0

Section		Pass Rate	Failed	Passed
Audit Record Content	AWS Log metric filter and alarm does not exist for unauthorized API... Informational	0%	2	0
Audit Record Content	AWS Redshift database does not have audit logging enabled Informational	0%	1	0
Protection of Audit Information	AWS CloudTrail bucket is publicly accessible Low	100%	0	25
Protection of Audit Information	AWS CloudTrail log validation is not enabled in all regions Low	33%	2	1
Protection of Audit Information	AWS CloudTrail logs are not encrypted using Cus... Informational	66%	1	2
Protection of Audit Information	AWS Database Migration Service endpoint do not have SSL... Low	100%	0	0
Protection of Audit Information	AWS Kinesis streams are not encrypted using Server Side En... Low	100%	0	0
Protection of Audit Information	AWS Kinesis streams encryption using default KMS... Informational	100%	0	0
Protection of Audit Information	AWS S3 Bucket Policy allows public access to CloudTrail logs Low	100%	0	25
Protection of Audit Information	AWS S3 buckets do not have server side encryption Low	100%	0	25

Audit and Accountability / Section Audit Record Content



2 Resource(s) Failed

058264157785, 818698786219

Compliance Section: Audit Record Content — Informational

- a. Include the following content in audit records:
- 1. What type of event occurred
 - 2. When the event occurred
 - 3. Where the event occurred
 - 4. Source of the event
 - 5. Outcome of the event
 - 6. Identity of the individuals, subjects, objects, or entities associated with the event
- b. Provide additional information for audit records as needed.

AWS Log metric filter and alarm does not exist for AWS Config configuration changes

This policy identifies the AWS regions which do not have a log metric filter and alarm for AWS Config configuration changes. Monitoring changes to AWS Config configuration will help ensure sustained visibility of configuration items within the AWS account. It is recommended that a metric filter and alarm be established for detecting changes to AWS Config's configurations.

NOTE: This policy will trigger alert if you have at least one Cloudtrail with the multi trail is enabled, Logs all management events in your account and is not set with specific log metric filter and alarm.

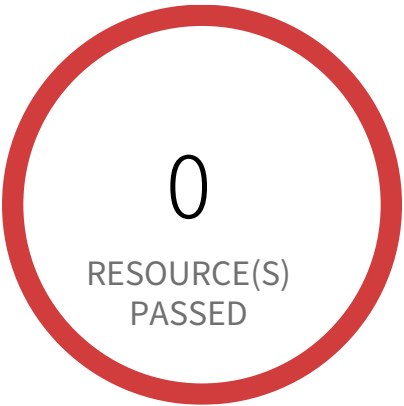
First Seen January 28, 2025 at 12:06:58 PM UTC | **Resource Type** Other

Recommendations

- 1. Sign in to AWS Console
- 2. Navigate to CloudWatch dashboard
- 3. Click on 'Log groups' in the 'Logs' section (Left panel)
- 4. Select the log group created for your CloudTrail trail event logs (CloudTrail should be multi trail enabled with all management events captured) and click 'Create Metric Filter' button.
- 5. In 'Define Logs Metric Filter' page, add 'Filter pattern' value as
{ (\$.eventSource = config.amazonaws.com) && ((\$.eventName=StopConfigurationRecorder)||(\$.eventName=DeleteDeliveryChannel)||(\$.eventName=PutDeliveryChannel)||(\$.eventName=PutConfigurationRecorder)) }
- and Click on 'Assign Metric'
- 6. In 'Create Metric Filter and Assign a Metric' page, Choose Filter Name, Metric Details parameter according to your requirement and click on 'Create Filter'
- 7. Click on 'Create Alarm',
- In Step 1 specify metric details and conditions details as required and click on 'Next'

- In Step 2 Select an SNS topic either by creating a new topic or use existing SNS topic/ARN and click on 'Next'
- In Step 3 Select name and description to alarm and click on 'Next'
- In Step 4 Preview your data entered and click on 'Create Alarm'

Audit and Accountability / Section Audit Record Content



2 Resource(s) Failed

818698786219, 058264157785

Compliance Section: Audit Record Content Informational

- a. Include the following content in audit records:
- 1. What type of event occurred
 - 2. When the event occurred
 - 3. Where the event occurred
 - 4. Source of the event
 - 5. Outcome of the event
 - 6. Identity of the individuals, subjects, objects, or entities associated with the event
- b. Provide additional information for audit records as needed.

AWS Log metric filter and alarm does not exist for AWS management console authentication failures

This policy identifies the AWS accounts which do not have a log metric filter and alarm for AWS management console authentication failures. Monitoring failed console logins may decrease lead time to detect an attempt to brute force a credential, which may provide an indicator, such as source IP, that can be used in other event correlation. It is recommended that a metric filter and alarm be established for failed console authentication attempts.

NOTE: This policy will trigger alert if you have at least one Cloudtrail with the multi trail is enabled, Logs all management events and is not set with specific log metric filter and alarm in your account.

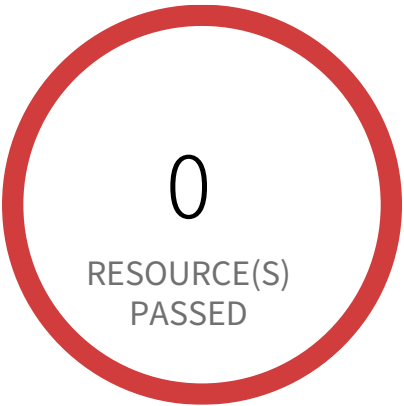
First Seen January 28, 2025 at 12:06:58 PM UTC | **Resource Type** Other

Recommendations

- 1. Sign in to AWS Console
 - 2. Navigate to CloudWatch dashboard
 - 3. Click on 'Log groups' in the 'Logs' section (Left panel)
 - 4. Select the log group created for your CloudTrail trail event logs (Cloudtrail should be multi trail enabled with all Management Events captured) and click 'Create Metric Filter' button.
 - 5. In 'Define Logs Metric Filter' page, add 'Filter pattern' value as `{ ($.eventName = ConsoleLogin) && ($.errorMessage = "Failed authentication") }` and Click on 'Assign Metric'
 - 6. In 'Create Metric Filter and Assign a Metric' page, Choose Filter Name, Metric Details parameter according to your requirement and click on 'Create Filter'
 - 7. Click on 'Create Alarm',
- In Step 1, specify metric details and conditions details as required and click on 'Next'

- In Step 2, Select an SNS topic either by creating a new topic or use existing SNS topic/ARN and click on 'Next'
- In Step 3, Select name and description to alarm and click on 'Next'
- In Step 4, Preview your data entered and click on 'Create Alarm'

Audit and Accountability / Section Audit Record Content



2 Resource(s) Failed

058264157785, 818698786219

Compliance Section: Audit Record Content — Informational

- a. Include the following content in audit records:
- 1. What type of event occurred
 - 2. When the event occurred
 - 3. Where the event occurred
 - 4. Source of the event
 - 5. Outcome of the event
 - 6. Identity of the individuals, subjects, objects, or entities associated with the event
- b. Provide additional information for audit records as needed.

AWS Log metric filter and alarm does not exist for CloudTrail configuration changes

This policy identifies the AWS regions which do not have a log metric filter and alarm for CloudTrail configuration changes. Monitoring changes to CloudTrail's configuration will help ensure sustained visibility to activities performed in the AWS account. It is recommended that a metric filter and alarm be established for detecting changes to CloudTrail's configurations.

NOTE: This policy will trigger alert if you have at least one Cloudtrail with the multi trial is enabled, Logs all management events in your account and is not set with specific log metric filter and alarm.

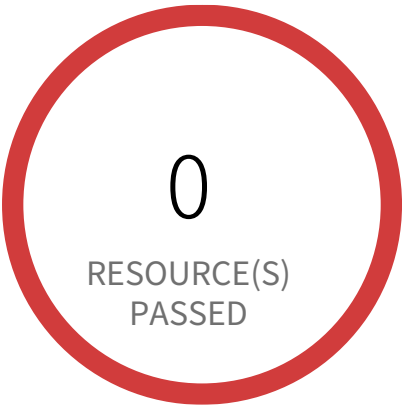
First Seen January 28, 2025 at 12:06:58 PM UTC | **Resource Type** Other

Recommendations

- 1. Sign in to AWS Console
 - 2. Navigate to CloudWatch dashboard
 - 3. Click on 'Log groups' in the 'Logs' section (Left panel)
 - 4. Select the log group created for your CloudTrail trail event logs (CloudTrail should be multi trail enabled with all management events captured) and click 'Create Metric Filter' button.
 - 5. In 'Define Logs Metric Filter' page, add 'Filter pattern' value as `{ ($.eventName = CreateTrail) || ($.eventName = UpdateTrail) || ($.eventName = DeleteTrail) || ($.eventName = StartLogging) || ($.eventName = StopLogging) }` and Click on 'Assign Metric'
 - 6. In 'Create Metric Filter and Assign a Metric' page, Choose Filter Name, Metric Details parameter according to your requirement and click on 'Create Filter'
 - 7. Click on 'Create Alarm',
- In Step 1 specify metric details and conditions details as required and click on 'Next'

- In Step 2 Select an SNS topic either by creating a new topic or use existing SNS topic/ARN and click on 'Next'
- In Step 3 Select name and description to alarm and click on 'Next'
- In Step 4 Preview your data entered and click on 'Create Alarm'

Audit and Accountability / Section Audit Record Content



2 Resource(s) Failed

058264157785, 818698786219

Compliance Section: Audit Record Content — Informational

- a. Include the following content in audit records:
- 1. What type of event occurred
 - 2. When the event occurred
 - 3. Where the event occurred
 - 4. Source of the event
 - 5. Outcome of the event
 - 6. Identity of the individuals, subjects, objects, or entities associated with the event
- b. Provide additional information for audit records as needed.

AWS Log metric filter and alarm does not exist for IAM policy changes

This policy identifies the AWS regions which do not have a log metric filter and alarm for IAM policy changes. Monitoring changes to IAM policies will help ensure authentication and authorization controls remain intact. It is recommended that a metric filter and alarm be established changes made to Identity and Access Management (IAM) policies.

NOTE: This policy will trigger alert if you have at least one Cloudtrail with the multi trail is enabled, Logs all management events in your account and is not set with specific log metric filter and alarm.

First Seen January 28, 2025 at 12:06:58 PM UTC | **Resource Type** Other

Recommendations

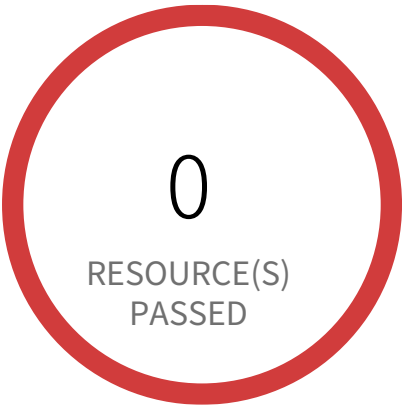
- 1. Sign in to AWS Console
- 2. Navigate to CloudWatch dashboard
- 3. Click on 'Log groups' in the 'Logs' section (Left panel)
- 4. Select the log group created for your CloudTrail trail event logs (CloudTrail should be multi trail enabled with all management events captured) and click 'Create Metric Filter' button.
- 5. In 'Define Logs Metric Filter' page, add 'Filter pattern' value as

```
{
($eventName=DeleteGroupPolicy)||($eventName=DeleteRolePolicy)||($eventName=DeleteUserPolicy)||($eventName=PutGroupPolicy)||($eventName=PutRolePolicy)||($eventName=PutUserPolicy)||($eventName=CreatePolicy)||($eventName=DeletePolicy)||($eventName=CreatePolicyVersion)||($eventName=DeletePolicyVersion)||($eventName=AttachRolePolicy)||($eventName=DetachRolePolicy)||($eventName=AttachUserPolicy)||($eventName=DetachUserPolicy)||($eventName=AttachGroupPolicy)||($eventName=DetachGroupPolicy) }
```

and Click on 'Assign Metric'

6. In 'Create Metric Filter and Assign a Metric' page, Choose Filter Name, Metric Details parameter according to your requirement and click on 'Create Filter'
7. Click on 'Create Alarm',
 - In Step 1 specify metric details and conditions details as required and click on 'Next'
 - In Step 2 Select an SNS topic either by creating a new topic or use existing SNS topic/ARN and click on 'Next'
 - In Step 3 Select name and description to alarm and click on 'Next'
 - In Step 4 Preview your data entered and click on 'Create Alarm'

Audit and Accountability / Section Audit Record Content



2 Resource(s) Failed

058264157785, 818698786219

Compliance Section: Audit Record Content Informational

- a. Include the following content in audit records:
- 1. What type of event occurred
 - 2. When the event occurred
 - 3. Where the event occurred
 - 4. Source of the event
 - 5. Outcome of the event
 - 6. Identity of the individuals, subjects, objects, or entities associated with the event
- b. Provide additional information for audit records as needed.

AWS Log metric filter and alarm does not exist for Network Access Control Lists (NACL) changes

This policy identifies the AWS regions which do not have a log metric filter and alarm for Network Access Control Lists (NACL) changes. Monitoring changes to NACLs will help ensure that AWS resources and services are not unintentionally exposed. It is recommended that a metric filter and alarm be established for changes made to NACLs.

NOTE: This policy will trigger alert if you have at least one Cloudtrail with the multi trail is enabled, Logs all management events in your account and is not set with specific log metric filter and alarm.

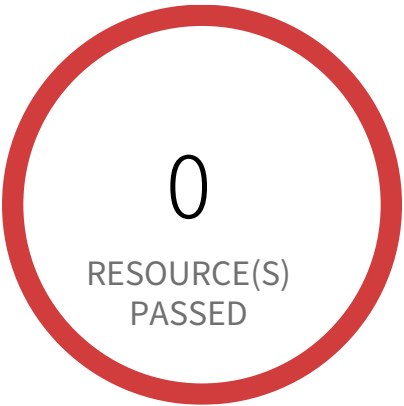
First Seen January 28, 2025 at 12:06:58 PM UTC | **Resource Type** Other

Recommendations

- 1. Sign in to AWS Console
- 2. Navigate to CloudWatch dashboard
- 3. Click on 'Log groups' in the 'Logs' section (Left panel)
- 4. Select the log group created for your CloudTrail trail event logs (CloudTrail should be multi trail enabled with all management events captured) and click 'Create Metric Filter' button.
- 5. In 'Define Logs Metric Filter' page, add 'Filter pattern' value as `{ ($.eventName = CreateNetworkAcl) || ($.eventName = CreateNetworkAclEntry) || ($.eventName = DeleteNetworkAcl) || ($.eventName = DeleteNetworkAclEntry) || ($.eventName = ReplaceNetworkAclEntry) || ($.eventName = ReplaceNetworkAclAssociation) }` and Click on 'Assign Metric'
- 6. In 'Create Metric Filter and Assign a Metric' page, Choose Filter Name, Metric Details parameter according to your requirement and click on 'Create Filter'
- 7. Click on 'Create Alarm',
 - In Step 1 specify metric details and conditions details as required and click on 'Next'

- In Step 2 Select an SNS topic either by creating a new topic or use existing SNS topic/ARN and click on 'Next'
- In Step 3 Select name and description to alarm and click on 'Next'
- In Step 4 Preview your data entered and click on 'Create Alarm'

Audit and Accountability / Section Audit Record Content



2 Resource(s) Failed

058264157785, 818698786219

Compliance Section: Audit Record Content — Informational

- a. Include the following content in audit records:
- 1. What type of event occurred
 - 2. When the event occurred
 - 3. Where the event occurred
 - 4. Source of the event
 - 5. Outcome of the event
 - 6. Identity of the individuals, subjects, objects, or entities associated with the event
- b. Provide additional information for audit records as needed.

AWS Log metric filter and alarm does not exist for Network gateways changes

This policy identifies the AWS regions which do not have a log metric filter and alarm for Network gateways changes. Monitoring changes to network gateways will help ensure that all ingress/egress traffic traverses the VPC border via a controlled path. It is recommended that a metric filter and alarm be established for changes to network gateways.

NOTE: This policy will trigger alert if you have at least one Cloudtrail with the multi trail is enabled, Logs all management events in your account and is not set with specific log metric filter and alarm.

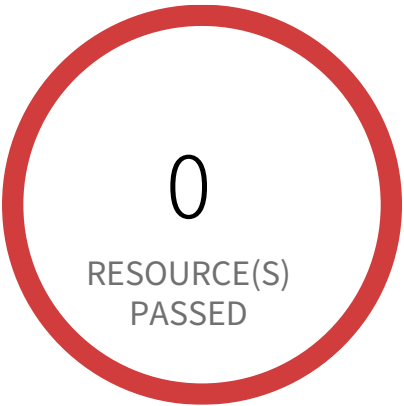
First Seen January 28, 2025 at 12:06:58 PM UTC | **Resource Type** Other

Recommendations

- 1. Sign in to AWS Console
- 2. Navigate to CloudWatch dashboard
- 3. Click on 'Log groups' in the 'Logs' section (Left panel)
- 4. Select the log group created for your CloudTrail trail event logs (CloudTrail should be multi trail enabled with all management events captured) and click 'Create Metric Filter' button.
- 5. In 'Define Logs Metric Filter' page, add 'Filter pattern' value as
`{ ($.eventName = CreateCustomerGateway) || ($.eventName = DeleteCustomerGateway) || ($.eventName = AttachInternetGateway) || ($.eventName = CreateInternetGateway) || ($.eventName = DeleteInternetGateway) || ($.eventName = DetachInternetGateway) }`
and Click on 'Assign Metric'
- 6. In 'Create Metric Filter and Assign a Metric' page, Choose Filter Name, Metric Details parameter according to your requirement and click on 'Create Filter'
- 7. Click on 'Create Alarm',
□- In Step 1 specify metric details and conditions details as required and click on 'Next'

- In Step 2 Select an SNS topic either by creating a new topic or use existing SNS topic/ARN and click on 'Next'
- In Step 3 Select name and description to alarm and click on 'Next'
- In Step 4 Preview your data entered and click on 'Create Alarm'

Audit and Accountability / Section Audit Record Content



2 Resource(s) Failed

058264157785, 818698786219

Compliance Section: Audit Record Content — Informational

- a. Include the following content in audit records:
- 1. What type of event occurred
 - 2. When the event occurred
 - 3. Where the event occurred
 - 4. Source of the event
 - 5. Outcome of the event
 - 6. Identity of the individuals, subjects, objects, or entities associated with the event
- b. Provide additional information for audit records as needed.

AWS Log metric filter and alarm does not exist for Route table changes

This policy identifies the AWS regions which do not have a log metric filter and alarm for Route table changes. Monitoring changes to route tables will help ensure that all VPC traffic flows through an expected path. It is recommended that a metric filter and alarm be established for changes to route tables.

NOTE: This policy will trigger alert if you have at least one Cloudtrail with the multi trail is enabled, Logs all management events in your account and is not set with specific log metric filter and alarm.

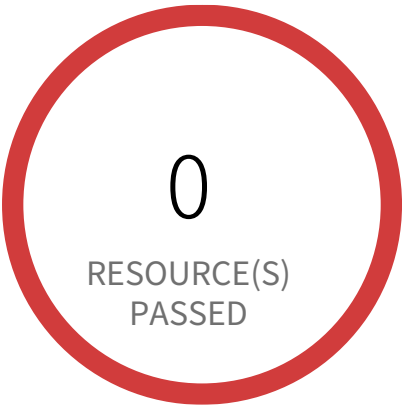
First Seen January 28, 2025 at 12:06:58 PM UTC | **Resource Type** Other

Recommendations

- 1. Sign in to AWS Console
- 2. Navigate to CloudWatch dashboard
- 3. Click on 'Log groups' in the 'Logs' section (Left panel)
- 4. Select the log group created for your CloudTrail trail event logs (CloudTrail should be multi trail enabled with all management events captured) and click 'Create Metric Filter' button.
- 5. In 'Define Logs Metric Filter' page, add 'Filter pattern' value as
{ (\$.eventName = CreateRoute) || (\$.eventName = CreateRouteTable) || (\$.eventName = ReplaceRoute) || (\$.eventName = ReplaceRouteTableAssociation) || (\$.eventName = DeleteRouteTable) || (\$.eventName = DeleteRoute) || (\$.eventName = DisassociateRouteTable) }
- and Click on 'Assign Metric'
- 6. In 'Create Metric Filter and Assign a Metric' page, Choose Filter Name, Metric Details parameter according to your requirement and click on 'Create Filter'
- 7. Click on 'Create Alarm',
- In Step 1 specify metric details and conditions details as required and click on 'Next'

- In Step 2 Select an SNS topic either by creating a new topic or use existing SNS topic/ARN and click on 'Next'
- In Step 3 Select name and description to alarm and click on 'Next'
- In Step 4 Preview your data entered and click on 'Create Alarm'

Audit and Accountability / Section Audit Record Content



2 Resource(s) Failed

058264157785, 818698786219

Compliance Section: Audit Record Content Informational

- a. Include the following content in audit records:
- 1. What type of event occurred
 - 2. When the event occurred
 - 3. Where the event occurred
 - 4. Source of the event
 - 5. Outcome of the event
 - 6. Identity of the individuals, subjects, objects, or entities associated with the event
- b. Provide additional information for audit records as needed.

AWS Log metric filter and alarm does not exist for S3 bucket policy changes

This policy identifies the AWS regions which do not have a log metric filter and alarm for S3 bucket policy changes. Monitoring changes to S3 bucket policies may reduce time to detect and correct permissive policies on sensitive S3 buckets. It is recommended that a metric filter and alarm be established for changes to S3 bucket policies.

NOTE: This policy will trigger alert if you have at least one Cloudtrail with the multi trail is enabled, Logs all management events in your account and is not set with specific log metric filter and alarm.

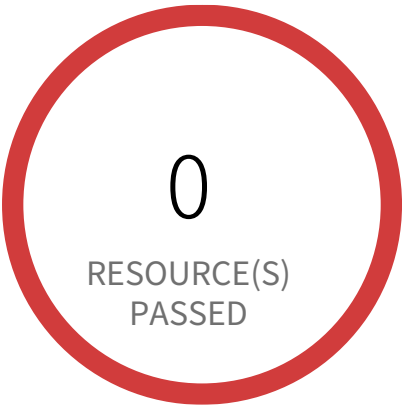
First Seen January 28, 2025 at 12:06:58 PM UTC | **Resource Type** Other

Recommendations

- 1. Sign in to AWS Console
- 2. Navigate to CloudWatch dashboard
- 3. Click on 'Log groups' in the 'Logs' section (Left panel)
- 4. Select the log group created for your CloudTrail trail event logs (CloudTrail should be multi trail enabled with all management events captured) and click 'Create Metric Filter' button.
- 5. In 'Define Logs Metric Filter' page, add 'Filter pattern' value as `{ ($eventSource = s3.amazonaws.com) && (($eventName = PutBucketAcl) || ($eventName = PutBucketPolicy) || ($eventName = PutBucketCors) || ($eventName = PutBucketLifecycle) || ($eventName = PutBucketReplication) || ($eventName = DeleteBucketPolicy) || ($eventName = DeleteBucketCors) || ($eventName = DeleteBucketLifecycle) || ($eventName = DeleteBucketReplication)) }` and Click on 'Assign Metric'
- 6. In 'Create Metric Filter and Assign a Metric' page, Choose Filter Name, Metric Details parameter according to your requirement and click on 'Create Filter'
- 7. Click on 'Create Alarm',

- In Step 1 specify metric details and conditions details as required and click on 'Next'
- In Step 2 Select an SNS topic either by creating a new topic or use existing SNS topic/ARN and click on 'Next'
- In Step 3 Select name and description to alarm and click on 'Next'
- In Step 4 Preview your data entered and click on 'Create Alarm'

Audit and Accountability / Section Audit Record Content



2 Resource(s) Failed

058264157785, 818698786219

Compliance Section: Audit Record Content — Informational

- a. Include the following content in audit records:
- 1. What type of event occurred
 - 2. When the event occurred
 - 3. Where the event occurred
 - 4. Source of the event
 - 5. Outcome of the event
 - 6. Identity of the individuals, subjects, objects, or entities associated with the event
- b. Provide additional information for audit records as needed.

AWS Log metric filter and alarm does not exist for VPC changes

This policy identifies the AWS regions which do not have a log metric filter and alarm for VPC changes. Monitoring changes to VPC will help ensure that resources and services are not unintentionally exposed. It is recommended that a metric filter and alarm be established for changes made to VPCs.

NOTE: This policy will trigger alert if you have at least one Cloudtrail with the multi trail is enabled, Logs all management events in your account and is not set with specific log metric filter and alarm.

First Seen January 28, 2025 at 12:06:58 PM UTC | **Resource Type** Other

Recommendations

- 1. Sign in to AWS Console
- 2. Navigate to CloudWatch dashboard
- 3. Click on 'Log groups' in the 'Logs' section (Left panel)
- 4. Select the log group created for your CloudTrail trail event logs (CloudTrail should be multi trail enabled with all management events captured) and click 'Create Metric Filter' button.
- 5. In 'Define Logs Metric Filter' page, add 'Filter pattern' value as
`{ ($eventName = CreateVpc) || ($eventName = DeleteVpc) || ($eventName = ModifyVpcAttribute) || ($eventName = AcceptVpcPeeringCon-
nection) || ($eventName = CreateVpcPeeringConnection) || ($eventName = DeleteVpcPeeringConnection) || ($eventName = RejectVpcPeer-
ingConnection) || ($eventName = AttachClassicLinkVpc) || ($eventName = DetachClassicLinkVpc) || ($eventName = DisableVpcClassicLink)
|| ($eventName = EnableVpcClassicLink) }`
and Click on 'Assign Metric'
- 6. In 'Create Metric Filter and Assign a Metric' page, Choose Filter Name, Metric Details parameter according to your requirement and click on 'Create Filter'

7. Click on 'Create Alarm',

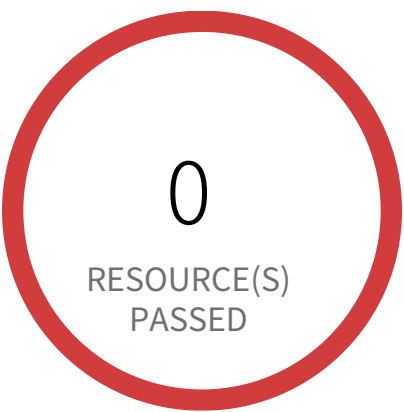
- In Step 1 specify metric details and conditions details as required and click on 'Next'

- In Step 2 Select an SNS topic either by creating a new topic or use existing SNS topic/ARN and click on 'Next'

- In Step 3 Select name and description to alarm and click on 'Next'

- In Step 4 Preview your data entered and click on 'Create Alarm'

Audit and Accountability / Section Audit Record Content



2 Resource(s) Failed

058264157785, 818698786219

Compliance Section: Audit Record Content Informational

- a. Include the following content in audit records:
- 1. What type of event occurred
 - 2. When the event occurred
 - 3. Where the event occurred
 - 4. Source of the event
 - 5. Outcome of the event
 - 6. Identity of the individuals, subjects, objects, or entities associated with the event
- b. Provide additional information for audit records as needed.

AWS Log metric filter and alarm does not exist for disabling or scheduled deletion of customer created CMKs

This policy identifies the AWS regions which do not have a log metric filter and alarm for disabling or scheduled deletion of customer created CMKs. Data encrypted with disabled or deleted keys will no longer be accessible. It is recommended that a metric filter and alarm be established for customer created CMKs which have changed state to disabled or scheduled deletion.

NOTE: This policy will trigger alert if you have at least one Cloudtrail with the multi trial is enabled, Logs all management events in your account and is not set with specific log metric filter and alarm.

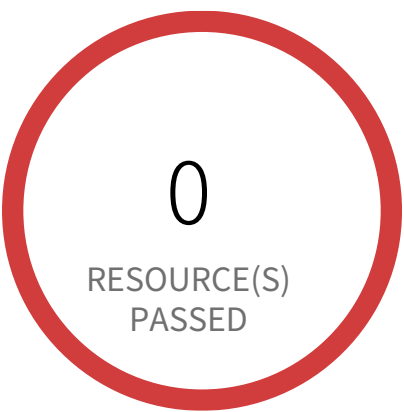
First Seen January 28, 2025 at 12:06:58 PM UTC | Resource Type Other

Recommendations

- 1. Sign in to AWS Console
 - 2. Navigate to CloudWatch dashboard
 - 3. Click on 'Log groups' in the 'Logs' section (Left panel)
 - 4. Select the log group created for your CloudTrail trail event logs (CloudTrail should be multi trail enabled with all management events captured) and click 'Create Metric Filter' button.
 - 5. In 'Define Logs Metric Filter' page, add 'Filter pattern' value as `{ ($.eventSource = kms.amazonaws.com) && (($.eventName=DisableKey)||($.eventName=ScheduleKeyDeletion)) }` and Click on 'Assign Metric'
 - 6. In 'Create Metric Filter and Assign a Metric' page, Choose Filter Name, Metric Details parameter according to your requirement and click on 'Create Filter'
 - 7. Click on 'Create Alarm',
- In Step 1 specify metric details and conditions details as required and click on 'Next'
 - In Step 2 Select an SNS topic either by creating a new topic or use existing SNS topic/ARN and click on 'Next'

- In Step 3 Select name and description to alarm and click on 'Next'
- In Step 4 Preview your data entered and click on 'Create Alarm'

Audit and Accountability / Section Audit Record Content



2 Resource(s) Failed

058264157785, 818698786219

Compliance Section: Audit Record Content Informational

- a. Include the following content in audit records:
- 1. What type of event occurred
 - 2. When the event occurred
 - 3. Where the event occurred
 - 4. Source of the event
 - 5. Outcome of the event
 - 6. Identity of the individuals, subjects, objects, or entities associated with the event
- b. Provide additional information for audit records as needed.

AWS Log metric filter and alarm does not exist for unauthorized API calls

This policy identifies the AWS regions which do not have a log metric filter and alarm for unauthorized API calls. Monitoring unauthorized API calls will help reveal application errors and may reduce the time to detect malicious activity. It is recommended that a metric filter and alarm be established for unauthorized API calls.

NOTE: This policy will trigger alert if you have at least one Cloudtrail with the multi trail is enabled, Logs all management events in your account and is not set with specific log metric filter and alarm.

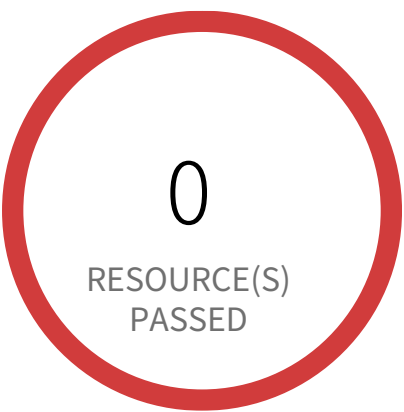
First Seen January 28, 2025 at 12:07:04 PM UTC | **Resource Type** Other

Recommendations

- 1. Sign in to AWS Console
- 2. Navigate to CloudWatch dashboard
- 3. Click on 'Log groups' in the 'Logs' section (Left panel)
- 4. Select the log group created for your CloudTrail trail event logs (CloudTrail should be multi trail enabled with all management events captured) and click 'Create Metric Filter' button.
- 5. In 'Define Logs Metric Filter' page, add 'Filter pattern' value as `{ ($.errorCode = "*UnauthorizedOperation") || ($.errorCode = "AccessDenied*") }` and Click on 'Assign Metric'
- 6. In 'Create Metric Filter and Assign a Metric' page, Choose Filter Name, Metric Details parameter according to your requirement and click on 'Create Filter'
- 7. Click on 'Create Alarm',
 - In Step 1 specify metric details and conditions details as required and click on 'Next'
 - In Step 2 Select an SNS topic either by creating a new topic or use existing SNS topic/ARN and click on 'Next'

- In Step 3 Select name and description to alarm and click on 'Next'
- In Step 4 Preview your data entered and click on 'Create Alarm'

Audit and Accountability / Section Audit Record Content



1 Resource(s) Failed
synthwave-stage-h8hn89cnu394

Compliance Section: Audit Record Content — Informational

- a. Include the following content in audit records:
 - 1. What type of event occurred
 - 2. When the event occurred
 - 3. Where the event occurred
 - 4. Source of the event
 - 5. Outcome of the event
 - 6. Identity of the individuals, subjects, objects, or entities associated with the event
- b. Provide additional information for audit records as needed.

AWS Redshift database does not have audit logging enabled

Audit logging is not enabled by default in Amazon Redshift. When you enable logging on your cluster, Amazon Redshift creates and uploads logs to Amazon S3 that capture data from the creation of the cluster to the present time.

First Seen February 19, 2025 at 5:10:47 PM UTC | **Resource Type** Managed Database

Recommendations

- 1. Login to AWS Console.
- 2. Goto Amazon Redshift service
- 3. On left navigation panel, click on Clusters
- 4. Click on the reported cluster
- 5. Click on Database tab and choose 'Configure Audit Logging'
- 6. On Enable Audit Logging, choose 'Yes'
- 7. Create a new s3 bucket or use an existing bucket
- 8. click Save

Audit and Accountability / Section Protection of Audit Information



0 Resource(s) Failed

Compliance Section: Protection of Audit Information ●●●● Low

- a. Protect audit information and audit logging tools from unauthorized access, modification, and deletion.
- b. Authorize access to management of audit logging functionality to only a subset of privileged users or roles.

AWS CloudTrail bucket is publicly accessible

This policy identifies publicly accessible S3 buckets that store CloudTrail data. These buckets contains sensitive audit data and only authorized users and applications should have access.

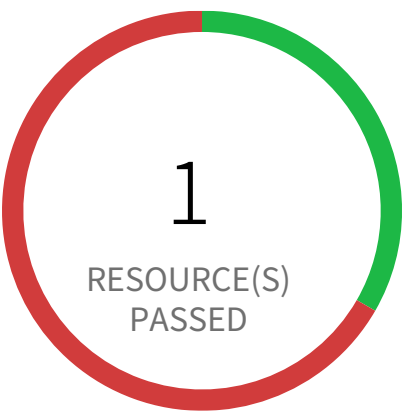
First Seen N/A | **Resource Type** Other

Recommendations

- 1. Login to the AWS Console
- 2. Navigate to the 'S3' service
- 3. Click on the 'S3' resource reported in the alert
- 4. Click on the 'Permissions'
- 5. If 'Access Control List' is set to 'Public' follow below steps
 - a. Under 'Access Control List', Click on 'Everyone' and uncheck all items
 - b. Click on Save
- 6. If 'Bucket Policy' is set to public follow below steps
 - a. Under 'Bucket Policy', modify the policy to remove public access
 - b. Click on Save
 - c. If 'Bucket Policy' is not required delete the existing 'Bucket Policy'.

Note: Make sure updating 'Access Control List' or 'Bucket Policy' does not affect S3 bucket data access.

Audit and Accountability / Section Protection of Audit Information



2 Resource(s) Failed
prisma-forward-scan-cloudtrail, cor-
tex-trail-469150289874-m-o-24072002

Compliance Section: Protection of Audit Information ●●●● Low

- a. Protect audit information and audit logging tools from unauthorized access, modification, and deletion.
- b. Authorize access to management of audit logging functionality to only a subset of privileged users or roles.

AWS CloudTrail log validation is not enabled in all regions

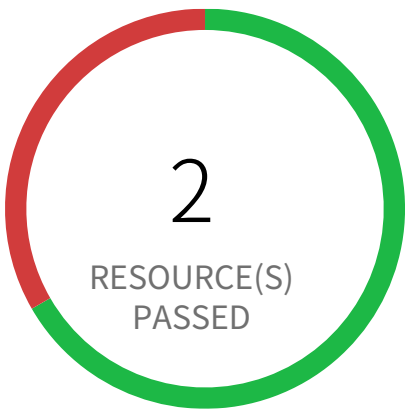
This policy identifies AWS CloudTrails in which log validation is not enabled in all regions. CloudTrail log file validation creates a digitally signed digest file containing a hash of each log that CloudTrail writes to S3. These digest files can be used to determine whether a log file was modified after CloudTrail delivered the log. It is recommended that file validation be enabled on all CloudTrails.

First Seen June 11, 2024 at 6:11:26 PM UTC | **Resource Type** CloudTrail Setting

Recommendations

- 1. Sign in to the AWS console
- 2. In the console, select the specific region from region drop down on the top right corner, for which the alert is generated
- 3. Access the 'CloudTrail' service.
- 4. For each trail reported, under Configuration > Storage Location, make sure 'Enable log file validation' is set to 'Yes'.

Audit and Accountability / Section Protection of Audit Information



1 Resource(s) Failed
prisma-forward-scan-cloudtrail

Compliance Section: Protection of Audit Information — Informational

- a. Protect audit information and audit logging tools from unauthorized access, modification, and deletion.
- b. Authorize access to management of audit logging functionality to only a subset of privileged users or roles.

AWS CloudTrail logs are not encrypted using Customer Master Keys (CMKs)

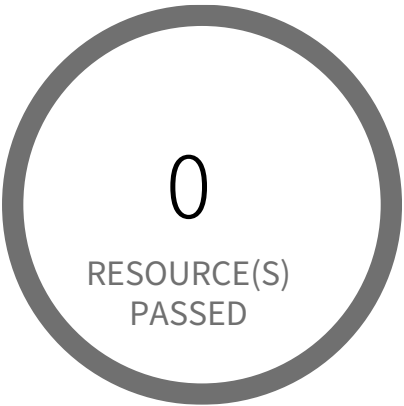
Checks to ensure that CloudTrail logs are encrypted. AWS CloudTrail is a service that enables governance, compliance, operational & risk auditing of the AWS account. It is a compliance and security best practice to encrypt the CloudTrail data since it may contain sensitive information.

First Seen June 11, 2024 at 6:11:26 PM UTC | **Resource Type** CloudTrail Setting

Recommendations

- 1. Login to AWS Console and navigate to the 'CloudTrail' service.
- 2. For each trail, under Configuration > Storage Location, select 'Yes' to 'Encrypt log files' setting
- 3. Choose an existing KMS key or create a new one to encrypt the logs with.

Audit and Accountability / Section Protection of Audit Information



0 Resource(s) Failed

Compliance Section: Protection of Audit Information ●●●● Low

- a. Protect audit information and audit logging tools from unauthorized access, modification, and deletion.
- b. Authorize access to management of audit logging functionality to only a subset of privileged users or roles.

AWS Database Migration Service endpoint do not have SSL configured

This policy identifies Database Migration Service (DMS) endpoints that are not configured with SSL to encrypt connections for source and target endpoints. It is recommended to use SSL connection for source and target endpoints; enforcing SSL connections help protect against 'man in the middle' attacks by encrypting the data stream between endpoint connections.

NOTE: Not all databases use SSL in the same way. An Amazon Redshift endpoint already uses an SSL connection and does not require an SSL connection set up by AWS DMS. So there are some exlcusions included in policy RQL to report only those endpoints which can be configured using DMS SSL feature.

For more details:
https://docs.aws.amazon.com/dms/latest/userguide/CHAP_Security.html#CHAP_Security.SSL

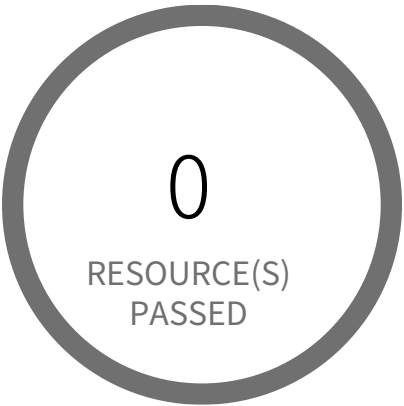
First Seen N/A | **Resource Type** Other

Recommendations

1. Log in to the AWS Console
2. Navigate to the AWS DMS dashboard
3. In the navigation pane, choose 'Endpoints'
4. Select the reported DMS endpoint
5. Under 'Actions', choose 'Modify'
6. In the 'Endpoint configuration' section, select the 'Secure Socket Layer (SSL) mode' from the dropdown list select suitable SSL mode according to your requirement other than 'none'.
7. Click on 'Save'

NOTE: Before modifying the SSL setting, you should be configured with the proper certificate you want to use for SSL connection under the DMS 'Certificate' service.

Audit and Accountability / Section Protection of Audit Information



0 Resource(s) Failed

Compliance Section: Protection of Audit Information ●●●● Low

- a. Protect audit information and audit logging tools from unauthorized access, modification, and deletion.
- b. Authorize access to management of audit logging functionality to only a subset of privileged users or roles.

AWS Kinesis streams are not encrypted using Server Side Encryption

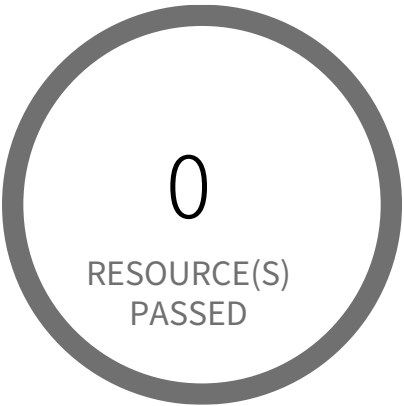
This Policy identifies the AWS Kinesis streams which are not encrypted using Server Side Encryption. Server Side Encryption is used to encrypt your sensitive data before it is written to the Kinesis stream storage layer and decrypted after it is retrieved from storage.

First Seen N/A | **Resource Type** Other

Recommendations

- 1. Sign in to the AWS Console
- 2. Go to Kinesis Service
- 3. Select the reported Kinesis data stream for the corresponding region
- 4. Under Server-side encryption, Click on Edit
- 5. Choose Enabled
- 6. Under KMS master key, You can choose any KMS other than the default (Default) aws/kinesis
- 7. Click Save

Audit and Accountability / Section Protection of Audit Information



0 Resource(s) Failed

Compliance Section: Protection of Audit Information — Informational

- a. Protect audit information and audit logging tools from unauthorized access, modification, and deletion.
- b. Authorize access to management of audit logging functionality to only a subset of privileged users or roles.

AWS Kinesis streams encryption using default KMS keys instead of Customer's Managed Master Keys

This policy identifies the AWS Kinesis streams which are encrypted with default KMS keys and not with Master Keys managed by Customer. It is a best practice to use customer managed Master Keys to encrypt your Amazon Kinesis streams data. It gives you full control over the encrypted data.

First Seen N/A | **Resource Type** Other

Recommendations

1. Sign in to the AWS Console
2. Go to Kinesis Service
3. Select the reported Kinesis data stream for the corresponding region
4. Under Server-side encryption, Click on Edit
5. Choose Enabled
6. Under KMS master key, You can choose any KMS other than the default (Default) aws/kinesis
7. Click Save

Audit and Accountability / Section Protection of Audit Information



0 Resource(s) Failed

Compliance Section: Protection of Audit Information ●●●● Low

- a. Protect audit information and audit logging tools from unauthorized access, modification, and deletion.
- b. Authorize access to management of audit logging functionality to only a subset of privileged users or roles.

AWS S3 Bucket Policy allows public access to CloudTrail logs

This policy scans your bucket policy that is applied to the S3 bucket to prevent public access to the CloudTrail logs. CloudTrail logs a record of every API call made in your AWS account. These logs file are stored in an S3 bucket. Bucket policy or the access control list (ACL) applied to the S3 bucket does not prevent public access to the CloudTrail logs. It is recommended that the bucket policy or access control list (ACL) applied to the S3 bucket that stores CloudTrail logs prevents public access. Allowing public access to CloudTrail log content may aid an adversary in identifying weaknesses in the affected account's use or configuration.

First Seen N/A | Resource Type Other

Recommendations

1. Sign in to the AWS Console
 2. Goto S3
 3. Choose the reported S3 bucket and click Properties
 4. In the Properties pane, click the Permissions tab.
 5. If the Edit bucket policy button is present, select it.
 6. Remove any statement having an effect Set to 'Allow' and a principal set to '*'.
- Note: We recommend that you do not configure CloudTrail to write into an S3 bucket that resides in a different AWS account.

Audit and Accountability / Section Protection of Audit Information



0 Resource(s) Failed

Compliance Section: Protection of Audit Information ●●●● Low

- a. Protect audit information and audit logging tools from unauthorized access, modification, and deletion.
- b. Authorize access to management of audit logging functionality to only a subset of privileged users or roles.

AWS S3 buckets do not have server side encryption

Customers can protect the data in S3 buckets using the AWS server-side encryption. If the server-side encryption is not turned on for S3 buckets with sensitive data, in the event of a data breach, malicious users can gain access to the data.

NOTE: Do NOT enable this policy if you are using 'Server-Side Encryption with Customer-Provided Encryption Keys (SSE-C).'

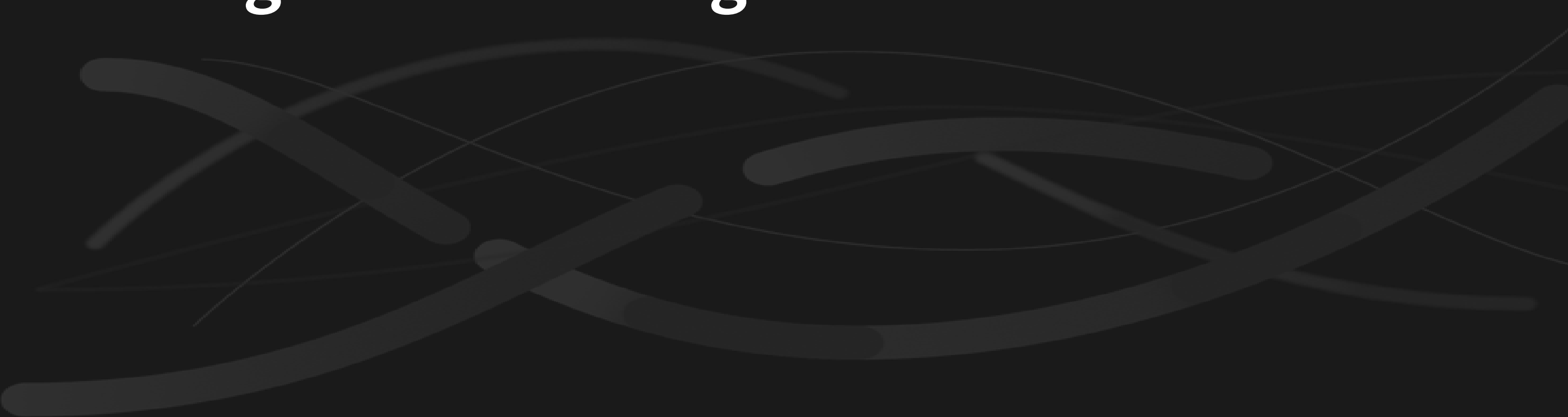
First Seen N/A | **Resource Type** Other

Recommendations

- 1. Login to the AWS Console and navigate to the 'S3' service
 - 2. Click on the reported S3 bucket
 - 3. Click on the 'Properties' tab
 - 4. Under the 'Default encryption' section, choose encryption option either AES-256 or AWS-KMS based on your requirement.
- For more information about Server-side encryption,
Default encryption:
<https://docs.aws.amazon.com/AmazonS3/latest/dev/bucket-encryption.html>
Policy based encryption:
<https://docs.aws.amazon.com/AmazonS3/latest/dev/serv-side-encryption.html>

3

Configuration Management

An abstract graphic consisting of several thick, dark gray curved lines that overlap and intersect, creating a sense of motion and complexity. The lines are set against a dark gray background.

Configuration Management Overview

Section			Pass Rate	Failed	Passed
Baseline Configuration	AWS Auto Scaling group launch configuration configured with Instance... Medium	100%	0	0	
Baseline Configuration	AWS Auto Scaling group launch configuration not configured with In... Medium	100%	0	0	
Baseline Configuration	AWS DocumentDB cluster deletion protection is disabled Informational	100%	0	0	
Baseline Configuration	AWS ECR Repository not configured with a lifecycle policy Informational	100%	0	5	
Baseline Configuration	AWS Neptune cluster deletion protection is disabled Informational	100%	0	0	
Baseline Configuration	AWS Web Application Firewall (AWS WAF) Classic logging is dis... Informational	100%	0	0	
Configuration Settings	AWS ACM Certificate with wildcard domain name Low	100%	0	0	
Configuration Settings	AWS API Gateway endpoints without client certificate authentication Low	100%	0	0	
Configuration Settings	AWS API gateway request authorisation is not set Low	100%	0	0	
Configuration Settings	AWS API gateway request parameter is not validated Low	100%	0	0	

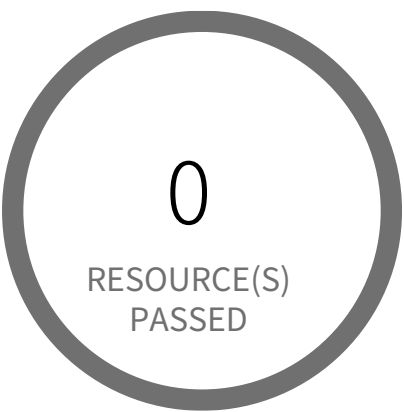
Section		Pass Rate	Failed	Passed
Configuration Settings	AWS Application Load Balancer (ALB) is not using the latest predefined se... Low	100%	0	1
Configuration Settings	AWS Certificate Manager (ACM) contains certificate pending valida... Informational	100%	0	0
Configuration Settings	AWS Certificate Manager (ACM) has certificates expiring in 30 days or less Low	100%	0	0
Configuration Settings	AWS Certificate Manager (ACM) has expired certificates Low	100%	0	0
Configuration Settings	AWS Certificate Manager (ACM) has invalid or failed certificate Low	100%	0	0
Configuration Settings	AWS CloudFront web distribution with AWS Web Application Fire... Informational	100%	0	0
Configuration Settings	AWS CloudFront web distribution with geo restriction disabled Low	100%	0	0
Configuration Settings	AWS CloudTrail S3 buckets have not enabled MFA Delete Informational	96%	1	24
Configuration Settings	AWS Cloudfront Distribution with S3 have Origin Access set to disabled Low	100%	0	0
Configuration Settings	AWS Config Recording is disabled Informational	0%	57	0
Configuration Settings	AWS Config must record all possible resources Informational	100%	0	0

Section			Pass Rate	Failed	Passed
Configuration Settings	AWS Database Migration Service (DMS) has expired certificates Low		100%	0	0
Configuration Settings	AWS EBS Snapshot with access for unmonitored cloud accounts Low		16%	5	1
Configuration Settings	AWS EKS cluster control plane assigned multiple security groups Low		100%	0	1
Configuration Settings	AWS EMR cluster is not configured with security configuration Informational		100%	0	0
Configuration Settings	AWS ElastiCache Redis cluster with Redis AUTH feature disabled Low		100%	0	0
Configuration Settings	AWS Elastic Load Balancer (Classic) with cross-zone load balancing disabled Low		100%	0	0
Configuration Settings	AWS Elastic Load Balancer (ELB) not in use Informational		100%	0	0
Configuration Settings	AWS Elastic Load Balancer (ELB) with ACM certificate expired or... Informational		100%	0	0
Configuration Settings	AWS Elastic Load Balancer (ELB) with IAM certificate expiring in 90... Informational		100%	0	0
Configuration Settings	AWS Elastic Load Balancer v2 (ELBv2) load balancer with invalid... Informational		100%	0	1
Configuration Settings	AWS Elasticsearch domain has Dedicated master set to disabled Low		100%	0	0

Section				Pass Rate	Failed	Passed
Configuration Settings	AWS Elasticsearch domain has Zone Awareness set to disabled	Informational		100%	0	0
Configuration Settings	AWS Inactive users for more than 30 days	Low		3%	50	2
Configuration Settings	AWS Lambda nearing availability code storage limit	Informational		100%	0	1
Configuration Settings	AWS NAT Gateways are not being utilized for the default route	Low		100%	0	36
Configuration Settings	AWS Network Load Balancer (NLB) is not using the latest predefined security...	Low		100%	0	1
Configuration Settings	AWS RDS Snapshot with access for unmonitored cloud accounts	Low		100%	0	5
Configuration Settings	AWS RDS instance with Multi-Availability Zone disabled	Informational		0%	1	0
Configuration Settings	AWS RDS instance with copy tags to snapshots disabled	Informational		100%	0	1
Configuration Settings	AWS RDS minor upgrades not enabled	Low		100%	0	1
Configuration Settings	AWS Route53 Public Zone with Private Records	Low		100%	0	0
Configuration Settings	AWS S3 Object Versioning is disabled	Low		4%	24	1

Section			Pass Rate	Failed	Passed
Configuration Settings	AWS S3 bucket is not configured with MFA Delete	Low	96%	1	24
Configuration Settings	AWS S3 buckets with configurations set to host websites	Informational	100%	0	25
Configuration Settings	AWS VPC allows unauthorized peering	Informational	100%	0	0
Configuration Settings	AWS VPC not in use	Informational	100%	0	25
Configuration Settings	AWS regions nearing VPC Private Gateway IPSec Limit	Informational	100%	0	0
Configuration Settings	AWS regions nearing VPC Private Gateway limit	Informational	100%	0	0

Configuration Management / Section Baseline Configuration



0 Resource(s) Failed

Compliance Section: Baseline Configuration ●●●● Medium

- a. Develop and maintain under configuration control, a current baseline configuration of the system.
- b. Review and update the baseline configuration of the system [Assignment: organization-defined frequency] and when system components are installed or modified.

AWS Auto Scaling group launch configuration configured with Instance Metadata Service hop count greater than 1

This policy identifies the autoscaling group launch configuration where the Instance Metadata Service network hops count is set to greater than 1. A launch configuration is an instance configuration template that an Auto Scaling group uses to launch EC2 instances. With the metadata response hop limit count for the IMDS greater than 1, the PUT response that contains the secret token can travel outside the EC2 instance. Only metadata with a limited hop count for all your EC2 instances is recommended.

First Seen N/A | **Resource Type** Other

Recommendations

You cannot modify a launch configuration after you create it. To change the launch configuration for an Auto Scaling group, use an existing launch configuration as the basis for a new launch configuration with IMDS with a hop count equal to 1.

To update the Auto Scaling group to use the new launch configuration follow the steps below:

1. Open the Amazon EC2 console.
2. On the left navigation pane, under 'Auto Scaling', choose 'Auto Scaling Groups' and Choose 'Launch configurations' near the top of the page.
3. Select the reported launch configuration, choose Actions, then click 'Copy launch configuration'. This sets up a new launch configuration with the same options as the original, but with 'Copy' added to the name.
4. On the 'Create launch configuration' page, expand 'Advanced details' under 'Additional Configuration - optional'.
5. Under the 'Advanced details', go to the 'Metadata response hop limit' section.
6. Edit the text box and set the value to 1.
7. When you have finished, click on the 'Create launch configuration' button at the bottom of the page.
8. On the navigation pane, under Auto Scaling, choose Auto Scaling Groups.
9. Select the check box next to the Auto Scaling group.
10. A split pane opens up at the bottom part of the page, showing information about the group that's selected.
11. On the Details tab, click on the 'Edit' button adjacent to the 'Launch configuration' option.
12. Under the 'Launch configuration' dropdown, select the newly created launch configuration.

13. When you have finished changing your launch configuration, click on the 'Update' button at the bottom of the page.

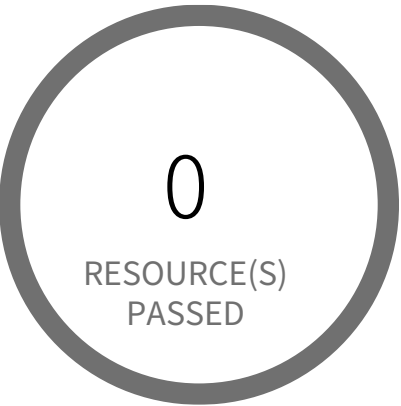
After you change the launch configuration for an Auto Scaling group, any new instances are launched with the new configuration options. Existing instances are not affected. To update existing instances,

1. Log in to the AWS Console
2. In the console, select the specific region from the region drop-down in the top right corner, for which the alert is generated.
3. Refer 'Configure instance metadata options for existing instances' section from the following URL:
<https://docs.aws.amazon.com/AWSEC2/latest/UserGuide/configuring-IMDS-existing-instances.html>

To delete the reported Auto Scaling group launch configuration follow the steps below:

1. Open the Amazon EC2 console.
2. On the left navigation pane, under 'Auto Scaling', choose 'Auto Scaling Groups' and Choose 'Launch configurations' near the top of the page.
3. Select the reported launch configuration, choose Actions, then click 'Delete launch configuration'.
4. Click on the 'Delete' button to delete the autoscaling group launch configuration.

Configuration Management / Section Baseline Configuration



0 Resource(s) Failed

Compliance Section: Baseline Configuration ●●● Medium

- a. Develop and maintain under configuration control, a current baseline configuration of the system.
- b. Review and update the baseline configuration of the system [Assignment: organization-defined frequency] and when system components are installed or modified.

AWS Auto Scaling group launch configuration not configured with Instance Metadata Service v2 (IMDSv2)

This policy identifies the autoscaling group launch configuration where IMDSv2 is set to optional. A launch configuration is an instance configuration template that an Auto Scaling group uses to launch EC2 instances. With IMDSv2, every request is now protected by session authentication. Version 2 of the IMDS adds new protections that weren't available in IMDSv1 to further safeguard your EC2 instances created by the autoscaling group. It is recommended to use only IMDSv2 for all your EC2 instances.

First Seen N/A | Resource Type Other

Recommendations

You cannot modify a launch configuration after you create it. To change the launch configuration for an Auto Scaling group, use an existing launch configuration as the basis for a new launch configuration with IMDSv2 enabled.

To update the Auto Scaling group to use the new launch configuration follow the steps below:

1. Open the Amazon EC2 console.
2. On the left navigation pane, under 'Auto Scaling', choose 'Auto Scaling Groups' and Choose 'Launch configurations' near the top of the page.
3. Select the reported launch configuration and choose Actions, then click 'Copy launch configuration'. This sets up a new launch configuration with the same options as the original, but with 'Copy' added to the name.
4. On the 'Create launch configuration' page, expand 'Advanced details' under 'Additional Configuration - optional'.
5. Under the 'Advanced details', go to the 'Metadata version' section.
6. Select 'V2 only (token required)' option.
7. When you have finished, click on the 'Create launch configuration' button at the bottom of the page.
8. On the navigation pane, under Auto Scaling, choose Auto Scaling Groups.
9. Select the check box next to the Auto Scaling group.
10. A split pane opens up at the bottom part of the page, showing information about the group that's selected.
11. On the Details tab, click on the 'Edit' button adjacent to the 'Launch template' option.
12. On top right, click 'Switch to launch configuration'
13. Under the 'Launch configuration' dropdown, select the newly created launch configuration.

14. When you have finished changing your launch configuration, click on the 'Update' button at the bottom of the page.

After you change the launch configuration for an Auto Scaling group, any new instances are launched with the new configuration options. Existing instances are not affected. To update existing instances,

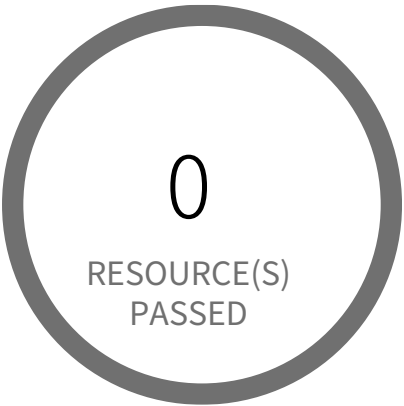
1. Log in to the AWS Console
2. In the console, select the specific region from the region drop-down in the top right corner, for which the alert is generated.
3. Refer the following URL:
<https://docs.aws.amazon.com/AWSEC2/latest/UserGuide/configuring-IMDS-existing-instances.html>

To delete the reported Auto Scaling group launch configuration follow the steps below:

1. Open the Amazon EC2 console.
2. On the left navigation pane, under 'Auto Scaling', choose 'Auto Scaling Groups' and Choose 'Launch configurations' near the top of the page.
3. Select the reported launch configuration and choose Actions, then click 'Delete launch configuration'.
4. Click on the 'Delete' button to delete the autoscaling group launch configuration.

NOTE: Ensure adequate precautions before you enforce the use of IMDSv2, as applications or agents that use IMDSv1 for instance metadata access will break.

Configuration Management / Section Baseline Configuration



0 Resource(s) Failed

Compliance Section: Baseline Configuration — Informational

- a. Develop and maintain under configuration control, a current baseline configuration of the system.
- b. Review and update the baseline configuration of the system [Assignment: organization-defined frequency] and when system components are installed or modified.

AWS DocumentDB cluster deletion protection is disabled

This policy identifies AWS DocumentDB clusters for which deletion protection is disabled. Enabling deletion protection for DocumentDB clusters prevents irreversible data loss resulting from accidental or malicious operations.

First Seen N/A | **Resource Type** Other

Recommendations

1. Sign in to the AWS console
2. Select the region, from the region drop-down, for which the alert is generated
3. Navigate to Amazon DocumentDB Dashboard
4. Select the reported DocumentDB cluster
5. From top right 'Actions' drop down list select 'Enable deletion protection'
6. Schedule the modifications and click on 'Modify cluster'

Configuration Management / Section Baseline Configuration



0 Resource(s) Failed

Compliance Section: Baseline Configuration — Informational

- a. Develop and maintain under configuration control, a current baseline configuration of the system.
- b. Review and update the baseline configuration of the system [Assignment: organization-defined frequency] and when system components are installed or modified.

AWS ECR Repository not configured with a lifecycle policy

This policy identifies AWS ECR Repositories that are not configured with a lifecycle policy. Amazon ECR lifecycle policies enable you to specify the lifecycle management of images in a repository. This helps to automate the cleanup of unused images and the expiration of images based on age or count. As best practice, it is recommended to configure ECR repository with lifecycle policy which helps to avoid unintentionally using outdated images in your repository.

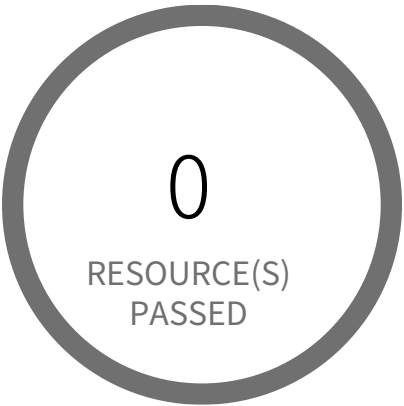
First Seen N/A | **Resource Type** Other

Recommendations

To configure AWS ECR Repository with a lifecycle policy follow the steps mentioned in below URL:

https://docs.aws.amazon.com/AmazonECR/latest/userguide/lpp_creation.html

Configuration Management / Section Baseline Configuration



0 Resource(s) Failed

Compliance Section: Baseline Configuration — Informational

- a. Develop and maintain under configuration control, a current baseline configuration of the system.
- b. Review and update the baseline configuration of the system [Assignment: organization-defined frequency] and when system components are installed or modified.

AWS Neptune cluster deletion protection is disabled

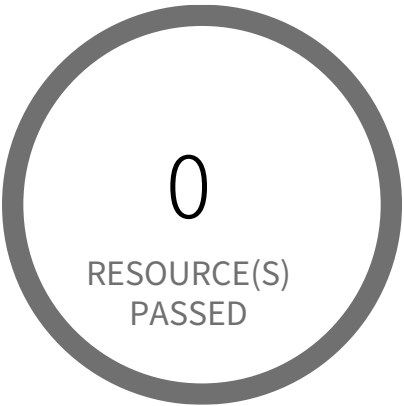
This policy identifies AWS Neptune clusters for which deletion protection is disabled. Enabling deletion protection for Neptune clusters prevents irreversible data loss resulting from accidental or malicious operations.

First Seen N/A | **Resource Type** Other

Recommendations

1. Sign in to the AWS console
2. Select the region, from the region drop-down, for which the alert is generated
3. Navigate to Neptune Dashboard
4. Select the reported Neptune cluster
5. Click on 'Modify' from top
6. Under 'Deletion protection' select 'Enable deletion protection'
7. Click on 'Continue'
8. Schedule the modifications and click on 'Modify cluster'

Configuration Management / Section Baseline Configuration



0 Resource(s) Failed

Compliance Section: Baseline Configuration — Informational

- a. Develop and maintain under configuration control, a current baseline configuration of the system.
- b. Review and update the baseline configuration of the system [Assignment: organization-defined frequency] and when system components are installed or modified.

AWS Web Application Firewall (AWS WAF) Classic logging is disabled

This policy identifies Classic Web Application Firewalls (AWS WAFs) for which logging is disabled. Enabling WAF logging, logs all web requests inspected by the service which can be used for debugging and additional forensics. The logs will help to understand why certain rules are triggered and why certain web requests are blocked. You can also integrate the logs with any SIEM and log analysis tools for further analysis. It is recommended to enable logging on your Classic Web Application Firewalls (WAFs).

For details:
<https://docs.aws.amazon.com/waf/latest/developerguide/classic-logging.html>

NOTE: Global (CloudFront) WAF resources are out of scope for this policy.

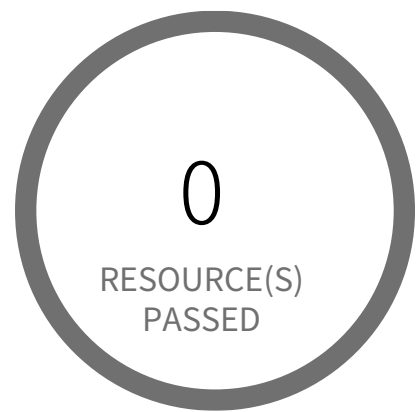
First Seen N/A | **Resource Type** Other

Recommendations

To enable logging on your reported WAFs, follow below mentioned URL:
<https://docs.aws.amazon.com/waf/latest/developerguide/classic-logging.html#logging-management>

NOTE: No additional cost to enable logging on AWS WAF (minus Kinesis Firehose and any storage cost).
For Kinesis Firehose or any storage additional charges refer <https://aws.amazon.com/cloudwatch/pricing/>

Configuration Management / Section Configuration Settings



0 Resource(s) Failed

Compliance Section: Configuration Settings ●●●● Low

- a. Establish, document, and implement the following configuration settings for the system that reflect the most restrictive mode consistent with operational requirements: [Assignment: organization-defined configuration settings].
- b. Identify, document, and approve any deviations from established configuration settings.

AWS ACM Certificate with wildcard domain name

This policy identifies ACM Certificates which are using wildcard certificates for wildcard domain name instead of single domain name certificates. ACM allows you to use an asterisk (*) in the domain name to create an ACM Certificate containing a wildcard name that can protect several sites in the same domain. For example, a wildcard certificate issued for *.prismacloud.io can match both www.prismacloud.io and images.prismacloud.io. When you use wildcard certificates, if the private key of a certificate is compromised, then all domain and subdomains that use the compromised certificate are potentially impacted. So it is recommended to use single domain name certificates instead of wildcard certificates to reduce the associated risks with a compromised domain or subdomain.

First Seen N/A | **Resource Type** Other

Recommendations

To resolve this alert, you have to replace the reported wildcard certificate with a single domain name certificate for all the first-level subdomains resulting from the domain name of the website secured with the wildcard certificate and delete the reported wildcard domain certificate.

To create a new certificate with a single domain:

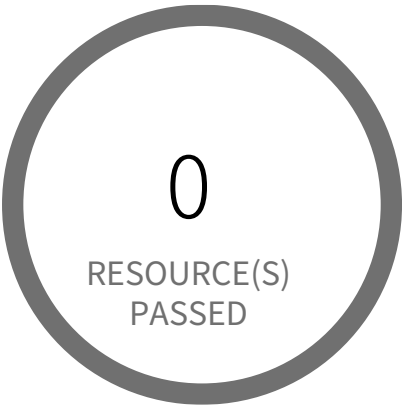
1. Sign in to the AWS console
2. In the console, select the specific region from the region drop-down on the top right corner, for which the alert is generated
3. Navigate to AWS Certificate Manager (ACM) and click on 'Request certificate' from the left panel.
4. On the 'Request certificate' page, select 'Request a public certificate' as the 'Certificate type' and click 'Next'.
5. In the 'Request public certificate' page,
 - a. Specify Domain Name: In the 'Domain names' section, type the fully qualified domain name (e.g., `subdomain.yourdomain.com`) in the 'Fully qualified domain name' box.
 - b. Select Validation Method: In the 'Validation method' section, choose the validation method that suits your requirements (e.g., DNS validation or Email validation).
 - c. Choose Key Algorithm:** In the 'Key algorithm' section, select an appropriate encryption algorithm. Be aware that some algorithms may not be supported by all AWS services.
 - d. Review and Request:** Review the domain name and validation method details, then click 'Request'.

6. Wait for the certificate status to change from 'Pending validation' to 'Issued'. Once issued, access your application's web server configuration and replace the wildcard certificate with the newly issued single-domain name certificate.

To delete a wildcard certificate:

1. Sign in to the AWS console
2. In the console, select the specific region from the region drop-down on the top right corner, for which the alert is generated
3. Go to Certificate Manager(ACM) service and select 'List certificates' from the left panel.
4. Choose the reported certificate
5. Ensure you disassociate the certificate from all its associated resources (e.g., Load Balancers, CloudFront distributions). After dissociation, click on 'Delete'.
6. On the 'Delete certificate' pop-up windows, click on the 'Delete' button

Configuration Management / Section Configuration Settings



0 Resource(s) Failed

Compliance Section: Configuration Settings ●●●● Low

- a. Establish, document, and implement the following configuration settings for the system that reflect the most restrictive mode consistent with operational requirements: [Assignment: organization-defined configuration settings].
- b. Identify, document, and approve any deviations from established configuration settings.

AWS API Gateway endpoints without client certificate authentication

API Gateway can generate an SSL certificate and use its public key in the backend to verify that HTTP requests to your backend system are from API Gateway. This allows your HTTP backend to control and accept only requests originating from Amazon API Gateway, even if the backend is publicly accessible.

Note: Some backend servers may not support SSL client authentication as API Gateway does and could return an SSL certificate error. For a list of incompatible backend servers, see Known Issues. <https://docs.aws.amazon.com/apigateway/latest/developerguide/api-gateway-known-issues.html>

First Seen N/A | Resource Type Other

Recommendations

These instructions assume you already completed Generate a Client Certificate Using the API Gateway Console. If not please generate a client certificate by following below steps and then Configure an API to Use SSL Certificates.

Steps to Generate a Client Certificate Using the API Gateway Console:

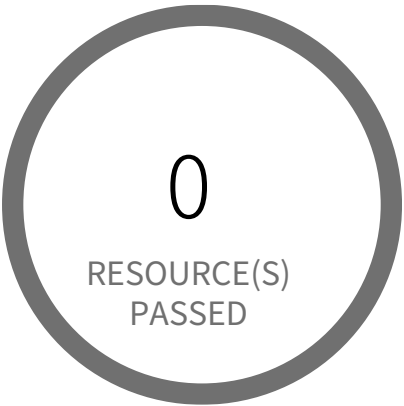
- 1. Login to AWS Console
- 2. Go to API Gateway console
- 3. In the main navigation pane (Left Panel), choose Client Certificates.
- 4. From the Client Certificates pane, choose Generate Client Certificate.
- 5. Optionally, for Edit, choose to add a descriptive title for the generated certificate and choose Save to save the description. API Gateway generates a new certificate and returns the new certificate GUID, along with the PEM-encoded public key.

Steps to Configure an API to Use SSL Certificates:

- 1. Login to AWS Console
- 2. Go to API Gateway console
- 3. In the API Gateway console, create or open an API for which you want to use the client certificate. Make sure the API has been deployed to a stage (Left Panel).
- 4. Choose Stages under the selected API and then choose a stage (Left Panel).

5. In the Stage Editor panel, select a certificate under the Client Certificate section.
6. Click Save Changes

Configuration Management / Section Configuration Settings



0 Resource(s) Failed

Compliance Section: Configuration Settings ●●●● Low

- a. Establish, document, and implement the following configuration settings for the system that reflect the most restrictive mode consistent with operational requirements: [Assignment: organization-defined configuration settings].
- b. Identify, document, and approve any deviations from established configuration settings.

AWS API gateway request authorisation is not set

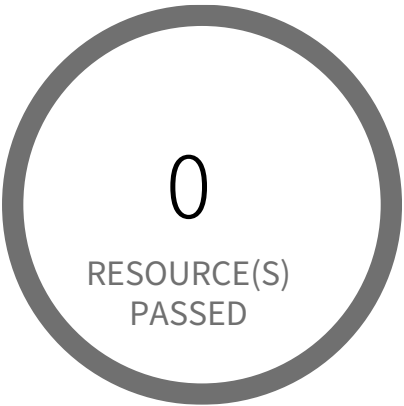
This policy identifies AWS API Gateways of protocol type REST for which the request authorisation is not set. The method request for API gateways takes the client input that is passed to the back end through the integration request. It is recommended to add authorization type to each of the method to add a layer of protection.

First Seen N/A | **Resource Type** Other

Recommendations

- 1. Login to AWS management console
- 2. Navigate to 'API Gateway' service
- 3. Select the region for which the API gateway is reported.
- 4. Find the alerted API by the API gateway ID which is the first part of reported resource and click on it
- 5. Navigate to the reported method
- 6. Click on the clickable link of 'Method Request'
- 7. Under section 'Settings', click on the pencil symbol for 'Authorization' field
- 8. From the dropdown, Select the type of Authorization as per the requirement
- 9. Click on the tick symbol next to it to save the changes

Configuration Management / Section Configuration Settings



0 Resource(s) Failed

Compliance Section: Configuration Settings ●●●● Low

- a. Establish, document, and implement the following configuration settings for the system that reflect the most restrictive mode consistent with operational requirements: [Assignment: organization-defined configuration settings].
- b. Identify, document, and approve any deviations from established configuration settings.

AWS API gateway request parameter is not validated

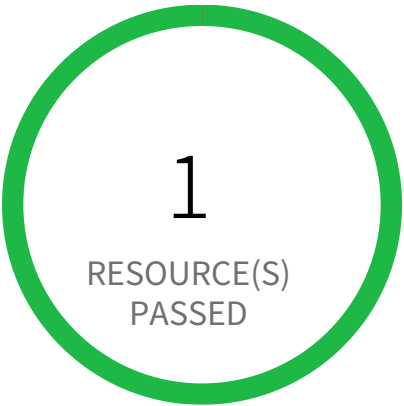
This policy identifies the AWS API gateways for which the request parameters are not validated. When the validation fails, API Gateway fails the request, returns a 400 error response to the caller, and publishes the validation results in CloudWatch Logs. It is recommended to perform basic validation of an API request before proceeding with the integration request to block unvalidated calls to the backend.

First Seen N/A | **Resource Type** Other

Recommendations

- 1. Login to AWS management console
- 2. Navigate to 'API Gateway' service
- 3. Select the region for which the API gateway is reported.
- 4. Find the alerted API by the API gateway ID which is the first part of reported resource and click on it
- 5. Navigate to the reported method
- 6. Click on the clickable link of 'Method Request'
- 7. Under section 'Settings' ,click on the pencil symbol for 'Request Validator' field
- 8. From the dropdown, Select the type of Request Validator as per the requirement
- 9. Click on the tick symbol next to it to save the changes

Configuration Management / Section Configuration Settings



0 Resource(s) Failed

Compliance Section: Configuration Settings ●●●● Low

- a. Establish, document, and implement the following configuration settings for the system that reflect the most restrictive mode consistent with operational requirements: [Assignment: organization-defined configuration settings].
- b. Identify, document, and approve any deviations from established configuration settings.

AWS Application Load Balancer (ALB) is not using the latest predefined security policy

This policy identifies Application Load Balancers (ALBs) are not using the latest predefined security policy. A security policy is a combination of protocols and ciphers. The protocol establishes a secure connection between a client and a server and ensures that all data passed between the client and your load balancer is private. A cipher is an encryption algorithm that uses encryption keys to create a coded message. So it is recommended to use the latest predefined security policy which uses only secured protocol and ciphers.

We recommend using either non-FIPS security policy ELBSecurityPolicy-TLS13-1-2-2021-06 or FIPS security policy ELBSecurityPolicy-TLS13-1-2-FIPS-2023-04 to meet compliance and security standards that require disabling certain TLS protocol versions or to support legacy clients that require deprecated ciphers.

For more details:

<https://docs.aws.amazon.com/elasticloadbalancing/latest/application/create-https-listener.html#describe-ssl-policies>

First Seen N/A | **Resource Type** Other

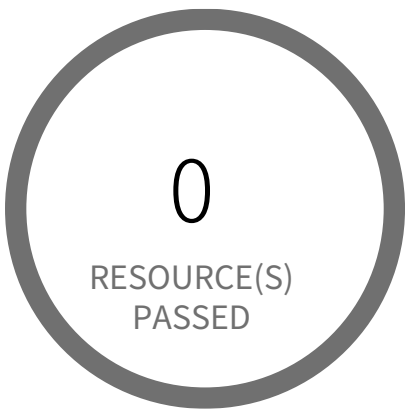
Recommendations

- 1. Log in to the AWS console
- 2. In the console, select the specific region from the region drop-down on the top right corner, for which the alert is generated
- 3. Go to the EC2 Dashboard, and select 'Load Balancers'
- 4. Click on the reported Load Balancer
- 5. On the 'Listeners' tab, Choose the 'HTTPS' or 'SSL' rule
- 6. Click on 'Edit Listener' in the 'Manage listener' dropdown, Change 'Security policy' to 'ELBSecurityPolicy-TLS13-1-2-2021-06' (non-FIPS) or 'ELBSecurityPolicy-TLS13-1-2-FIPS-2023-04' (FIPS) to meet compliance and security standards that require disabling certain TLS protocol

versions or to support legacy clients that require deprecated ciphers.

7. Click on 'Update' to save your changes

Configuration Management / Section Configuration Settings



0 Resource(s) Failed

Compliance Section: Configuration Settings Informational

- a. Establish, document, and implement the following configuration settings for the system that reflect the most restrictive mode consistent with operational requirements: [Assignment: organization-defined configuration settings].
- b. Identify, document, and approve any deviations from established configuration settings.

AWS Certificate Manager (ACM) contains certificate pending validation

This policy identifies invalid certificates which are in AWS Certificate Manager. When your Amazon ACM certificates are not validated within 72 hours after the request is made, those certificates become invalid and you will have to request new certificates, which could cause interruption to your applications or services. Though AWS Certificate Manager automatically renews certificates issued by the service that is used with other AWS resources. However, the ACM service does not automatically renew certificates that are not currently in use or not associated anymore with other AWS resources. So the renewal process including validation must be done manually before these certificates become invalid.

First Seen N/A | Resource Type Other

Recommendations

To validate Certificates:

1. Sign into the AWS console
2. In the console, select the specific region from region drop down on the top right corner, for which the alert is generated
3. Go to Certificate Manager(ACM) service
4. Choose the reported certificate
5. Validate your certificate for your domain using either Email or DNS validation, depending upon your certificate validation method.

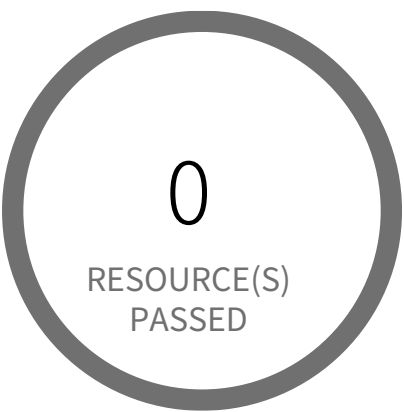
OR

If the certificate is not required you can delete that certificate. To delete invalid Certificates:

1. Sign into the AWS console
2. In the console, select the specific region from region drop down on the top right corner, for which the alert is generated
3. Go to Certificate Manager(ACM) service
4. Choose the reported certificate
5. Under 'Actions' drop-down click on 'Delete'

Note: This alert will get auto-resolved, as the certificate becomes invalid in 72 hours. It is recommended to either delete or validate the certificate within the timeframe.

Configuration Management / Section Configuration Settings



0 Resource(s) Failed

Compliance Section: Configuration Settings ●●●● Low

- a. Establish, document, and implement the following configuration settings for the system that reflect the most restrictive mode consistent with operational requirements: [Assignment: organization-defined configuration settings].
- b. Identify, document, and approve any deviations from established configuration settings.

AWS Certificate Manager (ACM) has certificates expiring in 30 days or less

This policy identifies ACM certificates expiring in 30 days or less, which are in the AWS Certificate Manager. If SSL/TLS certificates are not renewed prior to their expiration date, they will become invalid and the communication between the client and the AWS resource that implements the certificates is no longer secure. As a best practice, it is recommended to renew certificates before their validity period ends. AWS Certificate Manager automatically renews certificates issued by the service that is used with other AWS resources. However, the ACM service does not renew automatically certificates that are not in use or not associated anymore with other AWS resources. So the renewal process must be done manually before these certificates become invalid.

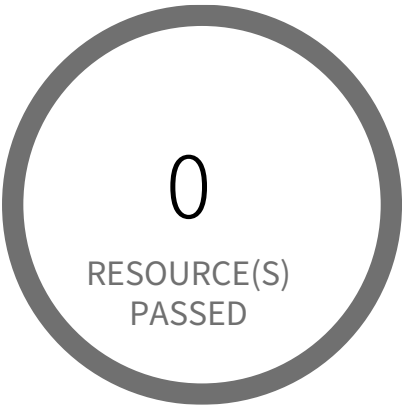
NOTE: If you wanted to be notified other than before or less than 30 days; you can clone this policy and replace '30' in RQL with your desired days value. For example, 15 days OR 7 days which will alert certificates expiring in 15 days or less OR 7 days or less respectively.

First Seen N/A | Resource Type Other

Recommendations

1. Log in to the AWS console
2. In the console, select the specific region from region drop down on the top right corner, for which the alert is generated
3. Go to the Certificate Manager(ACM) service
4. Choose the reported certificate
5. Verify that the 'Status' column shows 'Issued' for the reported certificate
6. Under 'Actions' drop-down select 'Reimport certificate' option
7. On the Import a certificate page, perform the following actions:
 - 7a. In 'Certificate body*' box, paste the PEM-encoded certificate to import, purchased from your SSL certificate provider.
 - 7b. In 'Certificate private key*' box, paste the PEM-encoded, unencrypted private key that matches the SSL/TLS certificate public key.
 - 7c.(Optional) In 'Certificate chain' box, paste the PEM-encoded certificate chain delivered with the certificate body specified at step 7a.
8. Click on 'Review and import' button
9. On the Review and import page, review the imported certificate details then click on 'Import'

Configuration Management / Section Configuration Settings



0 Resource(s) Failed

Compliance Section: Configuration Settings ●●●● Low

- a. Establish, document, and implement the following configuration settings for the system that reflect the most restrictive mode consistent with operational requirements: [Assignment: organization-defined configuration settings].
- b. Identify, document, and approve any deviations from established configuration settings.

AWS Certificate Manager (ACM) has expired certificates

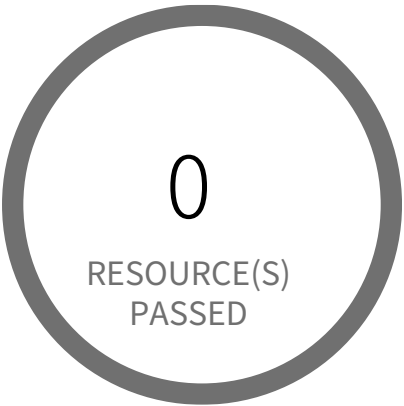
This policy identifies expired certificates which are in AWS Certificate Manager. AWS Certificate Manager (ACM) is the preferred tool to provision, manage, and deploy your server certificates. With ACM you can request a certificate or deploy an existing ACM or external certificate to AWS resources. This policy generates alerts if there are any expired ACM managed certificates. As a best practice, it is recommended to delete expired certificates.

First Seen N/A | **Resource Type** Other

Recommendations

- 1. Sign into the AWS console
- 2. In the console, select the specific region from region drop down on the top right corner, for which the alert is generated
- 3. Go to Certificate Manager(ACM) service
- 4. Choose the reported certificate
- 5. Verify that the 'Status' column shows 'Expired' for the reported certificate
- 6. Under 'Actions' drop-down click on 'Delete'

Configuration Management / Section Configuration Settings



0 Resource(s) Failed

Compliance Section: Configuration Settings ●●●● Low

- a. Establish, document, and implement the following configuration settings for the system that reflect the most restrictive mode consistent with operational requirements: [Assignment: organization-defined configuration settings].
- b. Identify, document, and approve any deviations from established configuration settings.

AWS Certificate Manager (ACM) has invalid or failed certificate

This policy identifies certificates in ACM which are either in Invalid or Failed state. If the ACM certificate is not validated within 72 hours, it becomes Invalid. An ACM certificate fails when,

- the certificate is requested for invalid public domains
- the certificate is requested for domains which are not allowed
- missing contact information
- typographical errors

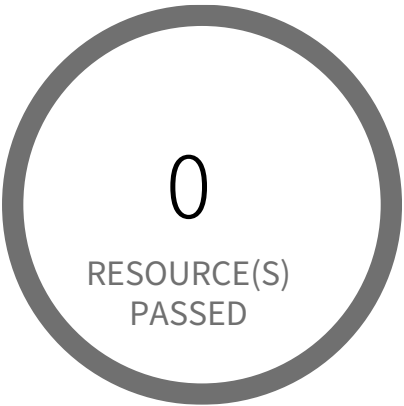
In such cases (Invalid or Failed certificate), you will have to request for a new certificate. It is strongly recommended to delete the certificates which are in failed or invalid state.

First Seen N/A | **Resource Type** Other

Recommendations

- To delete Certificates:
1. Sign into the AWS console
 2. In the console, select the specific region from region drop down on the top right corner, for which the alert is generated
 3. Go to Certificate Manager(ACM) service
 4. Choose the reported certificate
 5. Under 'Actions' drop-down click on 'Delete'

Configuration Management / Section Configuration Settings



0 Resource(s) Failed

Compliance Section: Configuration Settings Informational

- a. Establish, document, and implement the following configuration settings for the system that reflect the most restrictive mode consistent with operational requirements: [Assignment: organization-defined configuration settings].
- b. Identify, document, and approve any deviations from established configuration settings.

AWS CloudFront web distribution with AWS Web Application Firewall (AWS WAF) service disabled

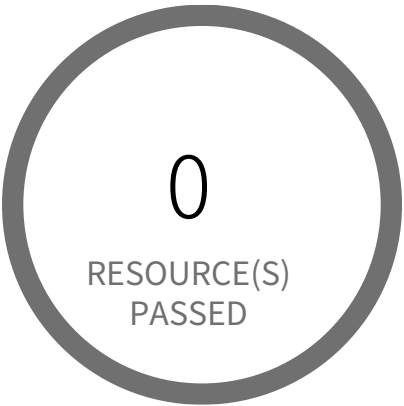
This policy identifies Amazon CloudFront web distributions which have the AWS Web Application Firewall (AWS WAF) service disabled. As a best practice, enable the AWS WAF service on CloudFront web distributions to protect against application layer attacks. To block malicious requests to your Cloudfront Content Delivery Network, define the block criteria in the WAF web access control list (web ACL).

First Seen N/A | **Resource Type** Other

Recommendations

- 1. Sign in to the AWS console
- 2. Go to the CloudFront Distributions Dashboard
- 3. Click on the reported web distribution
- 4. On 'General' tab, Click on 'Edit' button
- 5. On 'Edit Distribution' page, Choose a 'AWS WAF Web ACL' from dropdown.
- 6. Click on 'Yes, Edit'

Configuration Management / Section Configuration Settings



0 Resource(s) Failed

Compliance Section: Configuration Settings ●●●● Low

- a. Establish, document, and implement the following configuration settings for the system that reflect the most restrictive mode consistent with operational requirements: [Assignment: organization-defined configuration settings].
- b. Identify, document, and approve any deviations from established configuration settings.

AWS CloudFront web distribution with geo restriction disabled

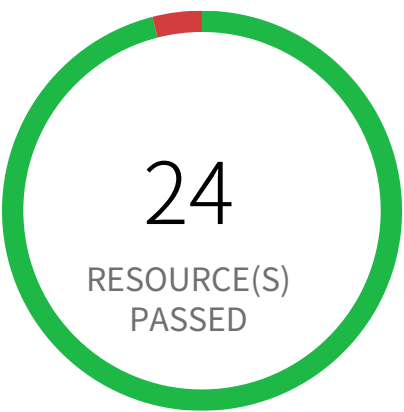
This policy identifies CloudFront web distributions which have geo restriction feature disabled. Geo Restriction has the ability to block IP addresses based on Geo IP by allowlist or denylist a country in order to allow or restrict users in specific locations from accessing web application content.

First Seen N/A | **Resource Type** Other

Recommendations

- 1. Sign in to the AWS console
- 2. Select the region, from the region drop-down, in which the alert is generated
- 3. Navigate to CloudFront Distributions Dashboard
- 4. Click on the reported distribution
- 5. On 'Restrictions' tab, Click on the 'Edit' button
- 6. On 'Edit Geo-Restrictions' page, Set 'Enable Geo-Restriction' to 'Yes' and allowlist/denylist countries as per your requirement.
- 7. Click on 'Yes, Edit'

Configuration Management / Section Configuration Settings



1 Resource(s) Failed
prisma-forward-scan-984345939

Compliance Section: Configuration Settings — Informational

- a. Establish, document, and implement the following configuration settings for the system that reflect the most restrictive mode consistent with operational requirements: [Assignment: organization-defined configuration settings].
- b. Identify, document, and approve any deviations from established configuration settings.

AWS CloudTrail S3 buckets have not enabled MFA Delete

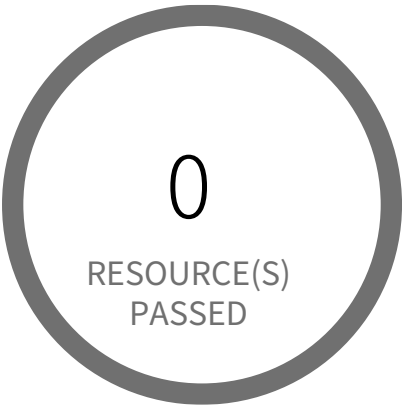
This policy identifies the S3 buckets which do not have Multi-Factor Authentication enabled for CloudTrails. For encryption of log files, CloudTrail defaults to use of S3 server-side encryption (SSE). We recommend adding an additional layer of security by adding MFA Delete to your S3 bucket. This will help to prevent deletion of CloudTrail logs without your explicit authorization. We also encourage you to use a bucket policy that places restrictions on which of your identity access management (IAM) users are allowed to delete S3 objects.

First Seen June 11, 2024 at 6:11:26 PM UTC | **Resource Type** Other

Recommendations

Enable MFA Delete on the bucket(s) you have configured to receive CloudTrail log files.
Note: We recommend that you do not configure CloudTrail to write into an S3 bucket that resides in a different AWS account.
Additional information on how to do this can be found here:
<http://docs.aws.amazon.com/AmazonS3/latest/dev/Versioning.html#MultiFactorAuthenticationDelete>

Configuration Management / Section Configuration Settings



0 Resource(s) Failed

Compliance Section: Configuration Settings ●●●● Low

- a. Establish, document, and implement the following configuration settings for the system that reflect the most restrictive mode consistent with operational requirements: [Assignment: organization-defined configuration settings].
- b. Identify, document, and approve any deviations from established configuration settings.

AWS Cloudfront Distribution with S3 have Origin Access set to disabled

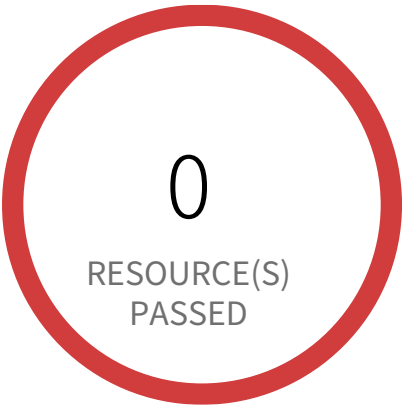
This policy identifies the AWS CloudFront distributions which are utilizing S3 bucket and have Origin Access Disabled. The origin access identity feature should be enabled for all your AWS CloudFront CDN distributions in order to restrict any direct access to your objects through Amazon S3 URLs.

First Seen N/A | **Resource Type** Other

Recommendations

- 1. Sign in to the AWS Console
- 2. Go to CloudFront
- 3. Choose the reported Distribution
- 4. Click on Distribution Settings
- 5. Click on 'Origins and Origin Groups
- 6. Select the S3 bucket and click on Edit
- 7. On the 'Restrict Bucket Access', Select Yes
- 8. Click on 'Yes, Edit'

Configuration Management / Section Configuration Settings



57 Resource(s) Failed

818698786219:AWS Bahrain, 058264157785:AWS Ohio, 058264157785:AWS Hyderabad, 058264157785:AWS Paris, 058264157785:AWS Sydney, 058264157785:AWS Mumbai, 058264157785:AWS Cape Town, 818698786219:AWS Spain, 818698786219:AWS Sydney, 058264157785:AWS Stockholm & 47 more

Compliance Section: Configuration Settings — Informational

- a. Establish, document, and implement the following configuration settings for the system that reflect the most restrictive mode consistent with operational requirements: [Assignment: organization-defined configuration settings].
- b. Identify, document, and approve any deviations from established configuration settings.

AWS Config Recording is disabled

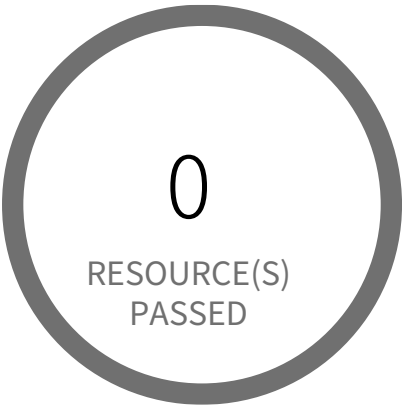
AWS Config is a web service that performs configuration management of supported AWS resources within your account and delivers log files to you. AWS config uses configuration recorder to detect changes in your resource configurations and capture these changes as configuration items. It continuously monitors and records your AWS resource configurations and allows you to automate the evaluation of recorded configurations against desired configurations. This policy generates alerts when AWS Config recorder is not enabled.

First Seen January 28, 2025 at 11:49:02 AM UTC | **Resource Type** Other

Recommendations

- 1. Sign in to the AWS Management Console
- 2. Select the specific region from the top down, for which the alert is generated
- 3. Navigate to service 'Config' from the 'Services' dropdown.
If AWS Config set up exists,
 - a. Go to Settings
 - b. Click on 'Turn On' button under 'Recording is Off' section,
 - c. provide required information for bucket and role with proper permission
If AWS Config set up doesn't exist
 - a. Click on 'Get Started'
 - b. For Step 1, Tick the check box for 'Record all resources supported in this region' under section 'Resource types to record'
 - c. Under section 'Amazon S3 bucket', select bucket with permission to Config services
 - d. Under section 'AWS Config role', select a role with permission to Config services
 - e. Click on 'Next'
 - f. For Step 2, Select required rule and click on 'Next' otherwise click on 'Skip'
 - g. For Step 3, Review the created 'Settings' and click on 'Confirm'

Configuration Management / Section Configuration Settings



0 Resource(s) Failed

Compliance Section: Configuration Settings — Informational

- a. Establish, document, and implement the following configuration settings for the system that reflect the most restrictive mode consistent with operational requirements: [Assignment: organization-defined configuration settings].
- b. Identify, document, and approve any deviations from established configuration settings.

AWS Config must record all possible resources

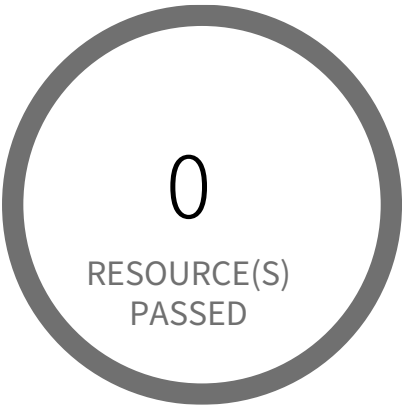
This policy identifies resources for which AWS Config recording is enabled but recording for all possible resources are disabled. AWS Config provides an inventory of your AWS resources and a history of configuration changes to these resources. You can use AWS Config to define rules that evaluate these configurations for compliance. Hence, it is important to enable this feature.

First Seen N/A | **Resource Type** Config Service Recorder

Recommendations

- 1. Login to the AWS and navigate to the 'Config' service
- 2. Change to the respective region and in the navigation pane, click on 'Settings'
- 3. Review the 'All resources' and Check the 2 options (3.a and 3.b)
 - 3.a Record all resources supported in this region
 - 3.b Include global resources (e.g., AWS IAM resources)

Configuration Management / Section Configuration Settings



0 Resource(s) Failed

Compliance Section: Configuration Settings ●●●● Low

- a. Establish, document, and implement the following configuration settings for the system that reflect the most restrictive mode consistent with operational requirements: [Assignment: organization-defined configuration settings].
- b. Identify, document, and approve any deviations from established configuration settings.

AWS Database Migration Service (DMS) has expired certificates

This policy identifies expired certificates that are in AWS Database Migration Service (DMS). AWS Database Migration Service (DMS) Certificate service is the preferred tool to provision, manage, and deploy your DMS endpoint certificates. As a best practice, it is recommended to delete expired certificates.

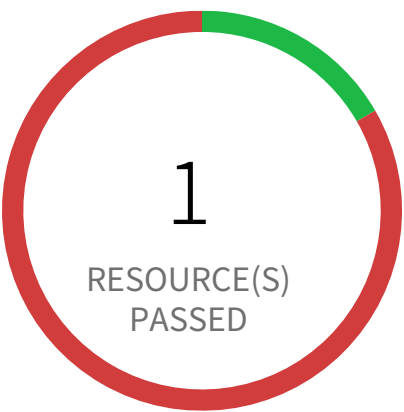
For more details:
https://docs.aws.amazon.com/dms/latest/userguide/CHAP_Security.html#CHAP_Security.SSL.ManagingCerts

First Seen N/A | **Resource Type** Other

Recommendations

1. Log in to the AWS Console
2. In the console, select the specific region from the region drop-down on the top right corner, for which the alert is generated
3. Navigate to 'AWS DMS' service
4. Click on 'Certificates', Choose the reported certificate
5. Make sure the reported certificate is already out of date from the 'Valid to' field
6. Click on 'Delete', to delete the expired certificate.

Configuration Management / Section Configuration Settings



5 Resource(s) Failed

snap-0d47c6cb9d3f1f396,
snap-0bf35b272167e62d2,
snap-036d0921bbb8d3125,
snap-04de50de9719b6b47,
snap-0f097a5ddc78b9b04

Compliance Section: Configuration Settings ●●●● Low

- a. Establish, document, and implement the following configuration settings for the system that reflect the most restrictive mode consistent with operational requirements: [Assignment: organization-defined configuration settings].
- b. Identify, document, and approve any deviations from established configuration settings.

AWS EBS Snapshot with access for unmonitored cloud accounts

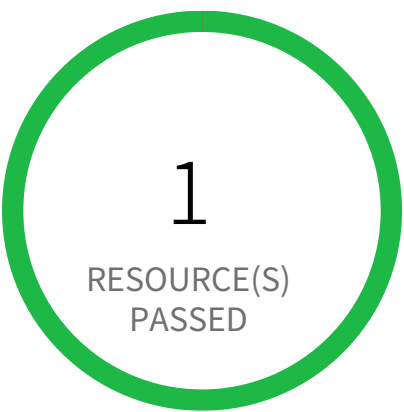
This policy identifies EBS Snapshot with access for unmonitored cloud accounts. The EBS Snapshots which have either the read / write permission opened up for Cloud Accounts which are NOT part of Cloud Accounts monitored by Prisma Cloud. These accounts with read / write privileges should be reviewed and confirmed that these are valid accounts of your organisation (or authorised by your organisation) and are not active under Prisma Cloud monitoring.

First Seen March 14, 2025 at 1:51:58 AM UTC | Resource Type Other

Recommendations

1. Sign in to the AWS console.
2. In the console, select the specific region from region drop down on the top right corner, for which the alert is generated.
3. Access the EC2 service, navigate to 'Snapshots' under 'Elastic Block Store' in left hand menu.
4. Select the identified 'EBS Snapshot' and select the tab 'Permissions'.
5. Review and delete the AWS Accounts which should not have read access.

Configuration Management / Section Configuration Settings



0 Resource(s) Failed

Compliance Section: Configuration Settings ●●●● Low

- a. Establish, document, and implement the following configuration settings for the system that reflect the most restrictive mode consistent with operational requirements: [Assignment: organization-defined configuration settings].
- b. Identify, document, and approve any deviations from established configuration settings.

AWS EKS cluster control plane assigned multiple security groups

Amazon EKS strongly recommends that you use a dedicated security group for each cluster control plane (one per cluster). This policy checks the number of security groups assigned to your cluster's control plane and alerts if there are more than one.

First Seen N/A | Resource Type Other

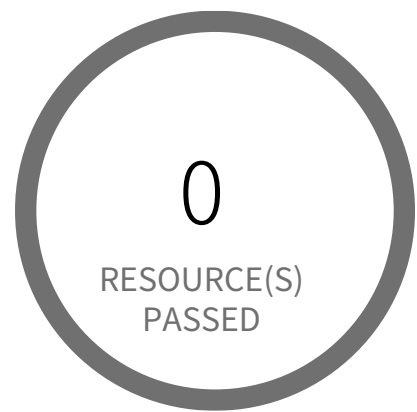
Recommendations

Create a single dedicated VPC security group for your EKS cluster control plane.

From the AWS console a security group cannot be added to, nor removed from, a Kubernetes cluster once it is created. To resolve this alert, create a new cluster with a single dedicated security group as per your requirements, then migrate all required cluster data from the reported cluster to this newly created cluster and delete the reported Kubernetes cluster.

1. Open the Amazon EKS dashboard.
2. Choose Create cluster.
3. On the Create cluster page, fill in the following fields:
 - Cluster name
 - Kubernetes version
 - Role name
 - VPC
 - Subnets
 - Security Groups - Choose your new dedicated control plane security group.
 - Endpoint private access
 - Endpoint public access
 - Logging
4. Choose Create.

Configuration Management / Section Configuration Settings



0 Resource(s) Failed

Compliance Section: Configuration Settings — Informational

- a. Establish, document, and implement the following configuration settings for the system that reflect the most restrictive mode consistent with operational requirements: [Assignment: organization-defined configuration settings].
- b. Identify, document, and approve any deviations from established configuration settings.

AWS EMR cluster is not configured with security configuration

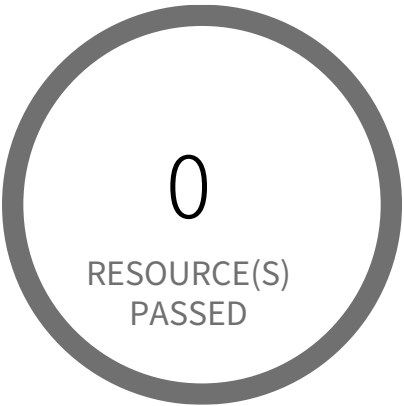
This policy identifies EMR clusters which are not configured with security configuration. With Amazon EMR release version 4.8.0 or later, you can use security configurations to configure data encryption, Kerberos authentication, and Amazon S3 authorization for EMRFS.

First Seen N/A | Resource Type Other

Recommendations

1. Log in to the AWS Console
2. In the console, select the specific region from region drop down on the top right corner, for which the alert is generated.
3. Navigate to 'EMR' dashboard from 'Services' dropdown
4. Go to 'Security configurations', click 'Create'
5. On the Create security configuration window,
6. In 'Name' box, provide a name for the new EMR security configuration
7. Follow below link to configure a security configuration
<https://docs.aws.amazon.com/emr/latest/ManagementGuide/emr-create-security-configuration.html>
8. Click on 'Create' button
9. On the left menu of EMR dashboard Click 'Clusters'
10. Select the EMR cluster for which the alert has been generated and click on the 'Clone' button from the top menu.
11. In the Cloning popup, choose 'Yes' and Click 'Clone'
12. On the Create Cluster page, in the Security Options section, click on 'security configuration'
13. From the 'Security configuration' drop down select the name of the security configuration created at step 4 to step 8, click 'Create Cluster'.
14. Once you the new cluster is set up verify its working and terminate the source cluster in order to stop incurring charges for it
15. On the left menu of EMR dashboard Click 'Clusters', from the list of clusters select the source cluster which is alerted
16. Click on the 'Terminate' button from the top menu
17. On the 'Terminate clusters' pop-up, click 'Terminate'

Configuration Management / Section Configuration Settings



0 Resource(s) Failed

Compliance Section: Configuration Settings ●●●● Low

- a. Establish, document, and implement the following configuration settings for the system that reflect the most restrictive mode consistent with operational requirements: [Assignment: organization-defined configuration settings].
- b. Identify, document, and approve any deviations from established configuration settings.

AWS ElastiCache Redis cluster with Redis AUTH feature disabled

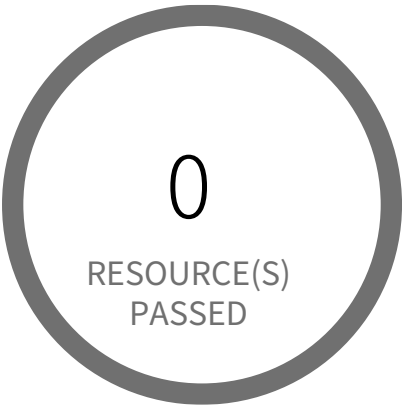
This policy identifies ElastiCache Redis clusters which have Redis AUTH feature disabled. Redis AUTH can improve data security by requiring the user to enter a password before they are granted permission to execute Redis commands on a password protected Redis server.

First Seen N/A | **Resource Type** Other

Recommendations

Kindly follow the doc to enable redis auth feature : <https://docs.aws.amazon.com/AmazonElastiCache/latest/dg/auth.html>

Configuration Management / Section Configuration Settings



0 Resource(s) Failed

Compliance Section: Configuration Settings ●●●● Low

- a. Establish, document, and implement the following configuration settings for the system that reflect the most restrictive mode consistent with operational requirements: [Assignment: organization-defined configuration settings].
- b. Identify, document, and approve any deviations from established configuration settings.

AWS Elastic Load Balancer (Classic) with cross-zone load balancing disabled

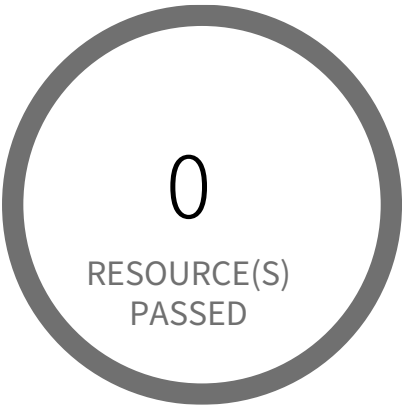
This policy identifies Classic Elastic Load Balancers which have cross-zone load balancing disabled. When Cross-zone load balancing enabled, classic load balancer distributes requests evenly across the registered instances in all enabled Availability Zones. Cross-zone load balancing reduces the need to maintain equivalent numbers of instances in each enabled Availability Zone, and improves your application's ability to handle the loss of one or more instances.

First Seen N/A | Resource Type Other

Recommendations

- 1. Sign into the AWS console
- 2. In the console, select the specific region from region drop down on the top right corner, for which the alert is generated
- 3. Navigate to EC2 dashboard
- 4. Click on 'Load Balancers' (Left Panel)
- 5. Select the reported ELB
- 6. On the Description tab, choose 'Change cross-zone load balancing setting'
- 7. On the 'Configure Cross-Zone Load Balancing' popup dialog, select 'Enable'
- 8. Click on 'Save'

Configuration Management / Section Configuration Settings



0 Resource(s) Failed

Compliance Section: Configuration Settings Informational

- a. Establish, document, and implement the following configuration settings for the system that reflect the most restrictive mode consistent with operational requirements: [Assignment: organization-defined configuration settings].
- b. Identify, document, and approve any deviations from established configuration settings.

AWS Elastic Load Balancer (ELB) not in use

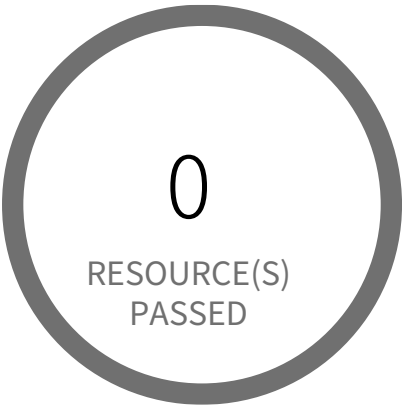
This policy identifies unused Elastic Load Balancers (ELBs) in your AWS account. Any Elastic Load Balancer in your AWS account is adding charges to your monthly bill, although it is not used by any resources. As a best practice, it is recommended to remove ELBs that are not associated with any instances, it will also help you avoid unexpected charges on your bill.

First Seen N/A | **Resource Type** Other

Recommendations

- To check and remove ELB that has no registered instances, perform the following:
1. Sign into the AWS console
 2. In the console, select the specific region from region drop down on the top right corner, for which the alert is generated
 3. Navigate to EC2 dashboard
 4. In the navigation pane, under 'Load balancing', click on 'Load Balancers'
 5. Select reported Elastic Load Balancer
 6. In 'Details' section, check If the selected load balancer 'Status' is '0 of 0 instances in service'. It means that there are no registered instances and the ELB can be safely removed.
 7. Click the 'Actions' dropdown from the ELB dashboard top menu, Select 'Delete loadbalacer'
 8. In the 'Delete Load Balancer' pop-up dialog, type confirm in the 'Type confirm to agree' and click 'Delete'

Configuration Management / Section Configuration Settings



0 Resource(s) Failed

Compliance Section: Configuration Settings — Informational

- a. Establish, document, and implement the following configuration settings for the system that reflect the most restrictive mode consistent with operational requirements: [Assignment: organization-defined configuration settings].
- b. Identify, document, and approve any deviations from established configuration settings.

AWS Elastic Load Balancer (ELB) with ACM certificate expired or expiring in 90 days

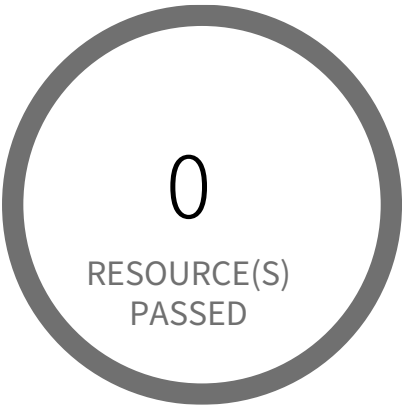
This policy identifies Elastic Load Balancers (ELB) which are using ACM certificates expired or expiring in 90 days. AWS Certificate Manager (ACM) is the preferred tool to provision, manage, and deploy your server certificates. With ACM you can request a certificate or deploy an existing ACM or external certificate to AWS resources. As a best practice, it is recommended to reimport expiring/expired certificates while preserving the ELB associations of the original certificate.

First Seen N/A | **Resource Type** Other

Recommendations

- 1. Sign into the AWS console
- 2. In the console, select the specific region from region drop down on the top right corner, for which the alert is generated
- 3. Go to Certificate Manager(ACM) service
- 4. Choose the reported certificate
- 5. Under 'Actions' drop-down click on 'Reimport certificate'
- 6. On the 'Import a certificate' page:
 - 6a. For 'Certificate body*', paste the PEM-encoded certificate to import
 - 6b. For 'Certificate private key*', paste the PEM-encoded, unencrypted private key that matches the SSL/TLS certificate public key
 - 6c. (Optional) For 'Certificate chain', paste the PEM-encoded certificate chain delivered
 - 6d. Click Review and import button to continue the process
- 7. On the 'Review and import' page, review the imported certificate details then click on 'Import'

Configuration Management / Section Configuration Settings



0 Resource(s) Failed

Compliance Section: Configuration Settings Informational

- a. Establish, document, and implement the following configuration settings for the system that reflect the most restrictive mode consistent with operational requirements: [Assignment: organization-defined configuration settings].
- b. Identify, document, and approve any deviations from established configuration settings.

AWS Elastic Load Balancer (ELB) with IAM certificate expiring in 90 days

This policy identifies Elastic Load Balancers (ELB) which are using IAM certificates expiring in 90 days or using expired certificates. Removing expired IAM certificates eliminates the risk and prevents the damage of credibility of the application/website behind the ELB. As a best practice, it is recommended to reimport expiring certificates while preserving the ELB associations of the original certificate.

First Seen N/A | **Resource Type** Other

Recommendations

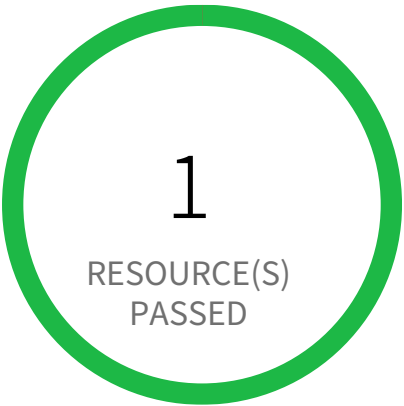
Removing invalid certificates via AWS Management Console is not currently supported. To delete/upload SSL/TLS certificates stored in IAM via the AWS API use the Command Line Interface (CLI).

Remediation CLI:

- 1. Run describe-load-balancers command to make sure that the expiring server certificate is not currently used by any active load balancer.
aws elb describe-load-balancers --region <COMPUTE_REGION> --load-balancer-names <ELB_NAME> --query 'LoadBalancerDescriptions[*].ListenerDescriptions[*].Listener.SSLCertificateId'
- This command output will return the Amazon Resource Name (ARN) for the SSL certificate currently used by the selected ELB:
[
 [
 "arn:aws:iam::1234567890:server-certificate/MyCertificate\"
]
]
- 2. Create new AWS IAM certificate with your desired parameters value
- 3. To upload new IAM Certificate:
aws iam upload-server-certificate --server-certificate-name <NEW_CERTIFICATE_NAME> --certificate-body file://Certificate.pem --certificate-chain file://CertificateChain.pem --private-key file://PrivateKey.pem
- 4. To replaces the existing SSL certificate for the specified HTTPS load balancer:
aws elb set-load-balancer-listener-ssl-certificate --load-balancer-name <ELB_NAME> --load-balancer-port 443 --ssl-certificate-id arn:aws:iam::1234567890:server-certificate/<NEW_CERTIFICATE_NAME>

5. Now that is safe to remove the expiring SSL/TLS certificate from AWS IAM, To delete it run:
`aws iam delete-server-certificate --server-certificate-name <CERTIFICATE_NAME>`

Configuration Management / Section Configuration Settings



0 Resource(s) Failed

Compliance Section: Configuration Settings Informational

- a. Establish, document, and implement the following configuration settings for the system that reflect the most restrictive mode consistent with operational requirements: [Assignment: organization-defined configuration settings].
- b. Identify, document, and approve any deviations from established configuration settings.

AWS Elastic Load Balancer v2 (ELBv2) load balancer with invalid security groups

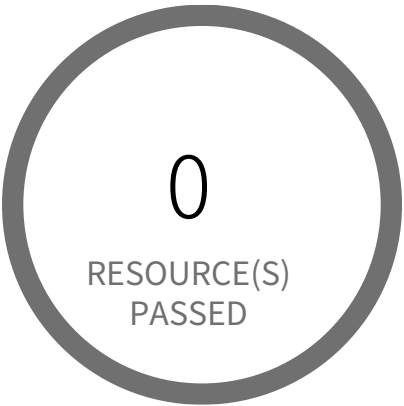
This policy identifies Elastic Load Balancer v2 (ELBv2) load balancers that do not have security groups with a valid inbound or outbound rule. A security group with no inbound/outbound rule will deny all incoming/outgoing requests. ELBv2 security groups should have at least one inbound and outbound rule, ELBv2 with no inbound/outbound permissions will deny all traffic incoming/outgoing to/from any resources configured behind that ELBv2; in other words, the ELBv2 is useless without inbound and outbound permissions.

First Seen N/A | Resource Type Other

Recommendations

1. Sign into the AWS console
2. In the console, select the specific region from region drop down on the top right corner, for which the alert is generated
3. Navigate to EC2 dashboard
4. In the navigation pane, under 'Load balancing', click on 'Load Balancers'
5. Select reported Elastic Load Balancer
6. Click on the 'Security' tab, click on each security group, it will open Security Group properties in a new tab in your browser.
7. For to check the Inbound rule, Click on the 'Inbound Rules'
8. If there are no rules, click on 'Edit rules', add an inbound rule according to your ELBv2 functional requirement.
9. For to check the Outbound rule, Click on the 'Outbound Rules'
10. If there are no rules, click on 'Edit rules', add an outbound rule according to your ELBv2 functional requirement.
11. Click on 'Save'

Configuration Management / Section Configuration Settings



0 Resource(s) Failed

Compliance Section: Configuration Settings ●●●● Low

- a. Establish, document, and implement the following configuration settings for the system that reflect the most restrictive mode consistent with operational requirements: [Assignment: organization-defined configuration settings].
- b. Identify, document, and approve any deviations from established configuration settings.

AWS Elasticsearch domain has Dedicated master set to disabled

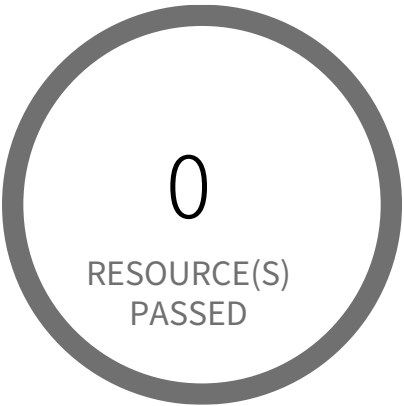
This policy identifies Elasticsearch domains for which Dedicated master is disabled in your AWS account. If dedicated master nodes are provided those handle the management tasks and cluster nodes can easily manage index and search requests from different types of workload and make them more resilient in production. Dedicated master nodes improve environmental stability by freeing all the management tasks from the cluster data nodes.

First Seen N/A | Resource Type Other

Recommendations

- 1. Sign into the AWS console
- 2. In the console, select the specific region from region drop down on the top right corner, for which the alert is generated
- 3. Navigate to Amazon OpenSearch Service Dashboard
- 4. Go to 'Domains' under Managed cluster from the left panel
- 5. Choose reported Elasticsearch domain
- 6. Click on 'Action' button and choose 'Edit cluster configuration'
- 7. On the 'Edit cluster configuration' page,
 - a. Check 'Enable dedicated master' checkbox to enable dedicated master nodes for the current cluster.
 - b. Select the 'Instance type' based on your ES cluster requirements from the dropdown list.
- Note: As dedicated master nodes do not hold any data nor process any search and query requests, the instance node for this role typically does not require a large amount of CPU/RAM memory.
- c. Select the 'Number of master nodes' from dropdown list to allocate dedicated master nodes.
- 8. Click on 'Save changes'

Configuration Management / Section Configuration Settings



0 Resource(s) Failed

Compliance Section: Configuration Settings Informational

- a. Establish, document, and implement the following configuration settings for the system that reflect the most restrictive mode consistent with operational requirements: [Assignment: organization-defined configuration settings].
- b. Identify, document, and approve any deviations from established configuration settings.

AWS Elasticsearch domain has Zone Awareness set to disabled

This policy identifies Elasticsearch domains for which Zone Awareness is disabled in your AWS account. Enabling Zone Awareness (cross-zone replication) increases the availability by distributing your Elasticsearch data nodes across two availability zones available in the same AWS region. It also prevents data loss and minimizes downtime in the event of node or availability zone failure.

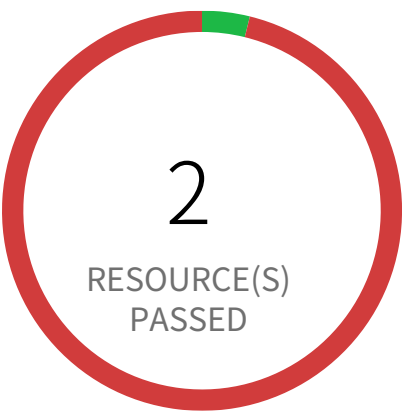
First Seen N/A | **Resource Type** Other

Recommendations

To enable Zone Awareness feature on existing Elasticsearch, following CLI can be used:
aws es update-elasticsearch-domain-config --domain-name <DOMAINNAME> --region <REGION> --elasticsearch-cluster-config ZoneAwarenessEnabled=true, ZoneAwarenessConfig={AvailabilityZoneCount=<COUNT>}

For more refer:
<https://docs.aws.amazon.com/elasticsearch-service/latest/developerguide/es-manageddomains-multiaz.html>

Configuration Management / Section Configuration Settings



50 Resource(s) Failed

privesc8-AttachGroupPolicy-user,
privesc-sageMakerCreateProcessingJobPass-
Role-user, fn1-privesc3-partial-user,
read-only-access-engg,
fp4-nonExploitableResourceConstraint-user,
privesc9-AttachRolePolicy-user,
privesc4-CreateAccessKey-user,
privesc5-CreateLoginProfile-user,
privesc-sageMakerCreateTrainingJobPass-
Role-user, privesc6-UpdateLoginProfile-user &
40 more

Compliance Section: Configuration Settings ●●●● Low

- a. Establish, document, and implement the following configuration settings for the system that reflect the most restrictive mode consistent with operational requirements: [Assignment: organization-defined configuration settings].
- b. Identify, document, and approve any deviations from established configuration settings.

AWS Inactive users for more than 30 days

This policy identifies users who are inactive for more than 30 days. Inactive user accounts are an easy target for attacker because any activity on the account will largely get unnoticed.

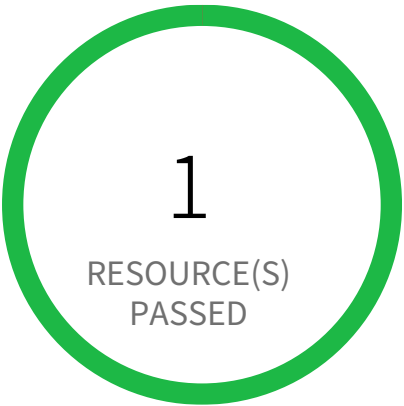
NOTE: Exception to this policy is, it is not valid for SSO login users and Root users

First Seen June 11, 2024 at 6:11:26 PM UTC | **Resource Type** IAM Credentials Report

Recommendations

- 1. Sign in to AWS console and navigate to IAM.
- 2. Identify the user reported and Make sure that the user has legitimate reason to be inactive for such an extended period.
- 3. Delete the user account, if the user no longer needs access to the console or no longer exists.

Configuration Management / Section Configuration Settings



0 Resource(s) Failed

Compliance Section: Configuration Settings — Informational

- a. Establish, document, and implement the following configuration settings for the system that reflect the most restrictive mode consistent with operational requirements: [Assignment: organization-defined configuration settings].
- b. Identify, document, and approve any deviations from established configuration settings.

AWS Lambda nearing availability code storage limit

This policy identifies Lambda nearing availability code storage limit per region. AWS provides a reasonable starting amount of compute and storage resources that you can use to run and store functions. As a best practice, it is recommended to either remove the functions that you no longer in use or reduce the code size of the functions that you do not want to remove. It will also help you avoid unexpected charges on your bill.

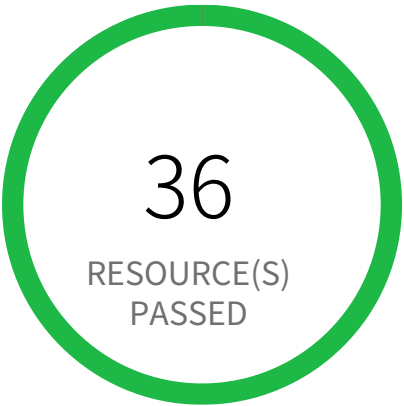
NOTE: As per <https://docs.aws.amazon.com/lambda/latest/dg/limits.html>. On the date, Lambda account limit per region is 75 GB. This policy will trigger an alert if Lambda account limit per region reached to 90% (i.e. 67500000 KB) of resource availability limit allocated. If you need more Lambda account code storage size per region, You can contact AWS for a service limit increase.

First Seen N/A | Resource Type Other

Recommendations

- 1. Sign into the AWS console
- 2. In the console, select the specific region from region drop down on the top right corner, for which the alert is generated
- 3. Navigate to the AWS Lambda Dashboard
- 4. Click on 'Functions', choose each the lambda function
- 5. Either remove the function that you no longer use or deduce the code size of the function that if you do not want to remove.

Configuration Management / Section Configuration Settings



0 Resource(s) Failed

Compliance Section: Configuration Settings ●●●● Low

- a. Establish, document, and implement the following configuration settings for the system that reflect the most restrictive mode consistent with operational requirements: [Assignment: organization-defined configuration settings].
- b. Identify, document, and approve any deviations from established configuration settings.

AWS NAT Gateways are not being utilized for the default route

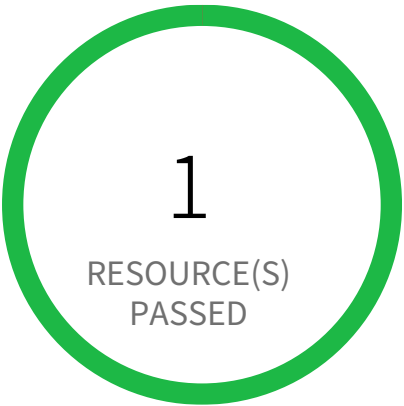
This policy identifies Route Tables which have NAT instances for the default route instead of NAT gateways. It is recommended to use NAT gateways as the AWS managed NAT Gateway provides a scalable and resilient method for allowing outbound internet traffic from your private VPC subnets.

First Seen N/A | Resource Type Other

Recommendations

- To create a NAT gateway:
1. Sign into the AWS console
 2. In the console, select the specific region from region drop down on the top right corner, for which the alert is generated
 3. Navigate to VPC Dashboard
 4. In the navigation pane, choose 'NAT Gateways'
 5. Click on 'Create NAT Gateway', Specify the subnet in which to create the NAT gateway, and select the allocation ID of an Elastic IP address to associate with the NAT gateway. When you're done, Click on 'Create a NAT Gateway'. The NAT gateway displays in the console. After a few moments, its status changes to Available, after which it's ready for you to use.
- To update Route Table:
- After you've created your NAT gateway, you must update your route tables for your private subnets to point internet traffic to the NAT gateway. We use the most specific route that matches the traffic to determine how to route the traffic.
1. Sign into the AWS console
 2. In the console, select the specific region from region drop down on the top right corner, for which the alert is generated
 3. Navigate to VPC Dashboard
 4. In the navigation pane, choose 'Route Tables'
 5. Select the reported route table associated with your private subnet
 6. Choose 'Routes' and Click on 'Edit routes'
 7. Replace the current route that points to the NAT instance with a route to the NAT gateway
 8. Click on 'Save routes'

Configuration Management / Section Configuration Settings



0 Resource(s) Failed

Compliance Section: Configuration Settings ●●●● Low

- a. Establish, document, and implement the following configuration settings for the system that reflect the most restrictive mode consistent with operational requirements: [Assignment: organization-defined configuration settings].
- b. Identify, document, and approve any deviations from established configuration settings.

AWS Network Load Balancer (NLB) is not using the latest predefined security policy

This policy identifies Network Load Balancers (NLBs) which are not using the latest predefined security policy. A security policy is a combination of protocols and ciphers. The protocol establishes a secure connection between a client and a server and ensures that all data passed between the client and your load balancer is private. A cipher is an encryption algorithm that uses encryption keys to create a coded message. So it is recommended to use the latest predefined security policy which uses only secured protocol and ciphers.

For more details:
<https://docs.aws.amazon.com/elasticloadbalancing/latest/network/create-tls-listener.html#describe-ssl-policies>

First Seen N/A | **Resource Type** Other

Recommendations

- 1. Log in to the AWS console
- 2. In the console, select the specific region from the region drop-down on the top right corner, for which the alert is generated
- 3. Go to the EC2 Dashboard, and select 'Load Balancers'
- 4. Click on the reported Load Balancer
- 5. On the 'Listeners' tab, click on 'Manage listener' button
- 6. Under Secure listener settings Change 'Security policy', choose the Policy name 'ELBSecurityPolicy-TLS13-1-2-2021-06'
- 7. Click 'Save changes'

Configuration Management / Section Configuration Settings



0 Resource(s) Failed

Compliance Section: Configuration Settings ●●●● Low

- a. Establish, document, and implement the following configuration settings for the system that reflect the most restrictive mode consistent with operational requirements: [Assignment: organization-defined configuration settings].
- b. Identify, document, and approve any deviations from established configuration settings.

AWS RDS Snapshot with access for unmonitored cloud accounts

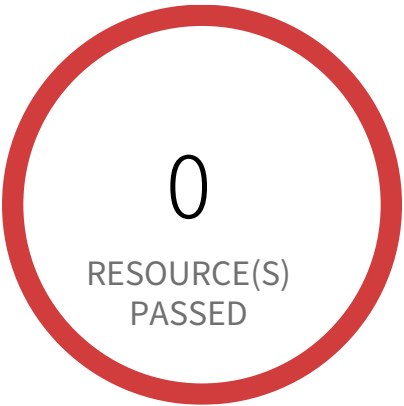
This policy identifies RDS snapshots with access for unmonitored cloud accounts. The RDS Snapshot which have either the read / write permission opened up for Cloud Accounts which are NOT part of Cloud Accounts monitored by Prisma Cloud. These accounts with read / write privileges should be reviewed and confirmed that these are valid accounts of your organisation (or authorised by your organisation) and are not active under Prisma Cloud monitoring.

First Seen N/A | **Resource Type** Other

Recommendations

1. Sign into the AWS console.
2. In the console, select the specific region from region drop down on the top right corner, for which the alert is generated
3. Navigate to the RDS service.
4. Select the identified 'RDS Snapshot' under the 'Snapshots' in the left hand menu.
5. Under the tab 'Snapshot Actions', selection the option 'Share Snapshot'.
6. Review and delete the AWS Accounts which should not have read access.

Configuration Management / Section Configuration Settings



1 Resource(s) Failed
database-1

Compliance Section: Configuration Settings — Informational

- a. Establish, document, and implement the following configuration settings for the system that reflect the most restrictive mode consistent with operational requirements: [Assignment: organization-defined configuration settings].
- b. Identify, document, and approve any deviations from established configuration settings.

AWS RDS instance with Multi-Availability Zone disabled

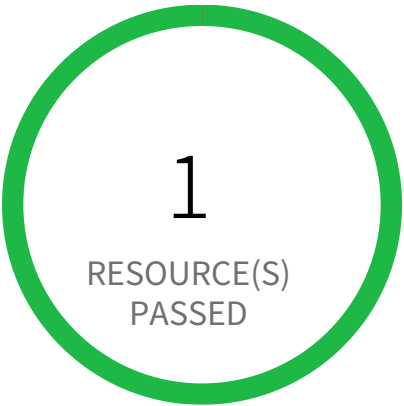
This policy identifies RDS instances which have Multi-Availability Zone(Multi-AZ) disabled. When RDS DB instance is enabled with Multi-AZ, RDS automatically creates a primary DB Instance and synchronously replicates the data to a standby instance in a different availability zone. These Multi-AZ deployments will improve primary node reachability by providing read replica in case of network connectivity loss or loss of availability in the primary’s availability zone for read/write operations, so by making them the best fit for production database workloads.

First Seen June 16, 2025 at 12:19:29 PM UTC | **Resource Type** Other

Recommendations

- 1. Sign into the AWS console
- 2. In the console, select the specific region from region drop down on the top right corner, for which the alert is generated
- 3. Navigate to 'Aurora abd RDS' console.
- 4. In the navigation pane, choose 'Databases', and then choose the DB instance is reported.
- 5. Choose 'Modify'.
- 6. In 'Availability & durability' section for the 'Multi-AZ Deployment', select 'Create a standby instance'
- 7. Click on 'Continue'
- 8. Under 'Schedule modifications', select 'When to apply modifications' and click on 'Modify DB Instance' to save your changes.

Configuration Management / Section Configuration Settings



0 Resource(s) Failed

Compliance Section: Configuration Settings Informational

- a. Establish, document, and implement the following configuration settings for the system that reflect the most restrictive mode consistent with operational requirements: [Assignment: organization-defined configuration settings].
- b. Identify, document, and approve any deviations from established configuration settings.

AWS RDS instance with copy tags to snapshots disabled

This policy identifies RDS instances that have copy tags to snapshots disabled. Copy tags to snapshots copies all the user-defined tags from the DB instance to snapshots. Copying tags allow you to add metadata and apply access policies to your Amazon RDS resources.

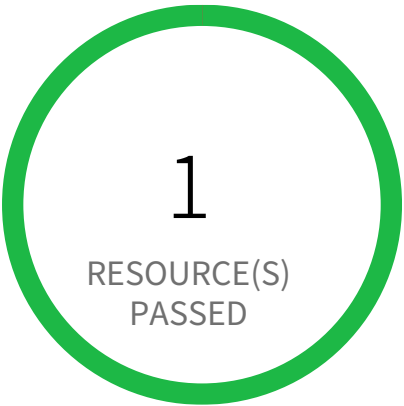
NOTE: Setting Copy tags to snapshots for an Aurora DB instance has no effect on the DB setting. So Aurora DB instances are excluded from policy check.

First Seen N/A | Resource Type Other

Recommendations

1. Sign into the AWS console
2. In the console, select the specific region from region drop down on the top right corner, for which the alert is generated
3. Navigate to Amazon RDS console
4. Choose DB Instances, and then select the reported DB instance
5. Click on 'Modify'
6. In 'Additional Configuration' section, In 'Backup' sub-section select the 'Copy tags to snapshots'
7. Click on 'Continue'
8. On the 'Summary of Modifications' panel, review the configuration changes. From 'Scheduling of Modifications' section, select whether changes to 'Apply immediately' or 'Apply during the next scheduled maintenance window'.
9. On the confirmation page, Review the changes and Click on 'Modify DB Instance' to save your changes.

Configuration Management / Section Configuration Settings



0 Resource(s) Failed

Compliance Section: Configuration Settings ●●●● Low

- a. Establish, document, and implement the following configuration settings for the system that reflect the most restrictive mode consistent with operational requirements: [Assignment: organization-defined configuration settings].
- b. Identify, document, and approve any deviations from established configuration settings.

AWS RDS minor upgrades not enabled

When Amazon Relational Database Service (Amazon RDS) supports a new version of a database engine, you can upgrade your DB instances to the new version. There are two kinds of upgrades: major version upgrades and minor version upgrades. Minor upgrades helps maintain a secure and stable RDS with minimal impact on the application. For this reason, we recommend that your automatic minor upgrade is enabled. Minor version upgrades only occur automatically if a minor upgrade replaces an unsafe version, such as a minor upgrade that contains bug fixes for a previous version.

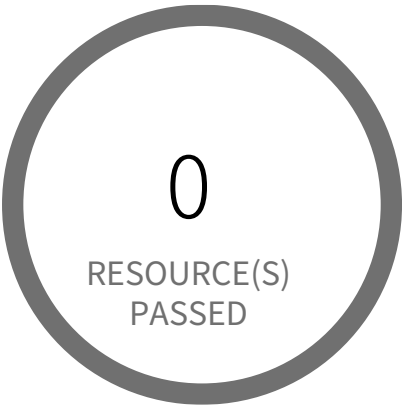
First Seen N/A | **Resource Type** Other

Recommendations

Enable RDS auto minor version upgrades.

- 1. Go to the AWS console RDS dashboard.
- 2. In the navigation pane, choose Instances.
- 3. Select the database instance you wish to configure.
- 4. From the 'Instance actions' menu, select Modify.
- 5. Under the Maintenance section, choose Yes for Auto minor version upgrade.
- 6. Select Continue and then Modify DB Instance.

Configuration Management / Section Configuration Settings



0 Resource(s) Failed

Compliance Section: Configuration Settings ●●●● Low

- a. Establish, document, and implement the following configuration settings for the system that reflect the most restrictive mode consistent with operational requirements: [Assignment: organization-defined configuration settings].
- b. Identify, document, and approve any deviations from established configuration settings.

AWS Route53 Public Zone with Private Records

A hosted zone is a container for records (An object in a hosted zone that you use to define how you want to route traffic for the domain or a subdomain), which include information about how you want to route traffic for a domain (such as example.com) and all of its subdomains (such as www.example.com, retail.example.com, and seattle.accounting.example.com). A hosted zone has the same name as the corresponding domain. A public hosted zone is a container that holds information about how you want to route traffic on the internet for a specific domain. It is best practice to avoid AWS Route 53 Public Hosted Zones containing DNS records for private IPs or resources within your AWS account to overcome information leakage of your internal network and resources.

First Seen N/A | Resource Type Other

Recommendations

You can not convert a public hosted zone into a private hosted zone. So, it is recommended to create and configure a Private Hosted Zone to manage private IPs within your Virtual Private Cloud (VPC) as Amazon Route 53 service will only return your private DNS records when queried from within the associated VPC, and delete the associated public hosted zone once the Private hosted zone is configured with all the records.

To create a private hosted zone using the Route 53 console:

- 1. For each VPC that you want to associate with the Route 53 hosted zone, change the following VPC settings to true:

☐ 'enableDnsHostnames'

☐ 'enableDnsSupport'

For more information, see Updating DNS Support (<http://docs.aws.amazon.com/AmazonVPC/latest/UserGuide/vpc-dns.html#vpc-dns-updating>) for Your VPC in the Amazon VPC User Guide.

- 2. Sign in to the AWS console

- 3. Go to Route 53 console

- 4. If you are new to Route 53, choose Get Started Now under DNS Management. If you are already using Route 53, choose Hosted Zones in the navigation pane.

- 5. Choose 'Create Hosted Zone'

- 6. In the Create Private Hosted Zone pane, enter a domain name and, optionally, a comment.

For information about how to specify characters other than a-z, 0-9, and - (hyphen) and how to specify internationalized domain names, see

DNS Domain Name Format (<https://docs.aws.amazon.com/Route53/latest/DeveloperGuide/DomainNameFormat.html>).

7. In the Type list, choose Private Hosted Zone for Amazon VPC

8. In the VPC ID list, choose the VPC that you want to associate with the hosted zone. If you want to associate more than one VPC with the hosted zone, you can add VPCs after you create the hosted zone.

Note: If the console displays the following message, you are trying to associate a VPC with this hosted zone that has already been associated with another hosted zone that has an overlapping namespace, such as example.com and retail.example.com:

'A conflicting domain is already associated with the given VPC or Delegation Set.'

9. Choose Create

10. To associate more VPCs with the new hosted zone, perform the following steps:

☐ a. Choose Back to Hosted Zones.

☐ b. Choose the radio button for the hosted zone.

☐ c. In the right pane, in VPC ID, choose another VPC that you want to associate with the hosted zone.

☐ d. Choose Associate New VPC.

☐ e. Repeat steps c and d until you have associated all of the VPCs that you want to with the hosted zone.

For More Information : <https://docs.aws.amazon.com/Route53/latest/DeveloperGuide/hosted-zone-private-creating.html>

To delete a public hosted zone using the Route 53 console:

1. Sign into the AWS console

2. Go Route53 console

3. Confirm that the hosted zone that you want to delete contains only an NS and an SOA record. If it contains additional records, delete them:

☐ a. Choose the name of the hosted zone that you want to delete.

☐ b. On the Record Sets page, if the list of records includes any records for which the value of the Type column is something other than NS or SOA, choose the row, and choose Delete Record Set. To select multiple, consecutive records, choose the first row, press and hold the Shift key, and choose the last row. To select multiple, non-consecutive records, choose the first row, press and hold the Ctrl key, and choose the remaining rows. Note: If you created any NS records for subdomains in the hosted zone, delete those records, too.

☐ c. Choose Back to Hosted Zones

4. On the Hosted Zones page, choose the row for the hosted zone that you want to delete.

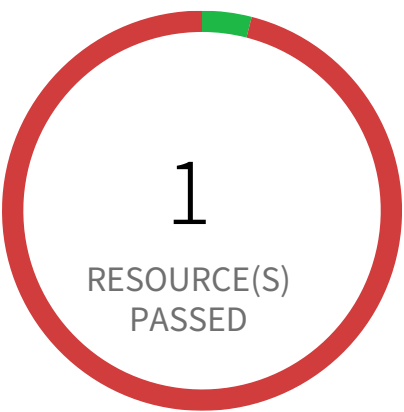
5. Choose Delete Hosted Zone.

6. Choose OK to confirm.

7. If you want to make the domain unavailable on the internet, we recommend that you transfer DNS service to a free DNS service and then delete the Route 53 hosted zone. This prevents future DNS queries from possibly being misrouted. If the domain is registered with Route 53, see Adding or Changing Name Servers and Glue Records for a Domain (<https://docs.aws.amazon.com/Route53/latest/DeveloperGuide/domain-name-servers-glue-records.html>) for information about how to replace Route 53 nameservers with name servers for the new DNS service. If the domain is registered with another registrar, use the method provided by the registrar to change name servers for the domain.

For More Information : <https://docs.aws.amazon.com/Route53/latest/DeveloperGuide/DeleteHostedZone.html>

Configuration Management / Section Configuration Settings



24 Resource(s) Failed

maincon-ceio23hnx834,
i-02630da789e78564e, i-0f7fad8e82b2280f0,
finance-secret-asdfsd3r53rtr-one,
finance-secret-der4t4tg5ght-three,
cf-templates-e38xdwjievlo-us-east-1,
aattack-path-secret-s3-bucket-as-
dfsd3r53rtr-one,
prisma-forward-scan-984345939,
cloudfoundation-lab-3248823847893,
pcds-scan-fcbb920f-c783-38ac-9302-c6cc5a89f7c
& 14 more

Compliance Section: Configuration Settings ●●●● Low

- a. Establish, document, and implement the following configuration settings for the system that reflect the most restrictive mode consistent with operational requirements: [Assignment: organization-defined configuration settings].
- b. Identify, document, and approve any deviations from established configuration settings.

AWS S3 Object Versioning is disabled

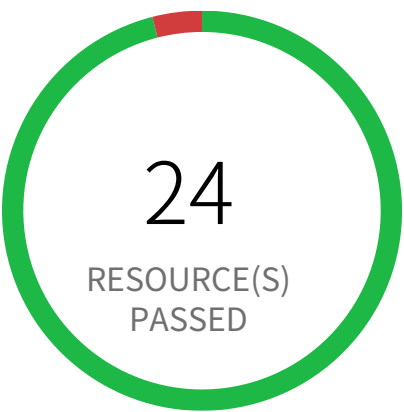
This policy identifies the S3 buckets which have Object Versioning disabled. S3 Object Versioning is an important capability in protecting your data within a bucket. Once you enable Object Versioning, you cannot remove it; you can suspend Object Versioning at any time on a bucket if you do not wish for it to persist. It is recommended to enable Object Versioning on S3.

First Seen October 18, 2023 at 8:51:01 AM UTC | **Resource Type** Other

Recommendations

- 1. Log into your AWS Console and select the S3 service.
- 2. Choose the reported S3 bucket and click the Properties tab in the upper right frame.
- 3. Expand the Versioning option
- 4. Click Enable Versioning
- 5. Click Save

Configuration Management / Section Configuration Settings



1 Resource(s) Failed
pays-app-dev-jd3jnx92j3

Compliance Section: Configuration Settings ●●●● Low

- a. Establish, document, and implement the following configuration settings for the system that reflect the most restrictive mode consistent with operational requirements: [Assignment: organization-defined configuration settings].
- b. Identify, document, and approve any deviations from established configuration settings.

AWS S3 bucket is not configured with MFA Delete

AWS S3 buckets lacking MFA Delete are susceptible to accidental or malicious data deletion.

The AWS S3 service allows versioning of objects, providing a mechanism for recovery from accidental deletions. However, without MFA Delete enabled, anyone with sufficient permissions can permanently delete object versions, bypassing versioning protection. This misconfiguration leaves data vulnerable to unauthorized removal or data breaches. An attacker could exploit this to permanently delete sensitive information.

Compromised credentials or unintended actions could lead to irreversible data loss. MFA Delete adds a crucial second layer of authentication, significantly reducing the risk of accidental or malicious object deletion. Implementing this best practice ensures data integrity and minimizes the impact of compromised credentials.

Enable MFA Delete on all versioned S3 buckets. Regularly audit bucket configurations to ensure MFA Delete remains enabled. Consider implementing least privilege access controls and robust access logging to further enhance security.

First Seen February 19, 2025 at 5:11:08 PM UTC | **Resource Type** Other

Recommendations

Using console you can enable versioning on the bucket but you cannot enable MFA delete.
You can do it via only with the AWS CLI:
aws s3api put-bucket-versioning --bucket <BUCKET_NAME> --versioning-configuration Status=Enabled,MFADelete=Enabled --mfa "<MFA_SERIAL_NUMBER> <MFA_CODE>"

NOTE: The bucket owner, the AWS account that created the bucket (root account), and all authorized IAM users can enable versioning, but only the bucket owner (root account) can enable MFA Delete. Successful execution will enable the S3 bucket versioning and MFA delete on the bucket.

Configuration Management / Section Configuration Settings



0 Resource(s) Failed

Compliance Section: Configuration Settings — Informational

- a. Establish, document, and implement the following configuration settings for the system that reflect the most restrictive mode consistent with operational requirements: [Assignment: organization-defined configuration settings].
- b. Identify, document, and approve any deviations from established configuration settings.

AWS S3 buckets with configurations set to host websites

Improperly configured AWS S3 buckets hosting websites pose a significant security risk, allowing unauthorized access to sensitive data. These buckets, if misconfigured, can expose data publicly without proper authentication or authorization.

The service involves configuring AWS S3 buckets to host websites using the 'website' configuration setting. Failure to restrict website hosting to only authorized buckets increases the risk of data breaches. Attackers could exploit this misconfiguration to gain unauthorized access to sensitive information stored within the bucket.

A successful exploit could lead to data exfiltration, reputational damage, and potential financial losses due to regulatory non-compliance. Restricting website hosting to explicitly authorized buckets ensures only intended content is publicly accessible, minimizing the attack surface and strengthening data security.

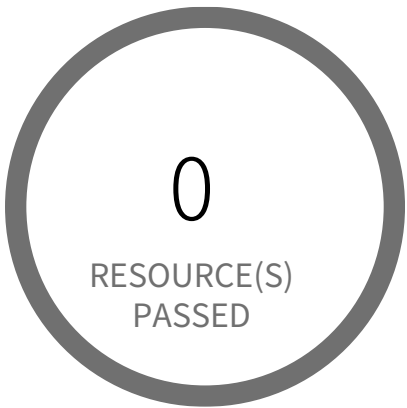
To mitigate this risk, regularly review and update S3 bucket configurations. Enable strong access controls, such as restricting bucket policies and using Identity and Access Management (IAM) to limit access. Disable website hosting for any bucket not explicitly designed to host a website.

First Seen N/A | **Resource Type** Other

Recommendations

- 1. Login to AWS Console
- 2. Goto S3 under Services
- 3. Choose the reported bucket
- 4. Goto Properties tab
- 5. Click on Static website hosting
- 6. Click on Disable website hosting
- 7. Click on Save

Configuration Management / Section Configuration Settings



0 Resource(s) Failed

Compliance Section: Configuration Settings — Informational

- a. Establish, document, and implement the following configuration settings for the system that reflect the most restrictive mode consistent with operational requirements: [Assignment: organization-defined configuration settings].
- b. Identify, document, and approve any deviations from established configuration settings.

AWS VPC allows unauthorized peering

This policy identifies the VPCs which have unauthorized peering. The recommended best practice is to disallow VPC peering between two VPCs from different AWS accounts, as this potentially enables unauthorized access to private resources.

First Seen N/A | **Resource Type** Other

Recommendations

- 1. Sign in to the AWS Console
- 2. Go to AWS VPC console at <https://console.aws.amazon.com/vpc/>
- 3. In the left navigation panel, select Peering Connection
- 4. Choose the reported Peering Connection
- 5. Click on Actions and select 'Delete VPC Peering Connection'
- 6. click on Yes, Delete

Configuration Management / Section Configuration Settings



0 Resource(s) Failed

Compliance Section: Configuration Settings Informational

- a. Establish, document, and implement the following configuration settings for the system that reflect the most restrictive mode consistent with operational requirements: [Assignment: organization-defined configuration settings].
- b. Identify, document, and approve any deviations from established configuration settings.

AWS VPC not in use

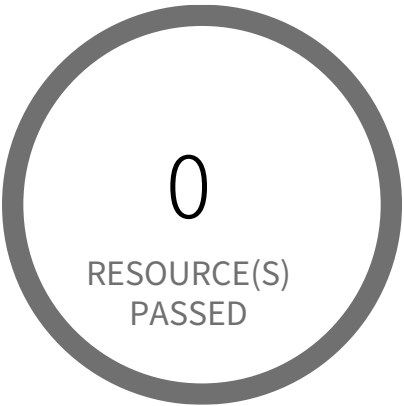
This policy identifies VPCs which are not in use. These VPC resources might be unintentionally launched and AWS also imposes a limit to the number of VPCs allowed per region. So it is recommended to either delete or use effectively such VPCs that do not have resources attached to them.

First Seen N/A | Resource Type Other

Recommendations

1. Sign into the AWS console
2. In the console, select the specific region from region drop down on the top right corner, for which the alert is generated
3. Navigate to VPC Dashboard
4. Click on 'Your VPCs' and Choose the reported VPC
5. If you want use reported VPC, Associate subnets to VPC or If you want to delete VPC, Click on 'Actions' and Choose 'Delete VPC' from the dropdown

Configuration Management / Section Configuration Settings



0 Resource(s) Failed

Compliance Section: Configuration Settings Informational

- a. Establish, document, and implement the following configuration settings for the system that reflect the most restrictive mode consistent with operational requirements: [Assignment: organization-defined configuration settings].
- b. Identify, document, and approve any deviations from established configuration settings.

AWS regions nearing VPC Private Gateway IPsec Limit

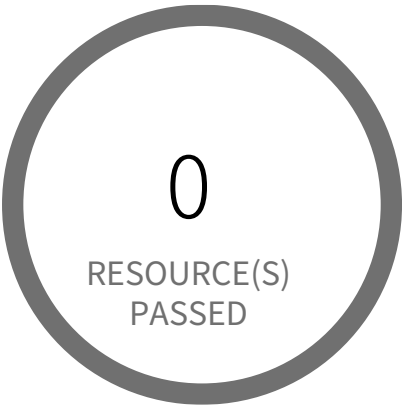
This policy identifies if your account is near the private gateway IPsec limitation per VPC per Region. AWS provides a reasonable starting limitation for the maximum number of VPC Private Gateway IPsec connections you can assign in each VPC. If you approach the limit in a particular VPC, this alert indicates that you have nearly exhausted your allocation.

First Seen N/A | Resource Type Other

Recommendations

1. Sign in to the AWS console.
 2. In the console, select the specific region from region drop down on the top right corner, for which the alert is generated.
 3. Navigate to VPC Dashboard
 4. Click on 'Site-to-Site VPN Connections' (Left Panel)
 5. Choose the VPN connection you want to delete, which more used or required
 6. Click on 'Actions' dropdown
 7. Click on 'Delete'
 8. On 'Delete' popup dialog, Click on 'Delete'
- NOTE: If existing VPN Connection is properly associated and exhausted your VPC Site-to-Site VPN Connections limit allocation, you can contact AWS for a service limit increase.

Configuration Management / Section Configuration Settings



0 Resource(s) Failed

Compliance Section: Configuration Settings — Informational

- a. Establish, document, and implement the following configuration settings for the system that reflect the most restrictive mode consistent with operational requirements: [Assignment: organization-defined configuration settings].
- b. Identify, document, and approve any deviations from established configuration settings.

AWS regions nearing VPC Private Gateway limit

This policy identifies if your account is near the private gateway limitation per VPC per Region. AWS provides a reasonable starting limitation for the maximum number of Virtual private gateways you can assign in each VPC. If you approach the limit in a particular VPC, this alert indicates that you have nearly exhausted your allocation.
NOTE: As per http://docs.aws.amazon.com/general/latest/gr/aws_service_limits.html Virtual private gateway per region limit is 5. This policy will trigger an alert if Virtual private gateway per region reached 80% (i.e. 4) of resource availability limit allocated.

First Seen N/A | **Resource Type** Other

Recommendations

1. Sign in to the AWS console
2. In the console, select the specific region from region drop down on the top right corner, for which the alert is generated
3. Navigate to VPC Dashboard
4. Click on 'Virtual Private Gateways' (Left Panel)
5. Choose the Virtual Private Gateway you want to delete, which is not used or required
6. Click on 'Actions' dropdown
7. Click on 'Delete Virtual Private Gateway'NOTE: If Virtual Private Gateway is already in use it can not be deleted. Make sure gateways unassociated before going to deleting it.
8. On 'Delete Virtual Private Gateway' popup dialog, Click on 'Yes, Delete'NOTE: If existing Virtual Private Gateways are properly associated and exhausted your VPC Virtual Private Gateway limit allocation, you can contact AWS for a service limit increase.

4

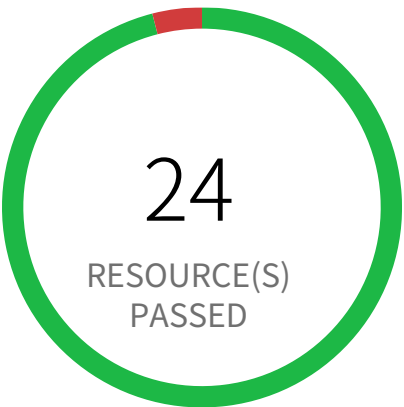
Identification and Authentication

Identification and Authentication Overview

Section		Pass Rate	Failed	Passed
User Identification, Authentication, and Re-Authentication	AWS... Informational	96%	1	24
User Identification, Authentication, and Re-Authentication	AWS S3 buck... Low	96%	1	24
Device Identification and Authentication	AWS EMR cluster is not configured with Ker... Low	100%	0	0
Multi-Factor Authentication	AWS CloudTrail S3 buckets have not enabled MFA Delete Informational	96%	1	24
Multi-Factor Authentication	AWS MFA is not enabled on Root account Medium	100%	0	52
Multi-Factor Authentication	AWS MFA not enabled for IAM users Low	96%	2	50
Multi-Factor Authentication	AWS S3 bucket is not configured with MFA Delete Low	96%	1	24
Multi-Factor Authentication	AWS root account configured with Virtual MFA Medium	100%	0	0
Password Management	AWS IAM Password policy is unsecure Low	100%	0	2
Password Management	AWS IAM password policy allows password reuse Informational	0%	2	0

Section			Pass Rate	Failed	Passed
Password Management	AWS IAM password policyv does not expire in 90 days	Informational	0%	2	0
Password Management	AWS IAM password policyv does not have a lowercase character	Informational	0%	2	0
Password Management	AWS IAM password policyv does not have a minimum of 14 charac...	Informational	0%	2	0
Password Management	AWS IAM password policyv does not have a number	Low	0%	2	0
Password Management	AWS IAM password policyv does not have a symbol	Informational	0%	2	0
Password Management	AWS IAM password policyv does not have an uppercase character	Informational	0%	2	0
Password Management	AWS IAM password policyv does not have password expiration pe...	Informational	0%	2	0

Identification and Authentication / Section User Identification, Authentication, and Re-Authentication



1 Resource(s) Failed
prisma-forward-scan-984345939

Compliance Section: User Identification, Authentication, and Re-Authentication — Informational

- a. Uniquely identify and authenticate system users, and associate that unique identification with processes acting on behalf of those users.
- b. Re-authenticate users when [Assignment: organization-defined circumstances or situations requiring re-authentication].

AWS CloudTrail S3 buckets have not enabled MFA Delete

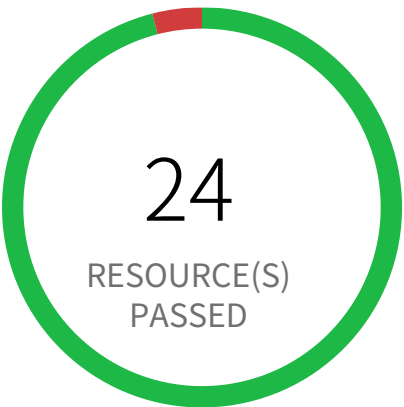
This policy identifies the S3 buckets which do not have Multi-Factor Authentication enabled for CloudTrails. For encryption of log files, CloudTrail defaults to use of S3 server-side encryption (SSE). We recommend adding an additional layer of security by adding MFA Delete to your S3 bucket. This will help to prevent deletion of CloudTrail logs without your explicit authorization. We also encourage you to use a bucket policy that places restrictions on which of your identity access management (IAM) users are allowed to delete S3 objects.

First Seen June 11, 2024 at 6:11:26 PM UTC | **Resource Type** Other

Recommendations

Enable MFA Delete on the bucket(s) you have configured to receive CloudTrail log files.
Note: We recommend that you do not configure CloudTrail to write into an S3 bucket that resides in a different AWS account.
Additional information on how to do this can be found here:
<http://docs.aws.amazon.com/AmazonS3/latest/dev/Versioning.html#MultiFactorAuthenticationDelete>

Identification and Authentication / Section User Identification, Authentication, and Re-Authentication



1 Resource(s) Failed
pays-app-dev-jd3jnx92j3

Compliance Section: User Identification, Authentication, and Re-Authentication Low

- a. Uniquely identify and authenticate system users, and associate that unique identification with processes acting on behalf of those users.
- b. Re-authenticate users when [Assignment: organization-defined circumstances or situations requiring re-authentication].

AWS S3 bucket is not configured with MFA Delete

AWS S3 buckets lacking MFA Delete are susceptible to accidental or malicious data deletion.

The AWS S3 service allows versioning of objects, providing a mechanism for recovery from accidental deletions. However, without MFA Delete enabled, anyone with sufficient permissions can permanently delete object versions, bypassing versioning protection. This misconfiguration leaves data vulnerable to unauthorized removal or data breaches. An attacker could exploit this to permanently delete sensitive information.

Compromised credentials or unintended actions could lead to irreversible data loss. MFA Delete adds a crucial second layer of authentication, significantly reducing the risk of accidental or malicious object deletion. Implementing this best practice ensures data integrity and minimizes the impact of compromised credentials.

Enable MFA Delete on all versioned S3 buckets. Regularly audit bucket configurations to ensure MFA Delete remains enabled. Consider implementing least privilege access controls and robust access logging to further enhance security.

First Seen February 19, 2025 at 5:11:08 PM UTC | Resource Type Other

Recommendations

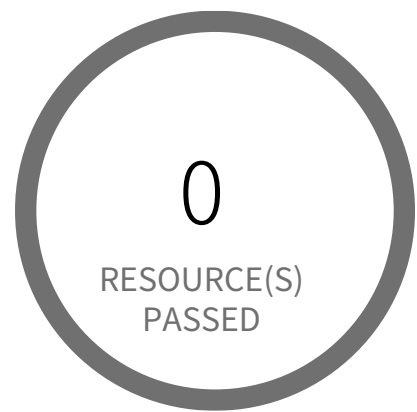
Using console you can enable versioning on the bucket but you cannot enable MFA delete.

You can do it via only with the AWS CLI:

```
aws s3api put-bucket-versioning --bucket <BUCKET_NAME> --versioning-configuration Status=Enabled,MFADelete=Enabled --mfa "<MFA_SERIAL_NUMBER> <MFA_CODE>"
```

NOTE: The bucket owner, the AWS account that created the bucket (root account), and all authorized IAM users can enable versioning, but only the bucket owner (root account) can enable MFA Delete. Successful execution will enable the S3 bucket versioning and MFA delete on the bucket.

Identification and Authentication / Section Device Identification and Authentication



0 Resource(s) Failed

Compliance Section: Device Identification and Authentication ●●●● Low

Uniquely identify and authenticate [Assignment: organization-defined devices or types of devices] before establishing a system connection.

AWS EMR cluster is not configured with Kerberos Authentication

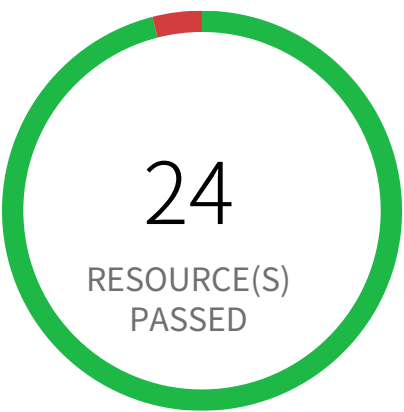
This policy identifies EMR clusters which are not configured with Kerberos Authentication. Kerberos uses secret-key cryptography to provide strong authentication so that passwords or other credentials aren't sent over the network in an unencrypted format.

First Seen N/A | **Resource Type** Other

Recommendations

1. Log in to the AWS Console
2. In the console, select the specific region from region drop down on the top right corner, for which the alert is generated
3. Navigate to 'EMR' dashboard from 'Services' dropdown
4. Go to 'Security configurations', click 'Create'
5. On the Create security configuration window,
6. In 'Name' box, provide a name for the new EMR security configuration
7. Under the section 'Enable Kerberos authentication' select the check box
8. Follow below link for configuration steps,
<https://docs.aws.amazon.com/emr/latest/ManagementGuide/emr-kerberos.html>
9. Click on 'Create' button
10. On the left menu of EMR dashboard Click 'Clusters'
11. Select the EMR cluster for which the alert has been generated and click on the 'Clone' button from the top menu
12. In the Cloning popup, choose 'Yes' and Click 'Clone'
13. On the Create Cluster page, in the Security Options section, click on 'security configuration'.
14. From the 'Security configuration' drop down select the name of the security configuration created at step 4 to step 8, click 'Create Cluster'
15. Once you the new cluster is set up verify its working and terminate the source cluster in order to stop incurring charges for it.
16. On the left menu of EMR dashboard Click 'Clusters', from the list of clusters select the source cluster which is alerted
17. Click on the 'Terminate' button from the top menu
18. On the 'Terminate clusters' pop-up, click 'Terminate'.

Identification and Authentication / Section Multi-Factor Authentication



1 Resource(s) Failed
prisma-forward-scan-984345939

Compliance Section: Multi-Factor Authentication — Informational

Implement multi-factor authentication for access to privileged and non-privileged accounts.

AWS CloudTrail S3 buckets have not enabled MFA Delete

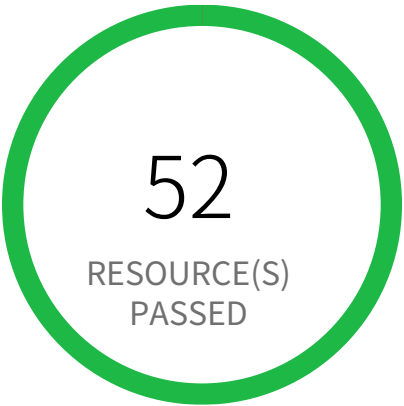
This policy identifies the S3 buckets which do not have Multi-Factor Authentication enabled for CloudTrails. For encryption of log files, CloudTrail defaults to use of S3 server-side encryption (SSE). We recommend adding an additional layer of security by adding MFA Delete to your S3 bucket. This will help to prevent deletion of CloudTrail logs without your explicit authorization. We also encourage you to use a bucket policy that places restrictions on which of your identity access management (IAM) users are allowed to delete S3 objects.

First Seen June 11, 2024 at 6:11:26 PM UTC | **Resource Type** Other

Recommendations

Enable MFA Delete on the bucket(s) you have configured to receive CloudTrail log files.
Note: We recommend that you do not configure CloudTrail to write into an S3 bucket that resides in a different AWS account.
Additional information on how to do this can be found here:
<http://docs.aws.amazon.com/AmazonS3/latest/dev/Versioning.html#MultiFactorAuthenticationDelete>

Identification and Authentication / Section Multi-Factor Authentication



0 Resource(s) Failed

Compliance Section: Multi-Factor Authentication ●●●● Medium

Implement multi-factor authentication for access to privileged and non-privileged accounts.

AWS MFA is not enabled on Root account

This policy identifies root account which has MFA enabled. Root accounts have privileged access to all AWS services. Without MFA, if the root credentials are compromised, unauthorized users will get full access to your account.

NOTE: This policy does not apply to AWS GovCloud Accounts. As you cannot enable an MFA device for AWS GovCloud (US) account root user. For more details refer: <https://docs.aws.amazon.com/govcloud-us/latest/UserGuide/govcloud-console.html>

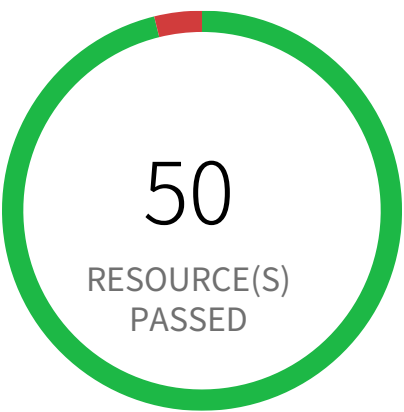
First Seen N/A | **Resource Type** IAM Account Summary

Recommendations

1. Log in to your AWS account using your primary root user.
2. Navigate to the security settings by clicking on your account name in the top-right corner and selecting 'Security credentials'.
3. In the 'Multi-Factor Authentication (MFA)' section, click on 'Assign MFA device' to begin the setup process.
4. In the setup wizard, provide a Device name for your virtual device and select 'Authenticator app' and then choose Next.
5. AWS will display the configuration details, including a QR code and a secret key for manual entry.
6. Open the authenticator application (like Google Authenticator or Microsoft Authenticator) on your mobile device.
7. Within your MFA app, use the option to add a new account, which typically involves scanning a QR code.
8. Scan the QR code displayed in the AWS console with your app; alternatively, manually type the provided secret key into the app.
9. Enter two consecutive one-time passwords generated by your app into the 'MFA code 1' and 'MFA code 2' fields in the AWS wizard and click 'Add MFA' to complete the setup.

Note: Carefully review and test the steps before implementing them. Enabling MFA on the root account is a critical security measure, but it may require adjustments to your existing workflows. Ensure that you have a backup plan in case of unexpected issues.

Identification and Authentication / Section Multi-Factor Authentication



2 Resource(s) Failed
mike-sa, read-only-access-engg

Compliance Section: Multi-Factor Authentication ●●●● Low

Implement multi-factor authentication for access to privileged and non-privileged accounts.

AWS MFA not enabled for IAM users

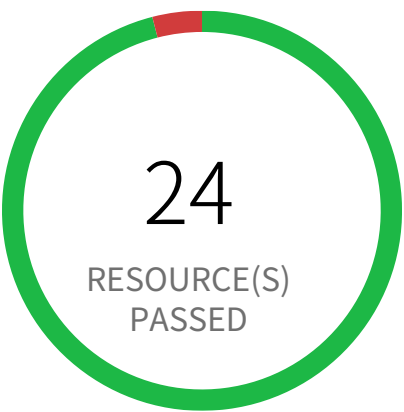
This policy identifies AWS IAM users for whom MFA is not enabled. AWS Multi-Factor Authentication (MFA) is a simple best practice that adds an extra layer of protection on top of your user name and password. Multiple factors provide increased security for your AWS account settings and resources.

First Seen February 7, 2024 at 8:51:07 PM UTC | **Resource Type** IAM Credentials Report

Recommendations

- 1. Sign in to the AWS and navigate to the 'IAM' service.
- 2. Navigate to the user that was reported in the alert.
- 3. Under 'Security Credentials', check "Assigned MFA Device" and follow the instructions to enable MFA for the user.

Identification and Authentication / Section Multi-Factor Authentication



1 Resource(s) Failed
pays-app-dev-jd3jnx92j3

Compliance Section: Multi-Factor Authentication ●●●● Low

Implement multi-factor authentication for access to privileged and non-privileged accounts.

AWS S3 bucket is not configured with MFA Delete

AWS S3 buckets lacking MFA Delete are susceptible to accidental or malicious data deletion.

The AWS S3 service allows versioning of objects, providing a mechanism for recovery from accidental deletions. However, without MFA Delete enabled, anyone with sufficient permissions can permanently delete object versions, bypassing versioning protection. This misconfiguration leaves data vulnerable to unauthorized removal or data breaches. An attacker could exploit this to permanently delete sensitive information.

Compromised credentials or unintended actions could lead to irreversible data loss. MFA Delete adds a crucial second layer of authentication, significantly reducing the risk of accidental or malicious object deletion. Implementing this best practice ensures data integrity and minimizes the impact of compromised credentials.

Enable MFA Delete on all versioned S3 buckets. Regularly audit bucket configurations to ensure MFA Delete remains enabled. Consider implementing least privilege access controls and robust access logging to further enhance security.

First Seen February 19, 2025 at 5:11:08 PM UTC | **Resource Type** Other

Recommendations

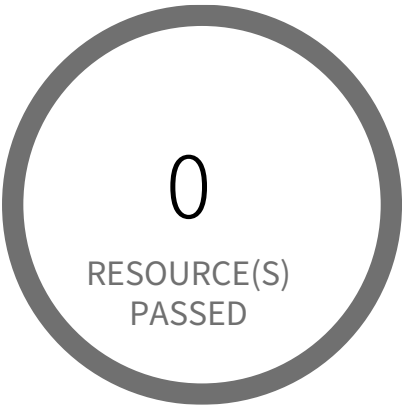
Using console you can enable versioning on the bucket but you cannot enable MFA delete.

You can do it via only with the AWS CLI:

```
aws s3api put-bucket-versioning --bucket <BUCKET_NAME> --versioning-configuration Status=Enabled,MFADelete=Enabled --mfa "<MFA_SERIAL_NUMBER> <MFA_CODE>"
```

NOTE: The bucket owner, the AWS account that created the bucket (root account), and all authorized IAM users can enable versioning, but only the bucket owner (root account) can enable MFA Delete. Successful execution will enable the S3 bucket versioning and MFA delete on the bucket.

Identification and Authentication / Section Multi-Factor Authentication



0 Resource(s) Failed

Compliance Section: Multi-Factor Authentication ●●●● Medium

Implement multi-factor authentication for access to privileged and non-privileged accounts.

AWS root account configured with Virtual MFA

This policy identifies AWS root accounts which are configured with Virtual MFA. Root is an important role in your account and root accounts must be configured with hardware MFA. Hardware MFA adds extra security because it requires users to type a unique authentication code from an approved authentication device when they access AWS websites or services.

First Seen N/A | **Resource Type** Other

Recommendations

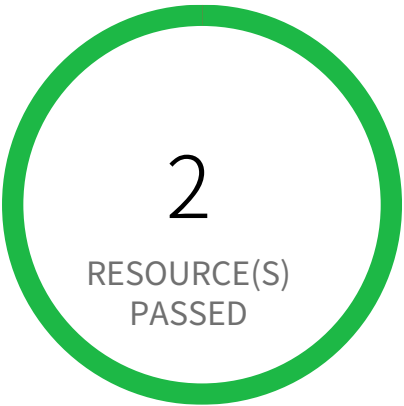
To manage MFA devices for your AWS account, you must use your root user credentials to sign in to AWS. You cannot manage MFA devices for the root user while signed in with other credentials.

- 1. Sign in to the AWS Management Console with your root user credentials
- 2. Go to IAM
- 3. Do one of the following:
 - Option 1: Choose Dashboard, and under Security Status, expand Activate MFA on your root account.
 - Option 2: On the right side of the navigation bar, select your account name, and then choose My Security Credentials. If necessary, choose Continue to Security Credentials. Then expand the Multi-Factor Authentication (MFA) section on the page.
- 4. Choose Manage MFA or Activate MFA, depending on which option you chose in the preceding step.
- 5. In the wizard, choose A hardware MFA device and then choose Next Step.
- 6. If you have U2F security key as hardware MFA device, choose U2F security key and click on Continue. Next plug the USB U2F security key, when setup is complete click on Close.
 - If you have any other hardware MFA device, choose Other hardware MFA device option
 - a. In the Serial Number box, type the serial number that is found on the back of the MFA device.
 - b. In the Authentication Code 1 box, type the six-digit number displayed by the MFA device. You might need to press the button on the front of the device to display the number.
 - c. Wait 30 seconds while the device refreshes the code, and then type the next six-digit number into the Authentication Code 2 box. You might need to press the button on the front of the device again to display the second number.
 - d. Choose Next Step. The MFA device is now associated with the AWS account.

Important:
Submit your request immediately after generating the authentication codes. If you generate the codes and then wait too long to submit the

request, the MFA device successfully associates with the user but the MFA device becomes out of sync. This happens because time-based one-time passwords (TOTP) expire after a short period of time. If this happens, you can resync the device.

Identification and Authentication / Section Password Management



0 Resource(s) Failed

Compliance Section: Password Management ●●●● Low

- a. Maintain a list of commonly-used, expected, or compromised passwords, and update the list [Assignment: organization-defined frequency] and when organizational passwords are suspected to have been compromised.
- b. Verify that passwords are not found on the list of commonly used, expected, or compromised passwords when users create or update passwords.
- c. Transmit passwords only over cryptographically protected channels.
- d. Store passwords in a cryptographically protected form.
- e. Select a new password upon first use after account recovery.
- f. Enforce the following composition and complexity rules for passwords: [Assignment: organization-defined composition and complexity rules].

AWS IAM Password policy is unsecure

Checks to ensure that IAM password policy is in place for the cloud accounts. As a security best practice, customers must have strong password policies in place. This policy ensures password policies are set with all following options:

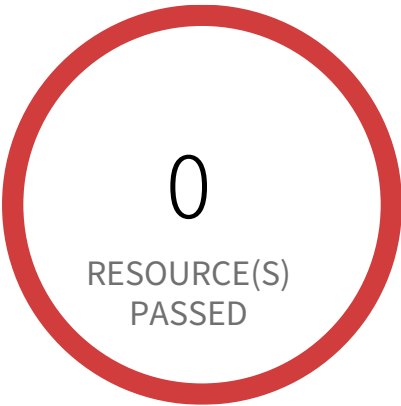
- Minimum Password Length
- At least one Uppercase letter
- At least one Lowercase letter
- At least one Number
- At least one Symbol/non-alphanumeric character
- Users have permission to change their own password
- Password expiration period
- Password reuse
- Password expiration requires administrator reset

First Seen N/A | Resource Type Other

Recommendations

1. Login to AWS Console and navigate to the 'IAM' Service
2. Click on 'Account Settings'
3. Under 'Password Policy', select and set all the options
4. Click on 'Apply password policy'

Identification and Authentication / Section Password Management



2 Resource(s) Failed
818698786219-iam-password-policy,
058264157785-iam-password-policy

Compliance Section: Password Management Informational

- a. Maintain a list of commonly-used, expected, or compromised passwords, and update the list [Assignment: organization-defined frequency] and when organizational passwords are suspected to have been compromised.
- b. Verify that passwords are not found on the list of commonly used, expected, or compromised passwords when users create or update passwords.
- c. Transmit passwords only over cryptographically protected channels.
- d. Store passwords in a cryptographically protected form.
- e. Select a new password upon first use after account recovery.
- f. Enforce the following composition and complexity rules for passwords: [Assignment: organization-defined composition and complexity rules].

AWS IAM password policy allows password reuse

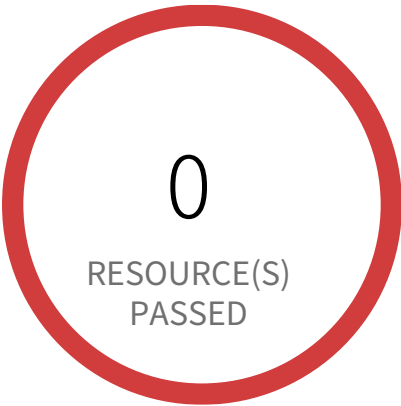
This policy identifies IAM policies which allow password reuse . AWS IAM (Identity & Access Management) allows customers to secure AWS console access. As a security best practice, customers must have strong password policies in place.

First Seen March 14, 2023 at 11:09:07 AM UTC | **Resource Type** Password Policy

Recommendations

- 1. Sign in to the AWS console and navigate to the 'IAM' service.
- 2. Click on 'Account Settings', check 'Prevent password reuse'.

Identification and Authentication / Section Password Management



2 Resource(s) Failed

058264157785-iam-password-policy,
818698786219-iam-password-policy

Compliance Section: Password Management Informational

- a. Maintain a list of commonly-used, expected, or compromised passwords, and update the list [Assignment: organization-defined frequency] and when organizational passwords are suspected to have been compromised.
- b. Verify that passwords are not found on the list of commonly used, expected, or compromised passwords when users create or update passwords.
- c. Transmit passwords only over cryptographically protected channels.
- d. Store passwords in a cryptographically protected form.
- e. Select a new password upon first use after account recovery.
- f. Enforce the following composition and complexity rules for passwords: [Assignment: organization-defined composition and complexity rules].

AWS IAM password policy does not expire in 90 days

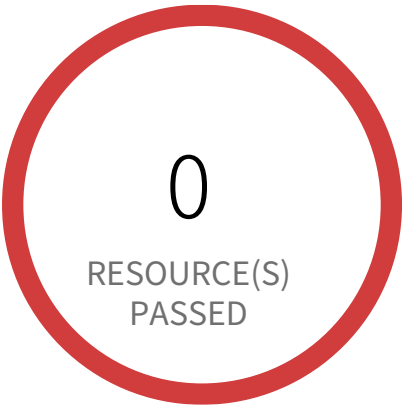
This policy identifies the IAM policies which does not have password expiration set to 90 days. AWS IAM (Identity & Access Management) allows customers to secure AWS console access. As a security best practice, customers must have strong password policies in place.

First Seen March 14, 2023 at 11:09:07 AM UTC | Resource Type Password Policy

Recommendations

1. Login to the AWS console and navigate to the 'IAM' service.
2. On the left navigation panel, Click on 'Account Settings'
3. check 'Enable password expiration' and enter a password expiration period.
4. Click on 'Apply password policy'

Identification and Authentication / Section Password Management



2 Resource(s) Failed
058264157785-iam-password-policy,
818698786219-iam-password-policy

Compliance Section: Password Management Informational

- a. Maintain a list of commonly-used, expected, or compromised passwords, and update the list [Assignment: organization-defined frequency] and when organizational passwords are suspected to have been compromised.
- b. Verify that passwords are not found on the list of commonly used, expected, or compromised passwords when users create or update passwords.
- c. Transmit passwords only over cryptographically protected channels.
- d. Store passwords in a cryptographically protected form.
- e. Select a new password upon first use after account recovery.
- f. Enforce the following composition and complexity rules for passwords: [Assignment: organization-defined composition and complexity rules].

AWS IAM password policy does not have a lowercase character

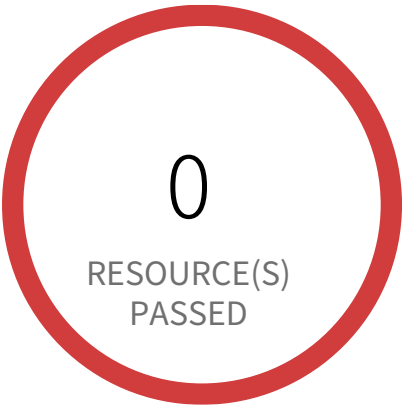
Checks to ensure that IAM password policy requires a lowercase character. AWS IAM (Identity & Access Management) allows customers to secure AWS console access. As a security best practice, customers must have strong password policies in place.

First Seen March 14, 2023 at 11:09:07 AM UTC | **Resource Type** Password Policy

Recommendations

1. Login to the AWS console and navigate to the 'IAM' service.
2. On the left navigation panel, Click on 'Account Settings'
3. check 'Require at least one lowercase letter'.
4. Click on 'Apply password policy'

Identification and Authentication / Section Password Management



2 Resource(s) Failed
058264157785-iam-password-policy,
818698786219-iam-password-policy

Compliance Section: Password Management — Informational

- a. Maintain a list of commonly-used, expected, or compromised passwords, and update the list [Assignment: organization-defined frequency] and when organizational passwords are suspected to have been compromised.
- b. Verify that passwords are not found on the list of commonly used, expected, or compromised passwords when users create or update passwords.
- c. Transmit passwords only over cryptographically protected channels.
- d. Store passwords in a cryptographically protected form.
- e. Select a new password upon first use after account recovery.
- f. Enforce the following composition and complexity rules for passwords: [Assignment: organization-defined composition and complexity rules].

AWS IAM password policy does not have a minimum of 14 characters

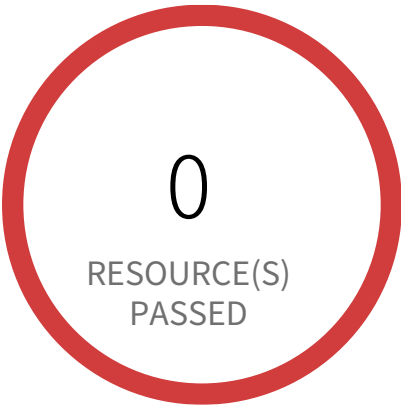
Checks to ensure that IAM password policy requires minimum of 14 characters. AWS IAM (Identity & Access Management) allows customers to secure AWS console access. As a security best practice, customers must have strong password policies in place.

First Seen March 14, 2023 at 11:09:07 AM UTC | **Resource Type** Password Policy

Recommendations

- 1. Login to the AWS console and navigate to the 'IAM' service.
- 2. On the left navigation panel, Click on 'Account Settings'
- 3. In the 'Minimum password length' field, put 14 or more (As per preference).
- 4. Click on 'Apply password policy'

Identification and Authentication / Section Password Management



2 Resource(s) Failed
818698786219-iam-password-policy,
058264157785-iam-password-policy

Compliance Section: Password Management ●●●● Low

- a. Maintain a list of commonly-used, expected, or compromised passwords, and update the list [Assignment: organization-defined frequency] and when organizational passwords are suspected to have been compromised.
- b. Verify that passwords are not found on the list of commonly used, expected, or compromised passwords when users create or update passwords.
- c. Transmit passwords only over cryptographically protected channels.
- d. Store passwords in a cryptographically protected form.
- e. Select a new password upon first use after account recovery.
- f. Enforce the following composition and complexity rules for passwords: [Assignment: organization-defined composition and complexity rules].

AWS IAM password policy does not have a number

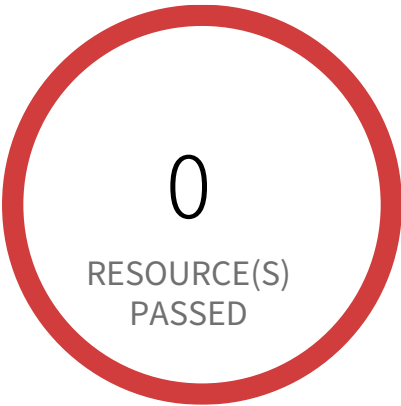
Checks to ensure that IAM password policy requires a number. AWS IAM (Identity & Access Management) allows customers to secure AWS console access. As a security best practice, customers must have strong password policies in place.

First Seen March 14, 2023 at 11:09:07 AM UTC | **Resource Type** Password Policy

Recommendations

- 1. Login to the AWS console and navigate to the 'IAM' service.
- 2. On the left navigation panel, Click on 'Account Settings'
- 3. check 'Require at least one number'.
- 4. Click on 'Apply password policy'

Identification and Authentication / Section Password Management



2 Resource(s) Failed
058264157785-iam-password-policy,
818698786219-iam-password-policy

Compliance Section: Password Management — Informational

- a. Maintain a list of commonly-used, expected, or compromised passwords, and update the list [Assignment: organization-defined frequency] and when organizational passwords are suspected to have been compromised.
- b. Verify that passwords are not found on the list of commonly used, expected, or compromised passwords when users create or update passwords.
- c. Transmit passwords only over cryptographically protected channels.
- d. Store passwords in a cryptographically protected form.
- e. Select a new password upon first use after account recovery.
- f. Enforce the following composition and complexity rules for passwords: [Assignment: organization-defined composition and complexity rules].

AWS IAM password policy does not have a symbol

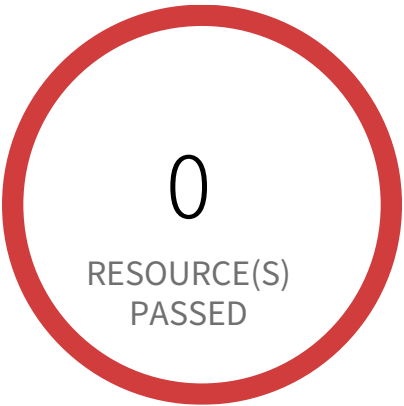
Checks to ensure that IAM password policy requires a symbol. AWS IAM (Identity & Access Management) allows customers to secure AWS console access. As a security best practice, customers must have strong password policies in place.

First Seen March 14, 2023 at 11:09:07 AM UTC | **Resource Type** Password Policy

Recommendations

- 1. Login to the AWS console and navigate to the 'IAM' service.
- 2. On the left navigation panel, Click on 'Account Settings'
- 3. check 'Require at least one non-alphanumeric character'.
- 4. Click on 'Apply password policy'

Identification and Authentication / Section Password Management



2 Resource(s) Failed
058264157785-iam-password-policy,
818698786219-iam-password-policy

Compliance Section: Password Management Informational

- a. Maintain a list of commonly-used, expected, or compromised passwords, and update the list [Assignment: organization-defined frequency] and when organizational passwords are suspected to have been compromised.
- b. Verify that passwords are not found on the list of commonly used, expected, or compromised passwords when users create or update passwords.
- c. Transmit passwords only over cryptographically protected channels.
- d. Store passwords in a cryptographically protected form.
- e. Select a new password upon first use after account recovery.
- f. Enforce the following composition and complexity rules for passwords: [Assignment: organization-defined composition and complexity rules].

AWS IAM password policy does not have an uppercase character

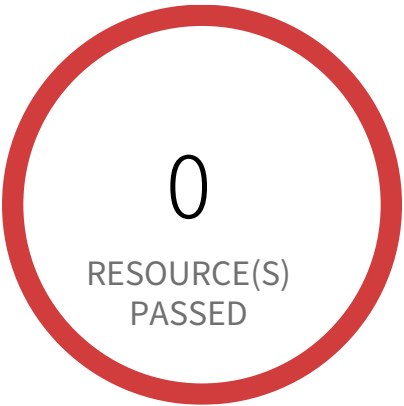
This policy identifies AWS accounts in which IAM password policy does not have an uppercase character. AWS IAM (Identity & Access Management) allows customers to secure AWS console access. As a security best practice, customers must have strong password policies in place.

First Seen March 14, 2023 at 11:09:07 AM UTC | **Resource Type** Password Policy

Recommendations

- 1. Login to the AWS console and navigate to the 'IAM' service.
- 2. On the left navigation panel, Click on 'Account Settings'
- 3. check 'Require at least one uppercase letter'.
- 4. Click on 'Apply password policy'

Identification and Authentication / Section Password Management



2 Resource(s) Failed

818698786219-iam-password-policy,
058264157785-iam-password-policy

Compliance Section: Password Management Informational

- a. Maintain a list of commonly-used, expected, or compromised passwords, and update the list [Assignment: organization-defined frequency] and when organizational passwords are suspected to have been compromised.
- b. Verify that passwords are not found on the list of commonly used, expected, or compromised passwords when users create or update passwords.
- c. Transmit passwords only over cryptographically protected channels.
- d. Store passwords in a cryptographically protected form.
- e. Select a new password upon first use after account recovery.
- f. Enforce the following composition and complexity rules for passwords: [Assignment: organization-defined composition and complexity rules].

AWS IAM password policy does not have password expiration period

Checks to ensure that IAM password policy has an expiration period. AWS IAM (Identity & Access Management) allows customers to secure AWS console access. As a security best practice, customers must have strong password policies in place.

First Seen March 14, 2023 at 11:09:07 AM UTC | Resource Type Password Policy

Recommendations

1. Login to the AWS console and navigate to the 'IAM' service.
2. On the left navigation panel, Click on 'Account Settings'
3. check 'Enable password expiration' and enter a password expiration period.
4. Click on 'Apply password policy'

5

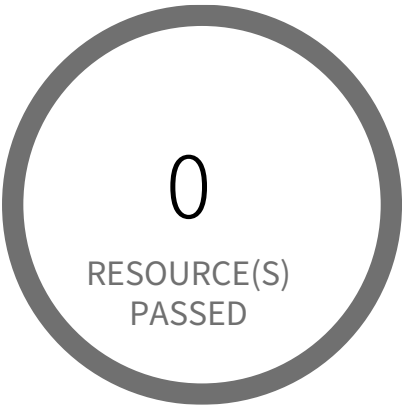
Incident response

Incident response Overview

[illegible]

Section		Pass Rate	Failed	Passed
Incident Monitoring, Reporting, and Response Assistance	AWSLog· Informational	0%	2	0
Incident Monitoring, Reporting, and Response Assistance	AWSLog· Informational	0%	2	0
Incident Monitoring, Reporting, and Response Assistance	AWSLog· Informational	0%	2	0
Incident Monitoring, Reporting, and Response Assistance	AWSLog· Informational	0%	2	0
Incident Monitoring, Reporting, and Response Assistance	AWSLog· Informational	0%	2	0
Incident Monitoring, Reporting, and Response Assistance	AWS... Informational	0%	1	0

Incident response / Section Incident Monitoring, Reporting, and Response Assistance



0 Resource(s) Failed

Compliance Section: Incident Monitoring, Reporting, and Response Assistance Informational

- a. Track and document system security incidents.
- b. Report suspected incidents to the organizational incident response capability within [Assignment: organization-defined time period].
- c. Report incident information to [Assignment: organization-defined authorities].
- d. Provide an incident response support resource that offers advice and assistance to system users on handling and reporting incidents.

AWS Elasticsearch domain has Index slow logs set to disabled

This policy identifies Elasticsearch domains for which Index slow logs is disabled in your AWS account. Enabling support for publishing indexing slow logs to AWS CloudWatch Logs enables you have full insight into the performance of indexing operations performed on your Elasticsearch clusters. This will help you in identifying performance issues caused by specific queries or due to changes in cluster usage, so that you can optimize your index configuration to address the problem.

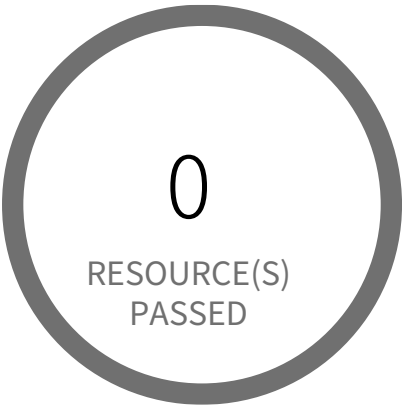
First Seen N/A | Resource Type Other

Recommendations

1. Sign into the AWS console
2. In the console, select the specific region from region drop down on the top right corner, for which the alert is generated
3. Navigate to Elasticsearch Service Dashboard
4. Choose reported Elasticsearch domain
5. Select the 'Logs' tab
6. In 'Set up Index slow logs' section,
 - a. click on 'Setup'
 - b. In 'Select CloudWatch Logs log group' setting, Create/Use existing CloudWatch Logs log group as per your requirement
 - c. In 'Specify CloudWatch access policy', Create new/Select an existing policy as per your requirement
 - d. Click on 'Enable'

The Index slow logs setting 'Status' should change now to 'Enabled'.

Incident response / Section Incident Monitoring, Reporting, and Response Assistance



0 Resource(s) Failed

Compliance Section: Incident Monitoring, Reporting, and Response Assistance Informational

- a. Track and document system security incidents.
- b. Report suspected incidents to the organizational incident response capability within [Assignment: organization-defined time period].
- c. Report incident information to [Assignment: organization-defined authorities].
- d. Provide an incident response support resource that offers advice and assistance to system users on handling and reporting incidents.

AWS Elasticsearch domain has Search slow logs set to disabled

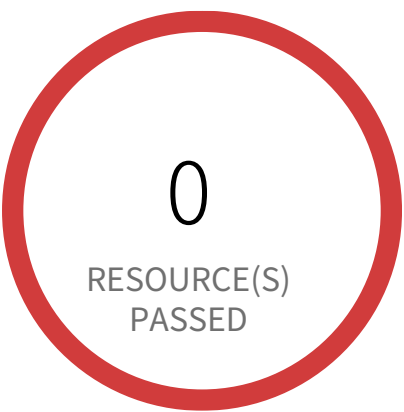
This policy identifies Elasticsearch domains for which Search slow logs is disabled in your AWS account. Enabling support for publishing Search slow logs to AWS CloudWatch Logs enables you to have full insight into the performance of search operations performed on your Elasticsearch clusters. This will help you in identifying performance issues caused by specific search queries so that you can optimize your queries to address the problem.

First Seen N/A | Resource Type Other

Recommendations

1. Sign into the AWS console
2. In the console, select the specific region from region drop down on the top right corner, for which the alert is generated
3. Navigate to Amazon OpenSearch Service Dashboard
4. From the navigation panel, Click on 'Domains' Under the 'Managed clusters'
5. Select the reported domain
6. Select the 'Logs' tab
7. In 'CloudWatch Logs' section, Choose 'Search slow logs' and click on 'Enable'
8. In 'Set up Search slow logs' section,
 - a. In 'Select log group from CloudWatch logs' setting, Create/Use existing CloudWatch Logs log group as per your requirement
 - b. In 'Specify CloudWatch access policy' section, Create/Select the 'Resource access policy' as per your requirement
9. Click 'Enable'

Incident response / Section Incident Monitoring, Reporting, and Response Assistance



2 Resource(s) Failed
058264157785, 818698786219

Compliance Section: Incident Monitoring, Reporting, and Response Assistance — Informational

- a. Track and document system security incidents.
- b. Report suspected incidents to the organizational incident response capability within [Assignment: organization-defined time period].
- c. Report incident information to [Assignment: organization-defined authorities].
- d. Provide an incident response support resource that offers advice and assistance to system users on handling and reporting incidents.

AWS Log metric filter and alarm does not exist for AWS Config configuration changes

This policy identifies the AWS regions which do not have a log metric filter and alarm for AWS Config configuration changes. Monitoring changes to AWS Config configuration will help ensure sustained visibility of configuration items within the AWS account. It is recommended that a metric filter and alarm be established for detecting changes to AWS Config's configurations.

NOTE: This policy will trigger alert if you have at least one Cloudtrail with the multi trail is enabled, Logs all management events in your account and is not set with specific log metric filter and alarm.

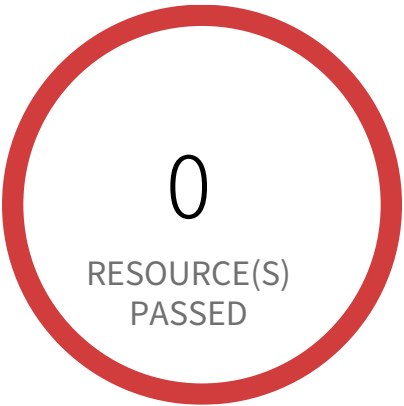
First Seen January 28, 2025 at 12:06:58 PM UTC | **Resource Type** Other

Recommendations

- 1. Sign in to AWS Console
- 2. Navigate to CloudWatch dashboard
- 3. Click on 'Log groups' in the 'Logs' section (Left panel)
- 4. Select the log group created for your CloudTrail trail event logs (CloudTrail should be multi trail enabled with all management events captured) and click 'Create Metric Filter' button.
- 5. In 'Define Logs Metric Filter' page, add 'Filter pattern' value as `{ ($.eventSource = config.amazonaws.com) && (($.eventName=StopConfigurationRecorder)||($.eventName=DeleteDeliveryChannel)||($.eventName=PutDeliveryChannel)||($.eventName=PutConfigurationRecorder)) }` and Click on 'Assign Metric'
- 6. In 'Create Metric Filter and Assign a Metric' page, Choose Filter Name, Metric Details parameter according to your requirement and click on 'Create Filter'
- 7. Click on 'Create Alarm',
 - In Step 1 specify metric details and conditions details as required and click on 'Next'
 - In Step 2 Select an SNS topic either by creating a new topic or use existing SNS topic/ARN and click on 'Next'

- In Step 3 Select name and description to alarm and click on 'Next'
- In Step 4 Preview your data entered and click on 'Create Alarm'

Incident response / Section Incident Monitoring, Reporting, and Response Assistance



2 Resource(s) Failed

818698786219, 058264157785

Compliance Section: Incident Monitoring, Reporting, and Response Assistance Informational

- a. Track and document system security incidents.
- b. Report suspected incidents to the organizational incident response capability within [Assignment: organization-defined time period].
- c. Report incident information to [Assignment: organization-defined authorities].
- d. Provide an incident response support resource that offers advice and assistance to system users on handling and reporting incidents.

AWS Log metric filter and alarm does not exist for AWS Organization changes

This policy identifies the AWS regions that do not have a log metric filter and alarm for AWS Organizations changes. Monitoring changes to AWS Organizations will help to ensure any unwanted, accidental, or intentional modifications that may lead to unauthorized access or other security breaches within the AWS account. It is recommended that a metric filter and alarm be established for detecting changes to AWS Organization's configurations.

NOTE: This policy will trigger an alert if you have at least one Cloudtrail with the multi trail enabled, Logs all management events in your account, and is not set with a specific log metric filter and alarm.

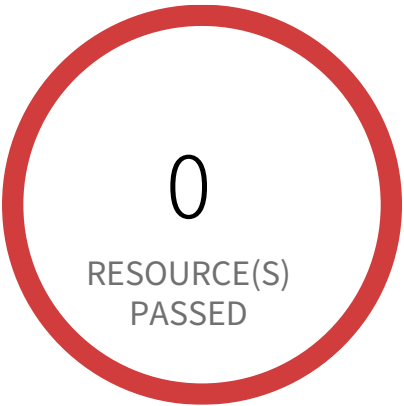
First Seen January 28, 2025 at 12:06:58 PM UTC | Resource Type Other

Recommendations

1. Sign in to the AWS Console.
2. Navigate to the CloudWatch dashboard.
3. Click on 'Log groups' in the 'Logs' section (Left panel)
4. Select the log group created for your CloudTrail trail event logs (Cloudtrail should be multi-trail enabled with all Management Events captured) and click the Actions Dropdown Button -> Click 'Create Metric Filter' button.
5. In the 'Define Pattern' page, add the 'Filter pattern' value as
{ (\$.eventSource = organizations.amazonaws.com) && ((\$.eventName = "AcceptHandshake") || (\$.eventName = "AttachPolicy") || (\$.eventName = "CreateAccount") || (\$.eventName = "CreateOrganizationalUnit") || (\$.eventName = "CreatePolicy") || (\$.eventName = "DeclineHandshake") || (\$.eventName = "DeleteOrganization") || (\$.eventName = "DeleteOrganizationalUnit") || (\$.eventName = "DeletePolicy") || (\$.eventName = "DetachPolicy") || (\$.eventName = "DisablePolicyType") || (\$.eventName = "EnablePolicyType") || (\$.eventName = "InviteAccountToOrganization") || (\$.eventName = "LeaveOrganization") || (\$.eventName = "MoveAccount") || (\$.eventName = "RemoveAccountFromOrganization") || (\$.eventName = "UpdatePolicy") || (\$.eventName = "UpdateOrganizationalUnit")) }
and Click on 'NEXT'.
6. In the 'Assign Metric' page, Choose Filter Name, and Metric Details parameter according to your requirement and click on 'Next'.

7. Under the 'Review and Create' page, Review details and click 'Create Metric Filter'.
8. To create an alarm based on a log group-metric filter, Refer to the below link
https://docs.aws.amazon.com/AmazonCloudWatch/latest/monitoring/Create_alarm_log_group_metric_filter.html

Incident response / Section Incident Monitoring, Reporting, and Response Assistance



2 Resource(s) Failed

818698786219, 058264157785

Compliance Section: Incident Monitoring, Reporting, and Response Assistance — Informational

- a. Track and document system security incidents.
- b. Report suspected incidents to the organizational incident response capability within [Assignment: organization-defined time period].
- c. Report incident information to [Assignment: organization-defined authorities].
- d. Provide an incident response support resource that offers advice and assistance to system users on handling and reporting incidents.

AWS Log metric filter and alarm does not exist for AWS management console authentication failures

This policy identifies the AWS accounts which do not have a log metric filter and alarm for AWS management console authentication failures. Monitoring failed console logins may decrease lead time to detect an attempt to brute force a credential, which may provide an indicator, such as source IP, that can be used in other event correlation. It is recommended that a metric filter and alarm be established for failed console authentication attempts.

NOTE: This policy will trigger alert if you have at least one Cloudtrail with the multi trail is enabled, Logs all management events and is not set with specific log metric filter and alarm in your account.

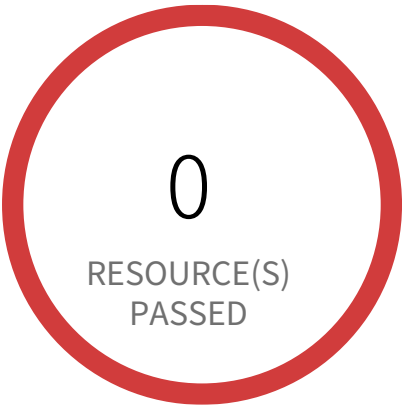
First Seen January 28, 2025 at 12:06:58 PM UTC | **Resource Type** Other

Recommendations

- 1. Sign in to AWS Console
- 2. Navigate to CloudWatch dashboard
- 3. Click on 'Log groups' in the 'Logs' section (Left panel)
- 4. Select the log group created for your CloudTrail trail event logs (Cloudtrail should be multi trail enabled with all Management Events captured) and click 'Create Metric Filter' button.
- 5. In 'Define Logs Metric Filter' page, add 'Filter pattern' value as { (\$.eventName = ConsoleLogin) && (\$.errorMessage = "Failed authentication") }
- and Click on 'Assign Metric'
- 6. In 'Create Metric Filter and Assign a Metric' page, Choose Filter Name, Metric Details parameter according to your requirement and click on 'Create Filter'
- 7. Click on 'Create Alarm',
- In Step 1, specify metric details and conditions details as required and click on 'Next'
- In Step 2, Select an SNS topic either by creating a new topic or use existing SNS topic/ARN and click on 'Next'

- In Step 3, Select name and description to alarm and click on 'Next'
- In Step 4, Preview your data entered and click on 'Create Alarm'

Incident response / Section Incident Monitoring, Reporting, and Response Assistance



2 Resource(s) Failed
058264157785, 818698786219

Compliance Section: Incident Monitoring, Reporting, and Response Assistance — Informational

- a. Track and document system security incidents.
- b. Report suspected incidents to the organizational incident response capability within [Assignment: organization-defined time period].
- c. Report incident information to [Assignment: organization-defined authorities].
- d. Provide an incident response support resource that offers advice and assistance to system users on handling and reporting incidents.

AWS Log metric filter and alarm does not exist for CloudTrail configuration changes

This policy identifies the AWS regions which do not have a log metric filter and alarm for CloudTrail configuration changes. Monitoring changes to CloudTrail's configuration will help ensure sustained visibility to activities performed in the AWS account. It is recommended that a metric filter and alarm be established for detecting changes to CloudTrail's configurations.

NOTE: This policy will trigger alert if you have at least one Cloudtrail with the multi trail is enabled, Logs all management events in your account and is not set with specific log metric filter and alarm.

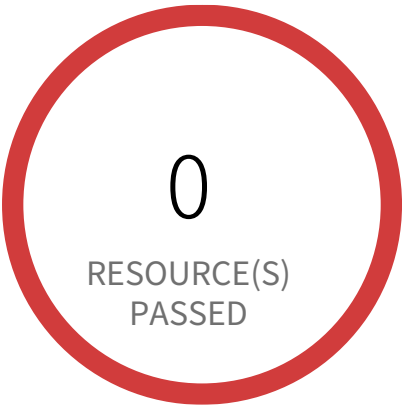
First Seen January 28, 2025 at 12:06:58 PM UTC | **Resource Type** Other

Recommendations

- 1. Sign in to AWS Console
- 2. Navigate to CloudWatch dashboard
- 3. Click on 'Log groups' in the 'Logs' section (Left panel)
- 4. Select the log group created for your CloudTrail trail event logs (CloudTrail should be multi trail enabled with all management events captured) and click 'Create Metric Filter' button.
- 5. In 'Define Logs Metric Filter' page, add 'Filter pattern' value as { (\$.eventName = CreateTrail) || (\$.eventName = UpdateTrail) || (\$.eventName = DeleteTrail) || (\$.eventName = StartLogging) || (\$.eventName = StopLogging) } and Click on 'Assign Metric'
- 6. In 'Create Metric Filter and Assign a Metric' page, Choose Filter Name, Metric Details parameter according to your requirement and click on 'Create Filter'
- 7. Click on 'Create Alarm',
 - In Step 1 specify metric details and conditions details as required and click on 'Next'
 - In Step 2 Select an SNS topic either by creating a new topic or use existing SNS topic/ARN and click on 'Next'

- In Step 3 Select name and description to alarm and click on 'Next'
- In Step 4 Preview your data entered and click on 'Create Alarm'

Incident response / Section Incident Monitoring, Reporting, and Response Assistance



2 Resource(s) Failed
058264157785, 818698786219

Compliance Section: Incident Monitoring, Reporting, and Response Assistance — Informational

- a. Track and document system security incidents.
- b. Report suspected incidents to the organizational incident response capability within [Assignment: organization-defined time period].
- c. Report incident information to [Assignment: organization-defined authorities].
- d. Provide an incident response support resource that offers advice and assistance to system users on handling and reporting incidents.

AWS Log metric filter and alarm does not exist for IAM policy changes

This policy identifies the AWS regions which do not have a log metric filter and alarm for IAM policy changes. Monitoring changes to IAM policies will help ensure authentication and authorization controls remain intact. It is recommended that a metric filter and alarm be established changes made to Identity and Access Management (IAM) policies.

NOTE: This policy will trigger alert if you have at least one Cloudtrail with the multi trail is enabled, Logs all management events in your account and is not set with specific log metric filter and alarm.

First Seen January 28, 2025 at 12:06:58 PM UTC | Resource Type Other

Recommendations

- 1. Sign in to AWS Console
- 2. Navigate to CloudWatch dashboard
- 3. Click on 'Log groups' in the 'Logs' section (Left panel)
- 4. Select the log group created for your CloudTrail trail event logs (CloudTrail should be multi trail enabled with all management events captured) and click 'Create Metric Filter' button.
- 5. In 'Define Logs Metric Filter' page, add 'Filter pattern' value as

```
{
($eventName=DeleteGroupPolicy)||($eventName=DeleteRolePolicy)||($eventName=DeleteUserPolicy)||($eventName=PutGroupPolicy)||($eventName=PutRolePolicy)||($eventName=PutUserPolicy)||($eventName=CreatePolicy)||($eventName=DeletePolicy)||($eventName=CreatePolicyVersion)||($eventName=DeletePolicyVersion)||($eventName=AttachRolePolicy)||($eventName=DetachRolePolicy)||($eventName=AttachUserPolicy)||($eventName=DetachUserPolicy)||($eventName=AttachGroupPolicy)||($eventName=DetachGroupPolicy) }
```

and Click on 'Assign Metric'
- 6. In 'Create Metric Filter and Assign a Metric' page, Choose Filter Name, Metric Details parameter according to your requirement and click on 'Create Filter'

7. Click on 'Create Alarm',

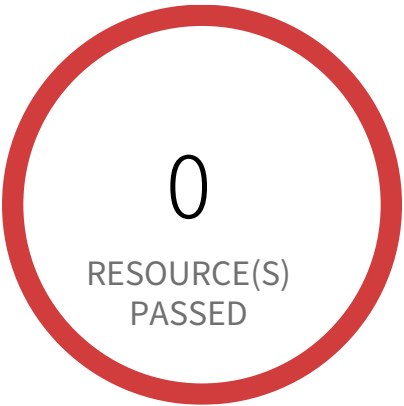
- In Step 1 specify metric details and conditions details as required and click on 'Next'

- In Step 2 Select an SNS topic either by creating a new topic or use existing SNS topic/ARN and click on 'Next'

- In Step 3 Select name and description to alarm and click on 'Next'

- In Step 4 Preview your data entered and click on 'Create Alarm'

Incident response / Section Incident Monitoring, Reporting, and Response Assistance



2 Resource(s) Failed
058264157785, 818698786219

Compliance Section: Incident Monitoring, Reporting, and Response Assistance — Informational

- a. Track and document system security incidents.
- b. Report suspected incidents to the organizational incident response capability within [Assignment: organization-defined time period].
- c. Report incident information to [Assignment: organization-defined authorities].
- d. Provide an incident response support resource that offers advice and assistance to system users on handling and reporting incidents.

AWS Log metric filter and alarm does not exist for Network Access Control Lists (NACL) changes

This policy identifies the AWS regions which do not have a log metric filter and alarm for Network Access Control Lists (NACL) changes. Monitoring changes to NACLs will help ensure that AWS resources and services are not unintentionally exposed. It is recommended that a metric filter and alarm be established for changes made to NACLs.

NOTE: This policy will trigger alert if you have at least one Cloudtrail with the multi trail is enabled, Logs all management events in your account and is not set with specific log metric filter and alarm.

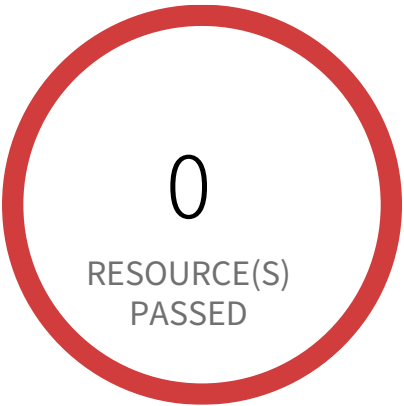
First Seen January 28, 2025 at 12:06:58 PM UTC | **Resource Type** Other

Recommendations

- 1. Sign in to AWS Console
- 2. Navigate to CloudWatch dashboard
- 3. Click on 'Log groups' in the 'Logs' section (Left panel)
- 4. Select the log group created for your CloudTrail trail event logs (CloudTrail should be multi trail enabled with all management events captured) and click 'Create Metric Filter' button.
- 5. In 'Define Logs Metric Filter' page, add 'Filter pattern' value as `{ ($.eventName = CreateNetworkAcl) || ($.eventName = CreateNetworkAclEntry) || ($.eventName = DeleteNetworkAcl) || ($.eventName = DeleteNetworkAclEntry) || ($.eventName = ReplaceNetworkAclEntry) || ($.eventName = ReplaceNetworkAclAssociation) }` and Click on 'Assign Metric'
- 6. In 'Create Metric Filter and Assign a Metric' page, Choose Filter Name, Metric Details parameter according to your requirement and click on 'Create Filter'
- 7. Click on 'Create Alarm',
 - In Step 1 specify metric details and conditions details as required and click on 'Next'
 - In Step 2 Select an SNS topic either by creating a new topic or use existing SNS topic/ARN and click on 'Next'

- In Step 3 Select name and description to alarm and click on 'Next'
- In Step 4 Preview your data entered and click on 'Create Alarm'

Incident response / Section Incident Monitoring, Reporting, and Response Assistance



2 Resource(s) Failed
058264157785, 818698786219

Compliance Section: Incident Monitoring, Reporting, and Response Assistance — Informational

- a. Track and document system security incidents.
- b. Report suspected incidents to the organizational incident response capability within [Assignment: organization-defined time period].
- c. Report incident information to [Assignment: organization-defined authorities].
- d. Provide an incident response support resource that offers advice and assistance to system users on handling and reporting incidents.

AWS Log metric filter and alarm does not exist for Network gateways changes

This policy identifies the AWS regions which do not have a log metric filter and alarm for Network gateways changes. Monitoring changes to network gateways will help ensure that all ingress/egress traffic traverses the VPC border via a controlled path. It is recommended that a metric filter and alarm be established for changes to network gateways.

NOTE: This policy will trigger alert if you have at least one Cloudtrail with the multi trail is enabled, Logs all management events in your account and is not set with specific log metric filter and alarm.

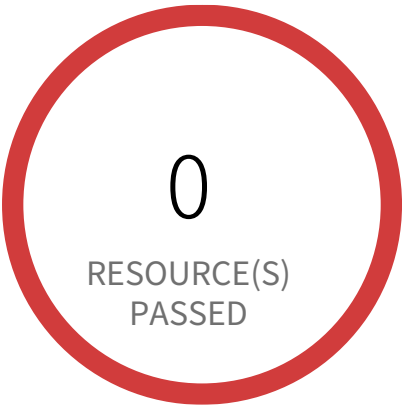
First Seen January 28, 2025 at 12:06:58 PM UTC | **Resource Type** Other

Recommendations

- 1. Sign in to AWS Console
- 2. Navigate to CloudWatch dashboard
- 3. Click on 'Log groups' in the 'Logs' section (Left panel)
- 4. Select the log group created for your CloudTrail trail event logs (CloudTrail should be multi trail enabled with all management events captured) and click 'Create Metric Filter' button.
- 5. In 'Define Logs Metric Filter' page, add 'Filter pattern' value as
{ (\$.eventName = CreateCustomerGateway) || (\$.eventName = DeleteCustomerGateway) || (\$.eventName = AttachInternetGateway) || (\$.eventName = CreateInternetGateway) || (\$.eventName = DeleteInternetGateway) || (\$.eventName = DetachInternetGateway) }
- and Click on 'Assign Metric'
- 6. In 'Create Metric Filter and Assign a Metric' page, Choose Filter Name, Metric Details parameter according to your requirement and click on 'Create Filter'
- 7. Click on 'Create Alarm',
 - In Step 1 specify metric details and conditions details as required and click on 'Next'
 - In Step 2 Select an SNS topic either by creating a new topic or use existing SNS topic/ARN and click on 'Next'

- In Step 3 Select name and description to alarm and click on 'Next'
- In Step 4 Preview your data entered and click on 'Create Alarm'

Incident response / Section Incident Monitoring, Reporting, and Response Assistance



2 Resource(s) Failed
058264157785, 818698786219

Compliance Section: Incident Monitoring, Reporting, and Response Assistance — Informational

- a. Track and document system security incidents.
- b. Report suspected incidents to the organizational incident response capability within [Assignment: organization-defined time period].
- c. Report incident information to [Assignment: organization-defined authorities].
- d. Provide an incident response support resource that offers advice and assistance to system users on handling and reporting incidents.

AWS Log metric filter and alarm does not exist for Route table changes

This policy identifies the AWS regions which do not have a log metric filter and alarm for Route table changes. Monitoring changes to route tables will help ensure that all VPC traffic flows through an expected path. It is recommended that a metric filter and alarm be established for changes to route tables.

NOTE: This policy will trigger alert if you have at least one Cloudtrail with the multi trail is enabled, Logs all management events in your account and is not set with specific log metric filter and alarm.

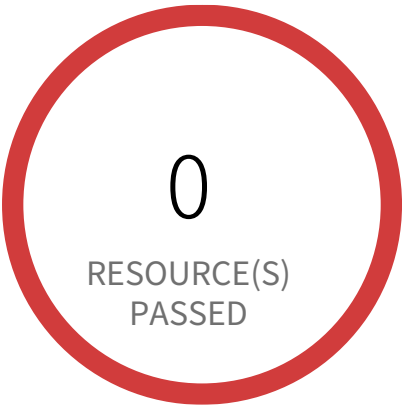
First Seen January 28, 2025 at 12:06:58 PM UTC | **Resource Type** Other

Recommendations

- 1. Sign in to AWS Console
- 2. Navigate to CloudWatch dashboard
- 3. Click on 'Log groups' in the 'Logs' section (Left panel)
- 4. Select the log group created for your CloudTrail trail event logs (CloudTrail should be multi trail enabled with all management events captured) and click 'Create Metric Filter' button.
- 5. In 'Define Logs Metric Filter' page, add 'Filter pattern' value as `{ ($.eventName = CreateRoute) || ($.eventName = CreateRouteTable) || ($.eventName = ReplaceRoute) || ($.eventName = ReplaceRouteTableAssociation) || ($.eventName = DeleteRouteTable) || ($.eventName = DeleteRoute) || ($.eventName = DisassociateRouteTable) }` and Click on 'Assign Metric'
- 6. In 'Create Metric Filter and Assign a Metric' page, Choose Filter Name, Metric Details parameter according to your requirement and click on 'Create Filter'
- 7. Click on 'Create Alarm',
 - In Step 1 specify metric details and conditions details as required and click on 'Next'
 - In Step 2 Select an SNS topic either by creating a new topic or use existing SNS topic/ARN and click on 'Next'

- In Step 3 Select name and description to alarm and click on 'Next'
- In Step 4 Preview your data entered and click on 'Create Alarm'

Incident response / Section Incident Monitoring, Reporting, and Response Assistance



2 Resource(s) Failed
058264157785, 818698786219

Compliance Section: Incident Monitoring, Reporting, and Response Assistance — Informational

- a. Track and document system security incidents.
- b. Report suspected incidents to the organizational incident response capability within [Assignment: organization-defined time period].
- c. Report incident information to [Assignment: organization-defined authorities].
- d. Provide an incident response support resource that offers advice and assistance to system users on handling and reporting incidents.

AWS Log metric filter and alarm does not exist for S3 bucket policy changes

This policy identifies the AWS regions which do not have a log metric filter and alarm for S3 bucket policy changes. Monitoring changes to S3 bucket policies may reduce time to detect and correct permissive policies on sensitive S3 buckets. It is recommended that a metric filter and alarm be established for changes to S3 bucket policies.

NOTE: This policy will trigger alert if you have at least one Cloudtrail with the multi trail is enabled, Logs all management events in your account and is not set with specific log metric filter and alarm.

First Seen January 28, 2025 at 12:06:58 PM UTC | **Resource Type** Other

Recommendations

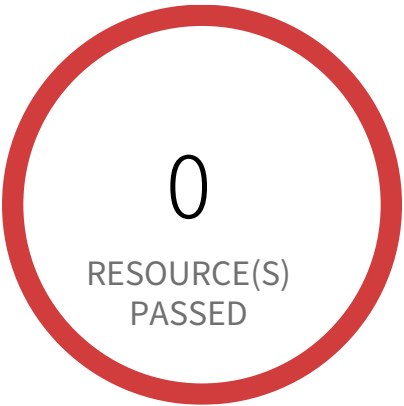
- 1. Sign in to AWS Console
- 2. Navigate to CloudWatch dashboard
- 3. Click on 'Log groups' in the 'Logs' section (Left panel)
- 4. Select the log group created for your CloudTrail trail event logs (CloudTrail should be multi trail enabled with all management events captured) and click 'Create Metric Filter' button.
- 5. In 'Define Logs Metric Filter' page, add 'Filter pattern' value as

```
{ ($.eventSource = s3.amazonaws.com) && (($.eventName = PutBucketAcl) || ($.eventName = PutBucketPolicy) || ($.eventName = PutBucketCors) || ($.eventName = PutBucketLifecycle) || ($.eventName = PutBucketReplication) || ($.eventName = DeleteBucketPolicy) || ($.eventName = DeleteBucketCors) || ($.eventName = DeleteBucketLifecycle) || ($.eventName = DeleteBucketReplication)) }
```

 and Click on 'Assign Metric'
- 6. In 'Create Metric Filter and Assign a Metric' page, Choose Filter Name, Metric Details parameter according to your requirement and click on 'Create Filter'
- 7. Click on 'Create Alarm',
 - In Step 1 specify metric details and conditions details as required and click on 'Next'
 - In Step 2 Select an SNS topic either by creating a new topic or use existing SNS topic/ARN and click on 'Next'

- In Step 3 Select name and description to alarm and click on 'Next'
- In Step 4 Preview your data entered and click on 'Create Alarm'

Incident response / Section Incident Monitoring, Reporting, and Response Assistance



2 Resource(s) Failed
058264157785, 818698786219

Compliance Section: Incident Monitoring, Reporting, and Response Assistance Informational

- a. Track and document system security incidents.
- b. Report suspected incidents to the organizational incident response capability within [Assignment: organization-defined time period].
- c. Report incident information to [Assignment: organization-defined authorities].
- d. Provide an incident response support resource that offers advice and assistance to system users on handling and reporting incidents.

AWS Log metric filter and alarm does not exist for VPC changes

This policy identifies the AWS regions which do not have a log metric filter and alarm for VPC changes. Monitoring changes to VPC will help ensure that resources and services are not unintentionally exposed. It is recommended that a metric filter and alarm be established for changes made to VPCs.

NOTE: This policy will trigger alert if you have at least one Cloudtrail with the multi trail is enabled, Logs all management events in your account and is not set with specific log metric filter and alarm.

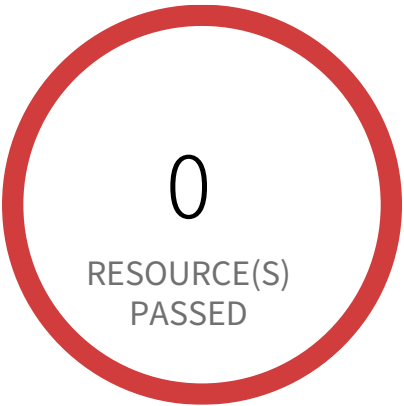
First Seen January 28, 2025 at 12:06:58 PM UTC | Resource Type Other

Recommendations

1. Sign in to AWS Console
2. Navigate to CloudWatch dashboard
3. Click on 'Log groups' in the 'Logs' section (Left panel)
4. Select the log group created for your CloudTrail trail event logs (CloudTrail should be multi trail enabled with all management events captured) and click 'Create Metric Filter' button.
5. In 'Define Logs Metric Filter' page, add 'Filter pattern' value as
{ (\$.eventName = CreateVpc) || (\$.eventName = DeleteVpc) || (\$.eventName = ModifyVpcAttribute) || (\$.eventName = AcceptVpcPeeringConnection) || (\$.eventName = CreateVpcPeeringConnection) || (\$.eventName = DeleteVpcPeeringConnection) || (\$.eventName = RejectVpcPeeringConnection) || (\$.eventName = AttachClassicLinkVpc) || (\$.eventName = DetachClassicLinkVpc) || (\$.eventName = DisableVpcClassicLink) || (\$.eventName = EnableVpcClassicLink) }
and Click on 'Assign Metric'
6. In 'Create Metric Filter and Assign a Metric' page, Choose Filter Name, Metric Details parameter according to your requirement and click on 'Create Filter'
7. Click on 'Create Alarm',
□- In Step 1 specify metric details and conditions details as required and click on 'Next'

- In Step 2 Select an SNS topic either by creating a new topic or use existing SNS topic/ARN and click on 'Next'
- In Step 3 Select name and description to alarm and click on 'Next'
- In Step 4 Preview your data entered and click on 'Create Alarm'

Incident response / Section Incident Monitoring, Reporting, and Response Assistance



2 Resource(s) Failed

058264157785, 818698786219

Compliance Section: Incident Monitoring, Reporting, and Response Assistance Informational

- a. Track and document system security incidents.
- b. Report suspected incidents to the organizational incident response capability within [Assignment: organization-defined time period].
- c. Report incident information to [Assignment: organization-defined authorities].
- d. Provide an incident response support resource that offers advice and assistance to system users on handling and reporting incidents.

AWS Log metric filter and alarm does not exist for disabling or scheduled deletion of customer created CMKs

This policy identifies the AWS regions which do not have a log metric filter and alarm for disabling or scheduled deletion of customer created CMKs. Data encrypted with disabled or deleted keys will no longer be accessible. It is recommended that a metric filter and alarm be established for customer created CMKs which have changed state to disabled or scheduled deletion.

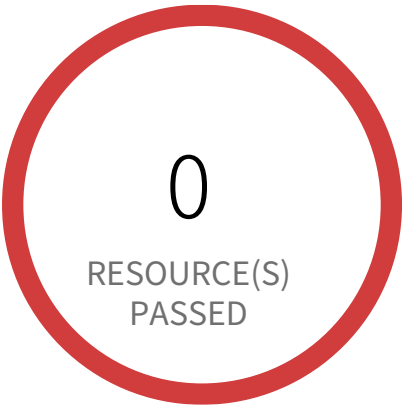
NOTE: This policy will trigger alert if you have at least one Cloudtrail with the multi trail is enabled, Logs all management events in your account and is not set with specific log metric filter and alarm.

First Seen January 28, 2025 at 12:06:58 PM UTC | **Resource Type** Other

Recommendations

1. Sign in to AWS Console
2. Navigate to CloudWatch dashboard
3. Click on 'Log groups' in the 'Logs' section (Left panel)
4. Select the log group created for your CloudTrail trail event logs (CloudTrail should be multi trail enabled with all management events captured) and click 'Create Metric Filter' button.
5. In 'Define Logs Metric Filter' page, add 'Filter pattern' value as `{ ($.eventSource = kms.amazonaws.com) && (($.eventName=DisableKey)||($.eventName=ScheduleKeyDeletion)) }` and Click on 'Assign Metric'
6. In 'Create Metric Filter and Assign a Metric' page, Choose Filter Name, Metric Details parameter according to your requirement and click on 'Create Filter'
7. Click on 'Create Alarm',
 - In Step 1 specify metric details and conditions details as required and click on 'Next'
 - In Step 2 Select an SNS topic either by creating a new topic or use existing SNS topic/ARN and click on 'Next'
 - In Step 3 Select name and description to alarm and click on 'Next'
 - In Step 4 Preview your data entered and click on 'Create Alarm'

Incident response / Section Incident Monitoring, Reporting, and Response Assistance



2 Resource(s) Failed
058264157785, 818698786219

Compliance Section: Incident Monitoring, Reporting, and Response Assistance — Informational

- a. Track and document system security incidents.
- b. Report suspected incidents to the organizational incident response capability within [Assignment: organization-defined time period].
- c. Report incident information to [Assignment: organization-defined authorities].
- d. Provide an incident response support resource that offers advice and assistance to system users on handling and reporting incidents.

AWS Log metric filter and alarm does not exist for unauthorized API calls

This policy identifies the AWS regions which do not have a log metric filter and alarm for unauthorized API calls. Monitoring unauthorized API calls will help reveal application errors and may reduce the time to detect malicious activity. It is recommended that a metric filter and alarm be established for unauthorized API calls.

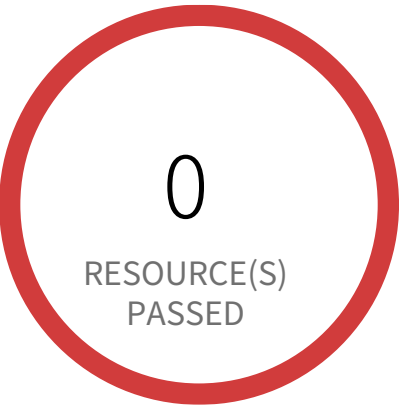
NOTE: This policy will trigger alert if you have at least one Cloudtrail with the multi trail is enabled, Logs all management events in your account and is not set with specific log metric filter and alarm.

First Seen January 28, 2025 at 12:07:04 PM UTC | **Resource Type** Other

Recommendations

1. Sign in to AWS Console
2. Navigate to CloudWatch dashboard
3. Click on 'Log groups' in the 'Logs' section (Left panel)
4. Select the log group created for your CloudTrail trail event logs (CloudTrail should be multi trail enabled with all management events captured) and click 'Create Metric Filter' button.
5. In 'Define Logs Metric Filter' page, add 'Filter pattern' value as `{ ($.errorCode = "*UnauthorizedOperation") || ($.errorCode = "AccessDenied*") }` and Click on 'Assign Metric'
6. In 'Create Metric Filter and Assign a Metric' page, Choose Filter Name, Metric Details parameter according to your requirement and click on 'Create Filter'
7. Click on 'Create Alarm',
 - In Step 1 specify metric details and conditions details as required and click on 'Next'
 - In Step 2 Select an SNS topic either by creating a new topic or use existing SNS topic/ARN and click on 'Next'
 - In Step 3 Select name and description to alarm and click on 'Next'
 - In Step 4 Preview your data entered and click on 'Create Alarm'

Incident response / Section Incident Monitoring, Reporting, and Response Assistance



2 Resource(s) Failed
058264157785, 818698786219

Compliance Section: Incident Monitoring, Reporting, and Response Assistance — Informational

- a. Track and document system security incidents.
- b. Report suspected incidents to the organizational incident response capability within [Assignment: organization-defined time period].
- c. Report incident information to [Assignment: organization-defined authorities].
- d. Provide an incident response support resource that offers advice and assistance to system users on handling and reporting incidents.

AWS Log metric filter and alarm does not exist for usage of root account

This policy identifies the AWS regions that do not have a log metric filter and alarm for usage of a root account. Monitoring for root account logins will provide visibility into the use of a fully privileged account and an opportunity to reduce its use it. Failure to monitor root account logins may result in a lack of visibility into unauthorized use or attempts to access the root account, posing potential security risks to your AWS environment. It is recommended that a metric filter and alarm be established for detecting changes to CloudTrail's configurations.

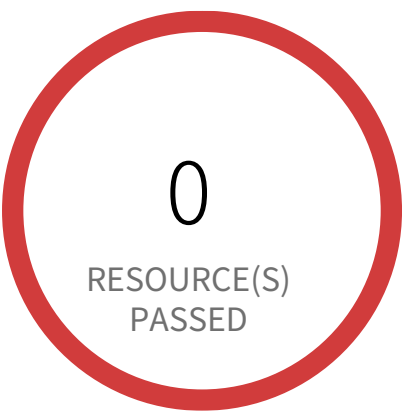
NOTE: This policy will trigger alert if you have at least one Cloudtrail with the multi trial is enabled, Logs all management events in your account and is not set with specific log metric filter and alarm.

First Seen January 28, 2025 at 12:06:58 PM UTC | **Resource Type** Other

Recommendations

1. Sign in to the AWS Console.
2. Navigate to the CloudWatch dashboard.
3. Click on 'Log groups' in the 'Logs' section (Left panel)
4. Select the log group created for your CloudTrail trail event logs (Cloudtrail should be multi-trail enabled with all Management Events captured) and click the Actions Dropdown Button -> Click 'Create Metric Filter' button.
5. In the 'Define Pattern' page, add the 'Filter pattern' value as `{ $.userIdentity.type = "Root" && $.userIdentity.invokedBy NOT EXISTS && $.eventType != "AwsServiceEvent" }` and Click on 'NEXT'.
6. In the 'Assign Metric' page, Choose Filter Name, and Metric Details parameter according to your requirement and click on 'Next'.
7. Under the 'Review and Create' page, Review details and click 'Create Metric Filter'.
8. To create an alarm based on a log group-metric filter, Refer to the below link
https://docs.aws.amazon.com/AmazonCloudWatch/latest/monitoring/Create_alarm_log_group_metric_filter.html

Incident response / Section Incident Monitoring, Reporting, and Response Assistance



1 Resource(s) Failed
synthwave-stage-h8hn89cnu394

Compliance Section: Incident Monitoring, Reporting, and Response Assistance — Informational

- a. Track and document system security incidents.
- b. Report suspected incidents to the organizational incident response capability within [Assignment: organization-defined time period].
- c. Report incident information to [Assignment: organization-defined authorities].
- d. Provide an incident response support resource that offers advice and assistance to system users on handling and reporting incidents.

AWS Redshift database does not have audit logging enabled

Audit logging is not enabled by default in Amazon Redshift. When you enable logging on your cluster, Amazon Redshift creates and uploads logs to Amazon S3 that capture data from the creation of the cluster to the present time.

First Seen February 19, 2025 at 5:10:47 PM UTC | **Resource Type** Managed Database

Recommendations

- 1. Login to AWS Console.
- 2. Goto Amazon Redshift service
- 3. On left navigation panel, click on Clusters
- 4. Click on the reported cluster
- 5. Click on Database tab and choose 'Configure Audit Logging'
- 6. On Enable Audit Logging, choose 'Yes'
- 7. Create a new s3 bucket or use an existing bucket
- 8. click Save

6

System and Communications Protection

An abstract graphic consisting of several thick, dark gray curved lines that overlap and intersect, creating a sense of motion or a network-like structure. The lines are positioned below the main title and above the page number.

System and Communications Protection Overview

Section			Pass Rate	Failed	Passed
Boundary Protection	AWS Amazon Machine Image (AMI) is publicly accessible	●●●● Low	100%	0	7
Boundary Protection	AWS CloudFormation template contains globally open resources	●●●● Low	100%	0	55
Boundary Protection	AWS CloudFront web distribution with AWS Web Application Firewall...	Informational	100%	0	0
Boundary Protection	AWS CloudFront web distribution with geo restriction disabled	●●●● Low	100%	0	0
Boundary Protection	AWS CloudTrail bucket is publicly accessible	●●●● Low	100%	0	25
Boundary Protection	AWS EBS Snapshot with access for unmonitored cloud accounts	●●●● Low	16%	5	1
Boundary Protection	AWS EBS snapshots are accessible to public	●●●● Medium	100%	0	6
Boundary Protection	AWS EKS cluster endpoint access publicly enabled	●●●● Low	0%	1	0
Boundary Protection	AWS Elasticsearch domain publicly accessible	●●●● Medium	100%	0	0

Section			Pass Rate	Failed	Passed
Boundary Protection	AWS Private ECR repository policy is overly permissive Medium	100%	0	6	
Boundary Protection	AWS RDS Snapshot with access for unmonitored cloud accounts Low	100%	0	5	
Boundary Protection	AWS RDS database instance is publicly accessible Medium	100%	0	1	
Boundary Protection	AWS RDS snapshots are accessible to public Medium	100%	0	5	
Boundary Protection	AWS S3 bucket accessible to unmonitored cloud accounts Low	68%	8	17	
Boundary Protection	AWS S3 buckets are accessible to any authenticated user Medium	100%	0	25	
Boundary Protection	AWS S3 buckets are accessible to public via ACL High	88%	3	22	
Network Communications – Deny by Default – Allow by Exception	AWS Low	50%	25	25	
Network Communications – Deny by Default – Allow by Exception	AWS Low	96%	2	48	
Network Communications – Deny by Default – Allow by Exception	Informational	100%	0	0	
Network Communications – Deny by Default – Allow by Exception	Informational	100%	0	0	

Section		Pass Rate	Failed	Passed
Network Communications – Deny by Default – Allow by Exception	Informational	100%	0	189
Network Communications – Deny by Default – Allow by Exception	Medium	100%	0	189
Network Communications – Deny by Default – Allow by Exception	Informational	100%	0	50
Network Communications – Deny by Default – Allow by Exception	Medium	78%	11	39
Network Communications – Deny by Default – Allow by Exception	Low	100%	0	36
Transmission and Storage Confidentiality	Medium	100%	0	0
Transmission and Storage Confidentiality	Medium	100%	0	0
Transmission and Storage Confidentiality	Low	100%	0	0
Transmission and Storage Confidentiality	Low	100%	0	0
Transmission and Storage Confidentiality	Low	100%	0	0
Transmission and Storage Confidentiality	Low	100%	0	0

Section		Pass Rate	Failed	Passed
Transmission and Storage Confidentiality	AWS EBS volume region with encryption is... Low	0%	17	0
Transmission and Storage Confidentiality	AWS ECS Cluster instance volume encryp... Low	100%	0	17
Transmission and Storage Confidentiality	AWS EMR cluster is not enabled with data... Low	100%	0	0
Transmission and Storage Confidentiality	AWS EMR cluster is not enabled with data... Low	100%	0	0
Transmission and Storage Confidentiality	AWS ElastiCache Memcached cluster with... Low	100%	0	0
Transmission and Storage Confidentiality	AWS ElastiCache Redis cluster with encryp... Low	100%	0	0
Transmission and Storage Confidentiality	AWS ElastiCache Redis with in-transit en... Low	100%	0	0
Transmission and Storage Confidentiality	AWS Elastic File System (EFS) with encryp... Low	100%	0	0
Transmission and Storage Confidentiality	AWS Elastic Load Balancer (Classic) SSL ne... Low	100%	0	0
Transmission and Storage Confidentiality	AWS Elastic Load Balancer v2 (ELBv2) SSL... Low	100%	0	1
Transmission and Storage Confidentiality	AWS Elastic Load Balancer v2 (ELBv2)... Medium	100%	0	1

Section		Pass Rate	Failed	Passed
Transmission and Storage Confidentiality	AWS Elastic Load Balancer v2 (ELBv2) with... Low	0%	1	0
Transmission and Storage Confidentiality	AWS Elastic Load Balancer with listener... Low	100%	0	0
Transmission and Storage Confidentiality	AWS Elasticsearch domain Encryption for... Low	100%	0	0
Transmission and Storage Confidentiality	AWS Glue connection do not have SSL con... Low	100%	0	0
Transmission and Storage Confidentiality	AWS MSK cluster encrvption in transit is... Medium	100%	0	0
Transmission and Storage Confidentiality	AWS Redshift does not have require ssl... Low	0%	1	0
Transmission and Storage Confidentiality	AWS Redshift instances are not encrypted Low	0%	1	0
Transmission and Storage Confidentiality	AWS S3 bucket not configured with se... Medium	88%	3	22
Transmission and Storage Confidentiality	AWS S3 buckets do not have server side en... Low	100%	0	25
Transmission and Storage Confidentiality	AWS SageMaker notebook instance not... Low	100%	0	0
Transmission and Storage Confidentiality	AWS SageMaker notebook instance Informational	100%	0	0

Section		Pass Rate	Failed	Passed
Cryptographic Key Establishment and Management	AWS Certificate Manager... Low	100%	0	0
Cryptographic Key Establishment and Management	AWS Customer... Informational	93%	2	29
Cryptographic Key Establishment and Management	AWS DynamoDB... Informational	100%	0	0
Cryptographic Key Establishment and Management	AWS EMR cluster... Informational	100%	0	0
Cryptographic Key Establishment and Management	AWS EMR cluster is not en... Low	100%	0	0
Cryptographic Key Establishment and Management	AWS Elastic File... Informational	100%	0	0
Cryptographic Key Establishment and Management	AWS Elastic Load... Informational	100%	0	0
Cryptographic Key Establishment and Management	AWS Elastic Load... Informational	100%	0	0
Cryptographic Key Establishment and Management	AWS IAM SSH keys for AWS... Low	100%	0	0
Cryptographic Key Establishment and Management	AWS IAM has expired... Low	100%	0	0
Cryptographic Key Establishment and Management	AWS IAM user has... Informational	100%	0	52

Section		Pass Rate	Failed	Passed
Cryptographic Key Establishment and Management	AWS KMS Key... Informational	100%	0	31
Cryptographic Key Establishment and Management	AWS KMS cus... Informational	100%	0	31
Cryptographic Key Establishment and Management	AWS Kinesis... Informational	100%	0	0
Cryptographic Key Establishment and Management	AWS RDS DB clus... Informational	100%	0	0
Cryptographic Key Establishment and Management	AWS RDS data... Informational	100%	0	1
Cryptographic Key Establishment and Management	AWS Redshift... Informational	100%	0	1
Cryptographic Key Establishment and Management	AWS SOS queue... Informational	100%	0	0
Cryptographic Key Establishment and Management	AWS access keys are not... Low	9%	47	5
Cryptographic Key Establishment and Management	AWS access keys... Informational	9%	47	5

System and Communications Protection / Section Boundary Protection



0 Resource(s) Failed

Compliance Section: Boundary Protection ●●●● Low

- a. Monitor and control communications at external managed interfaces to the system and key internal managed interfaces within the system.
- b. Implement subnetworks for publicly accessible system components that are physically or logically separated from internal networks.
- c. Connect to external systems only through managed interfaces that consist of boundary protection devices arranged in accordance with an organizational security architecture.

AWS Amazon Machine Image (AMI) is publicly accessible

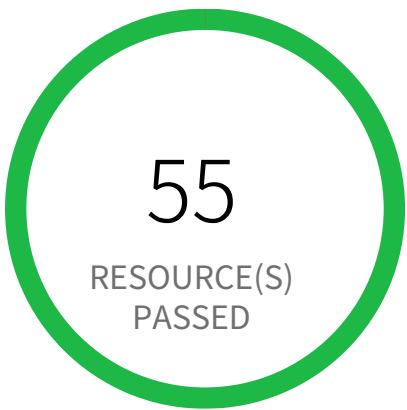
This policy identifies AWS AMIs which are owned by the AWS account and are accessible to the public. Amazon Machine Image (AMI) provides information to launch an instance in the cloud. The AMIs may contain proprietary customer information and should be accessible only to authorized internal users.

First Seen N/A | **Resource Type** VM Image

Recommendations

- 1. Login to the AWS Console and navigate to 'EC2' service.
- 2. In the navigation pane, choose AMIs.
- 3. Select your AMI from the list, and then choose Actions, Modify Image Permissions.
- 4. Choose Private and choose Save.

System and Communications Protection / Section Boundary Protection



0 Resource(s) Failed

Compliance Section: Boundary Protection ●●●● Low

- a. Monitor and control communications at external managed interfaces to the system and key internal managed interfaces within the system.
- b. Implement subnetworks for publicly accessible system components that are physically or logically separated from internal networks.
- c. Connect to external systems only through managed interfaces that consist of boundary protection devices arranged in accordance with an organizational security architecture.

AWS CloudFormation template contains globally open resources

This alert triggers if a CloudFormation template that when launched will result in resources allowing global network access. Below are three common causes:

- Security Group with a {0.0.0.0/0, ::/0} rule
- Network Access Control List with a {0.0.0.0/0, ::/0} rule
- Network Access Control List with -1 IpProtocol

First Seen N/A | **Resource Type** Other

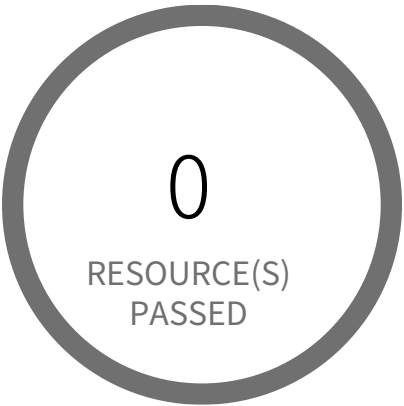
Recommendations

Prisma Cloud encourages you to review the template and ensure this is the intended behavior.

1. Goto the AWS CloudFormation dashboard.
2. Click on the Stack you want to modify.
3. Select the Template tab and then View in Designer.
4. Make your template modifications.
5. Check for syntax errors in your template by choosing Validate template near the top of the page.
6. Select Save from the file (icon) menu.
7. Choose Amazon S3 bucket, name your template and Save.
8. Copy the bucket URL and click OK.
9. Select Close to close Designer.
10. Click on the Stack you want to modify.
11. From the Actions pull down menu, select Update stack
12. Choose Replace current template and paste the URL from Designer into the Amazon S3 URL field. Then click on Next.
13. Specify stack details, then click on Next.

14. Configure stack options, then click on Next.
15. Review, then select Update stack near the bottom of the page.

System and Communications Protection / Section Boundary Protection



0 Resource(s) Failed

Compliance Section: Boundary Protection — Informational

- a. Monitor and control communications at external managed interfaces to the system and key internal managed interfaces within the system.
- b. Implement subnetworks for publicly accessible system components that are physically or logically separated from internal networks.
- c. Connect to external systems only through managed interfaces that consist of boundary protection devices arranged in accordance with an organizational security architecture.

AWS CloudFront web distribution with AWS Web Application Firewall (AWS WAF) service disabled

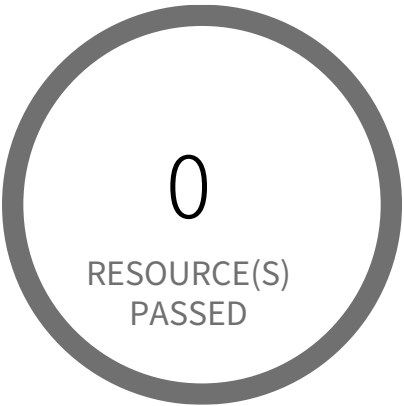
This policy identifies Amazon CloudFront web distributions which have the AWS Web Application Firewall (AWS WAF) service disabled. As a best practice, enable the AWS WAF service on CloudFront web distributions to protect against application layer attacks. To block malicious requests to your Cloudfront Content Delivery Network, define the block criteria in the WAF web access control list (web ACL).

First Seen N/A | **Resource Type** Other

Recommendations

1. Sign in to the AWS console
2. Go to the CloudFront Distributions Dashboard
3. Click on the reported web distribution
4. On 'General' tab, Click on 'Edit' button
5. On 'Edit Distribution' page, Choose a 'AWS WAF Web ACL' from dropdown.
6. Click on 'Yes, Edit'

System and Communications Protection / Section Boundary Protection



0 Resource(s) Failed

Compliance Section: Boundary Protection ●●●● Low

- a. Monitor and control communications at external managed interfaces to the system and key internal managed interfaces within the system.
- b. Implement subnetworks for publicly accessible system components that are physically or logically separated from internal networks.
- c. Connect to external systems only through managed interfaces that consist of boundary protection devices arranged in accordance with an organizational security architecture.

AWS CloudFront web distribution with geo restriction disabled

This policy identifies CloudFront web distributions which have geo restriction feature disabled. Geo Restriction has the ability to block IP addresses based on Geo IP by allowlist or denylist a country in order to allow or restrict users in specific locations from accessing web application content.

First Seen N/A | **Resource Type** Other

Recommendations

1. Sign in to the AWS console
2. Select the region, from the region drop-down, in which the alert is generated
3. Navigate to CloudFront Distributions Dashboard
4. Click on the reported distribution
5. On 'Restrictions' tab, Click on the 'Edit' button
6. On 'Edit Geo-Restrictions' page, Set 'Enable Geo-Restriction' to 'Yes' and allowlist/denylist countries as per your requirement.
7. Click on 'Yes, Edit'

System and Communications Protection / Section Boundary Protection



0 Resource(s) Failed

Compliance Section: Boundary Protection ●●●● Low

- a. Monitor and control communications at external managed interfaces to the system and key internal managed interfaces within the system.
- b. Implement subnetworks for publicly accessible system components that are physically or logically separated from internal networks.
- c. Connect to external systems only through managed interfaces that consist of boundary protection devices arranged in accordance with an organizational security architecture.

AWS CloudTrail bucket is publicly accessible

This policy identifies publicly accessible S3 buckets that store CloudTrail data. These buckets contains sensitive audit data and only authorized users and applications should have access.

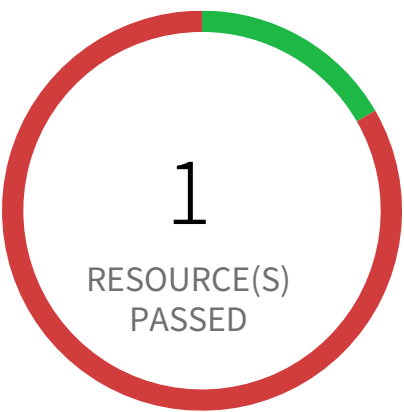
First Seen N/A | **Resource Type** Other

Recommendations

- 1. Login to the AWS Console
- 2. Navigate to the 'S3' service
- 3. Click on the 'S3' resource reported in the alert
- 4. Click on the 'Permissions'
- 5. If 'Access Control List' is set to 'Public' follow below steps
 - a. Under 'Access Control List', Click on 'Everyone' and uncheck all items
 - b. Click on Save
- 6. If 'Bucket Policy' is set to public follow below steps
 - a. Under 'Bucket Policy', modify the policy to remove public access
 - b. Click on Save
 - c. If 'Bucket Policy' is not required delete the existing 'Bucket Policy'.

Note: Make sure updating 'Access Control List' or 'Bucket Policy' does not affect S3 bucket data access.

System and Communications Protection / Section Boundary Protection



5 Resource(s) Failed

snap-0d47c6cb9d3f1f396,
snap-0bf35b272167e62d2,
snap-036d0921bbb8d3125,
snap-04de50de9719b6b47,
snap-0f097a5ddc78b9b04

Compliance Section: Boundary Protection ●●●● Low

- a. Monitor and control communications at external managed interfaces to the system and key internal managed interfaces within the system.
- b. Implement subnetworks for publicly accessible system components that are physically or logically separated from internal networks.
- c. Connect to external systems only through managed interfaces that consist of boundary protection devices arranged in accordance with an organizational security architecture.

AWS EBS Snapshot with access for unmonitored cloud accounts

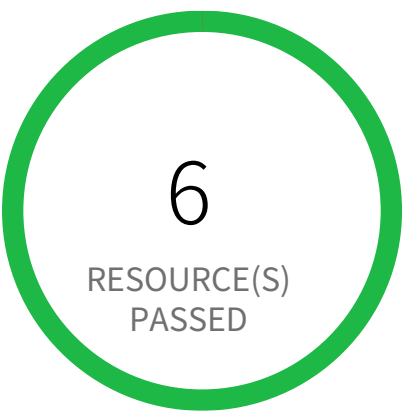
This policy identifies EBS Snapshot with access for unmonitored cloud accounts. The EBS Snapshots which have either the read / write permission opened up for Cloud Accounts which are NOT part of Cloud Accounts monitored by Prisma Cloud. These accounts with read / write privileges should be reviewed and confirmed that these are valid accounts of your organisation (or authorised by your organisation) and are not active under Prisma Cloud monitoring.

First Seen March 14, 2025 at 1:51:58 AM UTC | **Resource Type** Other

Recommendations

1. Sign in to the AWS console.
2. In the console, select the specific region from region drop down on the top right corner, for which the alert is generated.
3. Access the EC2 service, navigate to 'Snapshots' under 'Elastic Block Store' in left hand menu.
4. Select the identified 'EBS Snapshot' and select the tab 'Permissions'.
5. Review and delete the AWS Accounts which should not have read access.

System and Communications Protection / Section Boundary Protection



0 Resource(s) Failed

Compliance Section: Boundary Protection ●●● Medium

- a. Monitor and control communications at external managed interfaces to the system and key internal managed interfaces within the system.
- b. Implement subnetworks for publicly accessible system components that are physically or logically separated from internal networks.
- c. Connect to external systems only through managed interfaces that consist of boundary protection devices arranged in accordance with an organizational security architecture.

AWS EBS snapshots are accessible to public

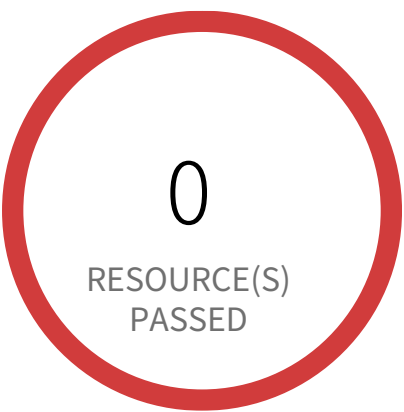
This policy identifies EC2 EBS snapshots which are accessible to public. Amazon Elastic Block Store (Amazon EBS) provides persistent block storage volumes for use with Amazon EC2 instances in the AWS Cloud. If EBS snapshots are inadvertently shared to public, any unauthorized user with AWS console access can gain access to the snapshots and gain access to sensitive data.

First Seen N/A | **Resource Type** Snapshot Settings

Recommendations

1. Log in to the AWS console
2. In the console, select the specific region from region drop down on the top right corner, for which the alert is generated
3. Navigate to 'EC2' service.
4. Under the 'Elastic Block Storage', click on the 'Snapshots'.
5. For the specific Snapshots, change the value of field 'Property' to 'Private'.
6. Under the section 'Encryption Details', set the value of 'Encryption Enabled' to 'Yes'.

System and Communications Protection / Section Boundary Protection



1 Resource(s) Failed
pc-national-bank

Compliance Section: Boundary Protection ●●●● Low

- a. Monitor and control communications at external managed interfaces to the system and key internal managed interfaces within the system.
- b. Implement subnetworks for publicly accessible system components that are physically or logically separated from internal networks.
- c. Connect to external systems only through managed interfaces that consist of boundary protection devices arranged in accordance with an organizational security architecture.

AWS EKS cluster endpoint access publicly enabled

When you create a new cluster, Amazon EKS creates an endpoint for the managed Kubernetes API server that you use to communicate with your cluster (using Kubernetes management tools such as kubectl). By default, this API server endpoint is public to the internet, and access to the API server is secured using a combination of AWS Identity and Access Management (IAM) and native Kubernetes Role Based Access Control (RBAC).

This policy checks your Kubernetes cluster endpoint access and triggers an alert if publicly enabled.

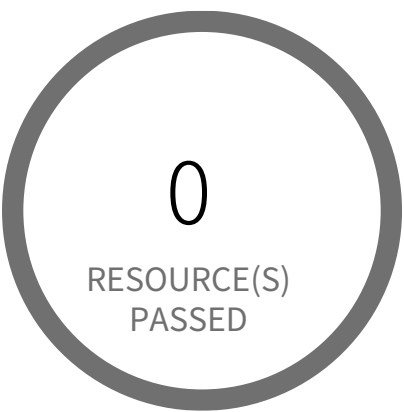
First Seen June 11, 2024 at 6:11:26 PM UTC | Resource Type Other

Recommendations

Enable private access to the Kubernetes API server so that all communication between your worker nodes and the API server stays within your VPC. Disable public access to your API server so that it's not accessible from the internet.

1. Login to AWS Console
2. Navigate to the Amazon EKS dashboard
3. Choose the name of the cluster to display your cluster information
4. Under Networking, choose 'Manage networking'
5. Select 'Private' radio button
6. Click on 'Save changes'

System and Communications Protection / Section Boundary Protection



0 Resource(s) Failed

Compliance Section: Boundary Protection ●●●● Medium

- a. Monitor and control communications at external managed interfaces to the system and key internal managed interfaces within the system.
- b. Implement subnetworks for publicly accessible system components that are physically or logically separated from internal networks.
- c. Connect to external systems only through managed interfaces that consist of boundary protection devices arranged in accordance with an organizational security architecture.

AWS Elasticsearch domain publicly accessible

This policy identifies Elasticsearch domains which are publicly accessible. Enabling VPCs for Elasticsearch domains provides flexibility and control over the clusters access with an extra layer of security than Elasticsearch domains that use public endpoints. It also keeps all traffic between your VPC and Elasticsearch domains within the AWS network instead of going over the public Internet.

First Seen N/A | **Resource Type** Other

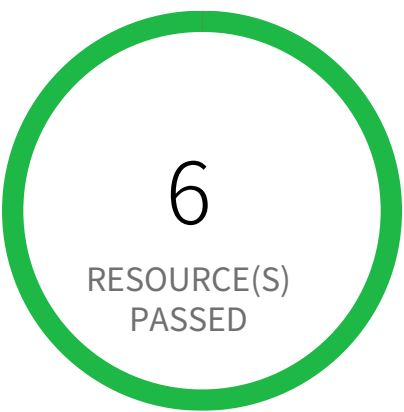
Recommendations

VPC for AWS Elasticsearch domain can be set only at the time of the creation of domain. So to resolve this alert, create a new domain with VPC, then migrate all required Elasticsearch domain data from the reported Elasticsearch domain to this newly created domain and delete reported Elasticsearch domain.

To set up the new ES domain with VPC, refer the following URL:
<https://docs.aws.amazon.com/elasticsearch-service/latest/developerguide/es-createupdatedomains.html>
To create Elasticsearch domain within VPC, In Network configuration choose VPC access instead of Public access.

To delete reported ES domain, refer the following URL:
<https://docs.aws.amazon.com/elasticsearch-service/latest/developerguide/es-gsg-deleting.html>

System and Communications Protection / Section Boundary Protection



0 Resource(s) Failed

Compliance Section: Boundary Protection ●●● Medium

- a. Monitor and control communications at external managed interfaces to the system and key internal managed interfaces within the system.
- b. Implement subnetworks for publicly accessible system components that are physically or logically separated from internal networks.
- c. Connect to external systems only through managed interfaces that consist of boundary protection devices arranged in accordance with an organizational security architecture.

AWS Private ECR repository policy is overly permissive

This policy identifies AWS Private ECR repositories that have overly permissive registry policies. An ECR(Elastic Container Registry) repository is a collection of Docker images available on the AWS cloud. These images might contain sensitive information which should be restricted to unauthorized users.

First Seen N/A | **Resource Type** Other

Recommendations

- 1. Log in to the AWS Console
- 2. In the console, select the specific region from region drop down on the top right corner, for which the alert is generated.
- 3. Navigate to 'ECR' dashboard from 'Services' dropdown
- 4. Go to 'Repository', from the left panel
- 5. Select the repository for which alert is being generated
- 6. Select the 'Permissions' option from left menu below 'repositories'
- 7. Click on 'Edit policy JSON' to modify the JSON so that Principal is restrictive
- 8. After modifications, click on 'Save'.

System and Communications Protection / Section Boundary Protection



0 Resource(s) Failed

Compliance Section: Boundary Protection ●●●● Low

- a. Monitor and control communications at external managed interfaces to the system and key internal managed interfaces within the system.
- b. Implement subnetworks for publicly accessible system components that are physically or logically separated from internal networks.
- c. Connect to external systems only through managed interfaces that consist of boundary protection devices arranged in accordance with an organizational security architecture.

AWS RDS Snapshot with access for unmonitored cloud accounts

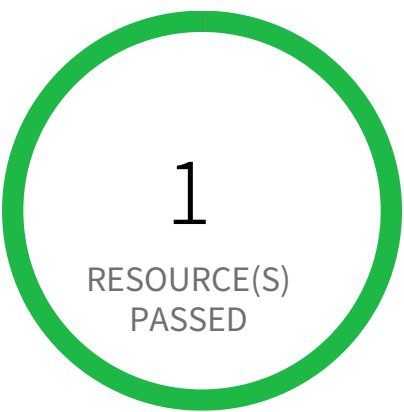
This policy identifies RDS snapshots with access for unmonitored cloud accounts. The RDS Snapshot which have either the read / write permission opened up for Cloud Accounts which are NOT part of Cloud Accounts monitored by Prisma Cloud. These accounts with read / write privileges should be reviewed and confirmed that these are valid accounts of your organisation (or authorised by your organisation) and are not active under Prisma Cloud monitoring.

First Seen N/A | **Resource Type** Other

Recommendations

1. Sign into the AWS console.
2. In the console, select the specific region from region drop down on the top right corner, for which the alert is generated
3. Navigate to the RDS service.
4. Select the identified 'RDS Snapshot' under the 'Snapshots' in the left hand menu.
5. Under the tab 'Snapshot Actions', selection the option 'Share Snapshot'.
6. Review and delete the AWS Accounts which should not have read access.

System and Communications Protection / Section Boundary Protection



0 Resource(s) Failed

Compliance Section: Boundary Protection ●●● Medium

- a. Monitor and control communications at external managed interfaces to the system and key internal managed interfaces within the system.
- b. Implement subnetworks for publicly accessible system components that are physically or logically separated from internal networks.
- c. Connect to external systems only through managed interfaces that consist of boundary protection devices arranged in accordance with an organizational security architecture.

AWS RDS database instance is publicly accessible

This policy identifies RDS database instances which are publicly accessible. DB instances should not be publicly accessible to protect the integrity of data. Public accessibility of DB instances can be modified by turning on or off the Public accessibility parameter.

First Seen N/A | **Resource Type** Other

Recommendations

To modify the RDS database publicly accessible setting:

1. Sign into the AWS console.
2. In the console, select the specific region from region drop down on the top right corner, for which the alert is generated
3. In the AWS console, locate and select the 'Aurora and RDS' service.
4. In the left navigation pane, click on 'Databases'. From the list of databases, locate and click on the DB identifier (name) of the specific RDS instance mentioned in the alert.
4. Click on the 'Modify' button to access the instance configuration settings.
5. Under the 'Connectivity' section expand to 'Additional configuration', locate the 'Public access' setting. Change the value to 'Not publicly accessible' to disable public access to the instance.
6. Click on 'Continue' to proceed to the next step. Select the desired 'Scheduling of modifications' option and click on 'Modify DB Instance' to apply the changes.

Note: Carefully review and test these steps before implementing them in your production environment. Modifying RDS instance settings can impact your application's functionality. Ensure you have a backup plan in place before making any changes.

System and Communications Protection / Section Boundary Protection



0 Resource(s) Failed

Compliance Section: Boundary Protection ●●●● Medium

- a. Monitor and control communications at external managed interfaces to the system and key internal managed interfaces within the system.
- b. Implement subnetworks for publicly accessible system components that are physically or logically separated from internal networks.
- c. Connect to external systems only through managed interfaces that consist of boundary protection devices arranged in accordance with an organizational security architecture.

AWS RDS snapshots are accessible to public

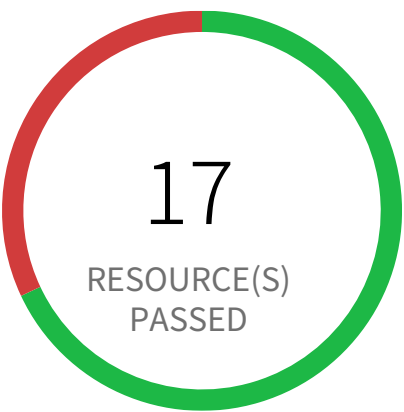
This policy identifies AWS RDS snapshots which are accessible to public. Amazon Relational Database Service (Amazon RDS) is a web service that makes it easier to setup and manage databases. If RDS snapshots are inadvertently shared to public, any unauthorized user with AWS console access can gain access to the snapshots and gain access to sensitive data.

First Seen N/A | **Resource Type** Managed Database Snapshot

Recommendations

- 1. Sign in to the AWS console
- 2. In the console, select the specific region from region drop down on the top right corner, for which the alert is generated
- 3. Navigate to the 'RDS' service.
- 4. For the RDS instance reported in the alert, change 'Publicly Accessible' setting to 'No'.

System and Communications Protection / Section Boundary Protection



8 Resource(s) Failed
pays-app-dev-jd3jnx92j3,
all-files-mxi29dnc2h92eh823h8934,
main-app-stage-2ncien92,
swiftapp-jdi92j98d3jnxdi32,
subs-dxh8f3n4x8f93, payments-dcnenh93,
maincon-ceio23hnx834,
micro-djm2983hdno3hnxdi23bh8d3yb289yd

Compliance Section: Boundary Protection ●●●● Low

- a. Monitor and control communications at external managed interfaces to the system and key internal managed interfaces within the system.
- b. Implement subnetworks for publicly accessible system components that are physically or logically separated from internal networks.
- c. Connect to external systems only through managed interfaces that consist of boundary protection devices arranged in accordance with an organizational security architecture.

AWS S3 bucket accessible to unmonitored cloud accounts

Unmonitored cloud accounts with read/write access to AWS S3 buckets pose a significant security risk. These accounts could potentially exfiltrate sensitive data or make unauthorized modifications.

AWS S3 buckets are cloud storage services. Granting read/write access to unmonitored cloud accounts bypasses security monitoring and control mechanisms. Attackers gaining access to such accounts could exploit this misconfiguration for data breaches or malicious activity.

The impact of this misconfiguration could be severe, including data loss, regulatory fines, and reputational damage. Restricting access to only authorized and monitored accounts ensures better control over data access and minimizes the risk of unauthorized actions.

To mitigate this risk, regularly review and update access control lists (ACLs) for all S3 buckets. Ensure that only trusted and monitored cloud accounts have necessary permissions. Implement strong authentication and authorization mechanisms and regularly audit access logs for suspicious activities.

First Seen June 19, 2025 at 7:34:42 AM UTC | **Resource Type** Other

Recommendations

1. Log in to the AWS Console
2. Navigate to the 'S3' service
3. Click on the reported S3 bucket
4. Click on the 'Permissions' tab
5. Navigate to the 'Access control list (ACL)' section and Click on the 'Edit'
6. Under 'Access for other AWS accounts', Add the Cloud Accounts that are monitored by Prisma Cloud
7. Click on 'Save changes'

System and Communications Protection / Section Boundary Protection



0 Resource(s) Failed

Compliance Section: Boundary Protection ●●●● Medium

- a. Monitor and control communications at external managed interfaces to the system and key internal managed interfaces within the system.
- b. Implement subnetworks for publicly accessible system components that are physically or logically separated from internal networks.
- c. Connect to external systems only through managed interfaces that consist of boundary protection devices arranged in accordance with an organizational security architecture.

AWS S3 buckets are accessible to any authenticated user

AWS S3 buckets configured with overly permissive access controls allow any authenticated user to access sensitive data. This misconfiguration exposes data to unauthorized internal users or compromised credentials.

AWS S3 buckets offer various access control mechanisms, including bucket policies and access control lists (ACLs). Incorrectly configuring these settings, allowing access to 'authenticated users', bypasses intended restrictions. Attackers with legitimate AWS credentials, even those with limited privileges, could access sensitive data stored in the bucket, leading to data breaches and potential regulatory violations.

Data breaches resulting from this misconfiguration can cause significant financial losses, reputational damage, and legal repercussions. Implementing least privilege access control ensures only authorized users and services can access specific S3 buckets and their contents, thereby minimizing the impact of compromised credentials.

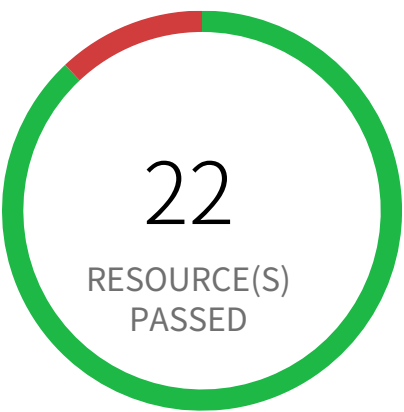
To mitigate this risk, restrict bucket access to specific IAM users, roles, or groups using granular policies. Implement strong access control lists, limiting access only to trusted IPs and services. Regularly review and audit bucket policies and ACLs to ensure appropriate access controls are maintained and updated as needed.

First Seen N/A | **Resource Type** Other

Recommendations

1. Sign in to the AWS Management Console and open the Amazon S3 console at <https://console.aws.amazon.com/s3/>.
2. In the left navigation pane, choose 'General purpose buckets'.
3. In the Buckets list, choose the name of the bucket that is reported.
4. Choose 'Permissions'.
5. Under 'Access control list (ACL)', choose 'Edit'.
6. To undo permissions for anyone with an AWS account, beside 'Authenticated Users group (anyone with an AWS account)', Uncheck the selection from the following ACL permissions: Objects – List, Bucket ACL – Read.
7. To save your changes, choose 'Save changes'.

System and Communications Protection / Section Boundary Protection



3 Resource(s) Failed
finance-secret-asdfsd3r53rtr-one, fi-
nance-secret-der4t4tg5ght-three, finance-se-
cret-der4t4tg5ght-two

Compliance Section: Boundary Protection ●●●● High

- a. Monitor and control communications at external managed interfaces to the system and key internal managed interfaces within the system.
- b. Implement subnetworks for publicly accessible system components that are physically or logically separated from internal networks.
- c. Connect to external systems only through managed interfaces that consist of boundary protection devices arranged in accordance with an organizational security architecture.

AWS S3 buckets are accessible to public via ACL

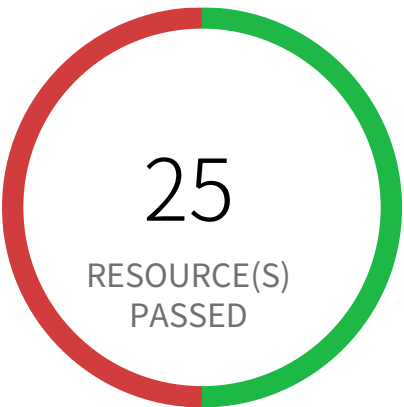
This policy identifies S3 buckets which are publicly accessible via ACL. Amazon S3 often used to store highly sensitive enterprise data and allowing public access to such S3 bucket through ACL would result in sensitive data being compromised. It is highly recommended to disable ACL configuration for all S3 buckets and use resource based policies to allow access to S3 buckets.

First Seen December 3, 2023 at 11:08:42 AM UTC | **Resource Type** Other

Recommendations

- 1. Login to the AWS Console
- 2. Navigate to the 'S3' service
- 3. Click on the 'S3' resource reported in the alert
- 4. Click on the 'Permissions'
- 5. If Access Control List' is set to 'Public' follow below steps
 - a. Under 'Access Control List', Click on 'Everyone' and uncheck all items
 - b. Click on Save

System and Communications Protection / Section Network Communications – Deny by Default – Allow by Exception



25 Resource(s) Failed
default & 15 more

Compliance Section: Network Communications – Deny by Default – Allow by Exception ●●●● Low

Deny network communications traffic by default, and allow network communications traffic by exception.

AWS Default Security Group does not restrict all traffic

This policy identifies the default security groups which does not restrict inbound and outbound traffic. A VPC comes with a default security group whose initial configuration denies all inbound traffic and allow all outbound traffic. If you do not specify a security group when you launch an instance, the instance is automatically assigned to this default security group. As a result, the instance may accidentally send outbound traffic. It is recommended that to remove any inbound and outbound rules in the default security group and not to attach the default security group to any resources.

First Seen June 11, 2024 at 6:11:28 PM UTC | **Resource Type** Other

Recommendations

Before making any changes, please check the impact on your applications/services.

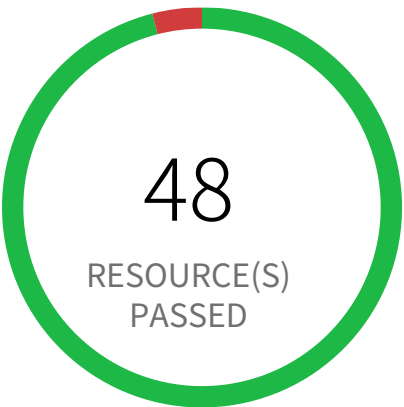
For Resources associated with the alerted security group:

- 1. Identify AWS resources that exist within the default security group
- 2. Create a set of least privilege security groups for those resources
- 3. Place the resources in those security groups
- 4. Remove the associated resources from the default security group

For alerted Security Groups:

- 1. Log in to the AWS console
- 2. In the console, select the specific region from the 'Region' drop-down on the top right corner, for which the alert is generated
- 3. Navigate to the 'VPC' service
- 4. For each region, Click on 'Security Groups' specific to the alert
- 5. On section 'Inbound rules', Click on 'Edit Inbound Rules' and remove the existing rule, click on 'Save'
- 6. On section 'Outbound rules', Click on 'Edit Outbound Rules' and remove the existing rule, click on 'Save'

System and Communications Protection / Section Network Communications – Deny by Default – Allow by Exception



2 Resource(s) Failed
eks-cluster-sg-pc-national-bank-425600227,
custom-security-group

Compliance Section: Network Communications – Deny by Default – Allow by Exception ●●●● Low

Deny network communications traffic by default, and allow network communications traffic by exception.

AWS EKS cluster security group overly permissive to all traffic

This policy identifies EKS cluster Security groups that are overly permissive to all traffic. Doing so, may allow a bad actor to brute force their way into the system and potentially get access to the entire network. Review your list of security group rules to ensure that your resources are not exposed. As a best practice, restrict traffic solely from known static IP addresses. Limit the access list to include known hosts, services, or specific employees only.

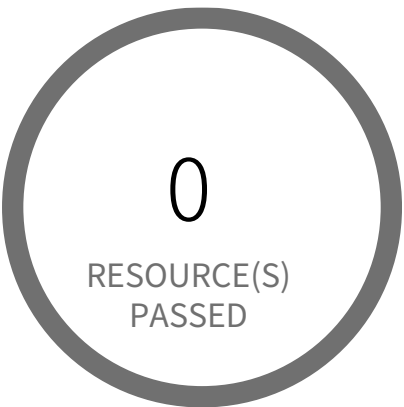
First Seen January 28, 2025 at 12:06:58 PM UTC | **Resource Type** Other

Recommendations

Before making any changes, please check the impact on your applications/services. If the Security Group reported indeed need to restrict all traffic, follow the instructions below:

- 1. Log in to the AWS console
- 2. Navigate to the 'VPC' service
- 3. Select the 'Security Group' reported in the alert
- 4. Click on 'Inbound Rules'
- 5. Remove the rule which has the 'Source' value as 0.0.0.0/0 or ::/0

System and Communications Protection / Section Network Communications – Deny by Default – Allow by Exception



0 Resource(s) Failed

Compliance Section: Network Communications – Deny by Default – Allow by Exception — Informational

Deny network communications traffic by default, and allow network communications traffic by exception.

AWS Elastic Load Balancer (ELB) has security group with no inbound rules

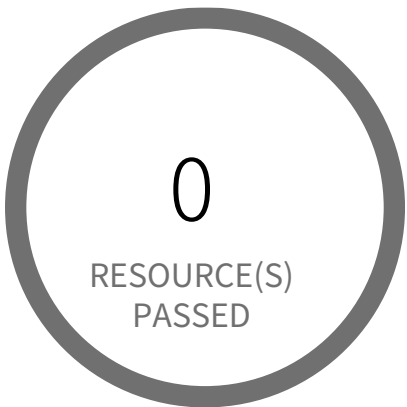
This policy identifies Elastic Load Balancers (ELB) which have security group with no inbound rules. A security group with no inbound rule will deny all incoming requests. ELB security groups should have at least one inbound rule, ELB with no inbound permissions will deny all traffic incoming to ELB; in other words, the ELB is useless without inbound permissions.

First Seen N/A | **Resource Type** Other

Recommendations

- 1. Sign into the AWS console
- 2. In the console, select the specific region from region drop down on the top right corner, for which the alert is generated
- 3. Navigate to EC2 Dashboard
- 4. Click on 'Load Balancers', choose the reported load balancer
- 5. Click on the 'Description' tab, click on the security group, it will open Security Group properties in a new tab in your browser
- 6. Click on the 'Inbound Rules'
- 7. If there are no rules, click on 'Edit rules', add an inbound rule according to your ELB functional requirement
- 8. Click on 'Save'

System and Communications Protection / Section Network Communications – Deny by Default – Allow by Exception



0 Resource(s) Failed

Compliance Section: Network Communications – Deny by Default – Allow by Exception — Informational

Deny network communications traffic by default, and allow network communications traffic by exception.

AWS Elastic Load Balancer (ELB) has security group with no outbound rules

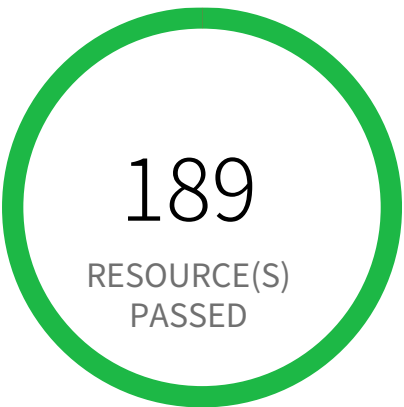
This policy identifies Elastic Load Balancers (ELB) which have security group with no outbound rules. A security group with no outbound rule will deny all outgoing requests. ELB security groups should have at least one outbound rule, ELB with no outbound permissions will deny all traffic going to any EC2 instances or resources configured behind that ELB; in other words, the ELB is useless without outbound permissions.

First Seen N/A | **Resource Type** Other

Recommendations

1. Log in to the AWS console
2. In the console, select the specific region from region drop down on the top right corner, for which the alert is generated
3. Navigate to EC2 Dashboard
4. Click on 'Load Balancers', choose the reported load balancer
5. Click on the 'Description' tab, click on the security group, it will open Security Group properties in a new tab in your browser
6. Click on the 'Outbound Rules'
7. If there are no rules, click on 'Edit rules', add an outbound rule according to your ELB functional requirement
8. Click on 'Save'

System and Communications Protection / Section Network Communications – Deny by Default – Allow by Exception



0 Resource(s) Failed

Compliance Section: Network Communications – Deny by Default – Allow by Exception Informational

Deny network communications traffic by default, and allow network communications traffic by exception.

AWS Elasticsearch IAM policy overly permissive to all traffic

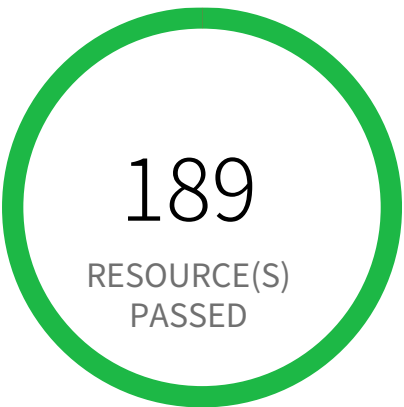
This policy identifies Elasticsearch IAM policies that are overly permissive to all traffic. Amazon Elasticsearch service makes it easy to deploy and manage Elasticsearch. Customers can create a domain where the service is accessible. The domain should be granted access restrictions so that only authorized users and applications have access to the service.

First Seen N/A | **Resource Type** Other

Recommendations

- 1. Log in to AWS console
- 2. Goto the IAM Services
- 3. Click on 'Policies' in the left-hand panel
- 4. Search for the Policy for which the Alert is generated and click on it
- 5. Under the Permissions tab, click on Edit policy
- 6. Under the Visual editor, for each of the 'Elasticsearch Service', click to expand and perform following.
 - 6.a. Click to expand 'Request conditions'
 - 6.b. Under the 'Source IP', remove the row with the entry '0.0.0.0/0' or ':::/0'. Add condition with restrictive IP ranges.
- 7. Click on Review policy and Save changes.

System and Communications Protection / Section Network Communications – Deny by Default – Allow by Exception



0 Resource(s) Failed

Compliance Section: Network Communications – Deny by Default – Allow by Exception ●●● Medium

Deny network communications traffic by default, and allow network communications traffic by exception.

AWS SageMaker notebook instance IAM policy overly permissive to all traffic

This policy identifies SageMaker notebook instances IAM policies that are overly permissive to all traffic. It is recommended that the SageMaker notebook instances should be granted access restrictions so that only authorized users and applications have access to the service.

For more details:
https://docs.aws.amazon.com/sagemaker/latest/dg/security_iam_id-based-policy-examples.html

First Seen N/A | **Resource Type** Other

Recommendations

- 1. Login to AWS console
- 2. Goto IAM Services
- 3. Click on 'Policies' in left hand panel
- 4. Search for the Policy for which the Alert is generated and click on it
- 5. Under Permissions tab, click on Edit policy
- 6. Under the Visual editor, for each of the 'SageMaker' Service, click to expand and perform following.
 - 6.a. Click to expand 'Request conditions'
 - 6.b. Under the 'Source IP', remove the row with the entry '0.0.0.0/0' or ':::/0'. Add condition with restrictive IP ranges.
- 7. Click on Review policy and Save changes.

System and Communications Protection / Section Network Communications – Deny by Default – Allow by Exception



0 Resource(s) Failed

Compliance Section: Network Communications – Deny by Default – Allow by Exception — Informational

Deny network communications traffic by default, and allow network communications traffic by exception.

AWS Security Group allows all traffic on RDP port (3389)

This policy identifies Security groups that allow all traffic on RDP port 3389. Doing so, may allow a bad actor to brute force their way into the system and potentially get access to the entire network. Review your list of security group rules to ensure that your resources are not exposed. As a best practice, restrict RDP solely to known static IP addresses. Limit the access list to include known hosts, services, or specific employees only.

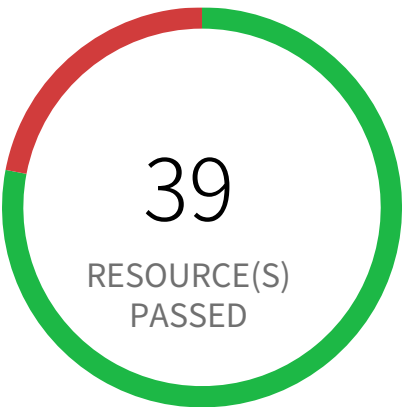
First Seen N/A | **Resource Type** Other

Recommendations

Before making any changes, please check the impact to your applications/services. If the Security Group reported indeed need to restrict all traffic, follow the instructions below:

- 1. Log in to the AWS Console
- 2. Navigate to the 'VPC' service
- 3. Select the 'Security Group' reported in the alert
- 4. Click on the 'Inbound Rule'
- 5. Remove the rule which has 'Source' value as 0.0.0.0/0 or ::/0 and 'Port Range' value as 3389 (or range containing 3389)

System and Communications Protection / Section Network Communications – Deny by Default – Allow by Exception



11 Resource(s) Failed
web-sg-42fedb5, exfil-ssh-hz6vX, ebillingtwo-ec2-ssh-der4t4tg5ght-two, web-sg-39afb9d, bastion_sg_hz6vX, launch-wizard-1, web-sg-2f195dc, ebillingthree-ec2-ssh-der4t4tg5ght-three, Kali Linux-2024.3-amd64-AutogenByAWSMP--1, custom-security-group & 1 more

Compliance Section: Network Communications – Deny by Default – Allow by Exception ●●● Medium

Deny network communications traffic by default, and allow network communications traffic by exception.

AWS Security Group allows all traffic on SSH port (22)

This policy identifies Security groups that allow all traffic on SSH port 22. Doing so, may allow a bad actor to brute force their way into the system and potentially get access to the entire network. Review your list of security group rules to ensure that your resources are not exposed. As a best practice, restrict SSH solely to known static IP addresses. Limit the access list to include known hosts, services, or specific employees only.

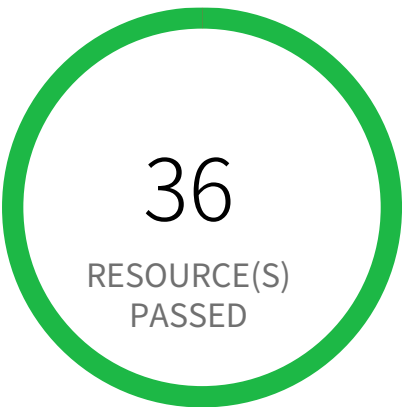
First Seen June 11, 2024 at 6:11:26 PM UTC | **Resource Type** Other

Recommendations

Before making any changes, please check the impact to your applications/services. If the Security Group reported indeed need to restrict all traffic, follow the instructions below:

- 1. Log in to the AWS Console
- 2. Navigate to the 'VPC' service
- 3. Select the 'Security Group' reported in the alert
- 4. Click on the 'Inbound Rule'
- 5. Remove the rule which has 'Source' value as 0.0.0.0/0 or ::/0 and 'Port Range' value as 22 (or range containing 22)

System and Communications Protection / Section Network Communications – Deny by Default – Allow by Exception



0 Resource(s) Failed

Compliance Section: Network Communications – Deny by Default – Allow by Exception ●●●● Low

Deny network communications traffic by default, and allow network communications traffic by exception.

AWS route table with VPC peering overly permissive to all traffic

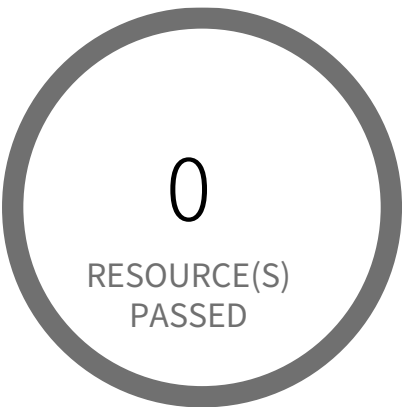
This policy identifies VPC route tables with VPC peering connection which are overly permissive to all traffic. Being highly selective in peering routing tables is a very effective way of minimizing the impact of breach as resources outside of these routes are inaccessible to the peered VPC.

First Seen N/A | **Resource Type** Other

Recommendations

- 1. Log in to the AWS Console
- 2. In the console, select the specific region from region drop down on the top right corner, for which the alert is generated.
- 3. Navigate to 'VPC' dashboard from 'Services' dropdown
- 4. From left menu, select 'Route Tables'
- 5. Click on the alerted route table
- 6. From top click on 'Action' button
- 7. From the Action menu dropdown, select 'Edit routes'
- 8. From the list of destination remove the extra permissive destination by clicking the cross symbol available for that destination
- 9. Add a destination with 'least access'
- 10. Click on 'Save Routes'.

System and Communications Protection / Section Transmission and Storage Confidentiality



0 Resource(s) Failed

Compliance Section: Transmission and Storage Confidentiality ●●● Medium

Implement cryptographic mechanisms to prevent the unauthorized disclosure of CUI during transmission and while in storage.

AWS CloudFront distribution is using insecure SSL protocols for HTTPS communication

CloudFront, a content delivery network (CDN) offered by AWS, is not using a secure cipher for distribution. It is a best security practice to enforce the use of secure ciphers TLSv1.0, TLSv1.1, and/or TLSv1.2 in a CloudFront Distribution's certificate configuration. This policy scans for any deviations from this practice and returns the results.

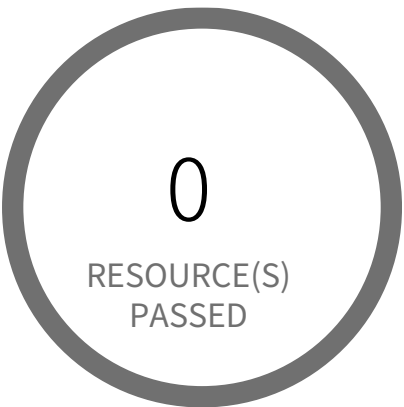
First Seen N/A | **Resource Type** Other

Recommendations

Communication between CloudFront and your Custom Origin should enforce the use of secure ciphers. Modify the CloudFront Origin's Origin SSL Protocol to include TLSv1.0, TLSv1.1, and/or TLSv1.2.

- 1. Go to the AWS console CloudFront dashboard.
- 2. Select your distribution Id.
- 3. Select the 'Origins' tab.
- 4. Check the origin you want to modify then select Edit.
- 5. Remove (uncheck) 'SSLv3' from Origin SSL Protocols.
- 6. Select 'Yes, Edit.'

System and Communications Protection / Section Transmission and Storage Confidentiality



0 Resource(s) Failed

Compliance Section: Transmission and Storage Confidentiality ●●● Medium

Implement cryptographic mechanisms to prevent the unauthorized disclosure of CUI during transmission and while in storage.

AWS CloudFront viewer protocol policy is not configured with HTTPS

For web distributions, you can configure CloudFront to require that viewers use HTTPS to request your objects, so connections are encrypted when CloudFront communicates with viewers.

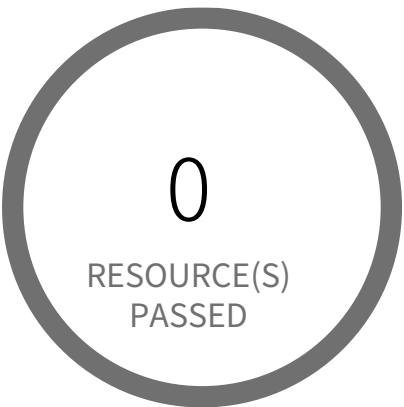
First Seen N/A | **Resource Type** Other

Recommendations

Configure CloudFront to require HTTPS between viewers and CloudFront.

- 1. Go to the AWS console CloudFront dashboard.
- 2. Select your distribution Id.
- 3. Select the 'Behaviors' tab.
- 4. Check the behavior you want to modify then select Edit.
- 5. Choose 'HTTPS Only' or 'Redirect HTTP to HTTPS' for Viewer Protocol Policy.
- 6. Select 'Yes, Edit.'

System and Communications Protection / Section Transmission and Storage Confidentiality



0 Resource(s) Failed

Compliance Section: Transmission and Storage Confidentiality ●●●● Low

Implement cryptographic mechanisms to prevent the unauthorized disclosure of CUI during transmission and while in storage.

[AWS CloudFront web distribution using insecure TLS version](#)

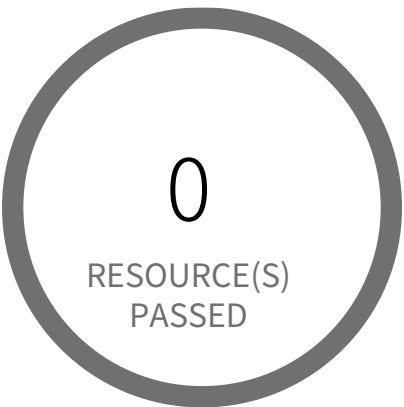
This policy identifies AWS CloudFront web distributions which are configured with TLS versions for HTTPS communication between viewers and CloudFront. As a best practice, use recommended TLSv1.2_2021 as the minimum protocol version in your CloudFront distribution security policies.

First Seen N/A | **Resource Type** Other

Recommendations

- 1. Sign in to the AWS console
- 2. Navigate to CloudFront Distributions Dashboard
- 3. Click on the reported distribution
- 4. On 'General' tab, Click on 'Edit' button under 'Settings'
- 5. On 'Edit Distribution' page, Set 'Security Policy' to TLSv1.2_2021
- 6. Click on 'Save changes'

System and Communications Protection / Section Transmission and Storage Confidentiality



0 Resource(s) Failed

Compliance Section: Transmission and Storage Confidentiality ●●●● Low

Implement cryptographic mechanisms to prevent the unauthorized disclosure of CUI during transmission and while in storage.

[AWS CloudFront web distribution with default SSL certificate](#)

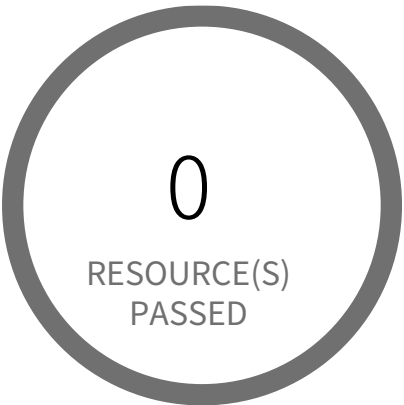
This policy identifies CloudFront web distributions which have a default SSL certificate to access CloudFront content. It is a best practice to use custom SSL Certificate to access CloudFront content. It gives you full control over the content data. custom SSL certificates also allow your users to access your content by using an alternate domain name. You can use a certificate stored in AWS Certificate Manager (ACM) or you can use a certificate stored in IAM.

First Seen N/A | **Resource Type** Other

Recommendations

- 1. Sign in to the AWS console
- 2. Select the region, from the region drop-down, in which the alert is generated
- 3. Navigate to CloudFront Distributions Dashboard
- 4. Click on the reported distribution
- 5. On the 'General' tab, Click on the 'Edit' button
- 6. On 'Edit Distribution' page set 'SSL Certificate' to 'Custom SSL Certificate (example.com):', Select a certificate or type your certificate ARN in the field and other parameters as per your requirement.
- 7. Click on 'Yes, Edit'

System and Communications Protection / Section Transmission and Storage Confidentiality



0 Resource(s) Failed

Compliance Section: Transmission and Storage Confidentiality ●●●● Low

Implement cryptographic mechanisms to prevent the unauthorized disclosure of CUI during transmission and while in storage.

AWS Database Migration Service endpoint do not have SSL configured

This policy identifies Database Migration Service (DMS) endpoints that are not configured with SSL to encrypt connections for source and target endpoints. It is recommended to use SSL connection for source and target endpoints; enforcing SSL connections help protect against 'man in the middle' attacks by encrypting the data stream between endpoint connections.

NOTE: Not all databases use SSL in the same way. An Amazon Redshift endpoint already uses an SSL connection and does not require an SSL connection set up by AWS DMS. So there are some exlcusions included in policy RQL to report only those endpoints which can be configured using DMS SSL feature.

For more details:
https://docs.aws.amazon.com/dms/latest/userguide/CHAP_Security.html#CHAP_Security.SSL

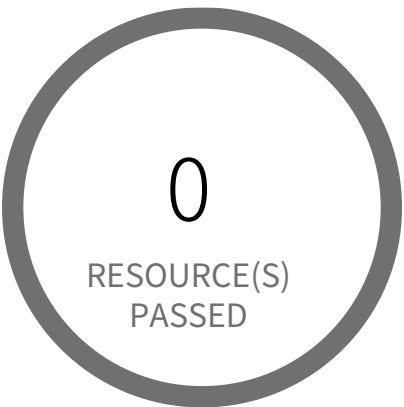
First Seen N/A | **Resource Type** Other

Recommendations

- 1. Log in to the AWS Console
- 2. Navigate to the AWS DMS dashboard
- 3. In the navigation pane, choose 'Endpoints'
- 4. Select the reported DMS endpoint
- 5. Under 'Actions', choose 'Modify'
- 6. In the 'Endpoint configuration' section, select the 'Secure Socket Layer (SSL) mode' from the dropdown list select suitable SSL mode according to your requirement other than 'none'.
- 7. Click on 'Save'

NOTE: Before modifying the SSL setting, you should be configured with the proper certificate you want to use for SSL connection under the DMS 'Certificate' service.

System and Communications Protection / Section Transmission and Storage Confidentiality



0 Resource(s) Failed

Compliance Section: Transmission and Storage Confidentiality Low

Implement cryptographic mechanisms to prevent the unauthorized disclosure of CUI during transmission and while in storage.

AWS DocumentDB Cluster is not enabled with data encryption in transit

This policy identifies Amazon DocumentDB Clusters for which data encryption in transit is disabled. Each DocumentDB Cluster is associated with a Cluster Parameter Group. It is highly recommended to implement in-transit encryption in order to protect data from unauthorized access as it travels through the network, between clients and the cluster.

First Seen N/A | Resource Type Other

Recommendations

To modify the Parameter group

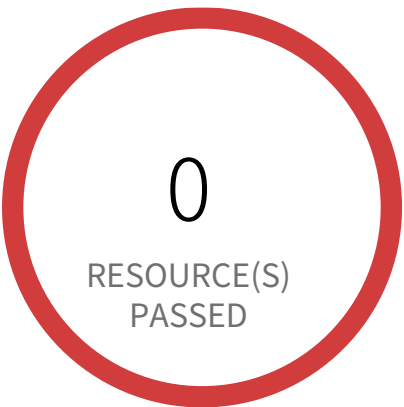
1. Sign in to the AWS console
2. Select the region, from the region drop-down, for which the alert is generated
3. Navigate to Amazon DocumentDB Dashboard
4. Click on the 'Parameter groups' (Left panel)
5. Select the db cluster parameter group which is associated with the DocumentDB cluster on which the alert is generated
6. Select the \"tls\" parameter
7. Click on \"Edit\" button
8. Set value to \"enabled\"
9. Click on \"Modify cluster parameter\" button

To restart the Document DB cluster

1. Sign in to the AWS console
2. Select the region, from the region drop-down, for which the alert is generated
3. Navigate to Amazon DocumentDB Dashboard
4. Click on the 'Clusters' (Left panel)
5. Select the db cluster parameter group which is associated with the DocumentDB cluster on which the alert is generated, and choose the button to the left of its name.

6. Choose \"Actions\", and then \"Reboot\".
7. Click on \"Reboot\" button.

System and Communications Protection / Section Transmission and Storage Confidentiality



17 Resource(s) Failed
818698786219:EBS:eu-west-3,
818698786219:EBS:us-west-2,
818698786219:EBS:ap-southeast-2,
818698786219:EBS:ap-northeast-1,
818698786219:EBS:ca-central-1,
818698786219:EBS:ap-northeast-3,
818698786219:EBS:eu-west-2,
818698786219:EBS:eu-central-1,
818698786219:EBS:eu-north-1,
818698786219:EBS:us-east-2 & 7 more

Compliance Section: Transmission and Storage Confidentiality ●●● Low

Implement cryptographic mechanisms to prevent the unauthorized disclosure of CUI during transmission and while in storage.

AWS EBS volume region with encryption is disabled

This policy identifies AWS regions in which new EBS volumes are getting created without any encryption. Encrypting data at rest reduces unintentional exposure of data stored in EBS volumes. It is recommended to configure EBS volume at the regional level so that every new EBS volume created in that region will be enabled with encryption by using a provided encryption key.

First Seen July 28, 2025 at 9:09:28 PM UTC | **Resource Type** Other

Recommendations

To enable encryption at region level by default, follow below URL:
<https://docs.aws.amazon.com/ebs/latest/userguide/work-with-ebs-encr.html#encryption-by-default>

Additional Information:

To detect existing EBS volumes that are not encrypted ; refer Saved Search:
AWS EBS volumes are not encrypted_RL

To detect existing EBS volumes that are not encrypted with CMK, refer Saved Search:
AWS EBS volume not encrypted using Customer Managed Key_RL

System and Communications Protection / Section Transmission and Storage Confidentiality



0 Resource(s) Failed

Compliance Section: Transmission and Storage Confidentiality ●●●● Low

Implement cryptographic mechanisms to prevent the unauthorized disclosure of CUI during transmission and while in storage.

AWS ECS Cluster instance volume encryption for data at rest is disabled

This policy identifies the ECS Cluster instance volumes for which encryption for data at rest is disabled. Encrypting data at rest reduces unintentional exposure of data and prevents unauthorized users from accessing sensitive data on your AWS ECS clusters. It is recommended to configure encryption for your ECS cluster instance volumes using an encryption key.

NOTE: ECS can be launched using ECS Fargate launch type or EC2 Instance. ECS Fargate launch type pulls images from the Elastic Container Registry, which are transmitted over HTTPS and are automatically encrypted at rest using S3 server-side encryption. So this policy is only applicable to ECS launched using EC2 Instances.

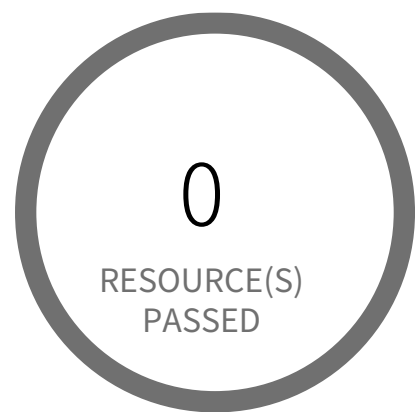
First Seen N/A | **Resource Type** Other

Recommendations

To enable encryption to your ECS Cluster instance volumes, follow below URL:
<https://docs.aws.amazon.com/AWSEC2/latest/UserGuide/EBSEncryption.html>

NOTE: The existing EBS volumes or snapshots cannot be encrypted, but when you copy unencrypted snapshots, or restore unencrypted volumes, the resulting snapshots or volumes are encrypted.

System and Communications Protection / Section Transmission and Storage Confidentiality



0 Resource(s) Failed

Compliance Section: Transmission and Storage Confidentiality ●●●● Low

Implement cryptographic mechanisms to prevent the unauthorized disclosure of CUI during transmission and while in storage.

[AWS EMR cluster is not enabled with data encryption at rest](#)

This policy identifies AWS EMR clusters for which data encryption at rest is not enabled. Encryption of data at rest is required to prevent unauthorized users from accessing the sensitive information available on your EMR clusters and associated storage systems.

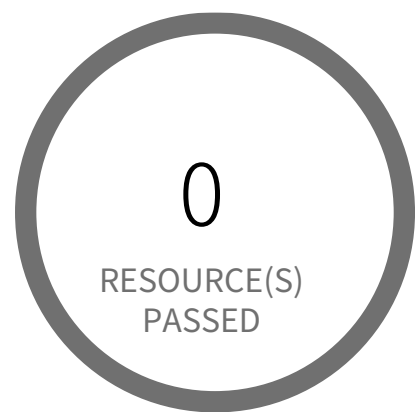
First Seen N/A | **Resource Type** Other

Recommendations

1. Login to the AWS Console.
2. In the console, select the specific region from region drop down on the top right corner, for which the alert is generated.
3. Navigate to 'EMR' dashboard from 'Services' dropdown.
4. Go to 'Security configurations', click 'Create'.
5. On the Create security configuration window,
6. In 'Name' box, provide a name for the new EMR security configuration.
7. For encryption At Rest select the required encryption type ('S3 encryption'/'Local disk encryption'/both) and follow below link for enabling the same.
8. <https://docs.aws.amazon.com/emr/latest/ManagementGuide/emr-encryption-enable.html>
9. Click on 'Create' button.
10. On the left menu of EMR dashboard Click 'Clusters'.
11. Select the EMR cluster for which the alert has been generated and click on the 'Clone' button from the top menu.
12. In the Cloning popup, choose 'Yes' and Click 'Clone'.
13. On the Create Cluster page, in the Security Options section, click on 'security configuration'.
14. From the 'Security configuration' drop down select the name of the security configuration created at step 4 to step 8, click 'Create Cluster'.
15. Once you the new cluster is set up verify its working and terminate the source cluster in order to stop incurring charges for it.
16. On the left menu of EMR dashboard Click 'Clusters', from the list of clusters select the source cluster which is alerted.

17. Click on the 'Terminate' button from the top menu.
18. On the 'Terminate clusters' pop-up, click 'Terminate'.

System and Communications Protection / Section Transmission and Storage Confidentiality



0 Resource(s) Failed

Compliance Section: Transmission and Storage Confidentiality ●●●● Low

Implement cryptographic mechanisms to prevent the unauthorized disclosure of CUI during transmission and while in storage.

[AWS EMR cluster is not enabled with data encryption in transit](#)

This policy identifies AWS EMR clusters which are not enabled with data encryption in transit. It is highly recommended to implement in-transit encryption in order to protect data from unauthorized access as it travels through the network, between clients and storage server. Enabling data encryption in-transit helps prevent unauthorized users from reading sensitive data between your EMR clusters and their associated storage systems.

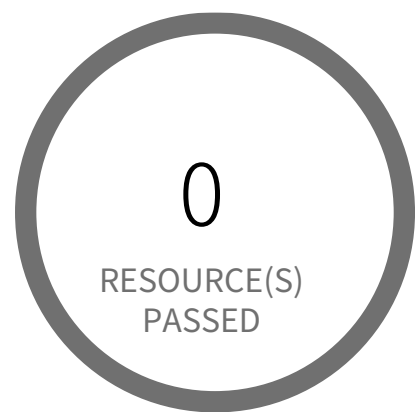
First Seen N/A | **Resource Type** Other

Recommendations

1. Login to the AWS Console.
2. In the console, select the specific region from region drop down on the top right corner, for which the alert is generated.
3. Navigate to 'EMR' dashboard from 'Services' dropdown
4. Go to 'Security configurations', click 'Create'.
5. On the Create security configuration window,
6. In 'Name' box, provide a name for the new EMR security configuration.
7. Under 'Data in transit encryption', check the box 'Enable in-transit encryption'.
8. From the dropdown of 'TLS certificate provider' select the appropriate certificate provider type and follow below link to create them.
Reference: <https://docs.aws.amazon.com/emr/latest/ManagementGuide/emr-encryption-enable.html>
9. Click on 'Create' button.
10. On the left menu of EMR dashboard Click 'Clusters'.
11. Select the EMR cluster for which the alert has been generated and click on the 'Clone' button from the top menu.
12. In the Cloning popup, choose 'Yes' and Click 'Clone'.
13. On the Create Cluster page, in the Security Options section, click on 'security configuration'.
14. From the 'Security configuration' drop down select the name of the security configuration created at step 4 to step 8, click 'Create Cluster'.
15. Once you the new cluster is set up verify its working and terminate the source cluster in order to stop incurring charges for it.

16. On the left menu of EMR dashboard Click 'Clusters', from the list of clusters select the source cluster which is alerted.
17. Click on the 'Terminate' button from the top menu.
18. On the 'Terminate clusters' pop-up, click 'Terminate'.

System and Communications Protection / Section Transmission and Storage Confidentiality



0 Resource(s) Failed

Compliance Section: Transmission and Storage Confidentiality ●●● Low

Implement cryptographic mechanisms to prevent the unauthorized disclosure of CUI during transmission and while in storage.

AWS ElastiCache Memcached cluster with in-transit encryption disabled

This policy identifies AWS ElastiCache Memcached clusters that have in-transit encryption disabled. It is highly recommended to implement in-transit encryption in order to protect data from unauthorized access as it travels through the network, between clients and cache servers. Enabling data encryption in-transit helps to prevent unauthorized users from reading sensitive data between your Memcached and their associated cache storage systems.

First Seen N/A | **Resource Type** Other

Recommendations

AWS ElastiCache Memcached in-transit encryption can be set, only at the time of creation. So to resolve this alert, create a new cluster with in-transit encryption enabled, then migrate all required ElastiCache Memcached cluster data from the reported ElastiCache Memcached cluster to this newly created cluster and delete reported ElastiCache Memcached cluster.

To create new ElastiCache Memcached cluster with In-transit encryption set, perform the following:

1. Sign into the AWS console
2. In the console, select the specific region from region drop down on the top right corner, for which the alert is generated
3. Navigate to ElastiCache
4. Click on 'Memcached clusters' under 'Resources'
5. Click on 'Create Memcached clusters' button
6. On the 'Cluster settings' page,
 - a. Enter a name for the new cache cluster
 - b. Select Memcached engine version from 'Engine version' dropdown list

Note: As of September 2022, In-transit encryption can be enabled only for AWS ElastiCache clusters with Memcached engine version 1.6.12 or later

- c. Enter the 'Subnet group settings' and click on 'Next'
- d. Under 'Security', Select 'Enable' checkbox under 'Encryption in transit'

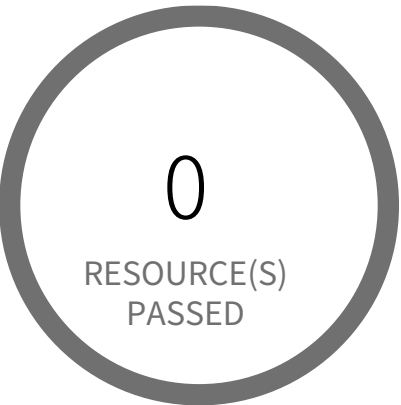
e. Fill in other necessary parameters

7. Click on 'Create' button to launch your new ElastiCache Memcached cluster

To delete reported ElastiCache Memcached cluster follow below given URL:

<https://docs.aws.amazon.com/AmazonElastiCache/latest/mem-ug/GettingStarted.DeleteCacheCluster.html>

System and Communications Protection / Section Transmission and Storage Confidentiality



0 Resource(s) Failed

Compliance Section: Transmission and Storage Confidentiality ●●● Low

Implement cryptographic mechanisms to prevent the unauthorized disclosure of CUI during transmission and while in storage.

AWS ElastiCache Redis cluster with encryption for data at rest disabled

This policy identifies ElastiCache Redis clusters which have encryption for data at rest(at-rest) is disabled. It is highly recommended to implement at-rest encryption in order to prevent unauthorized users from reading sensitive data saved to persistent media available on your Redis clusters and their associated cache storage systems.

First Seen N/A | **Resource Type** Other

Recommendations

AWS ElastiCache Redis cluster at-rest encryption can be set only at the time of the creation of the cluster. So to fix this alert, create a new cluster with at-rest encryption, then migrate all required ElastiCache Redis cluster data from the reported ElastiCache Redis cluster to this newly created cluster and delete reported ElastiCache Redis cluster.

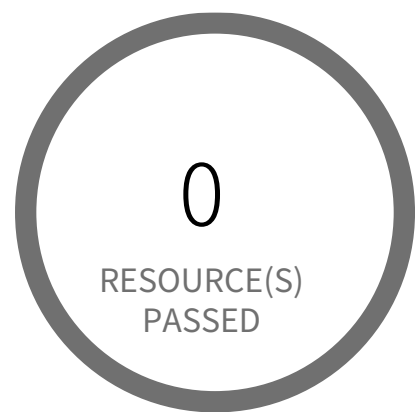
To create new ElastiCache Redis cluster with at-rest encryption set, perform the following:

- 1. Sign into the AWS console
- 2. In the console, select the specific region from region drop down on the top right corner, for which the alert is generated
- 3. Navigate to ElastiCache Dashboard
- 4. Click on Redis
- 5. Click on 'Create' button
- 6. On the 'Create your Amazon ElastiCache cluster' page,
 - a. Select 'Redis' cache engine type.
 - b. Enter a name for the new cache cluster
 - c. Select Redis engine version from 'Engine version compatibility' dropdown list.
- Note: As of July 2018, In-transit encryption can be enabled only for AWS ElastiCache clusters with Redis engine version 3.2.6 and 4.0.10.
- d. Click on 'Advanced Redis settings' to expand the cluster advanced settings panel
- e. Select 'Encryption at-rest' checkbox to enable encryption along with other necessary parameters
- 7. Click on 'Create' button to launch your new ElastiCache Redis cluster

To delete reported ElastiCache Redis cluster, perform the following:

1. Sign into the AWS console
2. In the console, select the specific region from region drop down on the top right corner, for which the alert is generated
3. Navigate to ElastiCache Dashboard
4. Click on Redis
5. Select reported Redis cluster
6. Click on 'Delete' button
7. In the 'Delete Cluster' dialog box, if you want a backup for your cluster select 'Yes' from the 'Create final backup' dropdown menu, provide a name for the cluster backup, then click on 'Delete'.

System and Communications Protection / Section Transmission and Storage Confidentiality



0 Resource(s) Failed

Compliance Section: Transmission and Storage Confidentiality ●●●● Low

Implement cryptographic mechanisms to prevent the unauthorized disclosure of CUI during transmission and while in storage.

AWS ElastiCache Redis with in-transit encryption disabled (Non-replication group)

This policy identifies ElastiCache Redis that are in non-replication groups or individual ElastiCache Redis and have in-transit encryption disabled. It is highly recommended to implement in-transit encryption in order to protect data from unauthorized access as it travels through the network, between clients and cache servers. Enabling data encryption in-transit helps prevent unauthorized users from reading sensitive data between your Redis and their associated cache storage systems.

First Seen N/A | **Resource Type** Other

Recommendations

AWS ElastiCache Redis in-transit encryption can be set, only at the time of creation. So to resolve this alert, create a new cluster with in-transit encryption enabled, then migrate all required ElastiCache Redis cluster data from the reported ElastiCache Redis cluster to this newly created cluster and delete reported ElastiCache Redis cluster.

To create new ElastiCache Redis cluster with In-transit encryption set, perform the following:

1. Sign into the AWS console
2. In the console, select the specific region from region drop down on the top right corner, for which the alert is generated
3. Navigate to ElastiCache Dashboard
4. Click on Redis
5. Click on 'Create' button
6. On the 'Create your Amazon ElastiCache cluster' page,
 - a. Select 'Redis' cache engine type.
 - b. Enter a name for the new cache cluster
 - c. Select Redis engine version from 'Engine version compatibility' dropdown list.

Note: As of July 2018, In-transit encryption can be enabled only for AWS ElastiCache clusters with Redis engine version 3.2.6 and 4.0.10.

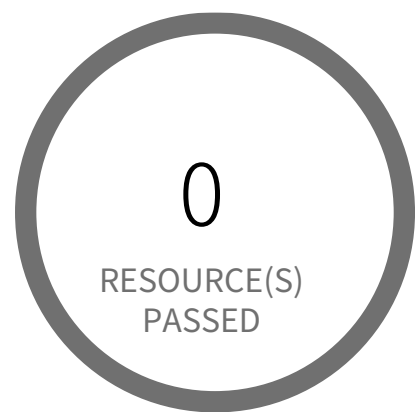
- d. Click on 'Advanced Redis settings' to expand the cluster advanced settings panel
- e. Select 'Encryption in-transit' checkbox to enable encryption along with other necessary parameters

7. Click on 'Create' button to launch your new ElastiCache Redis cluster

To delete reported ElastiCache Redis cluster, perform the following:

1. Sign into the AWS console
2. In the console, select the specific region from region drop down on the top right corner, for which the alert is generated
3. Navigate to ElastiCache Dashboard
4. Click on Redis
5. Select reported Redis cluster
6. Click on 'Delete' button
7. In the 'Delete Cluster' dialog box, if you want a backup for your cluster select 'Yes' from the 'Create final backup' dropdown menu, provide a name for the cluster backup, then click on 'Delete'.

System and Communications Protection / Section Transmission and Storage Confidentiality



0 Resource(s) Failed

Compliance Section: Transmission and Storage Confidentiality ●●●● Low

Implement cryptographic mechanisms to prevent the unauthorized disclosure of CUI during transmission and while in storage.

[AWS Elastic File System \(EFS\) with encryption for data at rest is disabled](#)

This policy identifies Elastic File Systems (EFSs) for which encryption for data at rest is disabled. It is highly recommended to implement at-rest encryption in order to prevent unauthorized users from reading sensitive data saved to EFSs.

First Seen N/A | **Resource Type** Other

Recommendations

AWS EFS Encryption of data at rest can only be enabled during file system creation. So to resolve this alert, create a new EFS with encryption enabled, then migrate all required file data from the reported EFS to this newly created EFS and delete reported EFS.

To create a new EFS with encryption enabled, perform the following:

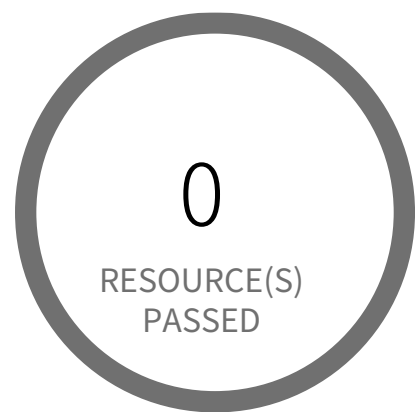
1. Sign in to the AWS console
2. In the console, select the specific region from the region drop-down on the top right corner, for which the alert is generated
3. Navigate to the EFS dashboard
4. Click on 'File systems' (Left Panel)
5. Click on the 'Create file system' button
6. On the 'Create file system' pop-up window,
7. Click on 'Customize' button to replicate the configurations of alerted file system as required
8. Ensure 'Enable encryption of data at rest' is selected
9. On the 'Review and create' step, Review all your setting and click on the 'Create' button

To delete reported EFS which does not has encryption, perform the following:

1. Sign in to the AWS console
2. In the console, select the specific region from the region drop-down on the top right corner, for which the alert is generated
3. Navigate to the EFS dashboard
4. Click on 'File systems' (Left Panel)

5. Select the reported file system
6. Click on 'Delete' button
7. In the 'Delete file system' popup box, To confirm the deletion enter the file system's ID and Click on 'Confirm'

System and Communications Protection / Section Transmission and Storage Confidentiality



0 Resource(s) Failed

Compliance Section: Transmission and Storage Confidentiality ●●●● Low

Implement cryptographic mechanisms to prevent the unauthorized disclosure of CUI during transmission and while in storage.

[AWS Elastic Load Balancer \(Classic\) SSL negotiation policy configured with vulnerable SSL protocol](#)

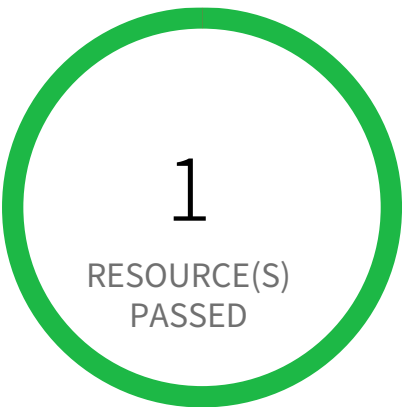
This policy identifies Elastic Load Balancers (Classic) which are configured with SSL negotiation policy containing vulnerable SSL protocol. The SSL protocol establishes a secure connection between a client and a server and ensures that all the data passed between the client and your load balancer is private. As a security best practice, it is recommended to use the latest version SSL protocol.

First Seen N/A | **Resource Type** Other

Recommendations

1. Sign into the AWS console
2. In the console, select the specific region from region drop down on the top right corner, for which the alert is generated
3. Navigate to EC2 Dashboard
4. Click on 'Load Balancers' (Left Panel)
5. Click on the reported Load Balancer
6. On 'Listeners' tab, Click on 'Edit' button
7. On 'Edit Listeners' popup for rule 'HTTPS/SSL',
 - If your cipher is 'Predefined Security Policy', change 'Cipher' to 'ELBSecurityPolicy-TLS-1-2-2017-01 or latest'
- OR
 - If your cipher is 'Custom Security Policy', Choose 'Protocol-TLSv1.2' only on 'SSL Protocols' section
8. Click on 'Save'

System and Communications Protection / Section Transmission and Storage Confidentiality



0 Resource(s) Failed

Compliance Section: Transmission and Storage Confidentiality ●●● Low

Implement cryptographic mechanisms to prevent the unauthorized disclosure of CUI during transmission and while in storage.

AWS Elastic Load Balancer v2 (ELBv2) SSL negotiation policy configured with weak ciphers

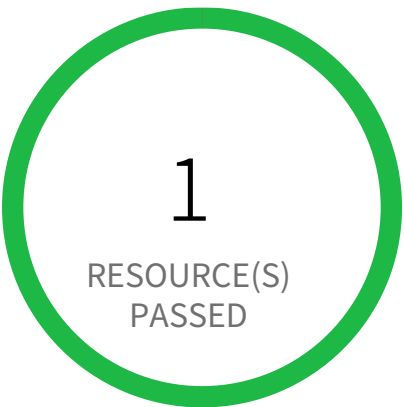
This policy identifies Elastic Load Balancers v2 (ELBv2) which are configured with SSL negotiation policy containing weak ciphers. An SSL cipher is an encryption algorithm that uses encryption keys to create a coded message. SSL protocols use several SSL ciphers to encrypt data over the Internet. As many of the other ciphers are not secure/weak, it is recommended to use only the ciphers recommended in the following AWS link: <https://docs.aws.amazon.com/elasticloadbalancing/latest/application/create-https-listener.html>

First Seen N/A | **Resource Type** Other

Recommendations

1. Log in to the AWS console
2. In the console, select the specific region from the region drop-down on the top right corner, for which the alert is generated
3. Go to the EC2 Dashboard, and select 'Load Balancers'
4. Click on the reported Load Balancer
5. On the 'Listeners' tab, Choose the 'HTTPS' or 'SSL' rule; Click on 'Manage Listeners', Change 'Security policy' to other than 'ELBSecurity-Policy-TLS-1-0-2015-04' as it contains DES-CBC3-SHA cipher, which is a weak cipher.
6. Click on 'Update' to save your changes.

System and Communications Protection / Section Transmission and Storage Confidentiality



0 Resource(s) Failed

Compliance Section: Transmission and Storage Confidentiality ●●● Medium

Implement cryptographic mechanisms to prevent the unauthorized disclosure of CUI during transmission and while in storage.

AWS Elastic Load Balancer v2 (ELBv2) listener that allow connection requests over HTTP

This policy identifies Elastic Load Balancers v2 (ELBv2) listener that are configured to accept connection requests over HTTP instead of HTTPS. As a best practice, use the HTTPS protocol to encrypt the communication between the application clients and the application load balancer.

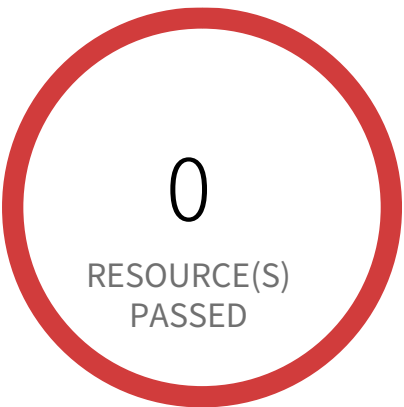
First Seen N/A | **Resource Type** Other

Recommendations

To update the listener protocol to HTTPS, perform the following actions,

1. Sign in to the AWS console
2. Select the region from the region drop-down, in which the alert is generated
3. Navigate to the EC2 dashboard
4. In the left navigation pane, scroll down and click on 'Load Balancers' under the 'Load Balancing' section.
5. Click on the name of the load balancer that is reported.
6. Click on the 'Listeners and rules' tab
7. Select the Listener rule that uses HTTP and click on the 'Edit listener' under 'Manage listener'.
8. Select 'HTTPS' in the 'Protocol' under 'Listener details' section, choose appropriate Default action, Security policy, and Default SSL certificate parameters as per your requirement.
9. Click on 'Save Changes'

System and Communications Protection / Section Transmission and Storage Confidentiality



1 Resource(s) Failed
aff8d40132a374dd5b26b66f35579c6a

Compliance Section: Transmission and Storage Confidentiality ●●●● Low

Implement cryptographic mechanisms to prevent the unauthorized disclosure of CUI during transmission and while in storage.

AWS Elastic Load Balancer v2 (ELBv2) with listener TLS/SSL is not configured

This policy identifies AWS Elastic Load Balancers v2 (ELBv2) which have non-secure listeners. As Load Balancers will be handling all incoming requests and routing the traffic accordingly. The listeners on the load balancers should always receive traffic over secure channel with a valid SSL certificate configured.

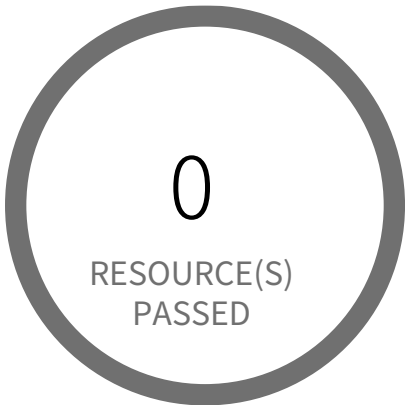
First Seen June 11, 2024 at 6:11:26 PM UTC | Resource Type Other

Recommendations

1. Log in to the AWS console and select the specific region where the alert was generated. You can find the region dropdown in the top right corner of the console.
2. From the AWS console, navigate to the EC2 dashboard.
3. In the left panel of the EC2 dashboard, click on 'Load Balancers' under 'Load Balancing'
4. Select the specific ELB reported in the alert.
5. On the 'Listeners' tab, click the 'Edit' button under the available listeners.
6. In the 'Load Balancer Protocol' dropdown,
 - 6a. select 'HTTPS (Secure HTTP)' for the listener protocol.
 - 6b. Select 'TLS' as the listener protocol.
7. Choose an appropriate security policy for the listener.
8. In the 'SSL Certificate' column, click 'Change'.
9. In the 'Select Certificate' popup dialog, choose a certificate from AWS Certificate Manager (ACM) or Identity and Access Management (IAM), or upload a new certificate based on your requirements. Click 'Save'.
10. Back in the 'Edit Listeners' dialog box, review the secure listener configuration and click 'Save'.

Note:Carefully review and test the changes before implementing them in a production environment. Incorrect configuration can disrupt traffic flow and impact application availability.

System and Communications Protection / Section Transmission and Storage Confidentiality



0 Resource(s) Failed

Compliance Section: Transmission and Storage Confidentiality ●●●● Low

Implement cryptographic mechanisms to prevent the unauthorized disclosure of CUI during transmission and while in storage.

AWS Elastic Load Balancer with listener TLS/SSL is not configured

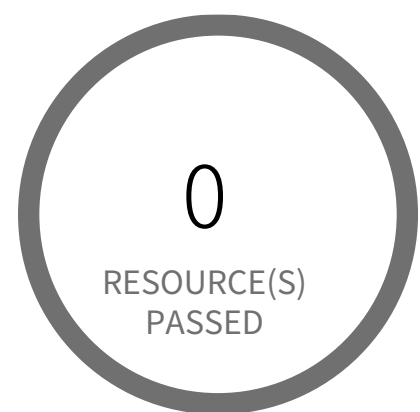
This policy identifies AWS Elastic Load Balancers which have non-secure listeners. As Load Balancers will be handling all incoming requests and routing the traffic accordingly. The listeners on the load balancers should always receive traffic over secure channel with a valid SSL certificate configured.

First Seen N/A | **Resource Type** Managed Load Balancer

Recommendations

1. Sign into the AWS console
2. In the console, select the specific region from region drop down on the top right corner, for which the alert is generated
3. Navigate to EC2 dashboard
4. Click on 'Load Balancers' (Left Panel)
5. Select the reported ELB
6. On the Listeners tab, Click the 'Edit' button under the available listeners
7. In the Load Balancer Protocol, Select 'HTTPS (Secure HTTP)' or 'SSL (Secure TCP)'
8. In the SSL Certificate column, click 'Change'
9. On 'Select Certificate' popup dialog, Choose a certificate from ACM or IAM or upload a new certificate based on requirement and Click on 'Save'
10. Back to the 'Edit listeners' dialog box, review the secure listeners configuration, then click on 'Save'

System and Communications Protection / Section Transmission and Storage Confidentiality



0 Resource(s) Failed

Compliance Section: Transmission and Storage Confidentiality ●●●● Low

Implement cryptographic mechanisms to prevent the unauthorized disclosure of CUI during transmission and while in storage.

AWS Elasticsearch domain Encryption for data at rest is disabled

This policy identifies Elasticsearch domains for which encryption is disabled. Encryption of data at rest is required to prevent unauthorized users from accessing the sensitive information available on your Elasticsearch domains components. This may include all data of file systems, primary and replica indices, log files, memory swap files and automated snapshots. The Elasticsearch uses AWS KMS service to store and manage the encryption keys. It is highly recommended to implement encryption at rest when you are working with production data that have sensitive information, to protect from unauthorized access.

First Seen N/A | **Resource Type** Other

Recommendations

Enabling the encryption feature on existing domains requires Elasticsearch 6.7 or later. If your Elasticsearch is 6.7 or later, follow the below steps to enable encryption on the existing Elasticsearch domain:

1. Sign in to the AWS console
2. In the console, select the specific region from the region drop-down on the top right corner, for which the alert is generated
3. Navigate to the Amazon OpenSearch Service Dashboard
4. Choose the reported Elasticsearch domain
5. Click on the 'Actions' button, from the drop-down select 'Edit security configuration'
6. In the Modify encryption page, select the 'Enable encryption of data at rest' checkbox under the 'Encryption' section and choose KMS key as per your requirement. It is recommended to choose KMS CMKs instead of the default KMS [Default(aws/es)], to get more granular control on your Elasticsearch domain data.
7. Click on 'Save changes'.

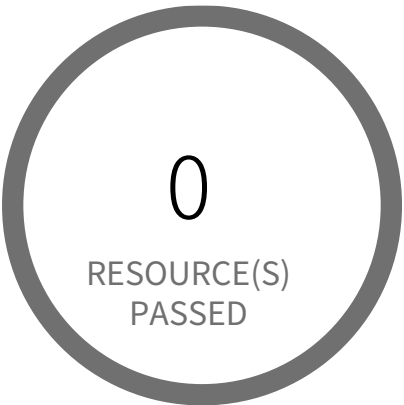
If your Elasticsearch is less than version 6.7, then AWS Elasticsearch Domain encryption can be set only at the time of the creation of the domain. To resolve this alert, create a new domain with encryption using KMS Keys and then migrate all required Elasticsearch domain data from the reported Elasticsearch domain to this newly created domain.

To set up the new Elasticsearch domain with encryption using KMS Key, refer to the following URL:

<https://docs.aws.amazon.com/elasticsearch-service/latest/developerguide/es-createupdatedomains.html>

To delete the reported ES domain, refer to the following URL:
<https://docs.aws.amazon.com/elasticsearch-service/latest/developerguide/es-gsg-deleting.html>

System and Communications Protection / Section Transmission and Storage Confidentiality



0 Resource(s) Failed

Compliance Section: Transmission and Storage Confidentiality ●●●● Low

Implement cryptographic mechanisms to prevent the unauthorized disclosure of CUI during transmission and while in storage.

AWS Glue connection do not have SSL configured

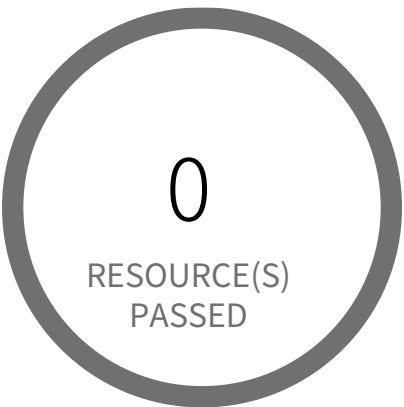
This policy identifies the Glue connections that are not configured with SSL to encrypt connections. It is recommended to use an SSL connection with hostname matching is enforced for the DB connection on the client; enforcing SSL connections help protect against 'man in the middle' attacks by encrypting the data stream between connections.

First Seen N/A | **Resource Type** Other

Recommendations

- 1. Log in to the AWS Console
- 2. In the console, select the specific region from the region drop-down on the top right corner, for which the alert is generated
- 3. Navigate to AWS Glue service
- 4. Click on 'Connections', Click on the reported Connection
- 5. Click on 'Edit'
- 6. On the 'Edit connection' page, Select 'Require SSL connection'
- 7. Click on 'Next'
- 8. Click on 'Finish'

System and Communications Protection / Section Transmission and Storage Confidentiality



0 Resource(s) Failed

Compliance Section: Transmission and Storage Confidentiality ●●● Medium

Implement cryptographic mechanisms to prevent the unauthorized disclosure of CUI during transmission and while in storage.

AWS MSK cluster encryption in transit is not enabled

This policy identifies AWS Managed Streaming for Apache Kafka clusters having in-transit encryption in a disabled state.

In-transit encryption secures data while it's being transferred between brokers. Without it, there's a risk of data interception during transit.

It is recommended to enable in-transit encryption among brokers within the cluster. This ensures that all data exchanged within the cluster is encrypted, effectively protecting it from potential eavesdropping and unauthorized access.

First Seen N/A | **Resource Type** Other

Recommendations

To enable in-transit encryption both within the cluster and client broker communication has to be configured with TLS.

To enable TLS encryption for client-broker communication, follow the below steps:

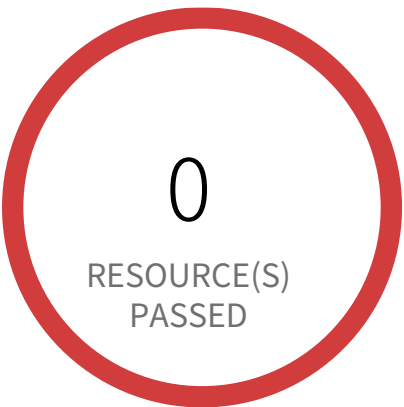
1. Sign in to the AWS Management Console and open the Amazon MSK console at <https://console.aws.amazon.com/msk/>.
2. On the navigation menu, choose 'Clusters', and select the MSK cluster for which you want to enable or edit in-transit encryption.
3. Under the 'Actions' dropdown, select 'Edit security settings'.
4. Under 'Encryption', please uncheck the 'Plaintext' option and make sure the 'TLS encryption' option is selected for 'Between clients and brokers' encryption configuration.
5. Click on 'Update' to save changes.

Enabling TLS encryption for within-cluster communication involves creating a new cluster. To create a new cluster, please follow the below steps:

1. Sign in to the AWS Management Console and open the Amazon MSK console at <https://console.aws.amazon.com/msk/>.
2. On the navigation menu, choose 'Clusters', then select 'Create cluster'.
3. Under the 'Create Cluster' page, please configure the cluster as per the requirements.
4. At Step 3, under 'Encryption', select 'TLS encryption' for the 'Between clients and brokers' checkbox.

5. Select 'TLS encryption' for the 'Within the cluster' checkbox.
6. After providing the required configuration in the remaining steps, Under step 5, click on 'Create cluster'.

System and Communications Protection / Section Transmission and Storage Confidentiality



1 Resource(s) Failed
synthwave-stage-h8hn89cnu394

Compliance Section: Transmission and Storage Confidentiality ●●●● Low

Implement cryptographic mechanisms to prevent the unauthorized disclosure of CUI during transmission and while in storage.

AWS Redshift does not have require_ssl configured

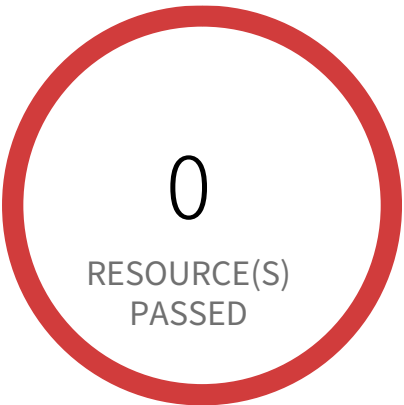
This policy identifies Redshift databases in which data connection to and from is occurring on an insecure channel. SSL connections ensures the security of the data in transit.

First Seen February 19, 2025 at 5:10:48 PM UTC | **Resource Type** Managed Database

Recommendations

- 1. Login to the AWS and navigate to the 'Amazon Redshift' service.
 - 2. Expand the identified 'Redshift' cluster and make a note of the 'Cluster Parameter Group'
 - 3. In the navigation panel, click on the 'Parameter group'.
 - 4. Select the identified 'Parameter Group' and click on 'Edit Parameters'.
 - 5. Review the require_ssl flag. Update the parameter 'require_ssl' to true and save it.
- Note: If the current parameter group is a Default parameter group, it cannot be edited. You will need to create a new parameter group and point it to an affected cluster.

System and Communications Protection / Section Transmission and Storage Confidentiality



1 Resource(s) Failed
synthwave-stage-h8hn89cnu394

Compliance Section: Transmission and Storage Confidentiality ●●●● Low

Implement cryptographic mechanisms to prevent the unauthorized disclosure of CUI during transmission and while in storage.

AWS Redshift instances are not encrypted

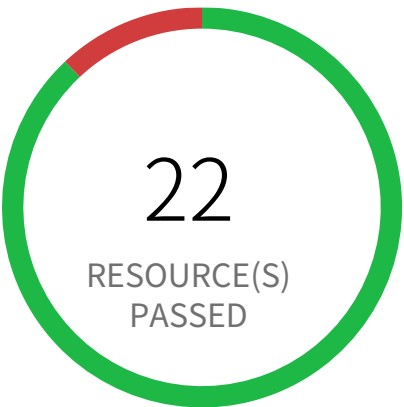
This policy identifies AWS Redshift instances which are not encrypted. These instances should be encrypted for clusters to help protect data at rest which otherwise can result in a data breach.

First Seen February 19, 2025 at 5:10:48 PM UTC | Resource Type Managed Database

Recommendations

To enable encryption on your Redshift cluster follow the steps mentioned in below URL:
<https://docs.aws.amazon.com/redshift/latest/mgmt/changing-cluster-encryption.html>

System and Communications Protection / Section Transmission and Storage Confidentiality



3 Resource(s) Failed
finance-secret-asdfsd3r53rtr-one, fi-
nance-secret-der4t4tg5ght-three, finance-se-
cret-der4t4tg5ght-two

Compliance Section: Transmission and Storage Confidentiality ●●● Medium

Implement cryptographic mechanisms to prevent the unauthorized disclosure of CUI during transmission and while in storage.

AWS S3 bucket not configured with secure data transport policy

AWS S3 buckets that are publicly accessible and lacking secure data transport are highly susceptible to data breaches during transit.

AWS S3 buckets should enforce data encryption using Secure Sockets Layer (SSL) to protect data transmitted between clients and the S3 service. Failure to enforce HTTPS allows attackers to intercept sensitive data in transit, leading to data exposure and potential breaches. Additionally, because the bucket is publicly accessible, untrusted IPs can access sensitive data without encryption.

The impact of this misconfiguration includes unauthorized access to sensitive data, data breaches, and potential regulatory fines. Enforcing HTTPS ensures all communication with publicly accessible S3 buckets is encrypted, protecting data confidentiality and integrity.

To mitigate this, configure bucket policies to explicitly deny all access except via HTTPS ('aws:SecureTransport: true') and remove public access permissions. Regularly review and update bucket policies to reflect evolving security needs and ensure that public access is minimized or removed.

First Seen June 11, 2024 at 6:11:26 PM UTC | **Resource Type** Other

Recommendations

- 1. Sign into the AWS console
- 2. Navigate to Amazon S3 Dashboard
- 3. Click on 'Buckets' (Left Panel)
- 4. Choose the reported S3 bucket
- 5. On 'Permissions' tab, Click on 'Bucket Policy'
- 6. Add a bucket policy that explicitly denies (Effect: Deny) all access (Action: s3:) from anybody who browses (Principal:) to Amazon S3 objects within an Amazon S3 bucket if they are not accessed through HTTPS (aws:SecureTransport: false). Below is the sample policy:

```
{
  "Sid": "ForceSSLOnlyAccess",
  "Effect": "Deny",
  "Principal": "*",
```

```
  "Action": "s3:GetObject",
  "Resource": "arn:aws:s3:::bucket_name/*",
  "Condition": {
    "Bool": {
      "aws:SecureTransport": "false"
    }
  }
}
```


System and Communications Protection / Section Transmission and Storage Confidentiality



0 Resource(s) Failed

Compliance Section: Transmission and Storage Confidentiality ●●●● Low

Implement cryptographic mechanisms to prevent the unauthorized disclosure of CUI during transmission and while in storage.

AWS S3 buckets do not have server side encryption

Customers can protect the data in S3 buckets using the AWS server-side encryption. If the server-side encryption is not turned on for S3 buckets with sensitive data, in the event of a data breach, malicious users can gain access to the data.

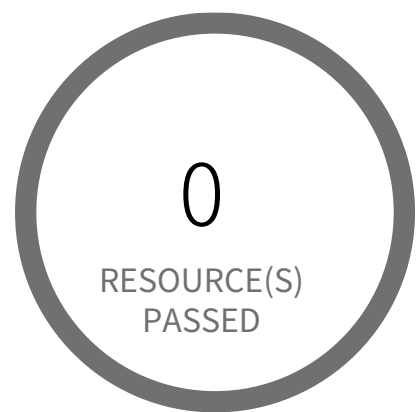
NOTE: Do NOT enable this policy if you are using 'Server-Side Encryption with Customer-Provided Encryption Keys (SSE-C).'

First Seen N/A | **Resource Type** Other

Recommendations

- 1. Login to the AWS Console and navigate to the 'S3' service
 - 2. Click on the reported S3 bucket
 - 3. Click on the 'Properties' tab
 - 4. Under the 'Default encryption' section, choose encryption option either AES-256 or AWS-KMS based on your requirement.
- For more information about Server-side encryption,
Default encryption:
<https://docs.aws.amazon.com/AmazonS3/latest/dev/bucket-encryption.html>
Policy based encryption:
<https://docs.aws.amazon.com/AmazonS3/latest/dev/serv-side-encryption.html>

System and Communications Protection / Section Transmission and Storage Confidentiality



0 Resource(s) Failed

Compliance Section: Transmission and Storage Confidentiality ●●●● Low

Implement cryptographic mechanisms to prevent the unauthorized disclosure of CUI during transmission and while in storage.

AWS SageMaker notebook instance not configured with data encryption at rest using KMS key

This policy identifies SageMaker notebook instances that are not configured with data encryption at rest using the AWS managed KMS key. It is recommended to implement encryption at rest in order to protect data from unauthorized entities.

For more details:

<https://docs.aws.amazon.com/sagemaker/latest/dg/encryption-at-rest.html>

First Seen N/A | **Resource Type** Other

Recommendations

AWS SageMaker notebook instance can not be configured with data encryption at rest once it is created. You need to create a new notebook instance with encryption at rest using the KMS key; migrate all required data from the reported notebook instance to the newly created notebook instance before you delete the reported notebook instance.

To create a New AWS SageMaker notebook instance,

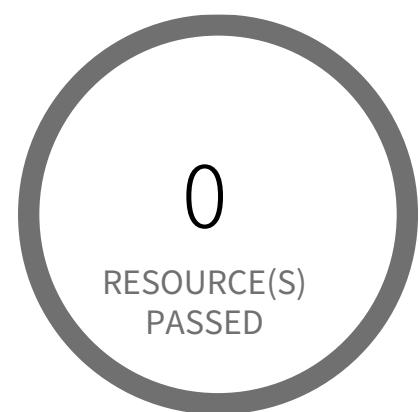
1. Log in to AWS console
2. Navigate to the AWS SageMaker dashboard
3. Choose Notebook instances and then choose 'Create notebook instance'
4. On the Create notebook instance page, From the 'Permissions and encryption' section, select the KMS key from the 'Encryption key - optional' dropdown list. If no KMS keys already, you have to create a KMS key first.
5. Choose other parameters as per your requirement and click on the 'Create notebook instance' button

To delete reported notebook instance,

1. Log in to AWS console
2. Navigate to the AWS SageMaker dashboard
3. Choose Notebook instances and Choose the reported notebook instance

4. Click on the 'Actions' dropdown menu and, select the 'Stop' option, and when instance stops, select the 'Delete' option.
5. Within Delete <notebook-instance-name> dialog box, click the Delete button to confirm the action.

System and Communications Protection / Section Transmission and Storage Confidentiality



0 Resource(s) Failed

Compliance Section: Transmission and Storage Confidentiality — Informational

Implement cryptographic mechanisms to prevent the unauthorized disclosure of CUI during transmission and while in storage.

AWS SageMaker notebook instance not encrypted using Customer Managed Key

This policy identifies SageMaker notebook instances that are not encrypted using Customer Managed Key. SageMaker notebook instances should be encrypted with Amazon KMS Customer Master Keys (CMKs) instead of AWS managed-keys in order to have more granular control over the data-at-rest encryption/decryption process and meet compliance requirements.

For more details:

<https://docs.aws.amazon.com/sagemaker/latest/dg/encryption-at-rest.html>

First Seen N/A | **Resource Type** Other

Recommendations

AWS SageMaker notebook instance encryption can not be modified once it is created. You need to create a new notebook instance with encryption using a custom KMS key; migrate all required data from the reported notebook instance to the newly created notebook instance before you delete the reported notebook instance.

To create a New AWS SageMaker notebook instance,

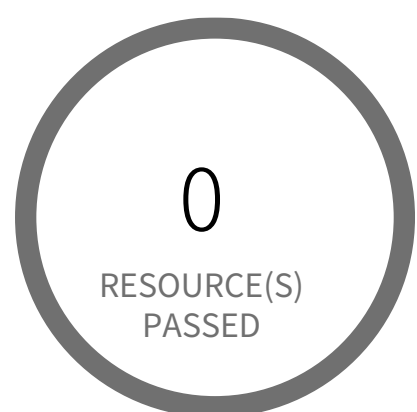
1. Log in to AWS console
2. Navigate to the AWS SageMaker dashboard
3. Choose Notebook instances and then choose 'Create notebook instance'
4. On the Create notebook instance page, within the 'Permissions and encryption' section, From the 'Encryption key - optional' dropdown list, choose a custom KMS key for the new SageMaker notebook instance.
5. Choose other parameters as per your requirement and click on the 'Create notebook instance' button

To delete reported notebook instance,

1. Log in to AWS console
2. Navigate to the AWS SageMaker dashboard
3. Choose Notebook instances and Choose the reported notebook instance

4. Click on the 'Actions' dropdown menu, select the 'Stop' option, and when instance stops, select the 'Delete' option.
5. Within Delete <notebook-instance-name> dialog box, click the Delete button to confirm the action.

System and Communications Protection / Section Cryptographic Key Establishment and Management



0 Resource(s) Failed

Compliance Section: Cryptographic Key Establishment and Management ● ● ● ● Low

Establish and manage cryptographic keys in the system in accordance with the following key management requirements: [Assignment: organization-defined requirements for key generation, distribution, storage, access, and destruction].

AWS Certificate Manager (ACM) has certificates expiring in 30 days or less

This policy identifies ACM certificates expiring in 30 days or less, which are in the AWS Certificate Manager. If SSL/TLS certificates are not renewed prior to their expiration date, they will become invalid and the communication between the client and the AWS resource that implements the certificates is no longer secure. As a best practice, it is recommended to renew certificates before their validity period ends. AWS Certificate Manager automatically renews certificates issued by the service that is used with other AWS resources. However, the ACM service does not renew automatically certificates that are not in use or not associated anymore with other AWS resources. So the renewal process must be done manually before these certificates become invalid.

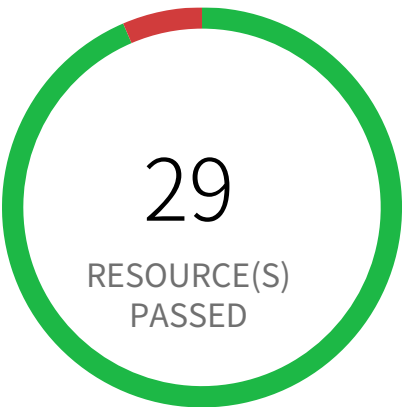
NOTE: If you wanted to be notified other than before or less than 30 days; you can clone this policy and replace '30' in RQL with your desired days value. For example, 15 days OR 7 days which will alert certificates expiring in 15 days or less OR 7 days or less respectively.

First Seen N/A | Resource Type Other

Recommendations

1. Log in to the AWS console
2. In the console, select the specific region from region drop down on the top right corner, for which the alert is generated
3. Go to the Certificate Manager(ACM) service
4. Choose the reported certificate
5. Verify that the 'Status' column shows 'Issued' for the reported certificate
6. Under 'Actions' drop-down select 'Reimport certificate' option
7. On the Import a certificate page, perform the following actions:
 - 7a. In 'Certificate body*' box, paste the PEM-encoded certificate to import, purchased from your SSL certificate provider.
 - 7b. In 'Certificate private key*' box, paste the PEM-encoded, unencrypted private key that matches the SSL/TLS certificate public key.
 - 7c.(Optional) In 'Certificate chain' box, paste the PEM-encoded certificate chain delivered with the certificate body specified at step 7a.
8. Click on 'Review and import' button
9. On the Review and import page, review the imported certificate details then click on 'Import'

System and Communications Protection / Section Cryptographic Key Establishment and Management



2 Resource(s) Failed
dig-security-c31127fb-706b-5d86-873c-3e364e17deb4,
sa-demo-automation

Compliance Section: Cryptographic Key Establishment and Management Informational

Establish and manage cryptographic keys in the system in accordance with the following key management requirements: [Assignment: organization-defined requirements for key generation, distribution, storage, access, and destruction].

AWS Customer Master Key (CMK) rotation is not enabled

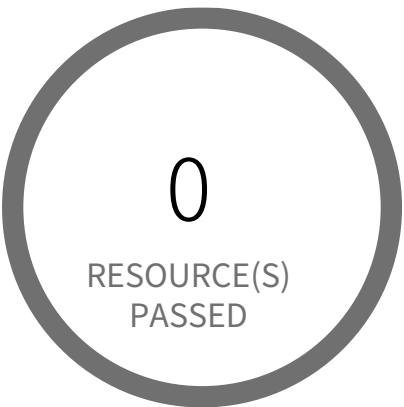
This policy identifies Customer Master Keys (CMKs) that are not enabled with key rotation. AWS KMS (Key Management Service) allows customers to create master keys to encrypt sensitive data in different services. As a security best practice, it is important to rotate the keys periodically so that if the keys are compromised, the data in the underlying service is still secure with the new keys.

First Seen June 11, 2024 at 6:11:26 PM UTC | **Resource Type** Managed Key Rotation Status

Recommendations

1. Log in to the AWS console
2. In the console, select the specific region from region drop-down on the top right corner, for which the alert is generated
3. Navigate to Key Management Service (KMS)
4. Click on 'Customer managed keys' (Left Panel)
5. Select reported KMS Customer managed key
6. Under the 'Key Rotation' tab, Enable 'Automatically rotate this CMK every year'
7. Click on Save

System and Communications Protection / Section Cryptographic Key Establishment and Management



0 Resource(s) Failed

Compliance Section: Cryptographic Key Establishment and Management Informational

Establish and manage cryptographic keys in the system in accordance with the following key management requirements: [Assignment: organization-defined requirements for key generation, distribution, storage, access, and destruction].

AWS DynamoDB encrypted using AWS owned CMK instead of AWS managed CMK

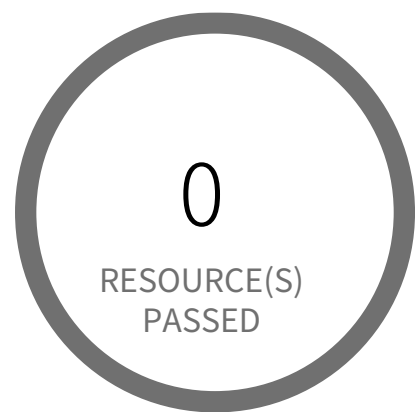
This policy identifies the DynamoDB tables that use AWS owned CMK (default) instead of AWS managed CMK (KMS) to encrypt data. AWS managed CMK provide additional features such as the ability to view the CMK and key policy, and audit the encryption and decryption of DynamoDB tables.

First Seen N/A | Resource Type Other

Recommendations

1. Sign in to AWS console
2. In the console, select the specific region from region drop down on the top right corner, for which the alert is generated.
3. Navigate to 'DynamoDB' dashboard
4. Select the reported table from the list of DynamoDB tables
5. In 'Overview' tab, go to 'Table Details' section
6. Click on the 'Manage Encryption' link available for 'Encryption Type'
7. On 'Manage Encryption' pop up window, Select 'KMS' as the encryption type.

System and Communications Protection / Section Cryptographic Key Establishment and Management



0 Resource(s) Failed

Compliance Section: Cryptographic Key Establishment and Management — Informational

Establish and manage cryptographic keys in the system in accordance with the following key management requirements: [Assignment: organization-defined requirements for key generation, distribution, storage, access, and destruction].

AWS EMR cluster is not configured with CSE CMK for data at rest encryption (Amazon S3 with EMRFS)

This policy identifies EMR clusters which are not configured with Client Side Encryption with Customer Master Keys(CSE CMK) for data at rest encryption of Amazon S3 with EMRFS. As a best practice, use Customer Master Keys (CMK) to encrypt the data in your EMR cluster and ensure full control over your data.

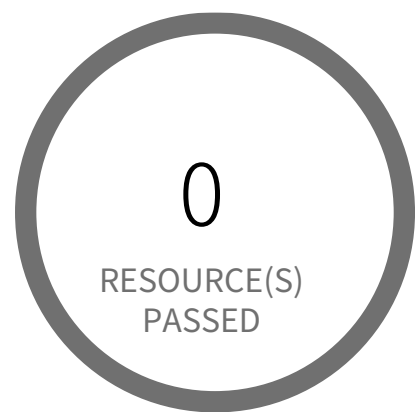
First Seen N/A | Resource Type Other

Recommendations

1. Log in to the AWS Console
2. In the console, select the specific region from region drop down on the top right corner, for which the alert is generated
3. Navigate to 'EMR' dashboard from 'Services' dropdown
4. Go to 'Security configurations', click 'Create'
5. On the Create security configuration window,
6. In 'Name' box, provide a name for the new EMR security configuration.
7. For encryption At Rest click the checkbox for 'Enable at-rest encryption for EMRFS data in Amazon S3'.
8. From the dropdown 'Default encryption mode' select 'CSE-Custom'. Follow below link for configuration steps.
<https://docs.aws.amazon.com/emr/latest/ManagementGuide/emr-encryption-enable.html>
9. Click on 'Create' button
10. On the left menu of EMR dashboard Click 'Clusters'
11. Select the EMR cluster for which the alert has been generated and click on the 'Clone' button from the top menu
12. In the Cloning popup, choose 'Yes' and Click 'Clone'.
13. On the Create Cluster page, in the Security Options section, click on 'security configuration'
14. From the 'Security configuration' drop down select the name of the security configuration created at step 4 to step 8, click 'Create Cluster'
15. Once you the new cluster is set up verify its working and terminate the source cluster in order to stop incurring charges for it.
16. On the left menu of EMR dashboard Click 'Clusters', from the list of clusters select the source cluster which is alerted

17. Click on the 'Terminate' button from the top menu.
18. On the 'Terminate clusters' pop-up, click 'Terminate'.

System and Communications Protection / Section Cryptographic Key Establishment and Management



0 Resource(s) Failed

Compliance Section: Cryptographic Key Establishment and Management ●●●● Low

Establish and manage cryptographic keys in the system in accordance with the following key management requirements: [Assignment: organization-defined requirements for key generation, distribution, storage, access, and destruction].

AWS EMR cluster is not enabled with local disk encryption using Custom key provider

This policy identifies AWS EMR clusters that are not enabled with local disk encryption using Custom key provider. Applications using the local file system on each cluster instance for intermediate data throughout workloads, where data could be spilled to disk when it overflows memory. With Local disk encryption at place, data at rest can be protected.

First Seen N/A | Resource Type Other

Recommendations

1. Login to the AWS Console.
2. In the console, select the specific region from region drop down on the top right corner, for which the alert is generated.
3. Navigate to 'EMR' dashboard from 'Services' dropdown.
4. Go to 'Security configurations', click 'Create'.
5. On the Create security configuration window,
6. In 'Name' box, provide a name for the new EMR security configuration.
7. Under 'Local disk encryption', check the box 'Enable at-rest encryption for local disks'.
8. Select 'Custom' Key provider type from the 'Key provider type' dropdown list.
9. Follow the below link for creating the custom key,

<https://docs.aws.amazon.com/emr/latest/ManagementGuide/emr-data-encryption-options.html>

10. Click on 'Create' button.
11. On the left menu of EMR dashboard Click 'Clusters'.
12. Select the EMR cluster for which the alert has been generated and click on the 'Clone' button from the top menu.
13. In the Cloning popup, choose 'Yes' and Click 'Clone'.
14. On the Create Cluster page, in the Security Options section, click on 'security configuration'.
15. From the 'Security configuration' drop down select the name of the security configuration created at step 4 to step 8, click 'Create'

Cluster'.

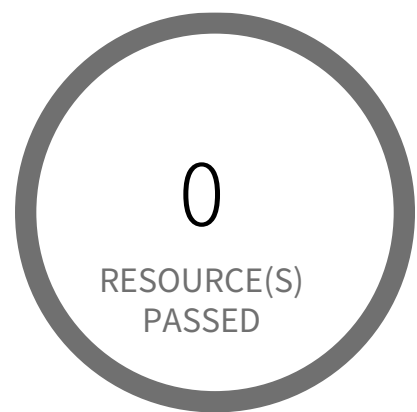
16. Once the new cluster is set up verify its working and terminate the source cluster.

17. On the left menu of EMR dashboard Click 'Clusters', from the list of clusters select the source cluster which is alerted.

18. Click on the 'Terminate' button from the top menu.

19. On the 'Terminate clusters' pop-up, click 'Terminate'.

System and Communications Protection / Section Cryptographic Key Establishment and Management



0 Resource(s) Failed

Compliance Section: Cryptographic Key Establishment and Management — Informational

Establish and manage cryptographic keys in the system in accordance with the following key management requirements: [Assignment: organization-defined requirements for key generation, distribution, storage, access, and destruction].

AWS Elastic File System (EFS) not encrypted using Customer Managed Key

This policy identifies Elastic File Systems (EFSs) which are encrypted with default KMS keys and not with Keys managed by Customer. It is a best practice to use customer managed KMS Keys to encrypt your EFS data. It gives you full control over the encrypted data.

First Seen N/A | Resource Type Other

Recommendations

AWS EFS Encryption of data at rest can only be enabled during file system creation. So to resolve this alert, create a new EFS with encryption enabled with the customer-managed key, then migrate all required data from the reported EFS to this newly created EFS and delete reported EFS.

To create new EFS with encryption enabled, perform the following:

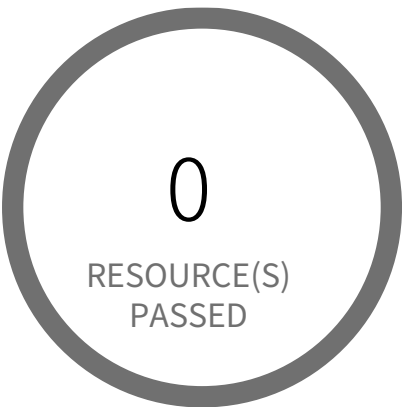
1. Sign into the AWS console
2. In the console, select the specific region from region drop down on the top right corner, for which the alert is generated
3. Navigate to EFS dashboard
4. Click on 'File systems' (Left Panel)
5. Click on 'Create file system' button
6. On the 'Configure file system access' step, specify EFS details as per your requirements and Click on 'Next Step'
7. On the 'Configure optional settings' step, Under 'Enable encryption' Choose 'Enable encryption of data at rest' and Select customer managed key [i.e. Other than (default)aws/elasticfilesystem] from 'Select KMS master key' dropdown list along with other parameters and Click on 'Next Step'
8. On the 'Review and create' step, Review all your setting and Click on 'Create File System' button

To delete reported EFS which does not has encryption, perform the following:

1. Sign into the AWS console

2. In the console, select the specific region from region drop down on the top right corner, for which the alert is generated
3. Navigate to EFS dashboard
4. Click on 'File systems' (Left Panel)
5. Select the reported file system
6. Click on 'Actions' drop-down
7. Click on 'Delete file system'
8. In the 'Permanently delete file system' popup box, To confirm the deletion enter the file system's ID and Click on 'Delete File System'

System and Communications Protection / Section Cryptographic Key Establishment and Management



0 Resource(s) Failed

Compliance Section: Cryptographic Key Establishment and Management — Informational

Establish and manage cryptographic keys in the system in accordance with the following key management requirements: [Assignment: organization-defined requirements for key generation, distribution, storage, access, and destruction].

AWS Elastic Load Balancer (ELB) with ACM certificate expired or expiring in 90 days

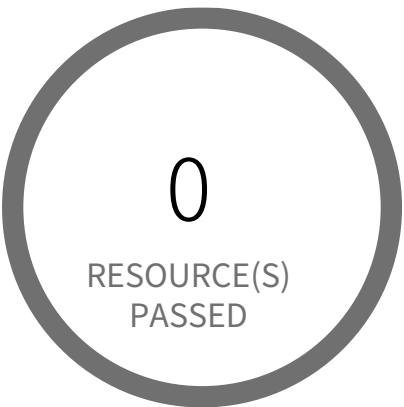
This policy identifies Elastic Load Balancers (ELB) which are using ACM certificates expired or expiring in 90 days. AWS Certificate Manager (ACM) is the preferred tool to provision, manage, and deploy your server certificates. With ACM you can request a certificate or deploy an existing ACM or external certificate to AWS resources. As a best practice, it is recommended to reimport expiring/expired certificates while preserving the ELB associations of the original certificate.

First Seen N/A | Resource Type Other

Recommendations

- 1. Sign into the AWS console
- 2. In the console, select the specific region from region drop down on the top right corner, for which the alert is generated
- 3. Go to Certificate Manager(ACM) service
- 4. Choose the reported certificate
- 5. Under 'Actions' drop-down click on 'Reimport certificate'
- 6. On the 'Import a certificate' page:
 - 6a. For 'Certificate body*', paste the PEM-encoded certificate to import
 - 6b. For 'Certificate private key*', paste the PEM-encoded, unencrypted private key that matches the SSL/TLS certificate public key
 - 6c. (Optional) For 'Certificate chain', paste the PEM-encoded certificate chain delivered
 - 6d. Click Review and import button to continue the process
- 7. On the 'Review and import' page, review the imported certificate details then click on 'Import'

System and Communications Protection / Section Cryptographic Key Establishment and Management



0 Resource(s) Failed

Compliance Section: Cryptographic Key Establishment and Management — Informational

Establish and manage cryptographic keys in the system in accordance with the following key management requirements: [Assignment: organization-defined requirements for key generation, distribution, storage, access, and destruction].

AWS Elastic Load Balancer (ELB) with IAM certificate expiring in 90 days

This policy identifies Elastic Load Balancers (ELB) which are using IAM certificates expiring in 90 days or using expired certificates. Removing expired IAM certificates eliminates the risk and prevents the damage of credibility of the application/website behind the ELB. As a best practice, it is recommended to reimport expiring certificates while preserving the ELB associations of the original certificate.

First Seen N/A | **Resource Type** Other

Recommendations

Removing invalid certificates via AWS Management Console is not currently supported. To delete/upload SSL/TLS certificates stored in IAM via the AWS API use the Command Line Interface (CLI).

Remediation CLI:

1. Run describe-load-balancers command to make sure that the expiring server certificate is not currently used by any active load balancer.
`aws elb describe-load-balancers --region <COMPUTE_REGION> --load-balancer-names <ELB_NAME> --query 'LoadBalancerDescriptions[*].ListenerDescriptions[*].Listener.SSLCertificateId'`

This command output will return the Amazon Resource Name (ARN) for the SSL certificate currently used by the selected ELB:

```
[
  [
    [
      "arn:aws:iam::1234567890:server-certificate/MyCertificate\"
    ]
  ]
]
```

2. Create new AWS IAM certificate with your desired parameters value

3. To upload new IAM Certificate:

```
aws iam upload-server-certificate --server-certificate-name <NEW_CERTIFICATE_NAME> --certificate-body file://Certificate.pem --certificate-chain file://CertificateChain.pem --private-key file://PrivateKey.pem
```

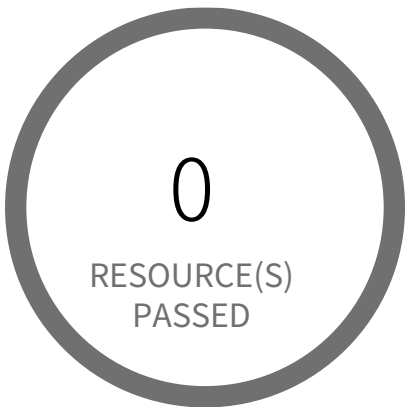

4. To replaces the existing SSL certificate for the specified HTTPS load balancer:

```
aws elb set-load-balancer-listener-ssl-certificate --load-balancer-name <ELB_NAME> --load-balancer-port 443 --ssl-certificate-id  
arn:aws:iam::1234567890:server-certificate/<NEW_CERTIFICATE_NAME>
```

5. Now that is safe to remove the expiring SSL/TLS certificate from AWS IAM, To delete it run:

```
aws iam delete-server-certificate --server-certificate-name <CERTIFICATE_NAME>
```

System and Communications Protection / Section Cryptographic Key Establishment and Management



0 Resource(s) Failed

Compliance Section: Cryptographic Key Establishment and Management ●●●● Low

Establish and manage cryptographic keys in the system in accordance with the following key management requirements: [Assignment: organization-defined requirements for key generation, distribution, storage, access, and destruction].

AWS IAM SSH keys for AWS CodeCommit have aged more than 90 days without being rotated

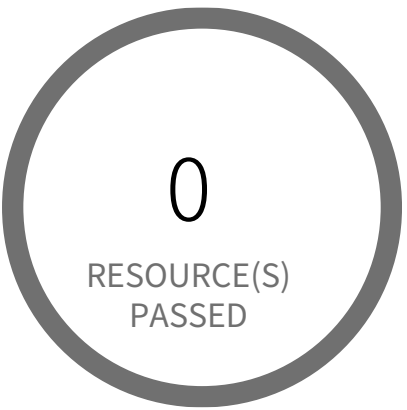
This policy identifies all of your IAM SSH public keys which haven't been rotated in the past 90 days. It is recommended to verify that they are rotated on a regular basis in order to protect your AWS CodeCommit repositories.

First Seen N/A | Resource Type Other

Recommendations

1. Login to AWS Console
 2. Goto IAM and select Users
 3. Choose the reported user
 4. Goto Security Credential
 5. Delete the SSH Key ID and upload a new SSH Key
- Key creation steps: <https://docs.aws.amazon.com/codecommit/latest/userguide/setting-up-ssh-unixes.html>

System and Communications Protection / Section Cryptographic Key Establishment and Management



0 Resource(s) Failed

Compliance Section: Cryptographic Key Establishment and Management ●●●● Low

Establish and manage cryptographic keys in the system in accordance with the following key management requirements: [Assignment: organization-defined requirements for key generation, distribution, storage, access, and destruction].

AWS IAM has expired SSL/TLS certificates

This policy identifies expired SSL/TLS certificates. To enable HTTPS connections to your website or application in AWS, you need an SSL/TLS server certificate. You can use ACM or IAM to store and deploy server certificates. Removing expired SSL/TLS certificates eliminates the risk that an invalid certificate will be deployed accidentally to a resource such as AWS Elastic Load Balancer (ELB), which can damage the credibility of the application/website behind the ELB. This policy generates alerts if there are any expired SSL/TLS certificates stored in AWS IAM. As a best practice, it is recommended to delete expired certificates.

First Seen N/A | Resource Type Other

Recommendations

Removing invalid certificates via AWS Management Console is not currently supported. To delete SSL/TLS certificates stored in IAM via the AWS API use the Command Line Interface (CLI).

Remediation CLI:

1. Run describe-load-balancers command to make sure that the expired server certificate is not currently used by any active load balancer.
`aws elb describe-load-balancers --region <COMPUTE_REGION> --load-balancer-names <ELB_NAME> --query 'LoadBalancerDescriptions[*].ListenerDescriptions[*].Listener.SSLCertificateId'`

This command output will return the Amazon Resource Name (ARN) for the SSL certificate currently used by the selected ELB:

```
[
  [
    [
      "arn:aws:iam::1234567890:server-certificate/MyCertificate"
    ]
  ]
]
```

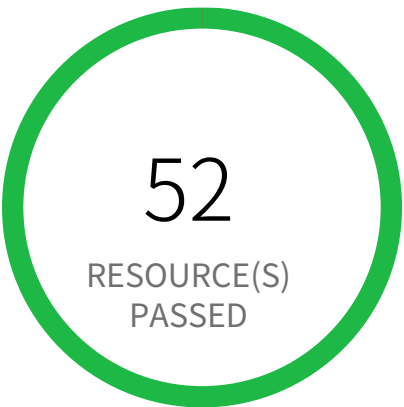
2. If the load balancer listener using the reported expired certificate is not removed before the certificate, the ELB may continue to use the same certificate and work improperly. To delete the ELB listener that is using the expired SSL certificate, run following command:

```
❏aws elb delete-load-balancer-listeners --region <COMPUTE_REGION> --load-balancer-name <ELB_NAME> --load-balancer-ports 443
```

3. Now that is safe to remove the expired SSL/TLS certificate from AWS IAM, To delete it run:

```
❏aws iam delete-server-certificate --server-certificate-name <CERTIFICATE_NAME>
```

System and Communications Protection / Section Cryptographic Key Establishment and Management



0 Resource(s) Failed

Compliance Section: Cryptographic Key Establishment and Management — Informational

Establish and manage cryptographic keys in the system in accordance with the following key management requirements: [Assignment: organization-defined requirements for key generation, distribution, storage, access, and destruction].

AWS IAM user has two active Access Keys

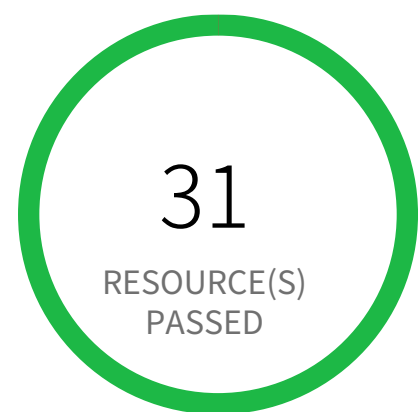
This policy identifies IAM users who have two active Access Keys. Each IAM user can have up to two Access Keys, having two Keys instead of one can lead to increased chances of accidental exposure. So it needs to be ensured that unused Access Keys are deleted.

First Seen N/A | **Resource Type** IAM Credentials Report

Recommendations

- 1. Sign in to the AWS Console and navigate to the 'IAM' service.
- 2. Click on Users in the navigation pane.
- 3. For the identified IAM user which has two active Access Keys, based on policies of your company, take appropriate action.
- 4. Create another IAM user with the specific objective performed by the 2nd Access Key.
- 5. Delete one of the unused Access Keys.

System and Communications Protection / Section Cryptographic Key Establishment and Management



0 Resource(s) Failed

Compliance Section: Cryptographic Key Establishment and Management — Informational

Establish and manage cryptographic keys in the system in accordance with the following key management requirements: [Assignment: organization-defined requirements for key generation, distribution, storage, access, and destruction].

AWS KMS Key scheduled for deletion

This policy identifies KMS Keys which are scheduled for deletion. Deleting keys in AWS KMS is destructive and potentially dangerous. It deletes the key material and all metadata associated with it and is irreversible. After a key is deleted, you can no longer decrypt the data that was encrypted under that key, which means that data becomes unrecoverable. You should delete a key only when you are sure that you don't need to use it anymore. If you are not sure, It is recommended that to disable the key instead of deleting it.

First Seen N/A | Resource Type Other

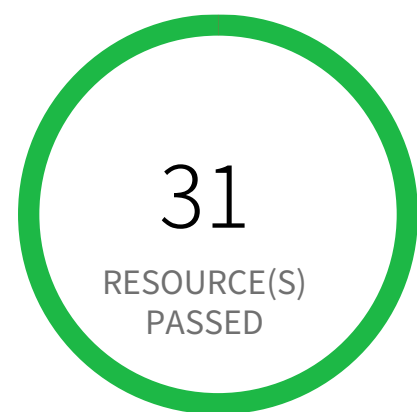
Recommendations

You should delete a KMS key only when you are sure that you don't need to use it anymore. To fix this alert, If you sure you no longer need a reported KMS key; dismiss the alert. If you are not sure, consider disabling the KMS key instead of deleting it.

To enable KMS CMKs which are scheduled for deletion, perform the following:

1. Sign into the AWS console
2. In the console, select the specific region from region drop down on the top right corner, for which the alert is generated
3. Navigate to Key Management Service (KMS)
4. Click on 'Customer managed keys' (Left Panel)
5. Select reported KMS Customer managed key
6. Click on 'Key actions' dropdown
7. Click on 'Cancel key deletion'
8. Click on 'Enable'

System and Communications Protection / Section Cryptographic Key Establishment and Management



0 Resource(s) Failed

Compliance Section: Cryptographic Key Establishment and Management — Informational

Establish and manage cryptographic keys in the system in accordance with the following key management requirements: [Assignment: organization-defined requirements for key generation, distribution, storage, access, and destruction].

AWS KMS customer managed external key expiring in 30 days or less

This policy identifies KMS customer managed external keys which are expiring in 30 days or less. As a best practice, it is recommended to reimport the same key material and specifying a new expiration date. If the key material expires, AWS KMS deletes the key material and the customer managed external key becomes unusable.

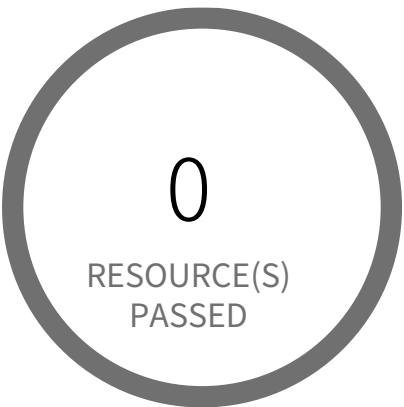
First Seen N/A | Resource Type Other

Recommendations

1. Sign into the AWS console
2. In the console, select the specific region from region drop down on the top right corner, for which the alert is generated
3. Navigate to Key Management Service (KMS) Dashboard
4. Click on Customer managed keys (Left Panel)
5. Click on reported KMS Customer managed key
6. Under 'Key material' section, Delete the existing key material before you reimport the key material by clicking on 'Delete key material'
7. Click on 'Upload key material'
8. Under 'Encrypted key material and import token' section, Reimport same encrypted key material and import token
9. Under 'Expiration option', Select 'Key material expires' and choose new expiration date in 'Key material expires at' date box
10. Click on 'Upload key material' button

NOTE: Deleting key material makes all data encrypted under the customer master key (CMK) unrecoverable unless you later import the same key material into the CMK. The CMK is not affected by this operation.

System and Communications Protection / Section Cryptographic Key Establishment and Management



0 Resource(s) Failed

Compliance Section: Cryptographic Key Establishment and Management — Informational

Establish and manage cryptographic keys in the system in accordance with the following key management requirements: [Assignment: organization-defined requirements for key generation, distribution, storage, access, and destruction].

AWS Kinesis streams encryption using default KMS keys instead of Customer's Managed Master Keys

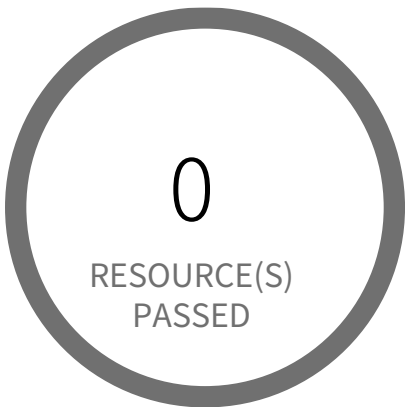
This policy identifies the AWS Kinesis streams which are encrypted with default KMS keys and not with Master Keys managed by Customer. It is a best practice to use customer managed Master Keys to encrypt your Amazon Kinesis streams data. It gives you full control over the encrypted data.

First Seen N/A | **Resource Type** Other

Recommendations

- 1. Sign in to the AWS Console
- 2. Go to Kinesis Service
- 3. Select the reported Kinesis data stream for the corresponding region
- 4. Under Server-side encryption, Click on Edit
- 5. Choose Enabled
- 6. Under KMS master key, You can choose any KMS other than the default (Default) aws/kinesis
- 7. Click Save

System and Communications Protection / Section Cryptographic Key Establishment and Management



0 Resource(s) Failed

Compliance Section: Cryptographic Key Establishment and Management — Informational

Establish and manage cryptographic keys in the system in accordance with the following key management requirements: [Assignment: organization-defined requirements for key generation, distribution, storage, access, and destruction].

AWS RDS DB cluster is encrypted using default KMS key instead of CMK

This policy identifies RDS DB(Relational Database Service Database) clusters which are encrypted using default KMS key instead of CMK (Customer Master Key). As a security best practice CMK should be used instead of default KMS key for encryption to gain the ability to rotate the key according to your own policies, delete the key, and control access to the key via KMS policies and IAM policies.

First Seen N/A | Resource Type Other

Recommendations

RDS DB clusters can be encrypted only while creating the database cluster. You can't convert an unencrypted DB cluster to an encrypted one. However, you can restore an unencrypted Aurora DB cluster snapshot to an encrypted Aurora DB cluster. To do this, specify a KMS encryption key when you restore from the unencrypted DB cluster snapshot.

Step 1: To create a 'Snapshot' of the unencrypted DB cluster,
https://docs.aws.amazon.com/AmazonRDS/latest/AuroraUserGuide/USER_CreateSnapshotCluster.html
NOTE: As you can't restore from a DB cluster snapshot to an existing DB cluster; a new DB cluster is created when you restore. Once the Snapshot status is 'Available'.

Step 2: Follow the below link to restoring the Cluster from a DB Cluster Snapshot,
https://docs.aws.amazon.com/AmazonRDS/latest/AuroraUserGuide/USER_RestoreFromSnapshot.html

- Once the DB cluster is restored and verified, follow below steps to delete the reported DB cluster,
1. Log in to the AWS Management Console
 2. In the console, select the specific region from region drop down on the top right corner, for which the alert is generated.
 3. Navigate to 'RDS' dashboard from 'Services' dropdown
 4. In the navigation pane, choose 'Databases'

5. In the list of DB instances, choose a writer instance for the DB cluster

6. Choose 'Actions', and then choose 'Delete'

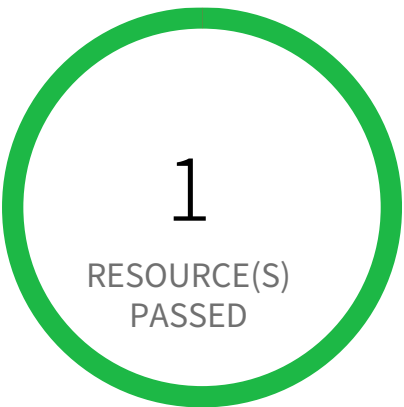
FMI:

1. While deleting a RDS DB cluster, customer has to disable 'Enable deletion protection' otherwise instance cannot be deleted

2. While deleting RDS DB instance , AWS application will ask the end user to take Final snapshot

3. If a RDS DB cluster has a writer role instance, then User has to delete the write instance to delete the main cluster (Delete option won't be enabled for main RDS DB cluster)

System and Communications Protection / Section Cryptographic Key Establishment and Management



0 Resource(s) Failed

Compliance Section: Cryptographic Key Establishment and Management — Informational

Establish and manage cryptographic keys in the system in accordance with the following key management requirements: [Assignment: organization-defined requirements for key generation, distribution, storage, access, and destruction].

AWS RDS database not encrypted using Customer Managed Key

This policy identifies RDS databases that are encrypted with default KMS keys and not with customer managed keys. As a best practice, use customer managed keys to encrypt the data on your RDS databases and maintain control of your keys and data on sensitive workloads.

First Seen N/A | **Resource Type** Other

Recommendations

Because you can set AWS RDS database encryption only during database creation, the process for resolving this alert requires you to create a new RDS database with a customer managed key for encryption, migrate the data from the reported database to this newly created database, and delete the RDS database identified in the alert.

To create a new RDS database with encryption using a customer managed key:

- 1. Log in to the AWS console.
- 2. Select the region for which the alert was generated.
- 3. Navigate to the Amazon RDS Dashboard.
- 4. Select 'Create database'.
- 5. On the 'Select engine' page, select 'Engine options' and 'Next'.
- 6. On the 'Choose use case' page, select 'Use case' of database and 'Next'.
- 7. On the 'Specify DB details' page, specify the database details you need and click 'Next'.

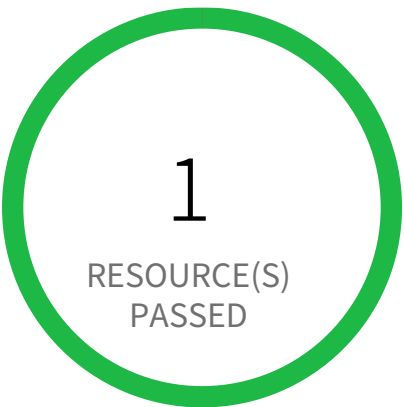
Note: Amazon RDS encryption has some limitation on region and type instances. For Availability of Amazon RDS Encryption refer to: <https://docs.aws.amazon.com/AmazonRDS/latest/UserGuide/Overview.Encryption.html#Overview.Encryption.Availability>

- 8. On the 'Configure advanced settings' page, Under 'Encryption', select 'Enable encryption' and select the customer managed key [i.e. Other than (default)aws/rds] from 'Master key' dropdown list].
- 9. Select 'Create database'.

To delete the RDS database that uses the default KMS keys, which triggered the alert:

1. Log in to the AWS console
2. Select the region for which the alert was generated.
3. Navigate to the Amazon RDS Dashboard.
4. Click on Instances, and select the reported RDS database.
5. Select the 'Instance actions' drop-down and click 'Delete'.
7. In the 'Delete' dialog, select the 'Create final snapshot?' checkbox, if you want a backup. Provide a name for the final snapshot, confirm deletion and select 'Delete'.

System and Communications Protection / Section Cryptographic Key Establishment and Management



0 Resource(s) Failed

Compliance Section: Cryptographic Key Establishment and Management — Informational

Establish and manage cryptographic keys in the system in accordance with the following key management requirements: [Assignment: organization-defined requirements for key generation, distribution, storage, access, and destruction].

AWS Redshift Cluster not encrypted using Customer Managed Key

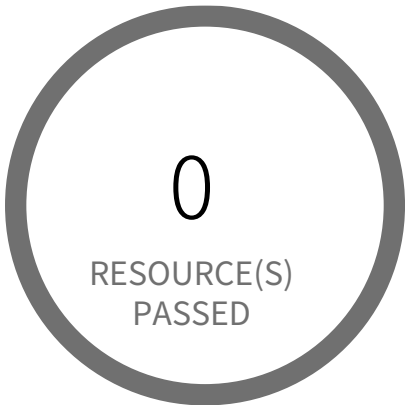
This policy identifies Redshift Clusters which are encrypted with default KMS keys and not with Keys managed by Customer. It is a best practice to use customer managed KMS Keys to encrypt your Redshift databases data. Customer-managed CMKs give you more flexibility, including the ability to create, rotate, disable, define access control for, and audit the encryption keys used to help protect your data.

First Seen N/A | **Resource Type** Other

Recommendations

To enable encryption with Customer Managed Key on your Redshift cluster follow the steps mentioned in below URL:
<https://docs.aws.amazon.com/redshift/latest/mgmt/changing-cluster-encryption.html>

System and Communications Protection / Section Cryptographic Key Establishment and Management



0 Resource(s) Failed

Compliance Section: Cryptographic Key Establishment and Management Informational

Establish and manage cryptographic keys in the system in accordance with the following key management requirements: [Assignment: organization-defined requirements for key generation, distribution, storage, access, and destruction].

AWS SQS queue encryption using default KMS key instead of CMK

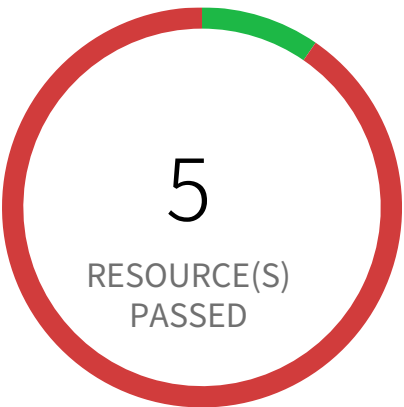
This policy identifies SQS queues which are encrypted with default KMS keys and not with Customer Master Keys(CMKs). It is a best practice to use customer managed Master Keys to encrypt your SQS queue messages. It gives you full control over the encrypted messages data.

First Seen N/A | Resource Type Other

Recommendations

1. Sign in to the AWS console
2. Select the region, from the region drop-down, in which the alert is generated
3. Navigate to Simple Queue Service (SQS) dashboard
4. Choose the reported Simple Queue Service (SQS)
5. Click on 'Queue Actions' and Choose 'Configure Queue' from the dropdown
6. On 'Configure' popup, Under 'Server-Side Encryption (SSE) Settings' section; Choose an 'AWS KMS Customer Master Key (CMK)' from the drop-down list or copy existing key ARN instead of (Default) alias/aws/sqs key.
7. Click on 'Save Changes'

System and Communications Protection / Section Cryptographic Key Establishment and Management



47 Resource(s) Failed

dev-user,
privesc-sageMakerCreatePresignedNote-
bookURL-user, user-der4t4tg5ght-two,
fp3-deny-iam-user, fp1-allow-and-deny-user,
k8s, privesc9-AttachRolePolicy-user,
fp5-nonExploitableConditionConstraint-user,
privesc-CloudFormationUpdateStack-user,
privesc4-CreateAccessKev-user & 37 more

Compliance Section: Cryptographic Key Establishment and Management ●●●● Low

Establish and manage cryptographic keys in the system in accordance with the following key management requirements: [Assignment: organization-defined requirements for key generation, distribution, storage, access, and destruction].

AWS access keys are not rotated for 90 days

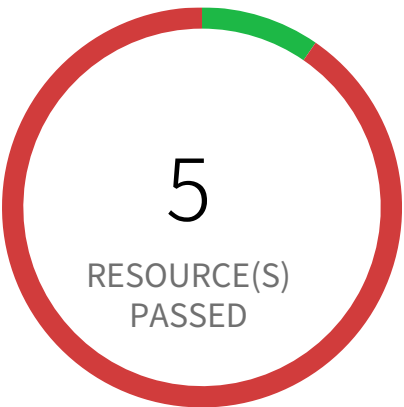
This policy identifies IAM users for which access keys are not rotated for 90 days. Access keys are used to sign API requests to AWS. As a security best practice, it is recommended that all access keys are regularly rotated to make sure that in the event of key compromise, unauthorized users are not able to gain access to your AWS services.

First Seen June 11, 2024 at 6:11:28 PM UTC | **Resource Type** Other

Recommendations

- 1. Sign in to the AWS console and navigate to the 'IAM' service.
- 2. Click on the user that was reported in the alert.
- 3. Click on 'Security Credentials' and for each 'Access Key'.
- 4. Follow the instructions below to rotate the Access Keys that are older than 90 days.
<https://aws.amazon.com/blogs/security/how-to-rotate-access-keys-for-iam-users/>

System and Communications Protection / Section Cryptographic Key Establishment and Management



47 Resource(s) Failed
privesc6-UpdateLoginProfile-user,
privesc7-AttachUserPolicy-user,
fn4-exploitableNotAction-user,
fn1-privesc3-partial-user,
privesc-ec2InstanceConnect-user,
privesc3-CreateEC2WithExistingInstancePro-
file-user, privesc-sre-user,
fp5-nonExploitableConditionConstraint-user,
privesc11-PutGroupPolicy-user,
user-asdfsd3r53rtr-one & 37 more

Compliance Section: Cryptographic Key Establishment and Management Informational

Establish and manage cryptographic keys in the system in accordance with the following key management requirements: [Assignment: organization-defined requirements for key generation, distribution, storage, access, and destruction].

AWS access keys not used for more than 45 days

This policy identifies IAM users for which access keys are not used for more than 45 days. Access keys allow users programmatic access to resources. However, if any access key has not been used in the past 45 days, then that access key needs to be deleted (even though the access key is inactive)

First Seen June 11, 2024 at 6:11:26 PM UTC | **Resource Type** IAM Credentials Report

Recommendations

To delete the reported AWS User access key follow below mentioned URL:
<https://aws.amazon.com/premiumsupport/knowledge-center/delete-access-key/>

7

System and Information Integrity

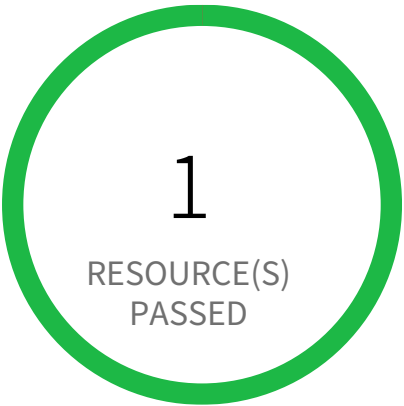
An abstract graphic consisting of several thick, dark gray curved lines that overlap and intersect, creating a sense of motion or a network. The lines are positioned in the lower half of the page, below the main title.

System and Information Integrity Overview

[illegible]

Section		Pass Rate	Failed	Passed
Security Alerts, Advisories, and Directives	AWS Log metric filter and alarm... Informational	0%	2	0
Security Alerts, Advisories, and Directives	AWS Log metric filter and alarm... Informational	0%	2	0
System Monitoring	AWS Default Security Group does not restrict all traffic Low	50%	25	25
System Monitoring	AWS EKS cluster security group overly permissive to all traffic Low	96%	2	48
System Monitoring	AWS Elastic Load Balancer (ELB) has security group with no inbound rules Informational	100%	0	0
System Monitoring	AWS Elastic Load Balancer (ELB) has security group with no outbound... Informational	100%	0	0
System Monitoring	AWS Elasticsearch IAM policy overly permissive to all traffic Informational	100%	0	189
System Monitoring	AWS SageMaker notebook instance IAM policy overly permissive to all traffic Medium	100%	0	189
System Monitoring	AWS Security Group allows all traffic on RDP port (3389) Informational	100%	0	50
System Monitoring	AWS Security Group allows all traffic on SSH port (22) Medium	78%	11	39
System Monitoring	AWS route table with VPC peering overly permissive to all traffic Low	100%	0	36

System and Information Integrity / Section Flaw Remediation



0 Resource(s) Failed

Compliance Section: Flaw Remediation ●●●● Low

- a. Identify, report, and correct system flaws.
- b. Install security-relevant software and firmware updates within [Assignment: organization-defined time period] of the release of the updates.

AWS RDS minor upgrades not enabled

When Amazon Relational Database Service (Amazon RDS) supports a new version of a database engine, you can upgrade your DB instances to the new version. There are two kinds of upgrades: major version upgrades and minor version upgrades. Minor upgrades helps maintain a secure and stable RDS with minimal impact on the application. For this reason, we recommend that your automatic minor upgrade is enabled. Minor version upgrades only occur automatically if a minor upgrade replaces an unsafe version, such as a minor upgrade that contains bug fixes for a previous version.

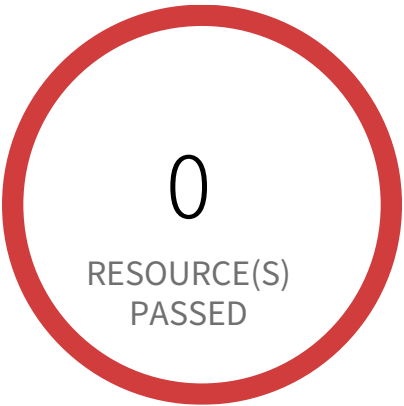
First Seen N/A | **Resource Type** Other

Recommendations

Enable RDS auto minor version upgrades.

1. Go to the AWS console RDS dashboard.
2. In the navigation pane, choose Instances.
3. Select the database instance you wish to configure.
4. From the 'Instance actions' menu, select Modify.
5. Under the Maintenance section, choose Yes for Auto minor version upgrade.
6. Select Continue and then Modify DB Instance.

System and Information Integrity / Section Security Alerts, Advisories, and Directives



2 Resource(s) Failed

058264157785, 818698786219

Compliance Section: Security Alerts, Advisories, and Directives Informational

- a. Receive system security alerts, advisories, and directives from external organizations on an ongoing basis.
- b. Generate and disseminate internal system security alerts, advisories, and directives, as necessary.

AWS Log metric filter and alarm does not exist for AWS Config configuration changes

This policy identifies the AWS regions which do not have a log metric filter and alarm for AWS Config configuration changes. Monitoring changes to AWS Config configuration will help ensure sustained visibility of configuration items within the AWS account. It is recommended that a metric filter and alarm be established for detecting changes to AWS Config's configurations.

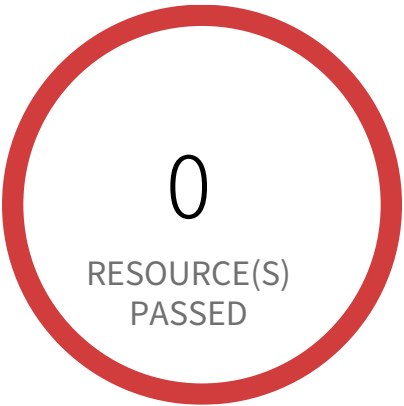
NOTE: This policy will trigger alert if you have at least one Cloudtrail with the multi trail is enabled, Logs all management events in your account and is not set with specific log metric filter and alarm.

First Seen January 28, 2025 at 12:06:58 PM UTC | Resource Type Other

Recommendations

1. Sign in to AWS Console
2. Navigate to CloudWatch dashboard
3. Click on 'Log groups' in the 'Logs' section (Left panel)
4. Select the log group created for your CloudTrail trail event logs (CloudTrail should be multi trail enabled with all management events captured) and click 'Create Metric Filter' button.
5. In 'Define Logs Metric Filter' page, add 'Filter pattern' value as `{ ($.eventSource = config.amazonaws.com) && (($.eventName=StopConfigurationRecorder)||($.eventName=DeleteDeliveryChannel)||($.eventName=PutDeliveryChannel)||($.eventName=PutConfigurationRecorder)) }` and Click on 'Assign Metric'
6. In 'Create Metric Filter and Assign a Metric' page, Choose Filter Name, Metric Details parameter according to your requirement and click on 'Create Filter'
7. Click on 'Create Alarm',
 - In Step 1 specify metric details and conditions details as required and click on 'Next'
 - In Step 2 Select an SNS topic either by creating a new topic or use existing SNS topic/ARN and click on 'Next'
 - In Step 3 Select name and description to alarm and click on 'Next'
 - In Step 4 Preview your data entered and click on 'Create Alarm'

System and Information Integrity / Section Security Alerts, Advisories, and Directives



2 Resource(s) Failed

818698786219, 058264157785

Compliance Section: Security Alerts, Advisories, and Directives — Informational

- a. Receive system security alerts, advisories, and directives from external organizations on an ongoing basis.
- b. Generate and disseminate internal system security alerts, advisories, and directives, as necessary.

AWS Log metric filter and alarm does not exist for AWS management console authentication failures

This policy identifies the AWS accounts which do not have a log metric filter and alarm for AWS management console authentication failures. Monitoring failed console logins may decrease lead time to detect an attempt to brute force a credential, which may provide an indicator, such as source IP, that can be used in other event correlation. It is recommended that a metric filter and alarm be established for failed console authentication attempts.

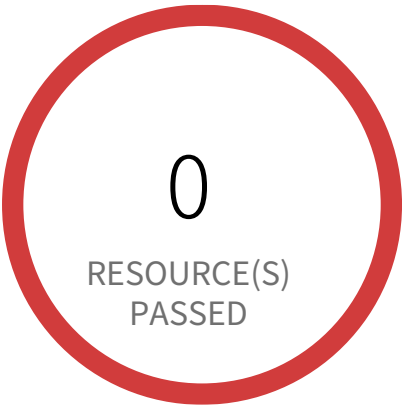
NOTE: This policy will trigger alert if you have at least one Cloudtrail with the multi trail is enabled, Logs all management events and is not set with specific log metric filter and alarm in your account.

First Seen January 28, 2025 at 12:06:58 PM UTC | **Resource Type** Other

Recommendations

- 1. Sign in to AWS Console
- 2. Navigate to CloudWatch dashboard
- 3. Click on 'Log groups' in the 'Logs' section (Left panel)
- 4. Select the log group created for your CloudTrail trail event logs (Cloudtrail should be multi trail enabled with all Management Events captured) and click 'Create Metric Filter' button.
- 5. In 'Define Logs Metric Filter' page, add 'Filter pattern' value as { (\$.eventName = ConsoleLogin) && (\$.errorMessage = "Failed authentication") } and Click on 'Assign Metric'
- 6. In 'Create Metric Filter and Assign a Metric' page, Choose Filter Name, Metric Details parameter according to your requirement and click on 'Create Filter'
- 7. Click on 'Create Alarm',
 - ▣ In Step 1, specify metric details and conditions details as required and click on 'Next'
 - ▣ In Step 2, Select an SNS topic either by creating a new topic or use existing SNS topic/ARN and click on 'Next'
 - ▣ In Step 3, Select name and description to alarm and click on 'Next'
 - ▣ In Step 4, Preview your data entered and click on 'Create Alarm'

System and Information Integrity / Section Security Alerts, Advisories, and Directives



2 Resource(s) Failed

058264157785, 818698786219

Compliance Section: Security Alerts, Advisories, and Directives — Informational

- a. Receive system security alerts, advisories, and directives from external organizations on an ongoing basis.
- b. Generate and disseminate internal system security alerts, advisories, and directives, as necessary.

AWS Log metric filter and alarm does not exist for CloudTrail configuration changes

This policy identifies the AWS regions which do not have a log metric filter and alarm for CloudTrail configuration changes. Monitoring changes to CloudTrail's configuration will help ensure sustained visibility to activities performed in the AWS account. It is recommended that a metric filter and alarm be established for detecting changes to CloudTrail's configurations.

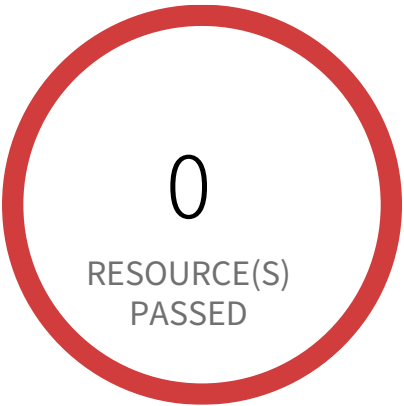
NOTE: This policy will trigger alert if you have at least one Cloudtrail with the multi trail is enabled, Logs all management events in your account and is not set with specific log metric filter and alarm.

First Seen January 28, 2025 at 12:06:58 PM UTC | **Resource Type** Other

Recommendations

1. Sign in to AWS Console
2. Navigate to CloudWatch dashboard
3. Click on 'Log groups' in the 'Logs' section (Left panel)
4. Select the log group created for your CloudTrail trail event logs (CloudTrail should be multi trail enabled with all management events captured) and click 'Create Metric Filter' button.
5. In 'Define Logs Metric Filter' page, add 'Filter pattern' value as
{ (\$.eventName = CreateTrail) || (\$.eventName = UpdateTrail) || (\$.eventName = DeleteTrail) || (\$.eventName = StartLogging) || (\$.eventName = StopLogging) }
and Click on 'Assign Metric'
6. In 'Create Metric Filter and Assign a Metric' page, Choose Filter Name, Metric Details parameter according to your requirement and click on 'Create Filter'
7. Click on 'Create Alarm',
 - In Step 1 specify metric details and conditions details as required and click on 'Next'
 - In Step 2 Select an SNS topic either by creating a new topic or use existing SNS topic/ARN and click on 'Next'
 - In Step 3 Select name and description to alarm and click on 'Next'
 - In Step 4 Preview your data entered and click on 'Create Alarm'

System and Information Integrity / Section Security Alerts, Advisories, and Directives



2 Resource(s) Failed

058264157785, 818698786219

Compliance Section: Security Alerts, Advisories, and Directives — Informational

- a. Receive system security alerts, advisories, and directives from external organizations on an ongoing basis.
- b. Generate and disseminate internal system security alerts, advisories, and directives, as necessary.

AWS Log metric filter and alarm does not exist for IAM policy changes

This policy identifies the AWS regions which do not have a log metric filter and alarm for IAM policy changes. Monitoring changes to IAM policies will help ensure authentication and authorization controls remain intact. It is recommended that a metric filter and alarm be established changes made to Identity and Access Management (IAM) policies.

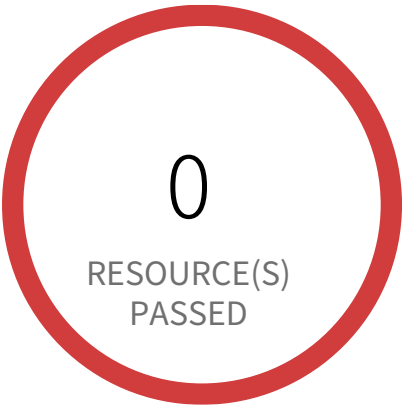
NOTE: This policy will trigger alert if you have at least one Cloudtrail with the multi trial is enabled, Logs all management events in your account and is not set with specific log metric filter and alarm.

First Seen January 28, 2025 at 12:06:58 PM UTC | **Resource Type** Other

Recommendations

1. Sign in to AWS Console
2. Navigate to CloudWatch dashboard
3. Click on 'Log groups' in the 'Logs' section (Left panel)
4. Select the log group created for your CloudTrail trail event logs (CloudTrail should be multi trail enabled with all management events captured) and click 'Create Metric Filter' button.
5. In 'Define Logs Metric Filter' page, add 'Filter pattern' value as
{
(\$eventName=DeleteGroupPolicy)||(\$eventName=DeleteRolePolicy)||(\$eventName=DeleteUserPolicy)||(\$eventName=PutGroupPolicy)||(\$eventName=PutRolePolicy)||(\$eventName=PutUserPolicy)||(\$eventName=CreatePolicy)||(\$eventName=DeletePolicy)||(\$eventName=CreatePolicyVersion)||(\$eventName=DeletePolicyVersion)||(\$eventName=AttachRolePolicy)||(\$eventName=DetachRolePolicy)||(\$eventName=AttachUserPolicy)||(\$eventName=DetachUserPolicy)||(\$eventName=AttachGroupPolicy)||(\$eventName=DetachGroupPolicy) }
and Click on 'Assign Metric'
6. In 'Create Metric Filter and Assign a Metric' page, Choose Filter Name, Metric Details parameter according to your requirement and click on 'Create Filter'
7. Click on 'Create Alarm',
 - ▣- In Step 1 specify metric details and conditions details as required and click on 'Next'
 - ▣- In Step 2 Select an SNS topic either by creating a new topic or use existing SNS topic/ARN and click on 'Next'
 - ▣- In Step 3 Select name and description to alarm and click on 'Next'
 - ▣- In Step 4 Preview your data entered and click on 'Create Alarm'

System and Information Integrity / Section Security Alerts, Advisories, and Directives



2 Resource(s) Failed

058264157785, 818698786219

Compliance Section: Security Alerts, Advisories, and Directives — Informational

- a. Receive system security alerts, advisories, and directives from external organizations on an ongoing basis.
- b. Generate and disseminate internal system security alerts, advisories, and directives, as necessary.

AWS Log metric filter and alarm does not exist for Network Access Control Lists (NACL) changes

This policy identifies the AWS regions which do not have a log metric filter and alarm for Network Access Control Lists (NACL) changes. Monitoring changes to NACLs will help ensure that AWS resources and services are not unintentionally exposed. It is recommended that a metric filter and alarm be established for changes made to NACLs.

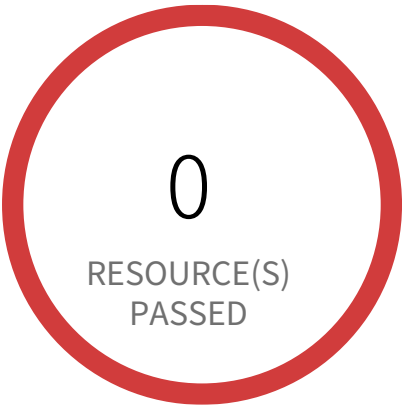
NOTE: This policy will trigger alert if you have at least one Cloudtrail with the multi trail is enabled, Logs all management events in your account and is not set with specific log metric filter and alarm.

First Seen January 28, 2025 at 12:06:58 PM UTC | **Resource Type** Other

Recommendations

- 1. Sign in to AWS Console
- 2. Navigate to CloudWatch dashboard
- 3. Click on 'Log groups' in the 'Logs' section (Left panel)
- 4. Select the log group created for your CloudTrail trail event logs (CloudTrail should be multi trail enabled with all management events captured) and click 'Create Metric Filter' button.
- 5. In 'Define Logs Metric Filter' page, add 'Filter pattern' value as
{ (\$.eventName = CreateNetworkAcl) || (\$.eventName = CreateNetworkAclEntry) || (\$.eventName = DeleteNetworkAcl) || (\$.eventName = DeleteNetworkAclEntry) || (\$.eventName = ReplaceNetworkAclEntry) || (\$.eventName = ReplaceNetworkAclAssociation) }
- and Click on 'Assign Metric'
- 6. In 'Create Metric Filter and Assign a Metric' page, Choose Filter Name, Metric Details parameter according to your requirement and click on 'Create Filter'
- 7. Click on 'Create Alarm',
 - In Step 1 specify metric details and conditions details as required and click on 'Next'
 - In Step 2 Select an SNS topic either by creating a new topic or use existing SNS topic/ARN and click on 'Next'
 - In Step 3 Select name and description to alarm and click on 'Next'
 - In Step 4 Preview your data entered and click on 'Create Alarm'

System and Information Integrity / Section Security Alerts, Advisories, and Directives



2 Resource(s) Failed

058264157785, 818698786219

Compliance Section: Security Alerts, Advisories, and Directives — Informational

- a. Receive system security alerts, advisories, and directives from external organizations on an ongoing basis.
- b. Generate and disseminate internal system security alerts, advisories, and directives, as necessary.

AWS Log metric filter and alarm does not exist for Network gateways changes

This policy identifies the AWS regions which do not have a log metric filter and alarm for Network gateways changes. Monitoring changes to network gateways will help ensure that all ingress/egress traffic traverses the VPC border via a controlled path. It is recommended that a metric filter and alarm be established for changes to network gateways.

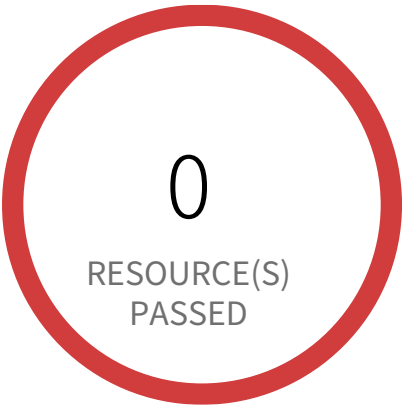
NOTE: This policy will trigger alert if you have at least one Cloudtrail with the multi trail is enabled, Logs all management events in your account and is not set with specific log metric filter and alarm.

First Seen January 28, 2025 at 12:06:58 PM UTC | **Resource Type** Other

Recommendations

- 1. Sign in to AWS Console
- 2. Navigate to CloudWatch dashboard
- 3. Click on 'Log groups' in the 'Logs' section (Left panel)
- 4. Select the log group created for your CloudTrail trail event logs (CloudTrail should be multi trail enabled with all management events captured) and click 'Create Metric Filter' button.
- 5. In 'Define Logs Metric Filter' page, add 'Filter pattern' value as
{ (\$.eventName = CreateCustomerGateway) || (\$.eventName = DeleteCustomerGateway) || (\$.eventName = AttachInternetGateway) || (\$.eventName = CreateInternetGateway) || (\$.eventName = DeleteInternetGateway) || (\$.eventName = DetachInternetGateway) }
- and Click on 'Assign Metric'
- 6. In 'Create Metric Filter and Assign a Metric' page, Choose Filter Name, Metric Details parameter according to your requirement and click on 'Create Filter'
- 7. Click on 'Create Alarm',
 - In Step 1 specify metric details and conditions details as required and click on 'Next'
 - In Step 2 Select an SNS topic either by creating a new topic or use existing SNS topic/ARN and click on 'Next'
 - In Step 3 Select name and description to alarm and click on 'Next'
 - In Step 4 Preview your data entered and click on 'Create Alarm'

System and Information Integrity / Section Security Alerts, Advisories, and Directives



2 Resource(s) Failed

058264157785, 818698786219

Compliance Section: Security Alerts, Advisories, and Directives — Informational

- a. Receive system security alerts, advisories, and directives from external organizations on an ongoing basis.
- b. Generate and disseminate internal system security alerts, advisories, and directives, as necessary.

AWS Log metric filter and alarm does not exist for Route table changes

This policy identifies the AWS regions which do not have a log metric filter and alarm for Route table changes. Monitoring changes to route tables will help ensure that all VPC traffic flows through an expected path. It is recommended that a metric filter and alarm be established for changes to route tables.

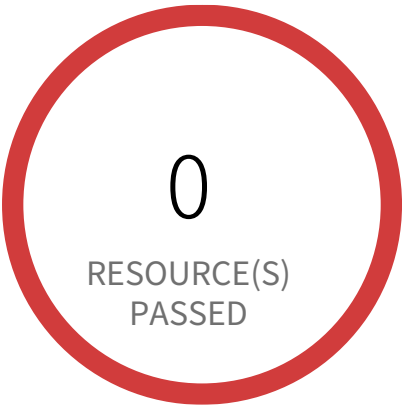
NOTE: This policy will trigger alert if you have at least one Cloudtrail with the multi trail is enabled, Logs all management events in your account and is not set with specific log metric filter and alarm.

First Seen January 28, 2025 at 12:06:58 PM UTC | **Resource Type** Other

Recommendations

- 1. Sign in to AWS Console
- 2. Navigate to CloudWatch dashboard
- 3. Click on 'Log groups' in the 'Logs' section (Left panel)
- 4. Select the log group created for your CloudTrail trail event logs (CloudTrail should be multi trail enabled with all management events captured) and click 'Create Metric Filter' button.
- 5. In 'Define Logs Metric Filter' page, add 'Filter pattern' value as
{ (\$.eventName = CreateRoute) || (\$.eventName = CreateRouteTable) || (\$.eventName = ReplaceRoute) || (\$.eventName = ReplaceRouteTableAssociation) || (\$.eventName = DeleteRouteTable) || (\$.eventName = DeleteRoute) || (\$.eventName = DisassociateRouteTable) }
- and Click on 'Assign Metric'
- 6. In 'Create Metric Filter and Assign a Metric' page, Choose Filter Name, Metric Details parameter according to your requirement and click on 'Create Filter'
- 7. Click on 'Create Alarm',
 - In Step 1 specify metric details and conditions details as required and click on 'Next'
 - In Step 2 Select an SNS topic either by creating a new topic or use existing SNS topic/ARN and click on 'Next'
 - In Step 3 Select name and description to alarm and click on 'Next'
 - In Step 4 Preview your data entered and click on 'Create Alarm'

System and Information Integrity / Section Security Alerts, Advisories, and Directives



2 Resource(s) Failed

058264157785, 818698786219

Compliance Section: Security Alerts, Advisories, and Directives — Informational

- a. Receive system security alerts, advisories, and directives from external organizations on an ongoing basis.
- b. Generate and disseminate internal system security alerts, advisories, and directives, as necessary.

AWS Log metric filter and alarm does not exist for S3 bucket policy changes

This policy identifies the AWS regions which do not have a log metric filter and alarm for S3 bucket policy changes. Monitoring changes to S3 bucket policies may reduce time to detect and correct permissive policies on sensitive S3 buckets. It is recommended that a metric filter and alarm be established for changes to S3 bucket policies.

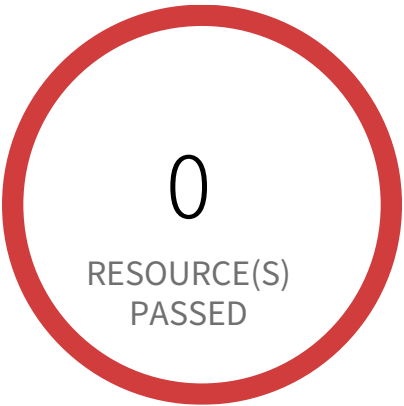
NOTE: This policy will trigger alert if you have at least one Cloudtrail with the multi trail is enabled, Logs all management events in your account and is not set with specific log metric filter and alarm.

First Seen January 28, 2025 at 12:06:58 PM UTC | **Resource Type** Other

Recommendations

1. Sign in to AWS Console
2. Navigate to CloudWatch dashboard
3. Click on 'Log groups' in the 'Logs' section (Left panel)
4. Select the log group created for your CloudTrail trail event logs (CloudTrail should be multi trail enabled with all management events captured) and click 'Create Metric Filter' button.
5. In 'Define Logs Metric Filter' page, add 'Filter pattern' value as
`{ ($.eventSource = s3.amazonaws.com) && (($eventName = PutBucketAcl) || ($.eventName = PutBucketPolicy) || ($.eventName = PutBucketCors) || ($.eventName = PutBucketLifecycle) || ($.eventName = PutBucketReplication) || ($.eventName = DeleteBucketPolicy) || ($.eventName = DeleteBucketCors) || ($.eventName = DeleteBucketLifecycle) || ($.eventName = DeleteBucketReplication)) }`
and Click on 'Assign Metric'
6. In 'Create Metric Filter and Assign a Metric' page, Choose Filter Name, Metric Details parameter according to your requirement and click on 'Create Filter'
7. Click on 'Create Alarm',
 - In Step 1 specify metric details and conditions details as required and click on 'Next'
 - In Step 2 Select an SNS topic either by creating a new topic or use existing SNS topic/ARN and click on 'Next'
 - In Step 3 Select name and description to alarm and click on 'Next'
 - In Step 4 Preview your data entered and click on 'Create Alarm'

System and Information Integrity / Section Security Alerts, Advisories, and Directives



2 Resource(s) Failed

058264157785, 818698786219

Compliance Section: Security Alerts, Advisories, and Directives — Informational

- a. Receive system security alerts, advisories, and directives from external organizations on an ongoing basis.
- b. Generate and disseminate internal system security alerts, advisories, and directives, as necessary.

AWS Log metric filter and alarm does not exist for VPC changes

This policy identifies the AWS regions which do not have a log metric filter and alarm for VPC changes. Monitoring changes to VPC will help ensure that resources and services are not unintentionally exposed. It is recommended that a metric filter and alarm be established for changes made to VPCs.

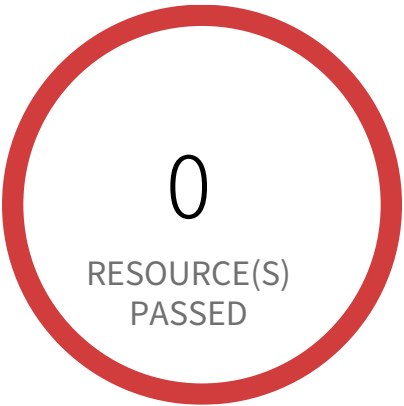
NOTE: This policy will trigger alert if you have at least one Cloudtrail with the multi trail is enabled, Logs all management events in your account and is not set with specific log metric filter and alarm.

First Seen January 28, 2025 at 12:06:58 PM UTC | **Resource Type** Other

Recommendations

1. Sign in to AWS Console
2. Navigate to CloudWatch dashboard
3. Click on 'Log groups' in the 'Logs' section (Left panel)
4. Select the log group created for your CloudTrail trail event logs (CloudTrail should be multi trail enabled with all management events captured) and click 'Create Metric Filter' button.
5. In 'Define Logs Metric Filter' page, add 'Filter pattern' value as
{ (\$.eventName = CreateVpc) || (\$.eventName = DeleteVpc) || (\$.eventName = ModifyVpcAttribute) || (\$.eventName = AcceptVpcPeeringCon-
nection) || (\$.eventName = CreateVpcPeeringConnection) || (\$.eventName = DeleteVpcPeeringConnection) || (\$.eventName = RejectVpcPeer-
ingConnection) || (\$.eventName = AttachClassicLinkVpc) || (\$.eventName = DetachClassicLinkVpc) || (\$.eventName = DisableVpcClassicLink)
|| (\$.eventName = EnableVpcClassicLink) }
and Click on 'Assign Metric'
6. In 'Create Metric Filter and Assign a Metric' page, Choose Filter Name, Metric Details parameter according to your requirement and click
on 'Create Filter'
7. Click on 'Create Alarm',
 - In Step 1 specify metric details and conditions details as required and click on 'Next'
 - In Step 2 Select an SNS topic either by creating a new topic or use existing SNS topic/ARN and click on 'Next'
 - In Step 3 Select name and description to alarm and click on 'Next'
 - In Step 4 Preview your data entered and click on 'Create Alarm'

System and Information Integrity / Section Security Alerts, Advisories, and Directives



2 Resource(s) Failed

058264157785, 818698786219

Compliance Section: Security Alerts, Advisories, and Directives — Informational

- a. Receive system security alerts, advisories, and directives from external organizations on an ongoing basis.
- b. Generate and disseminate internal system security alerts, advisories, and directives, as necessary.

AWS Log metric filter and alarm does not exist for disabling or scheduled deletion of customer created CMKs

This policy identifies the AWS regions which do not have a log metric filter and alarm for disabling or scheduled deletion of customer created CMKs. Data encrypted with disabled or deleted keys will no longer be accessible. It is recommended that a metric filter and alarm be established for customer created CMKs which have changed state to disabled or scheduled deletion.

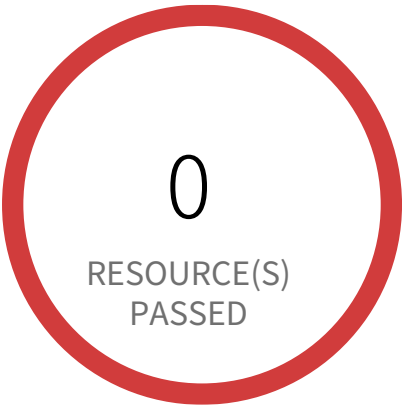
NOTE: This policy will trigger alert if you have at least one Cloudtrail with the multi trail is enabled, Logs all management events in your account and is not set with specific log metric filter and alarm.

First Seen January 28, 2025 at 12:06:58 PM UTC | **Resource Type** Other

Recommendations

- 1. Sign in to AWS Console
- 2. Navigate to CloudWatch dashboard
- 3. Click on 'Log groups' in the 'Logs' section (Left panel)
- 4. Select the log group created for your CloudTrail trail event logs (CloudTrail should be multi trail enabled with all management events captured) and click 'Create Metric Filter' button.
- 5. In 'Define Logs Metric Filter' page, add 'Filter pattern' value as `{ ($.eventSource = kms.amazonaws.com) && (($.eventName=DisableKey)||($.eventName=ScheduleKeyDeletion)) }` and Click on 'Assign Metric'
- 6. In 'Create Metric Filter and Assign a Metric' page, Choose Filter Name, Metric Details parameter according to your requirement and click on 'Create Filter'
- 7. Click on 'Create Alarm',
 - In Step 1 specify metric details and conditions details as required and click on 'Next'
 - In Step 2 Select an SNS topic either by creating a new topic or use existing SNS topic/ARN and click on 'Next'
 - In Step 3 Select name and description to alarm and click on 'Next'
 - In Step 4 Preview your data entered and click on 'Create Alarm'

System and Information Integrity / Section Security Alerts, Advisories, and Directives



2 Resource(s) Failed

058264157785, 818698786219

Compliance Section: Security Alerts, Advisories, and Directives — Informational

- a. Receive system security alerts, advisories, and directives from external organizations on an ongoing basis.
- b. Generate and disseminate internal system security alerts, advisories, and directives, as necessary.

AWS Log metric filter and alarm does not exist for unauthorized API calls

This policy identifies the AWS regions which do not have a log metric filter and alarm for unauthorized API calls. Monitoring unauthorized API calls will help reveal application errors and may reduce the time to detect malicious activity. It is recommended that a metric filter and alarm be established for unauthorized API calls.

NOTE: This policy will trigger alert if you have at least one Cloudtrail with the multi trail is enabled, Logs all management events in your account and is not set with specific log metric filter and alarm.

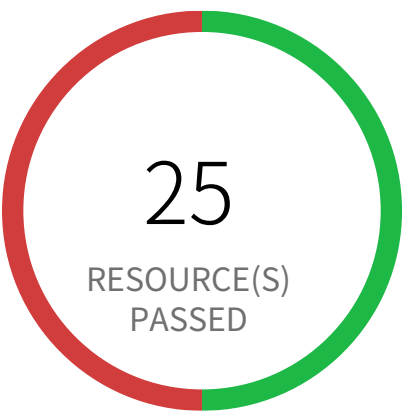
First Seen January 28, 2025 at 12:07:04 PM UTC | **Resource Type** Other

Recommendations

- 1. Sign in to AWS Console
- 2. Navigate to CloudWatch dashboard
- 3. Click on 'Log groups' in the 'Logs' section (Left panel)
- 4. Select the log group created for your CloudTrail trail event logs (CloudTrail should be multi trail enabled with all management events captured) and click 'Create Metric Filter' button.
- 5. In 'Define Logs Metric Filter' page, add 'Filter pattern' value as `{ ($.errorCode = "*UnauthorizedOperation") || ($.errorCode = "AccessDenied*") }` and Click on 'Assign Metric'
- 6. In 'Create Metric Filter and Assign a Metric' page, Choose Filter Name, Metric Details parameter according to your requirement and click on 'Create Filter'
- 7. Click on 'Create Alarm',
 - ☐- In Step 1 specify metric details and conditions details as required and click on 'Next'
 - ☐- In Step 2 Select an SNS topic either by creating a new topic or use existing SNS topic/ARN and click on 'Next'
 - ☐- In Step 3 Select name and description to alarm and click on 'Next'
 - ☐- In Step 4 Preview your data entered and click on 'Create Alarm'

System and Information Integrity / Section

System Monitoring



25 Resource(s) Failed
default & 15 more

Compliance Section: System Monitoring ●●●● Low

- a. Monitor the system to detect:
 - 1. Attacks and indicators of potential attacks and
 - 2. Unauthorized connections.
- b. Identify unauthorized use of the system.
- c. Monitor inbound and outbound communications traffic to detect unusual or unauthorized activities or conditions.

AWS Default Security Group does not restrict all traffic

This policy identifies the default security groups which does not restrict inbound and outbound traffic. A VPC comes with a default security group whose initial configuration denies all inbound traffic and allow all outbound traffic. If you do not specify a security group when you launch an instance, the instance is automatically assigned to this default security group. As a result, the instance may accidentally send outbound traffic. It is recommended that to remove any inbound and outbound rules in the default security group and not to attach the default security group to any resources.

First Seen June 11, 2024 at 6:11:28 PM UTC | **Resource Type** Other

Recommendations

Before making any changes, please check the impact on your applications/services.

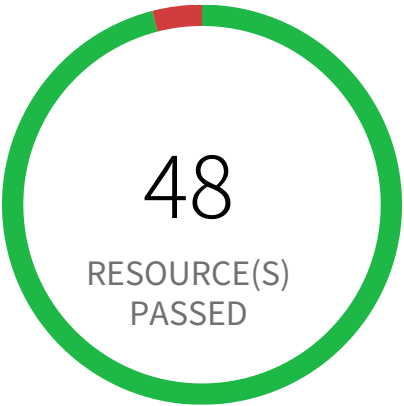
For Resources associated with the alerted security group:

- 1. Identify AWS resources that exist within the default security group
- 2. Create a set of least privilege security groups for those resources
- 3. Place the resources in those security groups
- 4. Remove the associated resources from the default security group

For alerted Security Groups:

- 1. Log in to the AWS console
- 2. In the console, select the specific region from the 'Region' drop-down on the top right corner, for which the alert is generated
- 3. Navigate to the 'VPC' service
- 4. For each region, Click on 'Security Groups' specific to the alert
- 5. On section 'Inbound rules', Click on 'Edit Inbound Rules' and remove the existing rule, click on 'Save'
- 6. On section 'Outbound rules', Click on 'Edit Outbound Rules' and remove the existing rule, click on 'Save'

System and Information Integrity / Section System Monitoring



2 Resource(s) Failed
eks-cluster-sg-pc-national-bank-425600227,
custom-security-group

Compliance Section: System Monitoring ●●●● Low

- a. Monitor the system to detect:
 - 1. Attacks and indicators of potential attacks and
 - 2. Unauthorized connections.
- b. Identify unauthorized use of the system.
- c. Monitor inbound and outbound communications traffic to detect unusual or unauthorized activities or conditions.

AWS EKS cluster security group overly permissive to all traffic

This policy identifies EKS cluster Security groups that are overly permissive to all traffic. Doing so, may allow a bad actor to brute force their way into the system and potentially get access to the entire network. Review your list of security group rules to ensure that your resources are not exposed. As a best practice, restrict traffic solely from known static IP addresses. Limit the access list to include known hosts, services, or specific employees only.

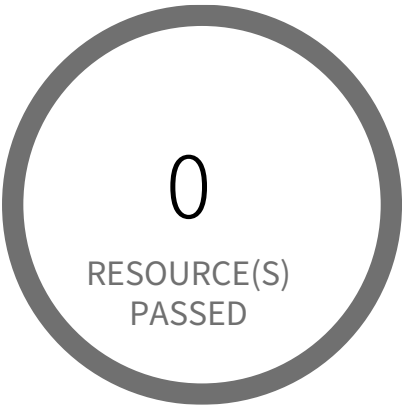
First Seen January 28, 2025 at 12:06:58 PM UTC | **Resource Type** Other

Recommendations

- Before making any changes, please check the impact on your applications/services. If the Security Group reported indeed need to restrict all traffic, follow the instructions below:
- 1. Log in to the AWS console
 - 2. Navigate to the 'VPC' service
 - 3. Select the 'Security Group' reported in the alert
 - 4. Click on 'Inbound Rules'
 - 5. Remove the rule which has the 'Source' value as 0.0.0.0/0 or ::/0

System and Information Integrity / Section

System Monitoring



0 Resource(s) Failed

Compliance Section: System Monitoring Informational

- a. Monitor the system to detect:
 - 1. Attacks and indicators of potential attacks and
 - 2. Unauthorized connections.
- b. Identify unauthorized use of the system.
- c. Monitor inbound and outbound communications traffic to detect unusual or unauthorized activities or conditions.

AWS Elastic Load Balancer (ELB) has security group with no inbound rules

This policy identifies Elastic Load Balancers (ELB) which have security group with no inbound rules. A security group with no inbound rule will deny all incoming requests. ELB security groups should have at least one inbound rule, ELB with no inbound permissions will deny all traffic incoming to ELB; in other words, the ELB is useless without inbound permissions.

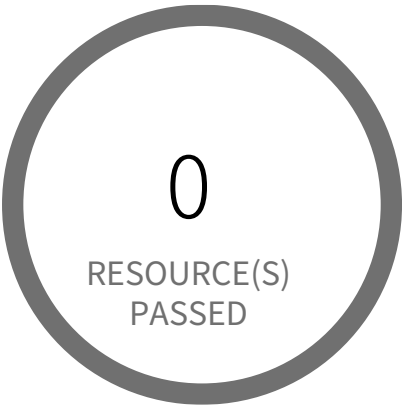
First Seen N/A | Resource Type Other

Recommendations

- 1. Sign into the AWS console
- 2. In the console, select the specific region from region drop down on the top right corner, for which the alert is generated
- 3. Navigate to EC2 Dashboard
- 4. Click on 'Load Balancers', choose the reported load balancer
- 5. Click on the 'Description' tab, click on the security group, it will open Security Group properties in a new tab in your browser
- 6. Click on the 'Inbound Rules'
- 7. If there are no rules, click on 'Edit rules', add an inbound rule according to your ELB functional requirement
- 8. Click on 'Save'

System and Information Integrity / Section

System Monitoring



0 Resource(s) Failed

Compliance Section: System Monitoring Informational

- a. Monitor the system to detect:
 - 1. Attacks and indicators of potential attacks and
 - 2. Unauthorized connections.
- b. Identify unauthorized use of the system.
- c. Monitor inbound and outbound communications traffic to detect unusual or unauthorized activities or conditions.

AWS Elastic Load Balancer (ELB) has security group with no outbound rules

This policy identifies Elastic Load Balancers (ELB) which have security group with no outbound rules. A security group with no outbound rule will deny all outgoing requests. ELB security groups should have at least one outbound rule, ELB with no outbound permissions will deny all traffic going to any EC2 instances or resources configured behind that ELB; in other words, the ELB is useless without outbound permissions.

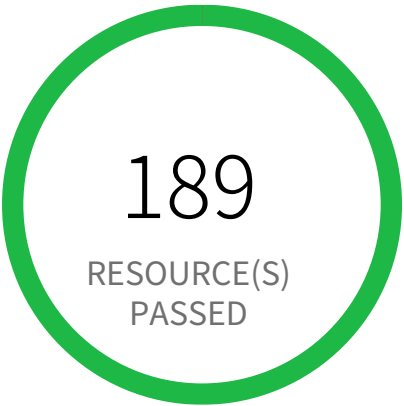
First Seen N/A | Resource Type Other

Recommendations

1. Log in to the AWS console
2. In the console, select the specific region from region drop down on the top right corner, for which the alert is generated
3. Navigate to EC2 Dashboard
4. Click on 'Load Balancers', choose the reported load balancer
5. Click on the 'Description' tab, click on the security group, it will open Security Group properties in a new tab in your browser
6. Click on the 'Outbound Rules'
7. If there are no rules, click on 'Edit rules', add an outbound rule according to your ELB functional requirement
8. Click on 'Save'

System and Information Integrity / Section

System Monitoring



0 Resource(s) Failed

Compliance Section: System Monitoring Informational

- a. Monitor the system to detect:
 - 1. Attacks and indicators of potential attacks and
 - 2. Unauthorized connections.
- b. Identify unauthorized use of the system.
- c. Monitor inbound and outbound communications traffic to detect unusual or unauthorized activities or conditions.

AWS Elasticsearch IAM policy overly permissive to all traffic

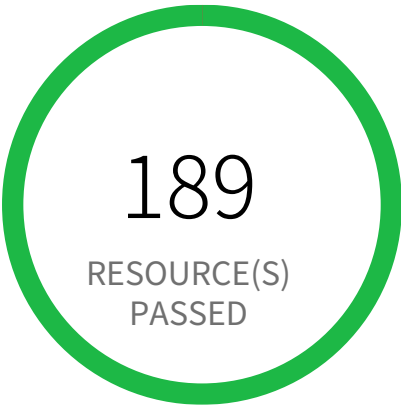
This policy identifies Elasticsearch IAM policies that are overly permissive to all traffic. Amazon Elasticsearch service makes it easy to deploy and manage Elasticsearch. Customers can create a domain where the service is accessible. The domain should be granted access restrictions so that only authorized users and applications have access to the service.

First Seen N/A | Resource Type Other

Recommendations

- 1. Log in to AWS console
- 2. Goto the IAM Services
- 3. Click on 'Policies' in the left-hand panel
- 4. Search for the Policy for which the Alert is generated and click on it
- 5. Under the Permissions tab, click on Edit policy
- 6. Under the Visual editor, for each of the 'Elasticsearch Service', click to expand and perform following.
 - 6.a. Click to expand 'Request conditions'
 - 6.b. Under the 'Source IP', remove the row with the entry '0.0.0.0/0' or ':::/0'. Add condition with restrictive IP ranges.
- 7. Click on Review policy and Save changes.

System and Information Integrity / Section System Monitoring



0 Resource(s) Failed

Compliance Section: System Monitoring ●●● Medium

- a. Monitor the system to detect:
 - 1. Attacks and indicators of potential attacks and
 - 2. Unauthorized connections.
- b. Identify unauthorized use of the system.
- c. Monitor inbound and outbound communications traffic to detect unusual or unauthorized activities or conditions.

AWS SageMaker notebook instance IAM policy overly permissive to all traffic

This policy identifies SageMaker notebook instances IAM policies that are overly permissive to all traffic. It is recommended that the SageMaker notebook instances should be granted access restrictions so that only authorized users and applications have access to the service.

For more details:
https://docs.aws.amazon.com/sagemaker/latest/dg/security_iam_id-based-policy-examples.html

First Seen N/A | **Resource Type** Other

Recommendations

- 1. Login to AWS console
- 2. Goto IAM Services
- 3. Click on 'Policies' in left hand panel
- 4. Search for the Policy for which the Alert is generated and click on it
- 5. Under Permissions tab, click on Edit policy
- 6. Under the Visual editor, for each of the 'SageMaker' Service, click to expand and perform following.
 - 6.a. Click to expand 'Request conditions'
 - 6.b. Under the 'Source IP', remove the row with the entry '0.0.0.0/0' or ':::/0'. Add condition with restrictive IP ranges.
- 7. Click on Review policy and Save changes.

System and Information Integrity / Section System Monitoring



0 Resource(s) Failed

Compliance Section: System Monitoring Informational

- a. Monitor the system to detect:
 - 1. Attacks and indicators of potential attacks and
 - 2. Unauthorized connections.
- b. Identify unauthorized use of the system.
- c. Monitor inbound and outbound communications traffic to detect unusual or unauthorized activities or conditions.

AWS Security Group allows all traffic on RDP port (3389)

This policy identifies Security groups that allow all traffic on RDP port 3389. Doing so, may allow a bad actor to brute force their way into the system and potentially get access to the entire network. Review your list of security group rules to ensure that your resources are not exposed. As a best practice, restrict RDP solely to known static IP addresses. Limit the access list to include known hosts, services, or specific employees only.

First Seen N/A | Resource Type Other

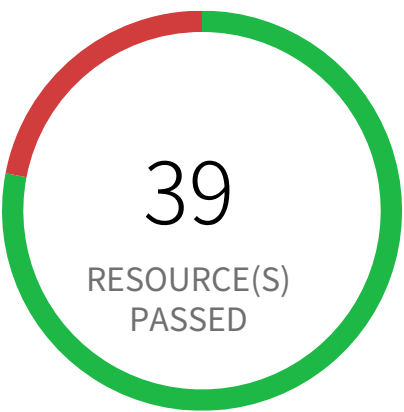
Recommendations

Before making any changes, please check the impact to your applications/services. If the Security Group reported indeed need to restrict all traffic, follow the instructions below:

- 1. Log in to the AWS Console
- 2. Navigate to the 'VPC' service
- 3. Select the 'Security Group' reported in the alert
- 4. Click on the 'Inbound Rule'
- 5. Remove the rule which has 'Source' value as 0.0.0.0/0 or ::/0 and 'Port Range' value as 3389 (or range containing 3389)

System and Information Integrity / Section

System Monitoring



11 Resource(s) Failed

web-sg-42fedb5, exfil-ssh-hz6vX, ebillingtwo-ec2-ssh-der4t4tg5ght-two, web-sg-39afb9d, bastion_sg_hz6vX, launch-wizard-1, web-sg-2f195dc, ebillingthree-ec2-ssh-der4t4tg5ght-three, Kali Linux-2024.3-amd64-AutogenByAWSMP--1, custom-security-group & 1 more

Compliance Section: System Monitoring ●●● Medium

- a. Monitor the system to detect:
1. Attacks and indicators of potential attacks and
 2. Unauthorized connections.
- b. Identify unauthorized use of the system.
- c. Monitor inbound and outbound communications traffic to detect unusual or unauthorized activities or conditions.

AWS Security Group allows all traffic on SSH port (22)

This policy identifies Security groups that allow all traffic on SSH port 22. Doing so, may allow a bad actor to brute force their way into the system and potentially get access to the entire network. Review your list of security group rules to ensure that your resources are not exposed. As a best practice, restrict SSH solely to known static IP addresses. Limit the access list to include known hosts, services, or specific employees only.

First Seen June 11, 2024 at 6:11:26 PM UTC | **Resource Type** Other

Recommendations

Before making any changes, please check the impact to your applications/services. If the Security Group reported indeed need to restrict all traffic, follow the instructions below:

1. Log in to the AWS Console
2. Navigate to the 'VPC' service
3. Select the 'Security Group' reported in the alert
4. Click on the 'Inbound Rule'
5. Remove the rule which has 'Source' value as 0.0.0.0/0 or ::/0 and 'Port Range' value as 22 (or range containing 22)

System and Information Integrity / Section

System Monitoring



0 Resource(s) Failed

Compliance Section: System Monitoring ●●●● Low

- a. Monitor the system to detect:
 - 1. Attacks and indicators of potential attacks and
 - 2. Unauthorized connections.
- b. Identify unauthorized use of the system.
- c. Monitor inbound and outbound communications traffic to detect unusual or unauthorized activities or conditions.

AWS route table with VPC peering overly permissive to all traffic

This policy identifies VPC route tables with VPC peering connection which are overly permissive to all traffic. Being highly selective in peering routing tables is a very effective way of minimizing the impact of breach as resources outside of these routes are inaccessible to the peered VPC.

First Seen N/A | Resource Type Other

Recommendations

- 1. Log in to the AWS Console
- 2. In the console, select the specific region from region drop down on the top right corner, for which the alert is generated.
- 3. Navigate to 'VPC' dashboard from 'Services' dropdown
- 4. From left menu, select 'Route Tables'
- 5. Click on the alerted route table
- 6. From top click on 'Action' button
- 7. From the Action menu dropdown, select 'Edit routes'
- 8. From the list of destination remove the extra permissive destination by clicking the cross symbol available for that destination
- 9. Add a destination with 'least access'
- 10. Click on 'Save Routes'.